

GIÁO TRÌNH

MẠNG MÁY TÍNH

Nguyên lý, giao thức, an toàn và phân tích dữ liệu mạng

Dành cho sinh viên ngành Khoa học dữ liệu

Ngô Hải Anh

ngohaianh@ioit.ac.vn

Lời nói đầu

Mạng máy tính là nền tảng cho hầu hết hệ thống số hiện đại: từ dịch vụ web, điện toán đám mây, thiết bị di động đến các hệ thống thu thập và phân tích dữ liệu. Đối với sinh viên Khoa học dữ liệu, việc hiểu mạng không chỉ dừng ở tên giao thức. Người học cần hiểu dữ liệu được đóng gói như thế nào, các trường header có ý nghĩa gì, packet được chuyển qua switch và router ra sao, các đại lượng hiệu năng được tính như thế nào, và dữ liệu mạng có thể được tổ chức để phân tích bằng ngôn ngữ lập trình và học máy ở mức cơ bản như thế nào.

Giáo trình trước tiên sẽ trình bày kỹ về kiến thức mạng. Các nội dung dữ liệu và học máy được đưa vào đúng thời điểm chúng giúp trả lời một câu hỏi mạng cụ thể: biểu diễn packet và flow, quan sát phân bố RTT, dự đoán đại lượng hiệu năng, phân loại trạng thái mạng hoặc phát hiện hành vi khác biệt. Wireshark được đặt ở phụ lục như một công cụ quan sát hỗ trợ, giúp người học hiểu hơn về cấu trúc gói tin mạng cũng như việc lưu giữ thông tin mạng để có thể khai thác và phân tích.

Bên cạnh hoạt động giảng dạy và nghiên cứu, tác giả có sở thích xây dựng các ứng dụng Android và phát hành trên Google Play. Đây cũng là một cách thử nghiệm các ý tưởng công nghệ trên những sản phẩm thực tế, từ trò chơi, công cụ hỗ trợ công việc đến ứng dụng liên quan đến an toàn thông tin. Sinh viên quan tâm có thể tham khảo và trải nghiệm một số ứng dụng sau:

Memory Quiz Game Trò chơi lật thẻ tìm các cặp hình giống nhau, phù hợp để thư giãn và rèn luyện khả năng ghi nhớ, tập trung và quan sát.

Mở trên Google Play: <https://play.google.com/store/apps/details?id=com.ngohaianh.memoryv2>

Banker Pro Toolkit Bộ công cụ gọn nhẹ hỗ trợ một số phép tính và nghiệp vụ thường gặp trong lĩnh vực ngân hàng.

Mở trên Google Play: <https://play.google.com/store/apps/details?id=com.ngohaianh.banker.pro.toolkit>

Ghi âm chuyển chữ Ứng dụng hỗ trợ ghi âm bài giảng, cuộc họp hoặc nội dung trao đổi và chuyển lời nói thành văn bản.

Mở trên Google Play: <https://play.google.com/store/apps/details?id=com.ngohaianh.giam.chuyenchu>

Permission Analyzer Công cụ hỗ trợ xem xét các quyền mà ứng dụng Android yêu cầu, qua đó giúp người dùng nhận biết tốt hơn các rủi ro tiềm ẩn liên quan đến bảo mật và quyền riêng tư.

<https://play.google.com/store/apps/details?id=com.ngohaianh.permission.risk.analyzer>

Các ứng dụng trên không phải là nội dung bắt buộc của học phần Mạng máy tính. Việc cài đặt và sử dụng hoàn toàn tự nguyện, không liên quan đến điểm số, đánh giá học tập hay bất kỳ yêu cầu nào của môn học. Nếu một ứng dụng mang lại đôi chút hữu ích hoặc niềm vui cho sinh viên, đó cũng là một động lực để tác giả tiếp tục giảng dạy, nghiên cứu và phát triển những sản phẩm mới.

Cấu trúc giáo trình

Phần	Nội dung
I	Nền tảng: dữ liệu mạng, phân tầng và mô hình TCP/IP.
II	TCP/IP và giao thức: Ethernet, IP, routing, TCP/UDP, DNS/DHCP/HTTP/HTTPS, mạng không dây và hiệu năng.
III	An toàn và phân tích: nguyên lý bảo vệ, tấn công, giám sát, classification và anomaly detection.
IV	Tổng hợp: các quy trình phân tích mạng hoàn chỉnh.
Phụ lục	Wireshark; công thức toán/thống kê; thuật ngữ, protocol map và port.

Mục lục

Lời nói đầu	i
Cấu trúc giáo trình	ii
I Nguyên lý nền tảng	1
1 Mạng máy tính và dữ liệu được truyền qua mạng	2
1.1 Mục tiêu và câu hỏi mở đầu	2
1.2 Khái niệm và vai trò của mạng máy tính	3
1.3 Thành phần và phạm vi mạng	4
1.4 Đơn vị và đường đi của dữ liệu	6
1.5 Các đại lượng đánh giá hoạt động mạng	8
1.6 Cơ sở khoa học dữ liệu 1: biến, kiểu dữ liệu, list và observation	10
1.7 Góc nhìn an toàn thông tin cho mạng	12
1.8 Tổng kết chương	13
2 Phân tầng, đóng gói và mô hình TCP/IP	19
2.1 Mục tiêu và câu hỏi mở đầu	19
2.2 Vì sao mạng cần phân tầng?	20
2.3 Dịch vụ, giao diện và giao thức	22
2.4 Các mô hình mạng OSI và TCP/IP	24
2.5 Đóng gói, địa chỉ, thiết bị và overhead	28
2.6 Luồng đi của dữ liệu mạng	31
2.7 Phân tích theo tầng về an toàn và góc nhìn dữ liệu	33
2.8 Tổng kết chương	35
II TCP/IP và các giao thức	40
3 Truyền dẫn, Ethernet và tầng liên kết dữ liệu	41

3.1	Mục tiêu và câu hỏi mở đầu	41
3.2	Nguyên lý truyền dẫn	42
3.3	Độ trễ và hiệu suất trên liên kết	44
3.4	Ethernet và cấu trúc frame	46
3.5	Địa chỉ MAC, switch và VLAN	48
3.6	Phát hiện lỗi trên liên kết	50
3.7	Cơ sở khoa học dữ liệu 2: array, DataFrame và trực quan hóa	51
3.8	An toàn tầng Data Link	54
3.9	Tổng kết chương	55
4	IPv4, IPv6, subnetting, ARP và ICMP	60
4.1	Mục tiêu và câu hỏi mở đầu	60
4.2	Địa chỉ IPv4 và cấu trúc gói tin	61
4.3	CIDR, chia mạng con và VLSM	64
4.4	Đích cùng mạng và default gateway	67
4.5	ARP và ICMP	69
4.6	IPv6 và chuyển tiếp từ IPv4	72
4.7	Cơ sở khoa học dữ liệu 3: missing value, thống kê và outlier	72
4.8	Các tấn công liên quan đến IP	75
4.9	Tổng kết chương	75
5	Chuyển tiếp, định tuyến và NAT	82
5.1	Mục tiêu và câu hỏi mở đầu	82
5.2	Chuyển tiếp gói tin và hoạt động của bộ định tuyến	83
5.3	Bảng định tuyến và longest-prefix matching	86
5.4	Đồ thị, chi phí đường đi và Dijkstra	88
5.5	Định tuyến tĩnh và động	90
5.6	NAT, PAT và port mapping	91
5.7	Dữ liệu định tuyến và trực quan hóa tuyến	93
5.8	An toàn định tuyến	96
5.9	Tổng kết chương	98
6	UDP, TCP và truyền dữ liệu đầu cuối	104
6.1	Mục tiêu và câu hỏi mở đầu	104
6.2	Port, socket và truyền dữ liệu liên tiến trình	105
6.3	UDP và truyền datagram không hướng-kết nối	107
6.4	TCP: connection và truyền byte tin cậy	109

6.5	Flow control, congestion control và hiệu năng TCP	112
6.6	Phân tích và trực quan hóa dữ liệu tầng Transport	115
6.7	An toàn, độ tin cậy ở tầng Transport	119
6.8	Ví dụ tổng hợp từ header đến dữ liệu	121
6.9	Tổng kết chương	121
7	DNS, DHCP, HTTP và các giao thức ứng dụng	127
7.1	Mục tiêu và câu hỏi mở đầu	127
7.2	Nguyên lý tầng Application	128
7.3	DNS	130
7.4	DHCP	133
7.5	HTTP	134
7.6	Các giao thức ứng dụng khác	137
7.7	Cơ sở khoa học dữ liệu 4: numerical và categorical data	139
7.8	An toàn tầng Application	142
7.9	Tổng kết chương	144
8	Mạng không dây và mạng di động	150
8.1	Mục tiêu và câu hỏi mở đầu	150
8.2	Nền tảng của truyền thông không dây	151
8.3	Wi-Fi và kiến trúc IEEE 802.11	153
8.4	CSMA/CA, roaming và hiệu năng Wi-Fi	155
8.5	Mạng di động 4G/5G	158
8.6	Cơ sở khoa học dữ liệu 5: time series và line plot	160
8.7	An toàn không dây và di động	162
8.8	Tổng kết chương	163
	Tài liệu tham khảo chọn lọc	168
9	Hiệu năng mạng và phân tích bằng hồi quy	169
9.1	Mục tiêu của chương	169
9.2	Các đại lượng mô tả hiệu năng mạng	170
9.3	Các thành phần độ trễ và BDP	172
9.4	QoS và phân bổ tài nguyên	177
9.5	Từ dữ liệu hiệu năng đến observation, feature, target và X/y	180
9.6	Chia train-test, baseline và tiền xử lý đúng nguyên tắc	183
9.7	Hồi quy tuyến tính: từ đường thẳng đến estimator	184
9.8	Đánh giá, phần dư và diễn giải dưới góc độ mạng	186

9.9 Tổng kết chương	188
-------------------------------	-----

III An toàn và phân tích mạng 192

10 Các nguyên lý bảo vệ hệ thống mạng 193

10.1 Mục tiêu và câu hỏi mở đầu	193
10.2 Tài sản, rủi ro và mục tiêu bảo vệ	194
10.3 Định danh, xác thực và phân quyền	196
10.4 Phòng vệ nhiều lớp, phân vùng và Zero Trust	198
10.5 Firewall, ACL và IDS/IPS	201
10.6 Mật mã, PKI, TLS và VPN	203
10.7 Security telemetry và giám sát có trách nhiệm	205
10.8 Tổng kết chương	206

11 Tấn công mạng, giám sát và phát hiện bất thường 210

11.1 Mục tiêu và câu hỏi mở đầu	210
11.2 Tấn công và dấu hiệu quan sát	211
11.3 Nguồn dữ liệu, IDS/IPS, SIEM và triage	214
11.4 Cơ sở máy học 1: phân loại, nhãn, X/y và baseline	216
11.5 Tiền xử lý dữ liệu và Pipeline	220
11.6 Logistic Regression, metric, threshold và Decision Tree	223
11.7 Cơ sở máy học 2: clustering và anomaly detection	227
11.8 Phân tích lỗi, drift và sử dụng có trách nhiệm	230
11.9 Tổng kết chương	233

IV Tổng hợp 239

12 Quy trình phân tích mạng 240

12.1 Mục tiêu và nguyên tắc tổng hợp	240
12.2 Quy trình phân tích mạng thông thường	242
12.3 Nghiên cứu tình huống 1: hồi quy hiệu năng	244
12.4 Nghiên cứu tình huống 2: phân loại trạng thái kết nối	246
12.5 Nghiên cứu tình huống 3: phân cụm và hành vi khác biệt	249
12.6 So sánh các quy trình và chuyển sang báo cáo	252
12.7 Bài tập tổng hợp	254
12.8 Tổng kết chương	256

A	Phân tích gói tin với Wireshark	260
A.1	Vai trò, phạm vi và nguyên tắc sử dụng	260
A.2	Giao diện, interface và phiên capture đầu tiên	261
A.3	Capture filter và display filter	262
A.4	Đọc các giao thức cốt lõi	263
A.5	Theo dõi stream, thống kê và xuất dữ liệu	264
A.6	Một quy trình phân tích hoàn chỉnh	265
A.7	Tra cứu nhanh và giới hạn cần nhớ	266
B	Thuật ngữ, bản đồ giao thức và port thường gặp	267
B.1	Bản đồ TCP/IP năm tầng	267
B.2	Protocol profiles tra cứu nhanh	268
B.3	Port và dịch vụ thường gặp	269
B.4	Các cặp thuật ngữ dễ nhầm	270
B.5	Thuật ngữ Việt–Anh chọn lọc	271

Phần I

Nguyên lý nền tảng

Chương 1

Mạng máy tính và dữ liệu được truyền qua mạng

1.1 Mục tiêu và câu hỏi mở đầu

1.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Khi một sinh viên mở trình duyệt và truy cập một trang web, điều gì thực sự “đi” từ máy tính của sinh viên đến máy chủ? Có phải cả trang web được gửi nguyên vẹn như một vật thể duy nhất? Vì sao máy tính cần biết địa chỉ IP, trong khi dữ liệu trên Wi-Fi hoặc Ethernet lại còn sử dụng địa chỉ MAC? Tại sao tốc độ đường truyền ghi trên hợp đồng có thể cao nhưng trang web vẫn phản hồi chậm?

Để trả lời các câu hỏi này, trước hết cần hình thành một cách nhìn thống nhất về mạng máy tính: mạng gồm những thành phần nào, dữ liệu được chia và đóng gói ra sao, được chuyển qua các thiết bị nào, và chất lượng truyền thông được đo bằng những đại lượng gì. Chương này xây dựng nền móng đó trước khi đi sâu vào mô hình phân tầng và từng giao thức cụ thể.

1.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Trình bày được khái niệm mạng máy tính và các mục đích chính của việc kết nối thiết bị.
- Nhận diện được thiết bị đầu cuối, switch, router, access point và liên kết mạng trong một sơ đồ đơn giản.
- Phân biệt được bit, byte, message, segment, datagram, packet, frame, connection và flow.
- Phân biệt được bandwidth, throughput, goodput, delay, packet loss và jitter.
- Thực hiện được các phép tính cơ bản về thời gian truyền, throughput và tỷ lệ mất packet.
- Biểu diễn một dãy phép đo mạng bằng biến, kiểu dữ liệu và Python list.
- Giải thích được ba mục tiêu bảo vệ cơ bản: bí mật, toàn vẹn và sẵn sàng.

- Thực hiện được một phép đo ping đơn giản, ghi kết quả và giải thích các giới hạn của phép đo.

1.2 Khái niệm và vai trò của mạng máy tính

1.2.1 Mạng máy tính là gì?

Mạng máy tính (computer network) là một tập hợp các thiết bị có khả năng trao đổi dữ liệu qua các liên kết truyền thông và tuân theo những quy tắc chung. Các thiết bị có thể là máy tính cá nhân, điện thoại, máy chủ, cảm biến, camera, máy in hoặc thiết bị điều khiển.

Ba thành phần tối thiểu của một quá trình truyền thông gồm:

- **nguồn:** nơi tạo hoặc gửi dữ liệu;
- **đích:** nơi nhận dữ liệu;
- **môi trường và quy tắc truyền thông:** cách dữ liệu được biểu diễn, chuyển đi và hiểu đúng ở phía nhận.

Ví dụ: hai người trao đổi thư

Một người viết thư, ghi địa chỉ người nhận và giao cho dịch vụ bưu chính. Dịch vụ bưu chính sử dụng phương tiện, tuyến đường và quy trình riêng để chuyển thư. Trong mạng máy tính, thiết bị nguồn tạo dữ liệu, các giao thức bổ sung thông tin điều khiển, còn liên kết và thiết bị trung gian chuyển dữ liệu đến đích.

Phép so sánh này giúp hình dung vai trò của nguồn, đích, địa chỉ và đường chuyển tiếp. Tuy nhiên, dữ liệu mạng không tồn tại như một phong bì vật lý xuyên suốt hành trình. Trên từng liên kết, dữ liệu được biểu diễn thành tín hiệu; tại router, lớp bao gói liên kết có thể được thay đổi.

1.2.2 Mục đích của việc kết nối

Các mạng máy tính được xây dựng để phục vụ nhiều mục đích:

- chia sẻ dữ liệu, máy in, ứng dụng và kết nối Internet;
- trao đổi thư điện tử, tin nhắn, thoại và video;
- truy cập dịch vụ tập trung như website, hệ thống kế toán hoặc cơ sở dữ liệu;
- phối hợp làm việc giữa người dùng ở nhiều địa điểm;
- thu thập dữ liệu từ cảm biến, thiết bị di động và hệ thống nghiệp vụ;
- sao lưu, giám sát và quản trị hệ thống từ xa.

1.2.3 Dịch vụ mạng và ứng dụng mạng

Một *dịch vụ mạng* (network service) là chức năng được cung cấp qua mạng, chẳng hạn phân giải tên miền, cấp địa chỉ IP, truyền tệp hoặc truy cập web. Một *ứng dụng mạng* (network application) là chương trình sử dụng hoặc cung cấp dịch vụ đó.

Ví dụ, trình duyệt là ứng dụng; HTTP là giao thức ứng dụng; máy chủ web cung cấp nội dung; DNS giúp biến tên miền thành địa chỉ IP. Các khái niệm này sẽ được làm rõ ở Chương 8.

1.2.4 Mạng trong doanh nghiệp và đời sống

Trong một doanh nghiệp, mạng kết nối nhân viên, chi nhánh, máy chủ, dịch vụ đám mây, camera, thiết bị bán hàng và hệ thống quản trị. Trong đời sống, người dùng gặp mạng khi truy cập Wi-Fi, gọi video, thanh toán trực tuyến, xem phim hoặc đồng bộ dữ liệu.

Ví dụ: một siêu thị

Một siêu thị hiện đại có thể sử dụng mạng cho máy quét mã vạch, máy tính tiền, máy chủ kho, camera, máy in hóa đơn và kết nối tới ngân hàng. Mỗi thiết bị có vai trò riêng nhưng cần trao đổi dữ liệu. Nếu mạng bị gián đoạn, một số quầy vẫn có thể hoạt động cục bộ, trong khi thanh toán hoặc đồng bộ kho có thể bị ảnh hưởng.

1.2.5 Client-server và peer-to-peer

Trong mô hình *mô hình máy khách-máy chủ* (client-server), client gửi yêu cầu và server cung cấp dịch vụ. Một máy có thể là client trong một phiên nhưng là server trong phiên khác.

Trong mô hình *ngang hàng* (peer-to-peer), các thiết bị có thể vừa yêu cầu vừa cung cấp tài nguyên cho nhau. Hai mô hình không loại trừ lẫn nhau; nhiều hệ thống thực tế kết hợp cả hai.

Nhầm lẫn thường gặp

Client không đồng nghĩa với máy yếu; server không nhất thiết là một máy vật lý lớn. Client và server mô tả vai trò trong một hoạt động truyền thông. Một phần mềm server có thể chạy trên máy tính thông thường, máy ảo hoặc dịch vụ đám mây.

1.3 Thành phần và phạm vi mạng

1.3.1 Thiết bị đầu cuối và giao diện mạng

Thiết bị đầu cuối (end system, host) là thiết bị nơi dữ liệu được tạo ra hoặc tiêu thụ. Mỗi thiết bị kết nối qua một hoặc nhiều *giao diện mạng* (network interface), chẳng hạn Ethernet, Wi-Fi hoặc kết nối di động. Một máy tính có thể đồng thời có Ethernet và Wi-Fi. Mỗi giao diện có thể mang địa chỉ riêng và tham gia vào những mạng khác nhau.

1.3.2 Switch, router và access point

Bảng 1.1: Vai trò cơ bản của một số thiết bị mạng

Thiết bị	Vai trò chính	Hình dung đời thường
Switch	Chuyển frame giữa các thiết bị trong mạng cục bộ	Nhân viên phân loại thư trong một tòa nhà hoặc khu nội bộ
Router	Chuyển packet giữa các mạng khác nhau	Trung tâm điều phối chọn chặng tiếp theo cho bưu kiện
Access point	Cho thiết bị không dây tham gia mạng cục bộ	Điểm tiếp nhận kết nối không dây vào hệ thống nội bộ
Modem/ONT (Optical Line Terminal)	Chuyển đổi tín hiệu phù hợp với công nghệ truy nhập	Bộ chuyển đổi giữa hạ tầng của người dùng và nhà cung cấp
Firewall	Cho phép hoặc từ chối lưu lượng theo chính sách	Bộ phận kiểm soát ra vào

Cần chú ý rằng thông tin so sánh trên chỉ giúp ghi nhớ vai trò tổng quát của các thiết bị mạng, còn chức năng thực tế phụ thuộc loại thiết bị, cấu hình và vị trí triển khai.

1.3.3 Liên kết có dây và không dây

Liên kết (link) là môi trường nối hai hoặc nhiều giao diện mạng. Liên kết có thể sử dụng cáp đồng, cáp quang hoặc sóng vô tuyến. Mỗi công nghệ có đặc điểm riêng về tốc độ, khoảng cách, nhiễu, độ trễ và khả năng chia sẻ môi trường.

1.3.4 LAN, WLAN, WAN và Internet

- mạng cục bộ* (Local Area Network, LAN): mạng cục bộ trong phạm vi nhà, phòng, tòa nhà hoặc khuôn viên nhỏ;
- mạng cục bộ không dây* (Wireless Local Area Network, WLAN): LAN sử dụng công nghệ không dây, thường là Wi-Fi;
- mạng diện rộng* (Wide Area Network, WAN): kết nối nhiều vị trí ở khoảng cách lớn;
- mạng Internet* (Internet): mạng của các mạng, sử dụng bộ giao thức Internet để kết nối rất nhiều hệ thống độc lập.

1.3.5 Đường đi của dữ liệu qua nhiều mạng

Khi nguồn và đích ở cùng mạng cục bộ, dữ liệu có thể được chuyển qua switch hoặc access point. Khi đích ở mạng khác, nguồn gửi packet tới router mặc định; packet có thể đi qua nhiều router trước khi tới mạng đích.

Ví dụ: đi từ nhà đến một trường đại học ở tỉnh khác

Người đi đường không cần biết toàn bộ chi tiết của mọi con phố. Trước hết họ ra khỏi khu dân cư, đi theo các tuyến đường lớn, qua một số nút giao, rồi vào khu vực đích. Tương tự, packet đi qua các router. Mỗi router quyết định chặng tiếp theo dựa trên thông tin định tuyến.

So với thực tế con người thì thành phần mạng có giới hạn: packet không tự “nhìn biển đường”. Router đọc header, tra bảng chuyển tiếp và đưa packet sang liên kết tiếp theo.

1.4 Đơn vị và đường đi của dữ liệu

1.4.1 Bit, byte và message

bit (bit) là đơn vị nhị phân có giá trị 0 hoặc 1. Tám bit tạo thành một *byte* (byte). Ứng dụng thường làm việc với *thông điệp* (message) như văn bản, yêu cầu web, bản ghi hoặc khối dữ liệu.

Quy ước đơn vị

Trong giáo trình, chữ **b** thường biểu diễn bit, còn chữ **B** biểu diễn byte. Vì $1\text{ B} = 8\text{ b}$, nhầm chữ hoa và chữ thường có thể tạo sai số tám lần.

1.4.2 Segment, datagram, packet và frame

Tên đơn vị dữ liệu phụ thuộc tầng và giao thức:

- dữ liệu TCP thường được gọi là *phân đoạn* (segment);
- dữ liệu UDP thường được gọi là *datagram* (datagram);
- dữ liệu tầng Network thường được gọi là *gói tin* (packet);
- dữ liệu tầng Data Link được gọi là *khung* (frame);
- tại tầng Physical, dữ liệu được truyền dưới dạng bit và tín hiệu.

Ở góc nhìn cơ bản nhất của kiến thức mạng máy tính, từ “packet” đôi khi được sử dụng theo nghĩa rộng để chỉ đơn vị dữ liệu bắt được trên mạng. Khi phân tích chính xác, cần xác định tầng đang nói đến.

1.4.3 Ví dụ về đóng gói

Gửi một tài liệu qua dịch vụ chuyển phát

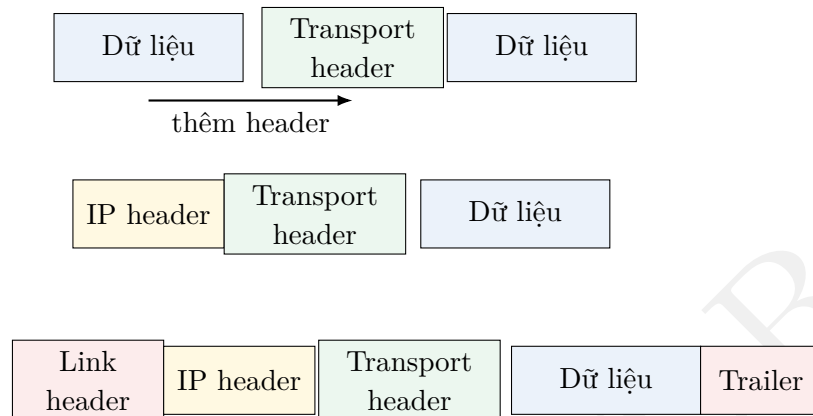
Một tài liệu được đặt trong phong bì, phong bì được đặt trong túi vận chuyển, trên mỗi lớp có thông tin phục vụ một phạm vi xử lý. Trong mạng, dữ liệu ứng dụng được bổ sung header của tầng Transport, tiếp theo là header tầng Network và header/trailer tầng Data Link.

Phép so sánh giúp hiểu ý tưởng đóng gói. Tuy nhiên, header không phải lớp vật liệu bao quanh theo nghĩa vật lý; nó là các bit được đặt trước hoặc sau payload theo định dạng giao thức.

1.4.4 Packet khác frame như thế nào?

Packet IP thường mang địa chỉ IP nguồn và đích để đi qua nhiều mạng. Frame mang địa chỉ liên kết, chẳng hạn MAC, để truyền trên một liên kết hoặc mạng cục bộ cụ thể.

Khi packet đi qua router, router nhận frame, lấy packet ra, kiểm tra và tạo frame mới cho liên kết tiếp theo. Vì vậy, frame có thể thay đổi theo từng chặng, còn packet IP vẫn đại diện cho việc chuyển dữ liệu từ nguồn IP đến đích IP, dù một số trường có thể được cập nhật.



1.4.5 Connection, session và flow

Kết nối (connection) mô tả quan hệ truyền thông được thiết lập và duy trì theo quy tắc của giao thức, điển hình là kết nối TCP. *Phiên* (session) thường mô tả một phiên tương tác ở mức ứng dụng hoặc người dùng, chẳng hạn một lần đăng nhập. *Luồng* (flow) là nhóm packet có chung một số thuộc tính, thường dùng để phân tích lưu lượng.

Một flow thường được nhận diện bằng năm thành phần:

địa chỉ IP nguồn, địa chỉ IP đích, port nguồn, port đích và giao thức Transport.

1.4.6 Ví dụ về packet và flow

Một đơn hàng trực tuyến có thể được chia thành nhiều kiện. Mỗi kiện gần giống một packet; toàn bộ các kiện của đơn hàng gần giống một flow. Thời gian từ kiện đầu tiên đến kiện cuối cùng tương tự flow duration.

Giới hạn: packet có thể đến khác thứ tự, bị mất hoặc được truyền lại; cách nhóm flow phụ thuộc quy tắc phân tích, không phải lúc nào cũng trùng với một “đơn hàng” ứng dụng.

1.4.7 Dữ liệu thực sự “đi” như thế nào?

Cách nói “packet đi qua mạng” là cách diễn đạt thuận tiện. Về vật lý, trên mỗi liên kết, các bit được mã hóa thành tín hiệu điện, quang hoặc vô tuyến. Thiết bị nhận tín hiệu, khôi phục bit, xử lý header và truyền tín hiệu mới trên chặng tiếp theo. Không có một vật thể duy nhất chạy xuyên qua toàn bộ Internet.

Nhầm lẫn thường gặp

Không nên hiểu rằng nội dung ứng dụng luôn được gửi thành một packet duy nhất. Dữ liệu lớn thường được chia thành nhiều đơn vị. Ngược lại, một frame có thể mang dữ liệu nhỏ cùng nhiều header. Kích thước, cách chia và cách tái hợp phụ thuộc giao thức và công nghệ mạng.

1.5 Các đại lượng đánh giá hoạt động mạng

1.5.1 Bandwidth, throughput và goodput

Băng thông (bandwidth) trong ngữ cảnh cơ bản thường chỉ khả năng truyền dữ liệu danh nghĩa của liên kết, đo bằng bit trên giây. *Thông lượng* (throughput) là tốc độ dữ liệu thực tế quan sát được trong một khoảng thời gian. *Thông lượng hữu ích* (goodput) là tốc độ dữ liệu hữu ích của ứng dụng, không tính header, truyền lại và một số overhead khác.

Thông thường:

$$\text{Goodput} \leq \text{Throughput} \leq \text{Bandwidth}.$$

Ví dụ: đường cao tốc

Số làn và tốc độ thiết kế gần với bandwidth. Số xe thực tế đi qua một điểm trong một giờ gần với throughput. Số xe chờ đứng hàng hóa hữu ích, không tính xe rỗng hoặc xe phải quay lại, gần với goodput.

Phép so sánh không hoàn toàn tương đương vì packet không chiếm không gian và vận hành giống xe, nhưng giúp phân biệt khả năng danh nghĩa với kết quả thực tế.

1.5.2 Bốn thành phần độ trễ

Độ trễ tại một nút thường được phân tích thành:

$$d_{\text{nodal}} = d_{\text{proc}} + d_{\text{queue}} + d_{\text{trans}} + d_{\text{prop}}.$$

Trong đó:

- d_{proc} : độ trễ xử lý (processing delay);
- d_{queue} : độ trễ hàng đợi (queueing delay);
- d_{trans} : độ trễ truyền dẫn (transmission delay);
- d_{prop} : độ trễ lan truyền (propagation delay).

1.5.3 Transmission delay

Nếu packet có kích thước L bit và liên kết có tốc độ R bit/s thì:

$$d_{\text{trans}} = \frac{L}{R}.$$

Đây là thời gian cần để đẩy toàn bộ bit của packet lên liên kết. Nó không phụ thuộc trực tiếp vào khoảng cách.

1.5.4 Propagation delay

Nếu khoảng cách liên kết là D mét và tốc độ lan truyền là v mét/s thì:

$$d_{prop} = \frac{D}{v}.$$

Độ trễ lan truyền phụ thuộc khoảng cách và môi trường, không phụ thuộc trực tiếp vào kích thước packet.

Ví dụ: đoàn tàu và đường ray

Thời gian đưa tất cả toa tàu qua cổng ga gần với transmission delay: đoàn càng dài hoặc cổng xử lý càng chậm thì mất nhiều thời gian. Thời gian đầu tàu chạy từ ga này đến ga khác gần với propagation delay: phụ thuộc khoảng cách và tốc độ di chuyển.

Ví dụ này giúp minh họa hai đại lượng nhưng chú ý rằng ở đây chúng ta bỏ qua không mô tả chính xác vật lý của tín hiệu điện hoặc quang.

1.5.5 Queueing delay

Độ trễ xếp hàng xuất hiện khi packet phải chờ liên kết đầu ra. Khi tốc độ packet đến gần khả năng phục vụ, hàng đợi có thể tăng nhanh. Nếu buffer đầy, packet có thể bị loại bỏ.

Ví dụ: quầy thanh toán

Khách hàng tương tự packet, quầy thanh toán tương tự liên kết đầu ra, tốc độ phục vụ tương tự link rate, còn khu vực chờ tương tự buffer. Khi khách đến ít, thời gian chờ thấp. Khi khách đến nhanh hơn khả năng phục vụ, hàng đợi tăng; nếu không còn chỗ, khách mới không được tiếp nhận.

1.5.6 Packet loss và jitter

Mất gói (packet loss) là tình trạng một số packet không đến được nơi cần đến hoặc bị loại bỏ. *Dao động độ trễ* (jitter) là sự biến động của độ trễ giữa các packet hoặc phép đo. Jitter quan trọng đối với thoại và video thời gian thực vì dữ liệu cần đến tương đối đều.

1.5.7 Round-trip time

Thời gian khứ hồi (round-trip time, RTT) là thời gian từ khi gửi một yêu cầu hoặc tín hiệu đến khi nhận phản hồi tương ứng. Lệnh ping thường đo RTT bằng ICMP. RTT không đơn giản bằng hai lần propagation delay; nó còn chịu ảnh hưởng của xử lý, xếp hàng, đường đi hai chiều và thiết bị đích.

1.5.8 Các nhầm lẫn thường gặp

Nhầm lẫn thường gặp

- Tốc độ ghi trên liên kết không đảm bảo ứng dụng luôn đạt throughput đó.
- Ping thấp không đảm bảo tải tệp nhanh; throughput còn phụ thuộc nhiều yếu tố.
- Packet loss bằng 0 trong vài phép đo không chứng minh mạng luôn ổn định.
- Một máy không trả lời ping chưa chắc đã ngừng hoạt động; ICMP có thể bị chặn.
- Transmission delay và propagation delay là hai đại lượng khác nhau.

1.6 Cơ sở khoa học dữ liệu 1: biến, kiểu dữ liệu, list và observation

1.6.1 Quan sát, biến và giá trị

Một *quan sát* (observation) là một lần ghi nhận đối tượng hoặc hiện tượng. Ví dụ, mỗi lần ping tạo một giá trị RTT; mỗi packet capture tạo một bản ghi packet; mỗi flow có thể tạo một hàng dữ liệu.

Một *biến* (variable) là đặc tính được ghi lại, chẳng hạn RTT, kích thước packet hoặc tên giao thức. Một *giá trị* (value) là kết quả cụ thể của biến tại một quan sát.

1.6.2 Biến định lượng và biến phân loại

- *Biến định lượng* (quantitative variable): biểu diễn số có ý nghĩa tính toán, như RTT, số packet, số byte.
- *Biến phân loại* (categorical variable): biểu diễn nhóm hoặc nhãn, như TCP, UDP, ICMP hoặc tên giao diện mạng.

Một cột chứa số không nhất thiết là định lượng. Ví dụ, port number được viết bằng số nhưng thường đóng vai trò định danh hoặc phân loại, không nên tính trung bình một cách máy móc.

1.6.3 Biến và kiểu dữ liệu Python

Đoạn code sau tạo bốn biến:

Listing 1.1: CH01-CODE-01 - Biến và kiểu dữ liệu cơ bản

```
packet_count = 120
average_rtt_ms = 23.5
protocol = "TCP"
is_retransmission = False

print(type(packet_count))
print(type(average_rtt_ms))
print(type(protocol))
print(type(is_retransmission))
```

Ý nghĩa:

- `packet_count` là số nguyên, kiểu `int`;
- `average_rtt_ms` là số thực, kiểu `float`;
- `protocol` là chuỗi, kiểu `str`;
- `is_retransmission` là giá trị đúng/sai, kiểu `bool`;
- hàm `type()` trả về kiểu của đối tượng.

1.6.4 Python list và dãy phép đo RTT

Listing 1.2: CH01-CODE-02 - Biểu diễn dãy RTT bằng list

```
rtt_values_ms = [18.2, 21.4, 19.8, 35.1, 20.5]

print(type(rtt_values_ms))
print(len(rtt_values_ms))
print(rtt_values_ms[0])
print(rtt_values_ms[-1])
```

Giải thích:

- cặp ngoặc vuông tạo `list`;
- mỗi phần tử là một phép đo RTT theo millisecond;
- `len()` trả về số phần tử;
- chỉ số 0 chọn phần tử đầu tiên;
- chỉ số -1 chọn phần tử cuối cùng;
- Python đánh chỉ số từ 0.

1.6.5 Tính tổng, số lượng và trung bình

Listing 1.3: CH01-CODE-03 - Tính RTT trung bình bằng các bước cơ bản

```
total_rtt = sum(rtt_values_ms)
number_of_measurements = len(rtt_values_ms)
mean_rtt = total_rtt / number_of_measurements

print("Total RTT:", total_rtt)
print("Number of measurements:", number_of_measurements)
print("Mean RTT:", mean_rtt)
```

Đoạn code tính trung bình theo công thức:

$$\text{mean} = \frac{\text{sum of values}}{\text{number of values}}.$$

Kết quả trung bình có cùng đơn vị với dữ liệu đầu vào, tức millisecond.

1.6.6 Kiểm tra dữ liệu trước khi kết luận

Trước khi tính toán hoặc vẽ, người học cần hỏi:

- mỗi giá trị biểu diễn điều gì;
- đơn vị là gì;
- có giá trị thiếu hoặc không hợp lệ không;
- các phép đo có cùng điều kiện không;
- số lượng quan sát có đủ cho kết luận hay không.

Chú ý

Không sử dụng một hàm chỉ vì code chạy được, mà trước hết phải hiểu dữ liệu đầu vào, kiểu dữ liệu, ý nghĩa của từng giá trị và kết quả đầu ra sẽ thu được.

1.7 Góc nhìn an toàn thông tin cho mạng

1.7.1 Tài sản, nguy cơ và biện pháp bảo vệ

Tài sản (asset) là những gì có giá trị cần bảo vệ, chẳng hạn dữ liệu, tài khoản, dịch vụ, thiết bị và uy tín. *Mối đe dọa* (threat) là khả năng xảy ra sự kiện gây hại. *Biện pháp bảo vệ* (security control) là cơ chế giảm khả năng hoặc tác động của nguy cơ.

Các khái niệm đầy đủ về threat, vulnerability và risk sẽ được trình bày ở Chương 11.

1.7.2 Tính bí mật

Tính bí mật (confidentiality) bảo đảm thông tin không bị đọc bởi đối tượng không được phép. Nghe lên trên mạng, chia sẻ sai quyền hoặc gửi dữ liệu không mã hóa có thể làm mất bí mật.

Ví dụ: phong bì kín

Một phong bì kín giúp người ngoài khó đọc nội dung, tương tự mã hóa giúp bảo vệ dữ liệu. Tuy nhiên, địa chỉ trên phong bì vẫn có thể nhìn thấy; tương tự, mã hóa nội dung không nhất thiết che giấu toàn bộ metadata mạng.

1.7.3 Tính toàn vẹn

Tính toàn vẹn (integrity) bảo đảm dữ liệu không bị thay đổi trái phép hoặc thay đổi được phát hiện. Cần phân biệt phát hiện lỗi truyền ngẫu nhiên với bảo vệ trước sửa đổi có chủ ý.

1.7.4 Tính sẵn sàng

Tính sẵn sàng (availability) bảo đảm người dùng hợp lệ có thể truy cập dịch vụ khi cần. Đứt cáp, mất điện, sai cấu hình, quá tải hoặc tấn công từ chối dịch vụ đều có thể làm giảm tính sẵn sàng.

1.7.5 Phòng vệ nhiều lớp

Không có một biện pháp đơn lẻ bảo vệ được mọi mục tiêu. Mã hóa hỗ trợ bí mật và toàn vẹn nhưng không ngăn được mọi hình thức làm nhẽn. Firewall kiểm soát lưu lượng nhưng không thay thế cập nhật phần mềm. Sao lưu hỗ trợ phục hồi nhưng không ngăn được rò rỉ dữ liệu.

1.7.6 Quyền riêng tư khi quan sát mạng

Dữ liệu packet, flow và log có thể chứa địa chỉ IP, tên miền, thời điểm hoạt động, định danh thiết bị hoặc nội dung nhạy cảm. Chỉ được quan sát mạng và dữ liệu trong phạm vi được phép; cần ẩn danh hóa trước khi chia sẻ.

1.8 Tổng kết chương

1.8.1 Tóm tắt chương

- Mạng máy tính kết nối các thiết bị để trao đổi dữ liệu và sử dụng dịch vụ theo các quy tắc chung.
- Thiết bị đầu cuối tạo hoặc tiêu thụ dữ liệu; switch, router và access point hỗ trợ chuyển dữ liệu trong những phạm vi khác nhau.
- Dữ liệu được mô tả bằng nhiều đơn vị như message, segment, datagram, packet và frame; tên gọi phụ thuộc tầng và giao thức.
- Packet và frame không đồng nghĩa: packet phục vụ chuyển qua nhiều mạng, còn frame gắn với một chặng liên kết cụ thể.
- Bandwidth là khả năng danh nghĩa; throughput là tốc độ thực tế; goodput chỉ tính dữ liệu hữu ích.
- Độ trễ gồm xử lý, xếp hàng, truyền dẫn và lan truyền.
- Packet loss và jitter ảnh hưởng chất lượng dịch vụ theo những cách khác nhau.
- Dữ liệu mạng có thể được biểu diễn thành các biến và danh sách để tính toán, lọc và trực quan hóa bằng Python.
- Bí mật, toàn vẹn và sẵn sàng là ba mục tiêu bảo vệ nền tảng.
- Mọi phép đo cần được đọc cùng đơn vị, điều kiện đo và giới hạn của công cụ.

1.8.2 Bài tập

Bài luyện tập 1

1. Đổi 12 MB sang megabit theo quy ước thập phân.

2. Một packet 1,000 byte được truyền trên liên kết 8 Mbit/s. Tính transmission delay.
3. Một liên kết dài 600 km có tốc độ lan truyền 2×10^8 m/s. Tính propagation delay.
4. Gửi 100 packet, nhận 97 phản hồi. Tính tỷ lệ mất.
5. Một ứng dụng nhận 500 MB trong 100 giây. Tính throughput trung bình theo Mbit/s.

Lời giải bài luyện tập 1

1. $12 \times 8 = 96$ Mbit.
2. $1,000 \times 8 = 8,000$ bit; $8,000 / (8 \times 10^6) = 0.001$ s = 1 ms.
3. 600 km = $600,000$ m; $600,000 / (2 \times 10^8) = 0.003$ s = 3 ms.
4. Mất 3 packet; tỷ lệ $3/100 \times 100\% = 3\%$.
5. $500 \times 8 = 4,000$ Mbit; $4,000/100 = 40$ Mbit/s.

Bài luyện tập 2

1. Một packet 1,500 byte đi qua ba liên kết giống nhau, mỗi liên kết 100 Mbit/s và có propagation delay 2 ms. Bỏ qua xử lý và xếp hàng. Tính tổng delay theo mô hình store-and-forward.
2. Trong 20 giây, mạng chuyển 200 MB, gồm 15 MB header và 5 MB truyền lại. Tính throughput và goodput.
3. Một phép ping thu được RTT 10, 12, 11, 60 và 12 ms. Tính mean; giải thích vì sao mean có thể không đại diện tốt cho bốn phép đo đầu gần nhau.
4. Hãy phân loại các biến sau là định lượng hay phân loại:
 - `rtt_ms`;
 - `protocol`;
 - `destination_port`;
 - `packet_count`.

Lời giải bài luyện tập 2

1. Transmission delay mỗi liên kết: $1,500 \times 8 / (100 \times 10^6) = 0.12$ ms. Mỗi liên kết có $0.12 + 2 = 2.12$ ms. Ba liên kết: 6.36 ms. Kết quả dựa trên giả định mỗi nút nhận toàn bộ packet trước khi gửi tiếp.
2. Throughput: $200 \times 8 / 20 = 80$ Mbit/s. Dữ liệu hữu ích: $200 - 15 - 5 = 180$ MB. Goodput: $180 \times 8 / 20 = 72$ Mbit/s.
3. Mean: $(10 + 12 + 11 + 60 + 12) / 5 = 21$ ms. Giá trị 60 ms kéo mean lên cao; median là 12 ms mô tả vị trí trung tâm tốt hơn trong mẫu nhỏ này. Median sẽ được học kỹ ở phần phân tích dữ liệu.
4. Phân loại các biến:
 - `rtt_ms`: định lượng;
 - `protocol`: phân loại;

- `destination_port`: thường xử lý như phân loại/định danh dù viết bằng số;
- `packet_count`: định lượng rời rạc.

Bài luyện tập 3

1. Một người kết luận: “Bandwidth của đường truyền là 200 Mbit/s nên tải tệp 1 GB chắc chắn mất 40 giây.” Hãy chỉ ra giả định và giới hạn của kết luận.
2. Một máy chủ web phản hồi bình thường nhưng không trả lời ping. Có thể kết luận máy chủ ngừng hoạt động không? Giải thích.
3. Một biểu đồ có năm giá trị RTT nhưng không ghi đơn vị trục y. Vì sao biểu đồ chưa đủ để diễn giải?

Lời giải bài luyện tập 3

1. 1 GB thập phân tương đương 8 Gbit; $8,000/200 = 40$ giây là thời gian lý tưởng nếu đạt toàn bộ bandwidth, không overhead, không chia sẻ, không retransmission và không giới hạn server/ứng dụng. Trong thực tế thời gian thường lớn hơn.
2. Không. ICMP có thể bị firewall chặn trong khi HTTP/HTTPS vẫn hoạt động. Cần kiểm tra dịch vụ bằng công cụ phù hợp và nhiều nguồn bằng chứng.
3. Không biết giá trị là millisecond, second hay đơn vị khác; cũng không rõ mỗi điểm là packet, flow hay phép đo. Thiếu đơn vị và đơn vị quan sát làm kết luận không đáng tin cậy.

1.8.3 Câu hỏi trắc nghiệm

1. Thiết bị nào chủ yếu chuyển packet giữa các mạng khác nhau?
 - A. Router
 - B. Switch
 - C. Máy in
 - D. Bàn phím
2. Đại lượng nào mô tả tốc độ dữ liệu thực tế quan sát được?
 - A. Throughput
 - B. Propagation distance
 - C. Frame address
 - D. Session name
3. Công thức đúng của transmission delay là gì?
 - A. Kích thước packet theo bit chia tốc độ liên kết theo bit/s
 - B. Khoảng cách chia kích thước packet
 - C. Tốc độ lan truyền chia khoảng cách
 - D. Số packet chia số router
4. Trong các đơn vị sau, đơn vị nào thuộc tầng Data Link?
 - A. Frame
 - B. Segment
 - C. Message
 - D. Session
5. Phát biểu nào đúng về packet và frame?
 - A. Frame thường gắn với một chặng liên kết, packet phục vụ chuyển qua nhiều mạng
 - B. Packet chỉ tồn tại trong mạng cục bộ
 - C. Frame luôn giữ nguyên qua mọi router

- D. Hai thuật ngữ luôn đồng nghĩa trong mọi ngữ cảnh
6. Nếu gửi 250 packet và mất 5 packet, tỷ lệ mất là bao nhiêu?
- A. 2%
 - B. 5%
 - C. 20%
 - D. 0.5%
7. Biến `protocol` chứa các giá trị TCP, UDP và ICMP thuộc loại nào?
- A. Biến phân loại
 - B. Biến định lượng liên tục
 - C. Độ trễ truyền dẫn
 - D. Địa chỉ vật lý
8. Tính sẵn sàng tập trung vào mục tiêu nào?
- A. Người dùng hợp lệ có thể sử dụng dịch vụ khi cần
 - B. Mọi dữ liệu đều công khai
 - C. Không cần sao lưu
 - D. Không có bất kỳ packet nào trên mạng
9. Phát biểu nào đúng về ping?
- A. Ping đo RTT bằng ICMP nhưng không chứng minh đầy đủ trạng thái mọi dịch vụ
 - B. Ping luôn đo bandwidth chính xác
 - C. Không trả lời ping chắc chắn nghĩa là máy đã tắt
 - D. Ping thay thế được mọi công cụ giám sát
10. Một tệp 10 MB tương đương bao nhiêu megabit theo quy ước thập phân?
- A. 80 Mbit
 - B. 10 Mbit
 - C. 1.25 Mbit
 - D. 800 Mbit

1.8.4 Đáp án và giải thích

Lời giải

1. **Đáp án đúng:** A. Router chuyển packet giữa các mạng khác nhau; switch chủ yếu chuyển frame trong mạng cục bộ.
2. **Đáp án đúng:** A. Throughput là tốc độ dữ liệu thực tế trong một khoảng thời gian.
3. **Đáp án đúng:** A. $d_{trans} = L/R$, với L là số bit và R là bit/s.
4. **Đáp án đúng:** A. Frame là PDU của tầng Data Link.

5. **Đáp án đúng:** A. Router thường tháo frame cũ và tạo frame mới cho liên kết tiếp theo, trong khi packet tiếp tục đại diện cho chuyển giao tầng Network.
6. **Đáp án đúng:** A. $5/250 \times 100\% = 2\%$.
7. **Đáp án đúng:** A. Các giá trị là tên nhóm giao thức nên đây là biến phân loại.
8. **Đáp án đúng:** A. Availability bảo đảm dịch vụ và dữ liệu có thể được sử dụng bởi người hợp lệ khi cần.
9. **Đáp án đúng:** A. Ping là một phép đo ICMP có phạm vi hạn chế; firewall có thể chặn ICMP.
10. **Đáp án đúng:** A. $10 \text{ MB} \times 8 = 80 \text{ Mbit}$.

Chương 2

Phân tầng, đóng gói và mô hình TCP/IP

2.1 Mục tiêu và câu hỏi mở đầu

Câu hỏi mở đầu

Khi trình duyệt gửi một yêu cầu đến máy chủ ở bên kia Internet, ứng dụng không tự điều khiển sóng Wi-Fi, không tự chọn cổng ra của switch và cũng không tự tính đường đi qua từng router. Vậy hệ thống mạng phân chia công việc như thế nào để một ứng dụng vẫn hoạt động khi công nghệ liên kết thay đổi từ Ethernet sang Wi-Fi hoặc 5G?

Ví dụ: một hồ sơ đi qua nhiều bộ phận

Một hồ sơ từ người gửi đến người nhận có thể lần lượt đi qua bộ phận tiếp nhận, đóng gói, vận chuyển giữa các cơ sở và giao tận nơi. Mỗi bộ phận chỉ cần biết nhiệm vụ của mình và quy tắc bàn giao với bộ phận kế cận. Nếu phương tiện vận chuyển thay đổi từ xe máy sang xe tải, người viết hồ sơ không phải viết lại nội dung.

Góc nhìn mạng: bộ phận tương ứng với tầng; quy trình giữa các thực thể cùng loại tương ứng với giao thức; dịch vụ bàn giao cho tầng trên tương ứng với service/interface. **Giới hạn:** tầng mạng là mô hình logic, không phải các phòng ban vật lý tách biệt; một hệ điều hành có thể thực hiện nhiều tầng trong cùng một kernel hoặc tiến trình.

Sau khi hoàn thành phần này, người học có thể

- Giải thích được vì sao mạng máy tính cần phân tầng và giới hạn của cách tiếp cận này.
- Phân biệt được service, interface, protocol, SDU và PDU.
- Ánh xạ được OSI, TCP/IP bốn tầng và mô hình Internet năm tầng.
- Theo dõi được quá trình encapsulation/decapsulation và xác định đúng message, segment / datagram, packet, frame và bit.
- Xác định được địa chỉ/định danh chính ở từng tầng: tên ứng dụng, port, IP, MAC.
- Tính được overhead và tỷ lệ dữ liệu hữu ích trong một ví dụ đơn giản.
- Nhìn một bảng packet và giải thích được một hàng/field đại diện cho điều gì mà chưa cần dùng công cụ capture cụ thể.

Tình huống mạng hoạt động

Chương dùng một tình huống nhất quán: một laptop kết nối Wi-Fi, nhận cấu hình mạng, phân giải tên miền và truy cập một website HTTPS. Tình huống này sẽ được theo dõi qua từng tầng; các chi tiết của Ethernet, IP, TCP, DNS và HTTPS sẽ được học sâu ở các chương sau.

2.2 Vì sao mạng cần phân tầng?

2.2.1 Độ phức tạp của truyền thông mạng

Để một ứng dụng gửi được dữ liệu đến một ứng dụng khác, hệ thống phải giải quyết đồng thời nhiều vấn đề:

- biểu diễn thông điệp của ứng dụng;
- xác định tiến trình nhận;
- chia dữ liệu thành các đơn vị phù hợp;
- kiểm soát thứ tự, lỗi và tốc độ gửi khi cần;
- xác định máy đích và lựa chọn đường đi;
- truyền dữ liệu qua mạng cục bộ;
- biến bit thành tín hiệu vật lý;
- xử lý mất packet, tắc nghẽn, thay đổi đường đi và khác biệt công nghệ liên kết.

Nếu tất cả chức năng được đặt trong một khối duy nhất, việc thiết kế, kiểm thử và thay thế công nghệ sẽ rất khó. Phân tầng tạo ra các ranh giới chức năng để giảm mức độ phụ thuộc trực tiếp giữa các phần.

2.2.2 Phân chia chức năng thành các tầng

Một tầng là một nhóm chức năng có liên quan. Tầng trên không cần biết toàn bộ chi tiết triển khai của tầng dưới; nó chỉ cần biết dịch vụ được cung cấp và cách yêu cầu dịch vụ đó.

Ví dụ, trình duyệt không cần biết máy tính đang dùng Ethernet, Wi-Fi hay kết nối di động. Trình duyệt yêu cầu hệ điều hành gửi dữ liệu qua socket. Các tầng dưới chịu trách nhiệm đưa dữ liệu đến đích qua công nghệ liên kết đang có.

Phân tầng không có nghĩa mỗi tầng hoàn toàn độc lập

Các tầng vẫn phụ thuộc vào nhau thông qua dịch vụ và thông tin điều khiển. Ranh giới tầng là một mô hình tổ chức, không phải một bức tường tuyệt đối. Trong hệ thống thực tế, một số chức năng có thể được tối ưu xuyên tầng, nhưng việc phân tầng vẫn là nền tảng để mô tả và chuẩn hóa.

2.2.3 Khả năng thay thế và phát triển độc lập

Giả sử tầng Application sử dụng dịch vụ truyền dữ liệu tin cậy của TCP. Khi công nghệ liên kết thay đổi từ Ethernet sang Wi-Fi, TCP và ứng dụng nhìn chung không phải thiết kế lại. Tương tự, một trình

duyet có thể hoạt động trên nhiều hệ điều hành và nhiều loại mạng vì các tầng bên dưới cung cấp giao diện tương thích.

Lợi ích chính gồm:

- giảm phạm vi thay đổi khi thay thế công nghệ;
- cho phép nhiều nhóm phát triển làm việc song song;
- tạo điều kiện chuẩn hóa giao thức;
- đơn giản hóa kiểm thử và khắc phục sự cố;
- hỗ trợ tái sử dụng chức năng.

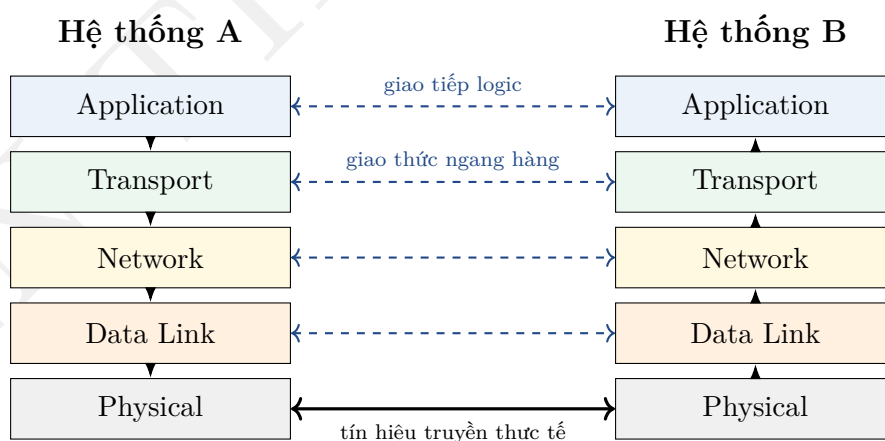
2.2.4 Khả năng tương tác giữa các hệ thống

Hai hệ thống của các nhà sản xuất khác nhau có thể liên lạc khi cùng tuân thủ các giao thức và định dạng đã công bố. Phân tầng giúp xác định rõ phần nào cần chuẩn hóa. Ví dụ:

- Ethernet chuẩn hóa cách tạo frame và truy nhập liên kết;
- IP chuẩn hóa định dạng packet và địa chỉ logic;
- TCP chuẩn hóa cơ chế truyền dữ liệu tin cậy;
- HTTP chuẩn hóa request và response của dịch vụ web.

2.2.5 Giao tiếp ngang hàng và truyền dữ liệu thực tế

Các thực thể cùng tầng ở hai hệ thống được mô tả là giao tiếp logic với nhau. TCP phía máy gửi dường như trao đổi TCP segment với TCP phía máy nhận. Tuy nhiên, segment không đi trực tiếp giữa hai thực thể TCP; nó được giao xuống IP, tiếp tục được đóng gói thành frame và truyền qua tín hiệu vật lý.



Hình 2.1: Giao tiếp logic giữa các tầng ngang hàng và đường truyền dữ liệu thực tế

2.2.6 Giới hạn của cách tiếp cận phân tầng

Phân tầng đem lại cấu trúc rõ ràng nhưng có các giới hạn:

- một số thông tin bị lặp lại ở nhiều tầng;
- header của các tầng tạo thêm overhead;
- ranh giới tầng quá cứng có thể làm giảm hiệu quả tối ưu;
- một chức năng có thể xuất hiện ở nhiều tầng, chẳng hạn mã hóa hoặc kiểm tra lỗi;
- các mô hình tầng khác nhau có thể dùng tên và cách nhóm chức năng khác nhau.

2.3 Dịch vụ, giao diện và giao thức

2.3.1 Dịch vụ của một tầng

Dịch vụ (service) mô tả tầng cung cấp điều gì cho tầng trên. Dịch vụ được nhìn từ phía người sử dụng tầng, không nhất thiết mô tả chi tiết cách tầng thực hiện công việc.

Ví dụ, TCP cung cấp cho ứng dụng một dòng byte tin cậy, có thứ tự. Ứng dụng không cần tự xử lý mọi packet mất hoặc đến sai thứ tự; TCP thực hiện các công việc đó.

2.3.2 Giao diện giữa hai tầng

Giao diện (interface) xác định cách tầng trên yêu cầu dịch vụ từ tầng dưới. Trong phần mềm mạng, socket API là một ví dụ về giao diện mà ứng dụng dùng để yêu cầu dịch vụ của tầng Transport.

Giao diện có thể gồm:

- các hàm hoặc lời gọi dịch vụ;
- tham số đầu vào;
- dữ liệu được chuyển xuống;
- trạng thái và lỗi trả về.

2.3.3 Giao thức giữa các thực thể ngang hàng

Giao thức (protocol) là tập hợp quy tắc quy định định dạng, thứ tự thông điệp và hành động của các thực thể cùng tầng. Một giao thức thường xác định:

- cú pháp: thông điệp có những trường nào;
- ngữ nghĩa: mỗi trường có ý nghĩa gì;
- thời điểm: khi nào gửi, chờ hoặc truyền lại;
- hành động: thực thể phải làm gì khi nhận một loại thông điệp.

Ví dụ: dịch vụ và giao thức không phải là một

TCP cung cấp dịch vụ truyền dữ liệu tin cậy cho ứng dụng. Để cung cấp dịch vụ đó, hai đầu TCP sử dụng giao thức gồm sequence number, acknowledgment, checksum, timeout và retransmission. Dịch vụ mô tả kết quả mà ứng dụng nhận được; giao thức mô tả quy tắc phối hợp giữa hai đầu TCP.

2.3.4 Đơn vị dữ liệu dịch vụ và đơn vị dữ liệu giao thức

Đơn vị dữ liệu dịch vụ (Service Data Unit, SDU) là dữ liệu tầng trên giao cho tầng dưới thông qua giao diện. Tầng dưới thêm thông tin điều khiển của mình để tạo thành *đơn vị dữ liệu giao thức* (Protocol Data Unit, PDU).

Có thể mô tả khái quát:

$$PDU_n = \text{Header}_n + \text{SDU}_n$$

Trong đó tầng n nhận SDU từ tầng trên và thêm header của tầng n . Ở Data Link, một số công nghệ còn thêm trailer.

2.3.5 Primitive dịch vụ ở mức khái niệm

Trong mô hình tham chiếu, dịch vụ đôi khi được mô tả bằng các *thao tác nguyên thủy* (primitive) – là một lệnh hoặc thao tác cơ bản, cho phép các tầng (layer) trong mô hình mạng giao tiếp với nhau qua *điểm truy cập dịch vụ* (Service Access Point - SAP), ví dụ như:

- REQUEST: tầng trên yêu cầu thực hiện một dịch vụ;
- INDICATION: tầng dưới thông báo một sự kiện đến tầng trên;
- RESPONSE: tầng trên phản hồi một indication;
- CONFIRM: tầng dưới xác nhận kết quả của request.

Người học không cần ghi nhớ mọi primitive cho từng giao thức, nhưng cần hiểu rằng dịch vụ có thể được mô tả độc lập với thông điệp giao thức ngang hàng.

2.3.6 Ví dụ tổng hợp: truy cập một website

Khi trình duyệt truy cập một website:

1. trình duyệt tạo HTTP request;
2. ứng dụng yêu cầu dịch vụ vận chuyển qua socket;
3. TCP hoặc QUIC sử dụng giao thức của tầng Transport;
4. IP cung cấp dịch vụ chuyển packet qua nhiều mạng;
5. Ethernet hoặc Wi-Fi cung cấp dịch vụ truyền frame trên liên kết hiện tại;
6. tầng Physical truyền bit dưới dạng tín hiệu.

Ở mỗi ranh giới, tầng trên sử dụng dịch vụ qua giao diện. Ở mỗi cặp thực thể ngang hàng, các bên tuân thủ giao thức tương ứng.

2.4 Các mô hình mạng OSI và TCP/IP

2.4.1 Nguồn gốc và mục đích

Mô hình *mô hình liên kết các hệ thống mở* (Open Systems Interconnection, OSI) của ISO được xây dựng như một mô hình tham chiếu nhằm mô tả chức năng truyền thông của các hệ thống mở. Giá trị quan trọng của OSI là cung cấp ngôn ngữ chung để phân loại chức năng, không phải khẳng định mọi giao thức Internet đều được thiết kế đúng theo bảy tầng tách biệt.

2.4.2 Physical và Data Link

Tầng Physical chịu trách nhiệm truyền bit qua môi trường vật lý. Nội dung thường gồm tín hiệu, đầu nối, tần số, điều chế, mã đường truyền và tốc độ truyền.

Tầng Data Link tạo frame, sử dụng địa chỉ trên liên kết, điều khiển truy nhập môi trường và phát hiện lỗi trên một liên kết. Ethernet và Wi-Fi thường được xếp vào tầng này, dù phần vật lý của chúng cũng quy định chi tiết thuộc tầng Physical.

2.4.3 Network và Transport

Tầng Network chịu trách nhiệm địa chỉ hóa logic, forwarding và routing packet qua nhiều mạng. IP là giao thức tiêu biểu.

Tầng Transport cung cấp truyền dữ liệu đầu cuối đến đầu cuối giữa các tiến trình. TCP cung cấp dịch vụ có kết nối và tin cậy; UDP cung cấp dịch vụ đơn giản, không thiết lập kết nối.

2.4.4 Session và Presentation

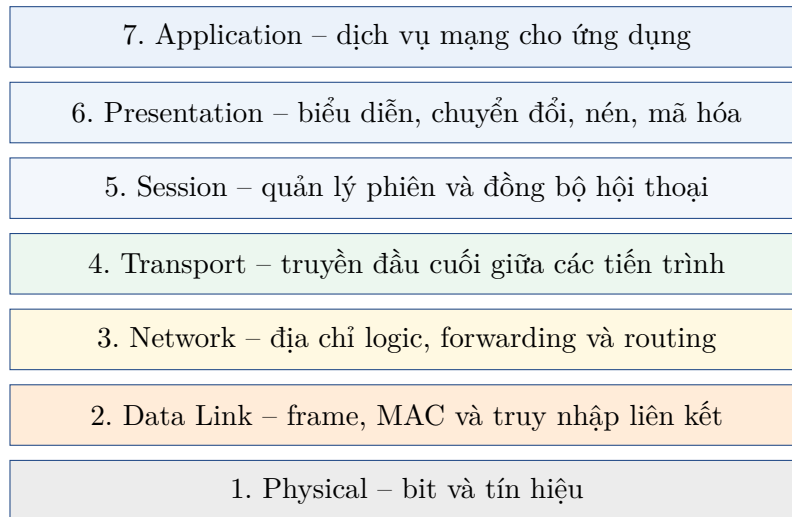
Tầng Session quản lý phiên giao tiếp, đồng bộ và điều phối hội thoại giữa các ứng dụng.

Tầng Presentation xử lý biểu diễn dữ liệu, chuyển đổi định dạng, mã hóa ký tự, nén và mã hóa ở mức trình bày.

Trong Internet hiện đại, các chức năng này thường được tích hợp vào thư viện, giao thức hoặc chính ứng dụng thay vì tồn tại như hai tầng độc lập rõ ràng.

Application. Tầng Application cung cấp các giao thức và dịch vụ trực tiếp cho chương trình người dùng, chẳng hạn HTTP, DNS, SMTP, SSH và DHCP. Tầng Application không đồng nhất với toàn bộ ứng dụng. Trình duyệt là một chương trình; HTTP là giao thức ứng dụng mà trình duyệt sử dụng.

2.4.5 Sơ đồ bảy tầng OSI



Hình 2.2: Bảy tầng của mô hình OSI

2.4.6 Giá trị và giới hạn của mô hình OSI

Mô hình OSI hữu ích khi:

- giải thích phạm vi chức năng;
- phân loại giao thức và thiết bị;
- khắc phục sự cố theo tầng;
- trao đổi kỹ thuật giữa các nhóm.

Tuy nhiên, không nên cố gắng ép mọi giao thức vào đúng một tầng duy nhất. Ví dụ, TLS thường được đặt giữa Application và Transport về mặt sử dụng, nhưng chức năng mã hóa có thể được diễn giải gần Presentation. Mục tiêu là hiểu chức năng, không phải tranh luận máy móc về một ô trong bảng.

2.4.7 Mô hình TCP/IP bốn tầng

Mô hình TCP/IP hình thành từ kiến trúc giao thức Internet thực tế. Cách trình bày phổ biến gồm bốn tầng:

1. Application;
2. Transport;
3. Internet;
4. Network Access hoặc Link.

So với OSI, mô hình TCP/IP gộp Session và Presentation vào Application; đồng thời gộp Data Link và Physical vào Network Access.

2.4.8 Mô hình Internet năm tầng dùng trong giáo trình

Để giảng dạy rõ hơn phần liên kết và phần vật lý, giáo trình sử dụng mô hình năm tầng:

1. Physical;
2. Data Link;
3. Network;
4. Transport;
5. Application.

Mô hình này không thay thế TCP/IP; nó tách tầng Network Access thành Data Link và Physical để thuận lợi khi học Ethernet, Wi-Fi, tín hiệu và độ trễ liên kết.

Phương pháp nhớ tên và vai trò năm tầng. Việc nhớ tên các tầng là cần thiết, tuy nhiên không nên nhớ kiểu học thuộc lòng hoặc sử dụng các câu viết tắt kiểu nhớ mẹo mà nên nhớ bền vững hơn bằng cách gắn mỗi tầng với một câu hỏi:

Bảng 2.1: Ghi nhớ các tầng bằng câu hỏi chức năng

Số	Tầng	Câu hỏi ghi nhớ
5	Application	Ứng dụng muốn trao đổi thông điệp gì?
4	Transport	Tiến trình nào nhận dữ liệu và cần mức tin cậy nào?
3	Network	Máy đích ở đâu và packet đi qua các mạng nào?
2	Data Link	Frame được chuyển qua liên kết hiện tại đến thiết bị kế tiếp thế nào?
1	Physical	Bit được biến thành tín hiệu và truyền trên môi trường nào?

Chuỗi ghi nhớ theo đối tượng

Ứng dụng tạo **message**; Transport chuyển giữa **process**; Network chuyển giữa **host qua nhiều mạng**; Data Link chuyển đến **nút kế tiếp trên liên kết**; Physical truyền **bit dưới dạng tín hiệu**.

2.4.9 Bảng ánh xạ tổng quát

Bảng 2.2: Ánh xạ giữa OSI, TCP/IP bốn tầng và mô hình Internet năm tầng

OSI	TCP/IP bốn tầng	Internet năm tầng
Application		
Presentation	Application	Application
Session		
Transport	Transport	Transport
Network	Internet	Network
Data Link	Network Access/Link	Data Link
Physical		Physical

Cách trả lời khi tài liệu dùng số tầng khác nhau. Người học nên trả lời theo ba bước:

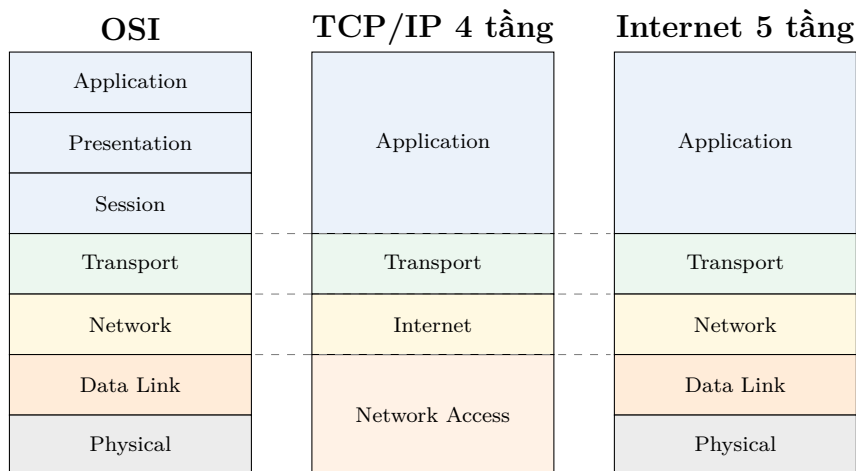
1. xác định tài liệu đang dùng mô hình nào;
2. nêu đúng số tầng và tên tầng trong mô hình đó;
3. ánh xạ sang mô hình năm tầng nếu cần so sánh.

Ví dụ: nếu hỏi “TCP thuộc tầng nào?”, câu trả lời là Transport trong cả OSI và TCP/IP. Nếu hỏi “Ethernet thuộc tầng nào?”, trong OSI và mô hình năm tầng là Data Link, còn trong TCP/IP bốn tầng thuộc Network Access/Link.

Bảng 2.3: Một số giao thức và vị trí thường dùng trong mô hình năm tầng

Tầng	Giao thức/công nghệ	Vai trò chính
Application	HTTP, DNS, DHCP, SMTP, SSH	Dịch vụ và thông điệp ứng dụng
Transport	TCP, UDP, QUIC	Truyền dữ liệu giữa các tiến trình
Network	IPv4, IPv6, ICMP	Địa chỉ logic và chuyển packet
Data Link	Ethernet, Wi-Fi, PPP	Frame và truyền trên liên kết
Physical	Cáp đồng, cáp quang, sóng vô tuyến	Bit và tín hiệu

Ví dụ phân loại giao thức.



Hình 2.3: Ảnh xạ trực quan giữa ba cách trình bày kiến trúc tầng

Sơ đồ ánh xạ trực quan.

2.5 Đóng gói, địa chỉ, thiết bị và overhead

2.5.1 Đóng gói dữ liệu

Khi dữ liệu đi xuống ngăn xếp giao thức, mỗi tầng thêm thông tin điều khiển của mình:

1. Application tạo message;
2. Transport thêm TCP/UDP header để tạo segment hoặc datagram;
3. Network thêm IP header để tạo packet;
4. Data Link thêm frame header và trailer;
5. Physical truyền chuỗi bit dưới dạng tín hiệu.

2.5.2 Tháo gói dữ liệu

Tại máy nhận, quá trình diễn ra theo chiều ngược lại. Mỗi tầng đọc và xử lý header của mình, kiểm tra điều kiện cần thiết rồi giao payload lên tầng trên. Nếu dữ liệu không hợp lệ hoặc không dành cho thực thể hiện tại, tầng có thể loại bỏ và ghi nhận lỗi.

2.5.3 PDU tại từng tầng

Bảng 2.4: Tên PDU thường dùng trong mô hình năm tầng

Tầng	Tên PDU thường dùng	Ghi chú
Application	Message hoặc Data	Tùy giao thức ứng dụng
Transport	TCP segment hoặc UDP datagram	Segment cho TCP; datagram cho UDP
Network	IP packet hoặc IP datagram	Giáo trình ưu tiên từ packet
Data Link	Frame	Có header và thường có trailer
Physical	Bits/Signals	Bit được biểu diễn bằng tín hiệu

2.5.4 Địa chỉ và định danh theo tầng

Bảng 2.5: Địa chỉ và định danh thường gặp

Tầng	Định danh	Phạm vi sử dụng
Application	Tên miền, URL, URI, tên dịch vụ	Định danh tài nguyên hoặc dịch vụ
Transport	Port number	Định danh tiến trình/dịch vụ trên host
Network	Địa chỉ IP	Định danh giao diện mạng và định tuyến qua nhiều mạng
Data Link	Địa chỉ MAC	Chuyển frame trên liên kết hoặc mạng cục bộ hiện tại
Physical	Không có địa chỉ giao thức tương đương	Truyền tín hiệu trên môi trường

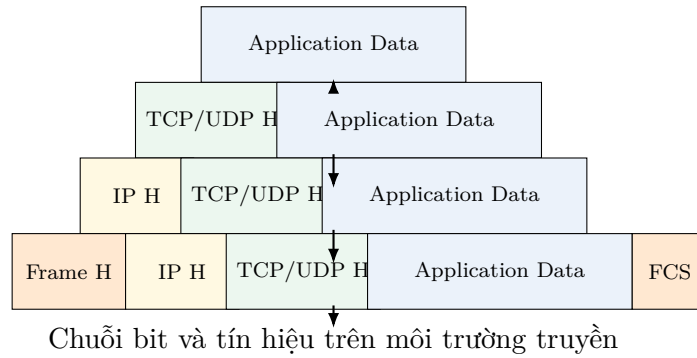
2.5.5 Thiết bị và phạm vi xử lý

Bảng 2.6: Thiết bị mạng và tầng xử lý chính

Thiết bị	Tầng chính	Thông tin thường xử lý
Repeater/Hub	Physical	Tín hiệu hoặc bit
Bridge/Switch	Data Link	MAC address và frame
Router	Network	địa chỉ IP và routing table
Stateful firewall	Network/Transport	IP, protocol, port và trạng thái kết nối
Proxy/Application gateway	Application	Thông điệp và chính sách ứng dụng

Một thiết bị hiện đại có thể xử lý nhiều tầng. Bảng trên nêu tầng chức năng chính, không phải giới hạn tuyệt đối.

2.5.6 Sơ đồ đóng gói



Hình 2.4: Quá trình đóng gói dữ liệu qua các tầng

2.5.7 Tính overhead và tỷ lệ dữ liệu hữu ích

Giả sử không xét padding, preamble và inter-frame gap. Nếu ứng dụng gửi D byte dữ liệu, tổng kích thước frame có thể được mô tả đơn giản:

$$L_{frame} = D + H_{transport} + H_{network} + H_{link} + T_{link}$$

Tỷ lệ dữ liệu hữu ích:

$$\eta = \frac{D}{L_{frame}} \times 100\%$$

Ví dụ 2.1: tính overhead khi dùng TCP/IPv4/Ethernet

Bài toán. Ứng dụng gửi 1200 byte dữ liệu. TCP header dài 20 byte, IPv4 header dài 20 byte, Ethernet header dài 14 byte và FCS dài 4 byte. Không xét preamble, inter-frame gap và padding. Tính kích thước frame, overhead và tỷ lệ dữ liệu hữu ích.

Lời giải.

$$L_{frame} = 1200 + 20 + 20 + 14 + 4 = 1258 \text{ byte}$$

$$Overhead = 20 + 20 + 14 + 4 = 58 \text{ byte}$$

$$\eta = \frac{1200}{1258} \times 100\% \approx 95.39\%$$

Ý nghĩa. Khoảng 95.39% số byte trong frame theo phạm vi tính này là dữ liệu ứng dụng. Kết quả chưa tính overhead vật lý, khoảng cách giữa các frame, ACK, retransmission hoặc các header tùy chọn.

2.5.8 Ảnh hưởng của kích thước payload

Khi header gần như cố định, payload nhỏ làm tỷ lệ overhead tăng. Đây là lý do không thể đánh giá hiệu quả chỉ bằng tốc độ liên kết; kích thước thông điệp, số packet, retransmission và cơ chế tầng dưới đều ảnh hưởng đến goodput.

Ví dụ 2.2: so sánh payload nhỏ và lớn

Vấn dùng tổng overhead 58 byte.

- Với payload 100 byte: $\eta = 100/158 \times 100\% \approx 63.29\%$.
- Với payload 1200 byte: $\eta \approx 95.39\%$.

Payload lớn làm tỷ lệ overhead thấp hơn. Tuy nhiên, không nên suy ra rằng payload càng lớn luôn càng tốt; giới hạn MTU, độ trễ, xác suất lỗi và yêu cầu ứng dụng vẫn phải được xem xét.

2.6 Luồng đi của dữ liệu mạng

2.6.1 Tình huống thực tế: truy cập website qua Wi-Fi

Xét máy tính xách tay truy cập một website qua Wi-Fi:

1. **Application:** trình duyệt tạo DNS query và HTTP/HTTPS request;
2. **Transport:** UDP/TCP/QUIC xác định port và cơ chế vận chuyển;
3. **Network:** IP xác định địa chỉ nguồn, đích và chuyển packet qua router;
4. **Data Link:** Wi-Fi tạo frame đến access point hoặc nút kế tiếp;
5. **Physical:** card Wi-Fi phát tín hiệu vô tuyến.

Trên đường đi, frame thay đổi theo từng liên kết, nhưng IP packet thường giữ địa chỉ đầu cuối, ngoại trừ trường hợp NAT hoặc cơ chế đặc biệt. Đây là điểm quan trọng để phân biệt phạm vi của Data Link và Network.

2.6.2 Một chuỗi giao thức thực tế

Khi máy vừa tham gia mạng rồi mở một website, một chuỗi điển hình có thể gồm:

1. DHCP hoặc cơ chế tương đương cung cấp cấu hình địa chỉ;
2. ARP/Neighbor Discovery tìm địa chỉ tầng liên kết của nút kế tiếp;
3. DNS phân giải tên miền thành địa chỉ IP;
4. TCP thiết lập connection hoặc QUIC sử dụng UDP tùy ứng dụng;
5. TLS thiết lập kênh bảo mật khi dùng HTTPS;
6. HTTP gửi request và nhận response.

Các giao thức không phải sáu “mạng” độc lập. Chúng phối hợp theo quan hệ lớp trên–lớp dưới và theo thời điểm. Trong các chương sau, mỗi giao thức sẽ được học bằng cùng một khung: tầng, PDU, header/field, địa chỉ, trạng thái và tình huống sử dụng.

Thực hành liên quan

Thực hành liên quan nằm trong Module 01, dùng dữ liệu của chính luồng giao tiếp đã mô tả ở đây. Việc phân tích packet bằng Wireshark được trình bày riêng trong phụ lục bổ trợ.

2.6.3 Bảng hồ sơ năm tầng để tự kiểm tra

Khi gặp một giao thức hoặc một trường header mới, người học có thể tự đặt năm câu hỏi: nó thuộc tầng nào, PDU nào, định danh nào, thiết bị nào chủ yếu xử lý và phạm vi hiệu lực đến đâu. Bảng sau là khung tham chiếu tối thiểu.

Tầng	PDU điển hình	Định danh	Thiết bị/điểm xử lý	Ví dụ
Application	message	tên tài nguyên dịch vụ	endpoint / application	HTTP, DNS, DHCP
Transport	segment / datagram	/ port	endpoint OS	TCP, UDP, QUIC*
Network	packet / datagram	/ địa chỉ IP	router / end-point	IPv4, IPv6, ICMP
Data Link	frame	MAC / địa chỉ liên kết	switch / NIC / AP	Ethernet, Wi-Fi
Physical	bit / symbol	–	PHY, môi trường truyền	cáp, quang, radio

Dấu * nhắc rằng QUIC chạy trên UDP nhưng cung cấp nhiều chức năng transport ở user space; đây là ví dụ cho thấy mô hình tầng giúp tư duy nhưng không phải mọi hệ thống hiện đại đều khớp hoàn hảo với một hộp duy nhất.

2.6.4 Header thay đổi ở đâu khi qua router?

Xét một host A gửi dữ liệu đến host B qua router R. Ở liên kết A–R, frame mang MAC của A và interface R phía A; tại R, frame cũ kết thúc. Router xử lý IP packet rồi tạo frame mới cho liên kết kế tiếp. Vì vậy:

- Data Link header/trailer thường được tạo lại theo từng hop;
- IP source/destination đầu cuối thường được giữ qua router thông thường, ngoại trừ NAT hoặc cơ chế đặc biệt;
- TTL/Hop Limit thay đổi theo hop;
- TCP/UDP port gắn với endpoint và không phải trường để switch Ethernet quyết định forwarding.

Bài suy luận nhanh

Nếu một capture ở hai phía của cùng router cho thấy destination MAC khác nhau nhưng destination IP giống nhau, đây thường là hành vi bình thường của encapsulation theo từng liên kết. Không nên kết luận packet bị “đổi đích” chỉ vì MAC thay đổi.

2.7 Phân tích theo tầng về an toàn và góc nhìn dữ liệu

2.7.1 An toàn mạng theo từng tầng

Góc nhìn an toàn, an ninh mạng

Tầng	Ví dụ nguy cơ	Ví dụ biện pháp
Application	Phishing, lỗi ứng dụng, đánh cắp phiên	Xác thực mạnh, kiểm tra đầu vào, HTTPS, chính sách ứng dụng
Transport	SYN flood, lạm dụng port, reset giả	Stateful firewall, rate limiting, SYN cookies
Network	IP spoofing, route hijacking, ICMP abuse	ACL, lọc nguồn, bảo vệ định tuyến, giám sát
Data Link	ARP poisoning, MAC flooding, evil twin	Segmentation, port security, WPA2/WPA3, kiểm tra ARP
Physical	Nghe lén tín hiệu, cắt cáp, phá hoại thiết bị	Kiểm soát vật lý, dự phòng, che chắn và giám sát

2.7.2 Phòng vệ nhiều lớp

Phòng vệ nhiều lớp (defense in depth) sử dụng nhiều cơ chế bảo vệ ở các tầng và vị trí khác nhau. Không một biện pháp đơn lẻ giải quyết mọi nguy cơ:

- HTTPS bảo vệ nội dung ứng dụng nhưng không ngăn mọi DoS;
- firewall lọc kết nối nhưng không tự sửa lỗi logic của ứng dụng;
- mã hóa Wi-Fi bảo vệ liên kết vô tuyến nhưng không thay thế xác thực ứng dụng;
- NAT thay đổi địa chỉ nhưng không phải là cơ chế bảo mật toàn diện.

2.7.3 Góc nhìn dữ liệu: một packet như một hàng

Một bảng packet tối thiểu có thể gồm:

Bảng 2.7: Data dictionary tối thiểu cho một bảng packet

Cột	Kiểu	Đơn vị	Ý nghĩa
frame.time_relative	float	second	Thời gian tương đối từ đầu capture
ip.src	string	–	Địa chỉ IP nguồn
ip.dst	string	–	Địa chỉ IP đích
transport	category	–	TCP hoặc UDP
src_port	integer	–	Port nguồn
dst_port	integer	–	Port đích
frame.len	integer	byte	Độ dài frame quan sát được
app_protocol	category	–	DNS, HTTP hoặc giao thức khác

Mỗi hàng phải được hiểu đúng là một packet hoặc frame quan sát được, không phải một flow hoàn chỉnh. Việc nhầm đơn vị quan sát sẽ dẫn đến kết luận sai ở các chương phân tích dữ liệu và học máy.

2.7.4 Nhầm lẫn thường gặp

Nhầm lẫn thường gặp

- **Nhầm mô hình với bộ giao thức:** OSI là mô hình tham chiếu; TCP/IP vừa là kiến trúc vừa gắn với bộ giao thức Internet.
- **Nhầm dịch vụ với giao thức:** dịch vụ mô tả điều tầng cung cấp; giao thức mô tả quy tắc giữa các thực thể ngang hàng.
- **Cho rằng Session và Presentation biến mất:** chức năng vẫn tồn tại nhưng thường được gộp vào Application.
- **Cho rằng MAC đi xuyên Internet:** MAC phục vụ liên kết hiện tại và có thể thay đổi ở mỗi hop.
- **Cho rằng router chỉ nhìn một trường:** tầng chính là Network, nhưng router hiện đại có thể xử lý thêm thông tin ở nhiều tầng.
- **Đếm PDU máy móc:** tên PDU phụ thuộc ngữ cảnh; cần hiểu payload và header hơn là tranh luận thuật ngữ.

Cơ sở khoa học dữ liệu: packet như một bản ghi có cấu trúc

Một packet quan sát được có thể biểu diễn thành một hàng dữ liệu với các trường như thời điểm, địa chỉ nguồn/đích, protocol và độ dài. Ở giai đoạn này, điều quan trọng chưa phải là pandas hay một thư viện cụ thể, mà là hai ý niệm:

- một hàng cần có **đơn vị quan sát** rõ ràng, ở đây là một packet;
- một field phải có **ý nghĩa, kiểu và đơn vị** rõ ràng trước khi dùng cho thống kê hay ML.

Các chương sau sẽ lần lượt đưa dữ liệu này vào array, DataFrame, biểu đồ và feature matrix.

2.8 Tổng kết chương

2.8.1 Tóm tắt chương

1. Phân tầng chia hệ thống truyền thông phức tạp thành các nhóm chức năng có ranh giới tương đối rõ.
2. Tầng trên sử dụng **dịch vụ** của tầng dưới qua **giao diện**; các thực thể cùng tầng trao đổi theo **giao thức**.
3. OSI có bảy tầng; TCP/IP thường được trình bày bằng bốn tầng; giáo trình dùng mô hình Internet năm tầng để tách Data Link và Physical.
4. Ba cách trình bày không mâu thuẫn nếu người học hiểu cách ánh xạ chức năng.
5. Đóng gói thêm header hoặc trailer ở mỗi tầng; tháo gói xử lý các thông tin đó theo chiều ngược lại.
6. Application gắn với message và dịch vụ; Transport gắn với process và port; Network gắn với IP và routing; Data Link gắn với frame và MAC; Physical gắn với bit và tín hiệu.
7. Header tạo overhead; payload nhỏ thường có tỷ lệ overhead lớn hơn.
8. Nguy cơ an toàn xuất hiện ở nhiều tầng, vì vậy cần phòng vệ nhiều lớp.
9. Khi phân tích packet, phải xác định rõ đơn vị quan sát và phạm vi của từng địa chỉ.

2.8.2 Bài luyện tập

Bài 2.1. Phân biệt dịch vụ, giao diện và giao thức bằng ví dụ TCP và socket.

Bài 2.2. Ánh xạ bảy tầng OSI sang TCP/IP bốn tầng và mô hình Internet năm tầng.

Bài 2.3. Cho các đối tượng: DNS, TCP, IPv4, Ethernet, cáp quang. Xếp chúng vào mô hình năm tầng và giải thích ngắn vai trò.

Bài 2.4. Khi host A gửi packet đến host B nằm ngoài subnet, địa chỉ IP đích và địa chỉ MAC đích trong frame đầu tiên thuộc về thiết bị nào?

Bài 2.5. Một ứng dụng gửi 500 byte dữ liệu qua UDP/IPv4/Ethernet. UDP header 8 byte, IPv4 header 20 byte, Ethernet header 14 byte và FCS 4 byte. Không xét phần khác. Tính kích thước frame và tỷ lệ dữ liệu hữu ích.

Bài 2.6. Với cùng overhead ở Bài 2.5, tính tỷ lệ dữ liệu hữu ích nếu payload chỉ có 50 byte. Nhận xét.

Bài 2.7. Một người cho rằng “HTTPS thuộc tầng Presentation nên không thuộc tầng Application”. Hãy phân tích nhận định.

Bài 2.8. Xác định tầng chính của hub, switch, router, stateful firewall và proxy. Giải thích vì sao từ “tầng chính” là cần thiết.

Bài 2.9. Nêu một nguy cơ và một biện pháp bảo vệ ở mỗi tầng của mô hình năm tầng.

Bài 2.10. Một bảng CSV có mỗi hàng là một packet. Có thể dùng số hàng để kết luận số kết nối TCP hay không? Giải thích.

Bài 2.11. Phát hiện lỗi trong lời giải sau: “Payload 1000 byte, tổng header 60 byte, vì vậy hiệu suất bằng $60/1000 = 6\%$.”

Bài 2.12. Vẽ lại quá trình đóng gói một DNS query dùng UDP/IPv4/Ethernet và ghi tên PDU ở từng tầng.

2.8.3 Lời giải bài luyện tập

Lời giải Bài 2.1

TCP cung cấp **dịch vụ** truyền byte tin cậy, có thứ tự cho ứng dụng. Socket API là một **giao diện** để ứng dụng yêu cầu dịch vụ vận chuyển. TCP sử dụng **giao thức** giữa hai đầu, gồm sequence number, acknowledgment, timeout và retransmission.

Lời giải Bài 2.2

OSI Application, Presentation và Session ánh xạ vào Application của TCP/IP. OSI Transport ánh xạ Transport. OSI Network ánh xạ Internet/Network. OSI Data Link và Physical cùng ánh xạ Network Access trong TCP/IP bốn tầng; trong mô hình năm tầng chúng được giữ riêng.

Lời giải Bài 2.3

DNS: Application; TCP: Transport; IPv4: Network; Ethernet: Data Link; cáp quang: Physical. Cách xếp dựa trên chức năng chính, không chỉ dựa vào tên công nghệ.

Lời giải Bài 2.4

Địa chỉ IP đích vẫn là địa chỉ của host B. Địa chỉ MAC đích trong frame đầu tiên thường là MAC của default gateway, vì B nằm ngoài subnet. Router tháo frame cũ và tạo frame mới cho liên kết kế tiếp.

Lời giải Bài 2.5

Tổng overhead: $8 + 20 + 14 + 4 = 46$ byte. Kích thước frame: $500 + 46 = 546$ byte.

$$\eta = \frac{500}{546} \times 100\% \approx 91.58\%.$$

Kết quả chưa tính overhead vật lý, padding, inter-frame gap hoặc phản hồi.

Lời giải Bài 2.6

Kích thước frame: $50 + 46 = 96$ byte.

$$\eta = \frac{50}{96} \times 100\% \approx 52.08\%.$$

Payload nhỏ làm overhead chiếm tỷ lệ lớn hơn.

Lời giải Bài 2.7

Trong OSI, chức năng mã hóa và biểu diễn có thể được liên hệ với Presentation. Trong kiến trúc TCP/IP, HTTPS được xem là dịch vụ ứng dụng dùng HTTP kết hợp TLS. Không nên kết luận HTTPS “không thuộc Application” chỉ vì một phần chức năng gần với Presentation. Cần nêu rõ

mô hình đang sử dụng.

Lời giải Bài 2.8

Hub: Physical; switch: Data Link; router: Network; stateful firewall: chủ yếu Network/Transport; proxy: Application. Từ “tầng chính” cần thiết vì thiết bị hiện đại có thể đọc và xử lý thông tin ở nhiều tầng.

Lời giải Bài 2.9

Ví dụ: Application – phishing/HTTPS và xác thực; Transport – SYN flood/rate limiting; Network – IP spoofing/ACL và lọc nguồn; Data Link – ARP poisoning/segmentation và kiểm tra ARP; Physical – cắt cáp/kiểm soát vật lý và dự phòng.

Lời giải Bài 2.10

Không. Một kết nối TCP có thể tạo nhiều packet, và một file capture có thể chứa packet của nhiều kết nối. Muốn đếm flow cần nhóm theo các trường nhận diện, thường gồm địa chỉ nguồn, địa chỉ đích, port nguồn, port đích và giao thức, đồng thời xem xét chiều và thời gian.

Lời giải Bài 2.11

$60/1000 = 6\%$ là tỷ lệ overhead so với payload, không phải hiệu suất. Kích thước tổng là 1060 byte; hiệu suất là $1000/1060 \times 100\% \approx 94.34\%$. Nếu muốn tỷ lệ overhead trên tổng, dùng $60/1060 \times 100\% \approx 5.66\%$.

Lời giải Bài 2.12

Application: DNS message; Transport: UDP datagram gồm UDP header và DNS message; Network: IPv4 packet gồm IP header và UDP datagram; Data Link: Ethernet frame gồm Ethernet header, IP packet và FCS; Physical: chuỗi bit/tín hiệu.

2.8.4 Câu hỏi trắc nghiệm

Câu 1. Phát biểu nào mô tả đúng nhất về dịch vụ của một tầng?

- A. Quy tắc trao đổi giữa hai thực thể ngang hàng.
- B. Điều tầng cung cấp cho tầng trên.
- C. Cấu trúc tín hiệu trên môi trường truyền.
- D. Danh sách địa chỉ của các router.

Câu 2. Trong mô hình Internet năm tầng, giao thức TCP thuộc tầng nào?

- A. Application.
- B. Transport.
- C. Network.
- D. Data Link.

Câu 3. Ba tầng nào của OSI thường được gộp vào Application trong TCP/IP?

- A. Application, Presentation và Session.
- B. Session, Transport và Network.

- C. Network, Data Link và Physical.
- D. Presentation, Network và Physical.

Câu 4. Khi packet đi qua một router thông thường, thông tin nào thường thay đổi theo từng liên kết?

- A. Tên miền trong DNS query.
- B. Địa chỉ IP đích cuối cùng.
- C. Ethernet header và địa chỉ MAC.
- D. Port đích của dịch vụ.

Câu 5. Đơn vị dữ liệu thường gọi tại tầng Data Link là gì?

- A. Message.
- B. Segment.
- C. Packet.
- D. Frame.

Câu 6. Điểm khác biệt chính giữa TCP/IP bốn tầng và mô hình Internet năm tầng là gì?

- A. Mô hình năm tầng bỏ tầng Transport.
- B. Mô hình năm tầng tách Network Access thành Data Link và Physical.
- C. Mô hình năm tầng gộp Network vào Application.
- D. Mô hình năm tầng không dùng IP.

Câu 7. Phát biểu nào đúng về giao thức?

- A. Giao thức chỉ mô tả dịch vụ cho tầng trên.
- B. Giao thức quy định định dạng, thứ tự thông điệp và hành động giữa các thực thể ngang hàng.
- C. Giao thức luôn phải hoạt động ở tầng Application.
- D. Một giao thức không có header.

Câu 8. Thiết bị nào có tầng xử lý chính là Network?

- A. Hub.
- B. Switch lớp 2.
- C. Router.
- D. Repeater.

Câu 9. Vì sao payload nhỏ thường có tỷ lệ overhead lớn hơn?

- A. Vì header cố định hoặc ít thay đổi chiếm tỷ lệ lớn hơn trong tổng dữ liệu.
- B. Vì địa chỉ IP biến mất.
- C. Vì tầng Physical không truyền bit.
- D. Vì UDP luôn thêm nhiều header hơn TCP.

Câu 10. Phát biểu nào phù hợp nhất với phòng vệ nhiều lớp?

- A. Chỉ cần mã hóa ở Application là đủ cho mọi nguy cơ.
- B. Chỉ cần NAT là không cần firewall.
- C. Kết hợp nhiều biện pháp ở các tầng và vị trí khác nhau.
- D. Chỉ bảo vệ tầng Physical vì các tầng khác là logic.

2.8.5 Đáp án và giải thích

Câu 1. Đáp án đúng: B. Dịch vụ mô tả điều tầng cung cấp cho tầng trên; giao thức mới là quy tắc trao đổi giữa các thực thể ngang hàng.

Câu 2. Đáp án đúng: B. TCP cung cấp truyền dữ liệu giữa các tiến trình đầu cuối nên thuộc Transport.

Câu 3. Đáp án đúng: A. TCP/IP gộp Application, Presentation và Session của OSI vào Application.

Câu 4. Đáp án đúng: C. Frame được tạo lại trên từng liên kết, nên địa chỉ MAC và header Data Link có thể thay đổi ở mỗi hop.

Câu 5. Đáp án đúng: D. PDU của Data Link thường được gọi là frame.

Câu 6. Đáp án đúng: B. Mô hình năm tầng tách Network Access/Link thành Data Link và Physical để mô tả chi tiết hơn.

Câu 7. Đáp án đúng: B. Giao thức quy định cú pháp, ngữ nghĩa, thứ tự và hành động giữa các thực thể ngang hàng.

Câu 8. Đáp án đúng: C. Router thực hiện forwarding dựa trên địa chỉ Network, chủ yếu là địa chỉ IP.

Câu 9. Đáp án đúng: A. Khi header gần như cố định, payload nhỏ làm phần header chiếm tỷ lệ lớn hơn trong tổng số byte.

Câu 10. Đáp án đúng: C. Phòng vệ nhiều lớp kết hợp kiểm soát ở nhiều tầng, nhiều vị trí và nhiều giai đoạn phòng ngừa, phát hiện, giảm thiểu, phục hồi.

Phần II

TCP/IP và các giao thức

Chương 3

Truyền dẫn, Ethernet và tầng liên kết dữ liệu

3.1 Mục tiêu và câu hỏi mở đầu

3.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Một máy tính gửi packet IP đến máy chủ trong cùng mạng cục bộ. Packet đó không tự “bay” qua dây mạng. Nó phải được đặt vào một Ethernet frame, biến thành chuỗi bit, rồi các bit được biểu diễn bằng tín hiệu điện, quang hoặc vô tuyến. Vì sao cần nhiều lớp biểu diễn như vậy? Tại sao switch quan tâm đến địa chỉ MAC, còn router quan tâm đến địa chỉ IP? Và khi một bit bị sai trên đường truyền, hệ thống phát hiện bằng cách nào?

Trong đời thường, một cuốn sách muốn được chuyển từ kho đến người mua phải trải qua nhiều hình thức biểu diễn: nội dung sách nằm trong cuốn sách; cuốn sách được đặt vào hộp; hộp có nhãn giao nhận; xe tải chở hộp trên một chặng; tại kho trung chuyển, hộp có thể được chuyển sang xe khác. Nội dung không đổi, nhưng phương tiện và thông tin điều khiển của từng chặng có thể thay đổi.

Ví dụ: hành khách và các chặng phương tiện

Một hành khách đi từ nhà đến một thành phố khác có thể đi bộ ra bến, lên xe buýt, chuyển sang tàu, rồi đi taxi ở chặng cuối. Mỗi chặng dùng một phương tiện và quy tắc cục bộ khác nhau. Vé tàu không thay thế địa chỉ nơi đến; biển số xe buýt không phải tên của hành khách.

Trong mạng, packet IP tương tự mục tiêu hành trình xuyên qua nhiều mạng, còn frame tương tự phương tiện của một chặng liên kết. Khi packet qua router, frame cũ kết thúc và một frame mới được tạo cho liên kết kế tiếp.

Giới hạn của mạng: hành khách là một vật thể liên tục, còn dữ liệu được tái biểu diễn thành tín hiệu trên từng liên kết. Ví dụ chỉ giúp phân biệt phạm vi end-to-end của packet với phạm vi từng chặng của frame.

3.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Giải thích được vai trò của tầng Physical và tầng Data Link trong mô hình Internet năm tầng.
- Phân biệt được bit, tín hiệu, frame, packet và payload.
- Tính được transmission delay, propagation delay, tổng độ trễ liên kết và hiệu suất frame.
- Mô tả được các trường chính của Ethernet frame và ý nghĩa của địa chỉ MAC.
- Giải thích được cách switch học địa chỉ, chuyển tiếp, lọc và flooding frame.
- Phân biệt được unicast, multicast, broadcast, collision domain và broadcast domain.
- Trình bày được mục đích của VLAN, access port, trunk port và thẻ IEEE 802.1Q ở mức nền tảng.
- Giải thích được nguyên lý phát hiện lỗi bằng parity, checksum và CRC ở mức trực quan.
- Sử dụng pandas và Matplotlib để thống kê, lọc và trực quan hóa dữ liệu Ethernet.
- Nhận diện được một số nguy cơ ở tầng Data Link và các biện pháp phòng vệ cơ bản.

3.2 Nguyên lý truyền dẫn

3.2.1 Bit và tín hiệu không phải là một khái niệm

bit (bit) là đơn vị thông tin logic có giá trị 0 hoặc 1. Bit không tự tồn tại dưới dạng một vật thể nhìn thấy được trên dây. Tầng Physical phải chọn một cách biểu diễn bit bằng trạng thái vật lý có thể truyền và nhận.

Môi trường	Dạng tín hiệu thường gặp	Ví dụ cách biểu diễn
Cáp đồng	Điện áp hoặc biến thiên điện	Mức điện áp, chuyển trạng thái, mã đường truyền
Cáp quang	Xung ánh sáng	Có hoặc không có xung, thay đổi pha hoặc cường độ
Không dây	Sóng điện từ	Thay đổi biên độ, tần số hoặc pha

Ví dụ: bản nhạc và âm thanh

Bản nhạc trên giấy là một cách mô tả logic. Khi biểu diễn, các ký hiệu được chuyển thành âm thanh trong không khí. Cùng một bản nhạc có thể được chơi bằng đàn piano, violin hoặc phát từ loa. Nội dung logic tương tự, nhưng tín hiệu vật lý khác nhau.

Trong mạng, cùng một chuỗi bit có thể đi qua cáp đồng, cáp quang và Wi-Fi trên các chặng khác nhau.

Giới hạn: tín hiệu mạng được mã hóa theo quy tắc kỹ thuật chính xác; không nên hiểu rằng mỗi bit luôn tương ứng đơn giản với “có điện” hoặc “không có điện”.

3.2.2 Môi trường truyền dẫn

Môi trường truyền dẫn có thể chia thành hai nhóm:

- *Có dẫn hướng* (guided media): tín hiệu đi trong cáp xoắn đôi, cáp đồng trục hoặc cáp quang.
- *Không dẫn hướng* (unguided media): tín hiệu lan truyền trong không gian, chẳng hạn Wi-Fi hoặc mạng di động.

Mỗi môi trường có đặc điểm riêng về băng thông, khoảng cách, suy hao, nhiễu, chi phí và khả năng triển khai. Không có một môi trường luôn tốt nhất cho mọi bài toán.

3.2.3 Bit rate, symbol rate và khả năng mang dữ liệu

Tốc độ bit (bit rate) là số bit được truyền trong một giây, thường ký hiệu là bit/s. *Tốc độ ký hiệu* (symbol rate) là số ký hiệu tín hiệu được phát trong một giây. Một symbol có thể biểu diễn một hoặc nhiều bit tùy cách điều chế hoặc mã hóa.

Nếu một symbol biểu diễn k bit và tốc độ symbol là S symbol/s, tốc độ bit lý tưởng là:

$$R = kS.$$

Ví dụ 4.1: từ symbol rate sang bit rate

Một hệ thống phát 1,000,000 symbol/s. Mỗi symbol có bốn trạng thái và do đó biểu diễn $\log_2 4 = 2$ bit. Tốc độ bit lý tưởng là:

$$R = 2 \times 1,000,000 = 2,000,000 \text{ bit/s} = 2 \text{ Mbit/s}.$$

Kết quả không nói rằng ứng dụng nhận được 2 Mbit/s dữ liệu hữu ích, vì còn có overhead và các yếu tố thực tế khác.

3.2.4 Suy hao, nhiễu và méo tín hiệu

Suy hao (attenuation) làm biên độ tín hiệu giảm theo khoảng cách. *Nhiễu* (noise) là năng lượng không mong muốn làm khó phân biệt tín hiệu. *Méo* (distortion) làm các thành phần của tín hiệu thay đổi không đồng đều.

Trong đời thường, giọng nói càng xa càng nhỏ; tiếng ồn trong phòng làm người nghe khó hiểu; tiếng vang làm câu nói bị kéo dài. Đây là các phép liên tưởng gần với suy hao, nhiễu và méo, nhưng tín hiệu số được xử lý bằng các phương pháp kỹ thuật cụ thể hơn nhiều.

3.2.5 Song công và chia sẻ môi trường

- *đơn công* (simplex): dữ liệu chỉ đi một chiều.
- *bán song công* (half-duplex): hai chiều nhưng không đồng thời.
- *song công toàn phần* (full-duplex): hai chiều đồng thời.

Ethernet hiện đại qua switch thường hoạt động full-duplex trên từng liên kết điểm-điểm. Wi-Fi dùng môi trường chia sẻ nên cách truy nhập khác và được trình bày ở Chương 9.

3.2.6 Giới hạn của tốc độ danh nghĩa

Một liên kết ghi “1 Gbit/s” mô tả tốc độ truyền bit danh nghĩa của công nghệ trong điều kiện xác định. Nó không đảm bảo ứng dụng luôn đạt 1 Gbit/s. Throughput thực tế còn phụ thuộc:

- overhead của frame và các tầng trên;
- năng lực thiết bị đầu cuối và switch;
- số luồng cùng chia sẻ tài nguyên;
- lỗi và retransmission;
- bottleneck ở chặng khác.

Nhầm lẫn thường gặp

Sai: “Cáp 1 Gbit/s nghĩa là tải tệp 1 GB trong một giây.”

1 Gbit/s bằng 125 MB/s về mặt đổi đơn vị, nhưng thời gian thực tế còn có overhead, tốc độ đĩa, giao thức, máy chủ và các chặng khác. Một tệp 1 GB thường cần lâu hơn 8 giây trên liên kết 1 Gbit/s.

3.3 Độ trễ và hiệu suất trên liên kết

3.3.1 Transmission delay

Độ trễ truyền dẫn (transmission delay) là thời gian cần để đẩy toàn bộ L bit của một frame hoặc packet lên liên kết có tốc độ R bit/s:

$$d_{\text{trans}} = \frac{L}{R}.$$

Đại lượng này phụ thuộc kích thước dữ liệu và tốc độ liên kết, không phụ thuộc trực tiếp vào khoảng cách.

Ví dụ: đoàn tàu qua cổng soát vé

Nếu 100 hành khách phải đi qua một cổng và cổng xử lý 10 người mỗi phút, cần 10 phút để toàn bộ đoàn đi qua. Khoảng cách từ cổng đến sân ga không ảnh hưởng thời gian “đưa hết người qua cổng”.

Tương tự, transmission delay đo thời gian đẩy toàn bộ bit lên liên kết, không đo thời gian bit đầu tiên lan đến đầu kia.

3.3.2 Propagation delay

Độ trễ lan truyền (propagation delay) là thời gian tín hiệu đi qua khoảng cách d với tốc độ lan truyền v :

$$d_{\text{prop}} = \frac{d}{v}.$$

Đại lượng này phụ thuộc khoảng cách và môi trường, không phụ thuộc trực tiếp vào kích thước frame.

3.3.3 Phân biệt hai loại độ trễ

Tiêu chí	Transmission delay	Propagation delay
Phụ thuộc kích thước dữ liệu	Có	Không
Phụ thuộc tốc độ liên kết	Có	Không trực tiếp
Phụ thuộc khoảng cách	Không	Có
Phụ thuộc tốc độ lan truyền	Không	Có
Câu hỏi trả lời	Bao lâu để đẩy hết bit?	Bao lâu tín hiệu đi hết chặng?

3.3.4 Ví dụ tính toán tổng hợp

Ví dụ 4.2: truyền một frame qua cáp

Một frame dài 1,500 byte được truyền trên liên kết 100 Mbit/s dài 2 km. Giả sử tốc độ lan truyền là 2×10^8 m/s.

Bước 1: đổi kích thước sang bit.

$$L = 1,500 \times 8 = 12,000 \text{ bit.}$$

Bước 2: transmission delay.

$$d_{\text{trans}} = \frac{12,000}{100 \times 10^6} = 1.2 \times 10^{-4} \text{ s} = 120 \mu\text{s.}$$

Bước 3: propagation delay.

$$d_{\text{prop}} = \frac{2,000}{2 \times 10^8} = 10^{-5} \text{ s} = 10 \mu\text{s.}$$

Nếu bỏ qua processing và queueing, thời gian từ lúc bắt đầu phát bit đầu tiên đến khi bit cuối cùng tới đích xấp xỉ:

$$120 + 10 = 130 \mu\text{s.}$$

3.3.5 Hiệu suất frame

Nếu một frame có payload P byte và tổng overhead tầng liên kết là H byte, hiệu suất ở mức đơn giản là:

$$\eta = \frac{P}{P + H} \times 100\%.$$

Ví dụ 4.3: ảnh hưởng của kích thước payload

Giả sử overhead được tính đơn giản là 18 byte.

Với payload 46 byte:

$$\eta_1 = \frac{46}{46 + 18} \times 100\% \approx 71.88\%.$$

Với payload 1,500 byte:

$$\eta_2 = \frac{1500}{1500 + 18} \times 100\% \approx 98.81\%.$$

Frame lớn có tỷ lệ payload cao hơn, nhưng frame quá lớn có thể làm tăng chi phí khi lỗi xảy ra và bị giới hạn bởi MTU của công nghệ.

3.3.6 Nhầm lẫn thường gặp khi tính độ trễ**Nhầm lẫn thường gặp**

- Không đổi byte sang bit trước khi chia cho bit/s.
- Dùng khoảng cách trong km nhưng tốc độ lan truyền tính bằng m/s.
- Cộng transmission delay nhiều lần mà không xem cơ chế pipelining.
- Cho rằng bandwidth lớn làm propagation delay nhỏ đi.
- Gọi tổng thời gian tải tệp là transmission delay, trong khi còn nhiều thành phần khác.

3.4 Ethernet và cấu trúc frame**3.4.1 Tầng Data Link giải quyết vấn đề gì?**

Tầng Data Link cung cấp truyền frame trên một liên kết hoặc trong phạm vi mạng cục bộ. Các chức năng thường gặp gồm:

- xác định ranh giới frame;
- địa chỉ hóa trên liên kết;
- điều khiển truy nhập môi trường;
- phát hiện một số lỗi truyền;
- chuyển packet của tầng Network qua liên kết cụ thể.

Ví dụ: giao hàng trong một khuôn viên

Địa chỉ quốc gia và thành phố giúp bưu kiện đi đến đúng khu vực, nhưng trong một khuôn viên lớn cần quy tắc cục bộ để chuyển đến đúng tòa nhà và cửa nhận hàng. Tầng Data Link giải quyết chẳng cục bộ tương tự như vậy.

Giới hạn: địa chỉ MAC không phải địa chỉ phòng hoặc người nhận theo nghĩa vật lý, và không cung cấp định tuyến xuyên Internet.

3.4.2 Ethernet và phạm vi sử dụng

Ethernet là họ công nghệ mạng cục bộ phổ biến ở tầng Data Link và Physical. Trong mạng Ethernet chuyển mạch hiện đại, mỗi thiết bị thường nối tới một cổng switch bằng liên kết điểm-điểm full-duplex. Ethernet không thay thế IP. Ethernet giúp chuyển frame trong phạm vi liên kết hoặc LAN; IP giúp packet đi qua nhiều mạng.

3.4.3 Cấu trúc Ethernet frame

Preamble	Destination MAC	Source MAC	Type/Length	Payload + padding	FCS
	6 byte	6 byte	2 byte	46–1500 byte	4 byte

Trong phân tích Wireshark, preamble và FCS có thể không xuất hiện đầy đủ tùy card mạng, driver và vị trí capture. Vì vậy, số byte nhìn thấy trong file capture có thể khác kích thước thực trên đường truyền.

3.4.4 Destination và Source MAC

- *Địa chỉ MAC đích* (destination MAC address): địa chỉ nhận frame trên liên kết.
- *Địa chỉ MAC nguồn* (source MAC address): địa chỉ giao diện đã phát frame trên liên kết đó.

Khi packet đi qua router, source và destination MAC thường thay đổi theo từng chặng; source và destination IP thường giữ nguyên end-to-end, trừ các cơ chế như NAT.

3.4.5 Type/Length và payload

Trường Type/Length cho biết giao thức tầng trên hoặc ý nghĩa chiều dài tùy dạng frame. Ví dụ EtherType thường dùng để nhận diện IPv4, ARP hoặc IPv6.

Payload mang packet tầng Network. Nếu payload quá ngắn, padding có thể được thêm để đạt kích thước frame tối thiểu.

3.4.6 Preamble, inter-frame gap và overhead thực tế

Preamble hỗ trợ đồng bộ ở tầng Physical. Giữa hai frame còn có khoảng nghỉ bắt buộc. Khi tính hiệu suất thực trên đường truyền, cần xác định rõ phạm vi overhead có bao gồm preamble và inter-frame gap hay không.

Quy tắc khi giải bài

Nếu đề bài chỉ nói “Ethernet header 14 byte và FCS 4 byte”, hãy dùng đúng phạm vi đó. Nếu đề yêu cầu kích thước trên đường truyền, cần xem có tính preamble, start frame delimiter và inter-frame gap hay không. Luôn ghi rõ giả định.

3.4.7 MTU và kích thước dữ liệu

Đơn vị truyền tối đa (Maximum Transmission Unit, MTU) là kích thước payload tầng Network lớn nhất mà liên kết có thể mang trong một frame theo cấu hình và công nghệ cụ thể. MTU ảnh hưởng tới cách tầng Network hoặc Transport phân chia dữ liệu.

Không nên đồng nhất MTU với kích thước toàn bộ frame. Với Ethernet thông dụng, MTU 1,500 byte thường nói đến payload IP, không bao gồm Ethernet header và FCS.

3.5 Địa chỉ MAC, switch và VLAN

3.5.1 Cấu trúc và cách viết địa chỉ MAC

Địa chỉ MAC Ethernet thường dài 48 bit và được viết thành sáu nhóm hex, ví dụ:

3C:52:82:1A:7B:90.

Hai bit trong octet đầu có ý nghĩa đặc biệt về unicast/multicast và địa chỉ toàn cục/cục bộ.

3.5.2 Unicast, multicast và broadcast

Loại	Ý nghĩa	Ví dụ
Unicast	Một giao diện đích	Frame gửi tới MAC cụ thể
Multicast	Một nhóm giao diện quan tâm	Một số giao thức phân phối nhóm
Broadcast	Mọi giao diện trong broadcast domain	FF:FF:FF:FF:FF:FF

Broadcast hữu ích cho một số cơ chế như ARP Request, nhưng broadcast quá nhiều làm mọi thiết bị trong miền phải tiếp nhận và xử lý ở mức nhất định.

3.5.3 Switch học địa chỉ như thế nào?

Switch học từ **source MAC** của frame đến. Khi frame xuất hiện ở cổng 3 với source MAC A, switch ghi rằng A có thể được tiếp cận qua cổng 3. Bản ghi thường có thời hạn và sẽ bị loại nếu không được làm mới.

Ví dụ: lễ tân ghi nhớ vị trí phòng ban

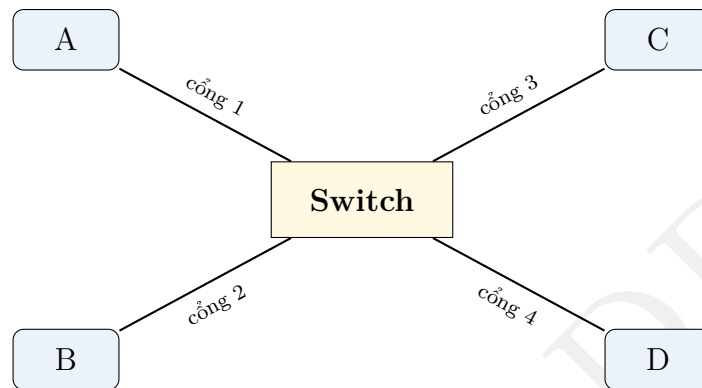
Lễ tân nhận thư từ Phòng Kế toán đi ra từ hành lang B. Từ đó, lễ tân ghi nhớ rằng thư gửi Kế toán có thể chuyển về hành lang B. Lễ tân học từ nơi thư *đi ra*, tương tự switch học từ source MAC.

Giới hạn: switch không hiểu nội dung nghiệp vụ của frame và bảng MAC không phải một danh bạ người dùng.

3.5.4 Forwarding, filtering và flooding

Khi nhận frame, switch tra destination MAC:

- nếu biết cổng đích và cổng đó khác cổng vào: chuyển tiếp ra cổng đích;
- nếu biết cổng đích chính là cổng vào: lọc, không gửi ngược lại;
- nếu chưa biết destination MAC: flooding ra các cổng phù hợp khác;
- nếu là broadcast: flooding trong broadcast domain.



3.5.5 Ví dụ cập nhật bảng MAC

Ví dụ 4.5: switch chưa biết địa chỉ đích

Ban đầu bảng MAC rỗng.

1. A gửi frame đến C qua cổng 1. Switch học A–cổng 1. Vì chưa biết C, switch flooding ra cổng 2, 3 và 4.
2. C trả lời A qua cổng 3. Switch học C–cổng 3. Destination A đã biết nên chỉ gửi frame ra cổng 1.
3. Từ thời điểm này, frame A đến C thường chỉ đi giữa cổng 1 và cổng 3.

Switch không cần cấu hình thủ công từng địa chỉ trong tình huống cơ bản.

3.5.6 Collision domain và broadcast domain

Trong Ethernet chuyển mạch full-duplex, mỗi cổng switch tạo một miền va chạm riêng và va chạm theo nghĩa Ethernet chia sẻ truyền thống hầu như không còn trên liên kết đó. Tuy nhiên, các cổng trong cùng VLAN vẫn thuộc cùng broadcast domain, trừ khi được router hoặc thiết bị tầng Network phân tách.

Nhầm lẫn thường gặp

Switch làm giảm va chạm và cô lập lưu lượng unicast tốt hơn hub, nhưng switch thông thường không tự chia nhỏ broadcast domain. VLAN hoặc router mới tạo ranh giới broadcast logic.

3.5.7 VLAN, access port và trunk port

Mạng LAN ảo (Virtual LAN, VLAN) tạo các broadcast domain logic trên cùng hạ tầng switch vật lý.

- *cổng truy nhập* (access port): thường gắn với một VLAN cho thiết bị đầu cuối.
- *cổng đường trục* (trunk port): mang frame của nhiều VLAN giữa các thiết bị mạng.
- *Thẻ 802.1Q* (IEEE 802.1Q tag): mang thông tin nhận diện VLAN trong frame trên trunk.

Ví dụ: tòa nhà dùng thẻ màu

Một tòa nhà có chung hành lang và thang máy, nhưng nhân viên từng đơn vị dùng thẻ màu khác nhau; thư nội bộ được phân loại theo màu để không chuyển sang nhóm khác. VLAN tạo sự phân tách logic trên hạ tầng chung tương tự như vậy.

Giới hạn: VLAN không phải cơ chế mã hóa. Nếu cấu hình sai hoặc thiết bị bị kiểm soát, dữ liệu vẫn có thể bị truy cập trái phép.

3.5.8 Inter-VLAN routing

Hai thiết bị ở VLAN khác nhau thường cần chức năng tầng Network để liên lạc, chẳng hạn router hoặc switch Layer 3. Frame broadcast của VLAN này không tự lan sang VLAN khác.

Điều này giúp giảm broadcast và hỗ trợ phân đoạn, nhưng thiết kế VLAN phải đi kèm chính sách định tuyến, ACL và giám sát phù hợp.

3.6 Phát hiện lỗi trên liên kết

3.6.1 Lỗi bit và mục tiêu phát hiện lỗi

Tín hiệu có thể bị nhiễu hoặc suy hao làm một hoặc nhiều bit nhận được khác bit đã gửi. Phát hiện lỗi thêm thông tin dư thừa để bên nhận kiểm tra tính nhất quán.

Phát hiện lỗi không đồng nghĩa sửa lỗi, và cũng không chứng minh dữ liệu chưa bị kẻ tấn công cố ý sửa. Cơ chế FCS được thiết kế chủ yếu cho lỗi truyền ngẫu nhiên, không phải xác thực mật mã.

3.6.2 Nguyên lý CRC

Kiểm tra dư thừa vòng (Cyclic Redundancy Check, CRC) xem chuỗi bit như đa thức nhị phân và thực hiện phép chia modulo 2 cho đa thức sinh. Phần dư được gắn vào frame. Bên nhận chia lại; phần dư không đúng cho thấy frame có lỗi.

Cần nhớ:

- phép cộng/trừ modulo 2 tương đương XOR, không có nhớ;
- đa thức sinh quyết định khả năng phát hiện mẫu lỗi;
- CRC phát hiện tốt nhiều lỗi burst thường gặp;
- CRC không cung cấp tính xác thực chống giả mạo.

3.6.3 Ví dụ CRC nhỏ

Ví dụ 4.7: phép chia modulo 2 minh họa

Giả sử dữ liệu 1101, đa thức sinh 1011 có bậc 3. Ta nối ba bit 0: 1101000, rồi chia modulo 2 cho 1011. Phần dư thu được là 001. Chuỗi gửi là 1101001.

Bên nhận chia 1101001 cho 1011; nếu phần dư bằng 0 thì frame vượt qua bước kiểm tra CRC theo mô hình này.

Ví dụ chỉ nhằm minh họa quy trình; Ethernet dùng CRC-32 với đa thức dài hơn nhiều.

3.6.4 FCS trong Ethernet

Chuỗi kiểm tra khung (Frame Check Sequence, FCS) của Ethernet chứa giá trị CRC. Thiết bị nhận kiểm tra FCS và thường loại frame lỗi. Card mạng hoặc driver có thể loại frame trước khi Wireshark thấy, nên packet capture trên máy đầu cuối thường không chứa đầy đủ các frame lỗi vật lý.

3.6.5 Phát hiện lỗi khác xác thực

Góc nhìn an toàn, an ninh mạng

Kẻ tấn công biết thuật toán CRC có thể sửa dữ liệu rồi tính lại CRC. Vì vậy, CRC không chứng minh người gửi là ai và không bảo vệ chống sửa đổi có chủ đích. Muốn bảo vệ tính toàn vẹn chống giả mạo cần cơ chế mật mã như MAC hoặc chữ ký số ở tầng phù hợp.

3.7 Cơ sở khoa học dữ liệu 2: array, DataFrame và trực quan hóa

3.7.1 Câu hỏi phân tích và data dictionary

Giả sử ta có một bảng dữ liệu Ethernet trong đó mỗi hàng biểu diễn một frame đã quan sát. Một data dictionary tối thiểu:

Cột	Kiểu	Đơn vị	Ý nghĩa
time_s	float	giây	Thời điểm tương đối
src_mac	string	–	MAC nguồn
dst_mac	string	–	MAC đích
ether_type	category	–	Giao thức tầng trên
frame_length	int	byte	Độ dài frame quan sát
is_broadcast	bool	–	Có phải broadcast hay không
vlan_id	nullable int	–	VLAN nếu có thể

Các câu hỏi có thể gồm: EtherType nào phổ biến nhất? Frame dài bao nhiêu? Broadcast chiếm tỷ lệ nào? Có VLAN nào phát sinh nhiều frame hơn không?

3.7.2 Tạo và kiểm tra DataFrame mẫu

```
import pandas as pd

frames = pd.DataFrame({
    "time_s": [0.00, 0.04, 0.08, 0.15, 0.21, 0.34, 0.51, 0.70],
    "src_mac": [
        "00:11:22:33:44:01", "00:11:22:33:44:02",
        "00:11:22:33:44:01", "00:11:22:33:44:03",
        "00:11:22:33:44:02", "00:11:22:33:44:01",
        "00:11:22:33:44:04", "00:11:22:33:44:01",
    ],
    "dst_mac": [
        "FF:FF:FF:FF:FF:FF", "00:11:22:33:44:01",
        "00:11:22:33:44:02", "FF:FF:FF:FF:FF:FF",
        "00:11:22:33:44:01", "00:11:22:33:44:04",
        "00:11:22:33:44:01", "00:11:22:33:44:02",
    ],
    "ether_type": ["ARP", "IPv4", "IPv4", "ARP",
                  "IPv4", "IPv6", "IPv6", "IPv4"],
    "frame_length": [64, 1514, 642, 64, 1280, 512, 900, 1514],
})

print(type(frames))
print(frames.shape)
print(frames.dtypes)
print(frames.head())
```

`frames.shape` trả về bộ (n, p) , trong đó n là số frame và p là số cột. Trước khi tính toán, cần kiểm tra `frame_length` có thực sự là số và các cột địa chỉ/giao thức có đúng kiểu mong đợi hay không. Trong notebook thực hành, cùng quy trình kiểm tra này sẽ được áp dụng sau khi đọc dữ liệu từ CSV.

3.7.3 Tạo Boolean mask

```
broadcast_mask = frames["dst_mac"].str.upper().eq(
    "FF:FF:FF:FF:FF:FF"
)

broadcast_frames = frames.loc[broadcast_mask].copy()

print(broadcast_mask.head())
print(broadcast_frames.shape)
```

Đoạn code được tách thành hai bước để người học thấy rõ:

- `broadcast_mask` là Series Boolean có một giá trị cho mỗi hàng;
- `frames.loc[broadcast_mask]` chọn các hàng có giá trị True;
- `copy()` chủ động tạo DataFrame độc lập để tránh cập nhật mơ hồ.

3.7.4 Đếm loại frame bằng value_counts

```
type_counts = frames["ether_type"].value_counts(
    dropna=False
)

print(type_counts)
```

value_counts() trả về số lần mỗi giá trị xuất hiện. dropna=False giữ cả nhóm thiếu dữ liệu để người học không vô tình bỏ qua.

3.7.5 Vẽ biểu đồ cột

```
import matplotlib.pyplot as plt

fig, ax = plt.subplots(figsize=(8, 4))

ax.bar(
    type_counts.index.astype(str),
    type_counts.values
)

ax.set_title("Number of frames by EtherType")
ax.set_xlabel("EtherType")
ax.set_ylabel("Frame count")

plt.tight_layout()
plt.show()
```

Trục x là nhóm EtherType; trục y là số frame. Biểu đồ trả lời câu hỏi về tần suất nhóm, không cho biết thứ tự thời gian hay nguyên nhân nhóm nào nhiều hơn.

3.7.6 Vẽ histogram kích thước frame

```
valid_lengths = frames["frame_length"].dropna()

fig, ax = plt.subplots(figsize=(8, 4))

ax.hist(valid_lengths, bins=20, edgecolor="black")
ax.set_title("Distribution of Ethernet frame length")
ax.set_xlabel("Frame length in bytes")
ax.set_ylabel("Number of frames")

plt.tight_layout()
plt.show()
```

bins=20 chia miền độ dài thành 20 khoảng. Histogram giúp thấy frame tập trung ở kích thước nào, nhưng không cho biết frame cụ thể thuộc ứng dụng nào nếu thiếu thêm trường dữ liệu.

3.7.7 Kiểm tra kết luận bằng số liệu

Sau khi nhìn biểu đồ, cần kiểm tra bằng thống kê:

```
summary = frames["frame_length"].describe(  
    percentiles=[0.25, 0.5, 0.75, 0.95]  
)  
  
broadcast_ratio = broadcast_mask.mean()  
  
print(summary)  
print("Broadcast ratio:", broadcast_ratio)
```

Vì Boolean được xem như 1 cho True và 0 cho False, mean của mask là tỷ lệ broadcast. Cần nhân 100 nếu muốn biểu diễn phần trăm.

Nhầm lẫn thường gặp

Không nên kết luận “mạng bị broadcast storm” chỉ vì có broadcast. ARP và một số giao thức dùng broadcast bình thường. Cần xem tỷ lệ, tốc độ theo thời gian, baseline và ảnh hưởng hiệu năng.

3.8 An toàn tầng Data Link

3.8.1 MAC spoofing

Giả mạo địa chỉ MAC (MAC spoofing) là việc cấu hình hoặc giả mạo địa chỉ MAC khác. Địa chỉ MAC không phải bằng chứng mạnh về danh tính người dùng, vì có thể thay đổi bằng phần mềm hoặc được hệ điều hành ngẫu nhiên hóa vì quyền riêng tư.

Biện pháp giảm thiểu có thể gồm xác thực truy nhập mạng, port security, giám sát thay đổi bất thường và không dựa duy nhất vào MAC để cấp quyền nhạy cảm.

3.8.2 MAC flooding

Kẻ tấn công có thể gửi nhiều frame với source MAC khác nhau nhằm làm đầy bảng MAC của switch. Tùy thiết bị và cấu hình, điều này có thể khiến lưu lượng unknown unicast bị flooding nhiều hơn.

Dấu hiệu dữ liệu có thể gồm số lượng source MAC mới tăng nhanh trên một cổng. Tuy nhiên, môi trường ảo hóa hoặc Wi-Fi tập trung cũng có thể tạo nhiều MAC hợp lệ, nên cần bối cảnh.

3.8.3 VLAN hopping và cấu hình trunk

VLAN hopping là nhóm kỹ thuật lợi dụng cấu hình VLAN hoặc trunk không an toàn để truy cập lưu lượng ngoài VLAN dự kiến. Phòng vệ tập trung vào cấu hình đúng access/trunk, vô hiệu hóa đàm phán không cần thiết, giới hạn VLAN được phép và không dùng VLAN mặc định một cách bất cẩn.

VLAN là phân đoạn logic, không phải mã hóa. Lưu lượng nhạy cảm vẫn cần bảo vệ ở các tầng trên.

3.8.4 Port security và segmentation

Port security có thể giới hạn số MAC hoặc MAC được phép trên cổng. Segmentation bằng VLAN giúp giảm broadcast domain và giới hạn phạm vi sự cố. Nhưng chính sách phải phù hợp môi trường; khóa cứng một MAC có thể gây khó cho điện thoại IP, máy ảo hoặc thiết bị thay thế.

3.9 Tổng kết chương

3.9.1 Tóm tắt chương

- Tầng Physical biểu diễn bit thành tín hiệu trên môi trường truyền; tầng Data Link đóng packet vào frame cho một liên kết.
- Transmission delay phụ thuộc kích thước dữ liệu và tốc độ liên kết; propagation delay phụ thuộc khoảng cách và tốc độ lan truyền.
- Ethernet frame chứa địa chỉ MAC nguồn, MAC đích, trường Type/Length, payload và FCS; một số thành phần vật lý có thể không xuất hiện trong capture.
- Switch học từ source MAC, rồi forwarding, filtering hoặc flooding dựa trên destination MAC.
- VLAN tạo broadcast domain logic; access port và trunk port có vai trò khác nhau.
- Parity, checksum và CRC phát hiện lỗi với mức hiệu quả khác nhau; CRC không thay thế cơ chế mật mã.
- Dữ liệu frame có thể phân tích bằng Boolean mask, `value_counts()`, `groupby()` và các biểu đồ phù hợp.
- An toàn tầng Data Link cần kết hợp cấu hình switch, segmentation, xác thực và giám sát; không nên tin cậy MAC như định danh tuyệt đối.

3.9.2 Bài luyện tập

1. Một frame 1,200 byte được truyền trên liên kết 20 Mbit/s. Tính transmission delay.
2. Tín hiệu đi 500 km với tốc độ 2×10^8 m/s. Tính propagation delay.
3. Một payload 500 byte được đặt trong frame có 18 byte overhead. Tính hiệu suất theo phạm vi giả định này.
4. Giải thích vì sao tăng bandwidth không làm propagation delay giảm trực tiếp.
5. Một switch có bảng A-cổng 1, C-cổng 3. Frame từ B ở cổng 2 gửi tới C. Switch học và chuyển tiếp như thế nào?
6. Vì sao destination MAC của packet đi Internet thường không phải MAC của máy chủ Internet?
7. Phân biệt collision domain và broadcast domain trong mạng switch.
8. Giải thích vì sao VLAN không thay thế mã hóa.
9. Với even parity, xác định bit parity cho chuỗi 1010111.
10. Nêu hai lý do Wireshark có thể không hiển thị FCS lỗi.

11. Viết pandas code tính tỷ lệ frame có `dst_mac` là broadcast.
12. Một biểu đồ cho thấy broadcast chiếm 8%. Có đủ cơ sở kết luận broadcast storm không? Giải thích.

3.9.3 Lời giải bài luyện tập

Bài 1

$L = 1,200 \times 8 = 9,600$ bit.

$$d_{\text{trans}} = \frac{9,600}{20 \times 10^6} = 0.00048 \text{ s} = 0.48 \text{ ms.}$$

Bài 2

500 km = 500,000 m.

$$d_{\text{prop}} = \frac{500,000}{2 \times 10^8} = 0.0025 \text{ s} = 2.5 \text{ ms.}$$

Bài 3

$$\eta = \frac{500}{500 + 18} \times 100\% \approx 96.53\%.$$

Kết quả chỉ đúng với phạm vi overhead 18 byte đã giả định.

Bài 4

Bandwidth/tốc độ liên kết quyết định tốc độ đẩy bit nên ảnh hưởng transmission delay. Propagation delay phụ thuộc khoảng cách và tốc độ lan truyền của tín hiệu trong môi trường. Tăng tốc độ liên kết không làm tín hiệu vật lý lan nhanh hơn một cách trực tiếp.

Bài 5

Switch học B-cổng 2 từ source MAC. Destination C đã có ở cổng 3, nên switch chỉ chuyển frame ra cổng 3. Bảng sau sự kiện có A-1, B-2, C-3.

Bài 6

Máy nguồn chỉ tạo frame cho chặng cục bộ. Nếu đích ở mạng xa, frame đầu tiên gửi tới default gateway, nên destination MAC là MAC của giao diện gateway. Destination IP vẫn là máy chủ từ xa.

Bài 7

Mỗi cổng switch full-duplex là một collision domain riêng. Các cổng trong cùng VLAN vẫn thuộc cùng broadcast domain. Router hoặc VLAN khác nhau tạo ranh giới broadcast.

Bài 8

VLAN chỉ phân tách logic và kiểm soát phạm vi frame. Dữ liệu trong VLAN không tự được mã hóa; người có quyền hoặc khai thác cấu hình sai vẫn có thể đọc dữ liệu. Cần TLS, IPsec hoặc cơ chế phù hợp ở tầng khác khi cần bí mật.

Bài 9

Chuỗi 1010111 có năm bit 1. Để tổng số bit 1 là chẵn, parity bit phải là 1.

Bài 10

Card mạng có thể loại frame lỗi trước khi chuyển cho hệ điều hành; driver có thể không cung cấp FCS cho phần mềm capture. Vì vậy Wireshark trên máy đầu cuối thường không thấy các frame lỗi vật lý hoặc trường FCS.

Bài 11

```
mask = frames["dst_mac"].str.upper().eq(
    "FF:FF:FF:FF:FF:FF"
)
broadcast_ratio = mask.mean()
print(broadcast_ratio)
```

Nhân kết quả với 100 để biểu diễn phần trăm.

Bài 12

Chưa đủ. Cần biết baseline, tốc độ broadcast theo thời gian, loại giao thức, số thiết bị, ảnh hưởng CPU/bandwidth và ngưỡng vận hành. Tỷ lệ 8% có thể bình thường hoặc bất thường tùy bối cảnh.

3.9.4 Câu hỏi trắc nghiệm

Câu 1. Đại lượng nào phụ thuộc trực tiếp vào kích thước frame và tốc độ liên kết?

- A. Propagation delay
- B. Transmission delay
- C. Tốc độ lan truyền
- D. Khoảng cách vật lý

Câu 2. Đơn vị dữ liệu của tầng Data Link là gì?

- A. Segment
- B. Packet
- C. Frame
- D. Message

Câu 3. Switch học địa chỉ MAC chủ yếu từ trường nào của frame đến?

- A. Destination MAC
- B. Source MAC
- C. Destination IP
- D. EtherType

Câu 4. Khi switch chưa biết destination MAC của một frame unicast, hành động cơ bản là gì?

- A. Loại frame ngay
- B. Gửi lên DNS
- C. Flooding ra các cổng phù hợp khác
- D. Thay destination MAC bằng broadcast

Câu 5. Địa chỉ broadcast Ethernet là địa chỉ nào?

- A. 00:00:00:00:00:00
- B. FF:FF:FF:FF:FF:FF
- C. 127.0.0.1
- D. 255.255.255.255

Câu 6. VLAN chủ yếu tạo ra điều gì?

- A. Mã hóa dữ liệu tự động
- B. Broadcast domain logic
- C. Địa chỉ IP công cộng
- D. Tốc độ lan truyền cao hơn

Câu 7. Mục đích chính của FCS trong Ethernet là gì?

- A. Định tuyến packet
- B. Mã hóa payload
- C. Phát hiện lỗi frame
- D. Xác thực người dùng

Câu 8. Phát biểu nào đúng về CRC?

- A. CRC cung cấp bí mật dữ liệu
- B. CRC chống mọi sửa đổi có chủ đích
- C. CRC phát hiện nhiều mẫu lỗi truyền nhưng không xác thực người gửi
- D. CRC thay thế chữ ký số

Câu 9. Biểu đồ nào phù hợp để xem phân bố độ dài frame?

- A. Histogram
- B. Pie chart bắt buộc
- C. Sơ đồ tuần tự
- D. Routing table

Câu 10. Khi packet đi tới mạng xa, destination MAC của frame đầu tiên thường là gì?

- A. MAC của máy chủ từ xa
- B. MAC của default gateway
- C. MAC broadcast trong mọi trường hợp
- D. Không có destination MAC

3.9.5 Đáp án và giải thích

Câu 1. Đáp án đúng: B. Transmission delay bằng kích thước bit chia tốc độ liên kết.

Câu 2. Đáp án đúng: C. Frame là PDU của tầng Data Link.

Câu 3. Đáp án đúng: B. Switch học vị trí source MAC từ cổng frame đi vào.

Câu 4. Đáp án đúng: C. Unknown unicast thường được flooding trong phạm vi VLAN phù hợp.

Câu 5. Đáp án đúng: B. FF:FF:FF:FF:FF:FF là broadcast MAC.

Câu 6. Đáp án đúng: B. VLAN tạo broadcast domain logic; nó không tự mã hóa dữ liệu.

Câu 7. Đáp án đúng: C. FCS chứa CRC để phát hiện lỗi frame.

Câu 8. Đáp án đúng: C. CRC hữu ích cho lỗi truyền nhưng không phải cơ chế xác thực mật mã.

Câu 9. Đáp án đúng: A. Histogram thể hiện phân bố của một biến định lượng.

Câu 10. Đáp án đúng: B. Chặng đầu gửi frame tới default gateway khi đích ở mạng xa.

Chương 4

IPv4, IPv6, subnetting, ARP và ICMP

4.1 Mục tiêu và câu hỏi mở đầu

4.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Một máy tính có địa chỉ 192.168.10.34/24 muốn gửi dữ liệu đến 192.168.10.80. Trong một trường hợp khác, nó muốn gửi đến 8.8.8.8. Máy tính quyết định đích ở cùng mạng hay mạng khác bằng cách nào? Khi đích ở cùng mạng, nó tìm địa chỉ MAC của máy nhận ra sao? Khi đích ở mạng xa, vì sao frame đầu tiên lại mang MAC của default gateway nhưng packet vẫn mang IP của máy chủ xa? Và khi router không chuyển tiếp được packet, thông tin phản hồi nào có thể xuất hiện?

Ví dụ: địa chỉ tòa nhà, tầng và căn hộ

Một địa chỉ giao hàng thường có nhiều mức: quốc gia, thành phố, đường, số nhà, tầng và căn hộ. Phần “đường và số nhà” giúp đơn vị vận chuyển đưa hàng đến đúng tòa nhà; phần “căn hộ” giúp giao đến đúng nơi bên trong tòa nhà. Tương tự, địa chỉ IPv4 gồm phần xác định mạng và phần xác định host trong mạng đó.

Prefix như /24 đóng vai trò quy ước cho biết bao nhiêu bit đầu được dùng làm phần mạng. Hai địa chỉ có cùng phần mạng theo prefix thích hợp được xem là cùng subnet.

Giới hạn của mạng: địa chỉ bưu chính có cấu trúc ngôn ngữ linh hoạt, còn địa chỉ IPv4 là một số 32 bit được xử lý bằng phép toán bit. Ví dụ chỉ giúp hình dung sự phân cấp, không thay thế phép tính subnet.

4.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Biểu diễn được địa chỉ IPv4 dưới dạng thập phân có dấu chấm và nhị phân 32 bit.
- Phân biệt được network address, host address, broadcast address, subnet mask và prefix length.
- Xác định được hai host có cùng subnet hay không bằng phép AND bit.

- Tính được số subnet, số địa chỉ và số host sử dụng được trong các bài toán CIDR cơ bản.
- Thực hiện được chia mạng con kích thước đều và VLSM theo yêu cầu số host.
- Đọc được các trường chính trong IPv4 header và giải thích vai trò của TTL, Protocol, Total Length và fragmentation.
- Giải thích được ARP Request, ARP Reply, ARP cache và việc dùng MAC của default gateway.
- Phân tích được thông điệp ICMP Echo, Destination Unreachable và Time Exceeded ở mức nền tảng.
- Giải thích được NAT/PAT, bảng ánh xạ và giới hạn của NAT.
- Dùng Python, NumPy, pandas và Matplotlib để chuyển đổi địa chỉ, thống kê RTT và trực quan hóa dữ liệu mạng.
- Nhận diện được ARP poisoning, ICMP abuse, IP spoofing và các biện pháp phòng vệ phù hợp.

4.2 Địa chỉ IPv4 và cấu trúc gói tin

4.2.1 IPv4 là địa chỉ logic 32 bit

Một địa chỉ IPv4 có 32 bit, thường được chia thành bốn nhóm 8 bit gọi là *bộ tám bit* (octet). Mỗi octet được viết dưới dạng số thập phân từ 0 đến 255, ngăn cách bằng dấu chấm.

Ví dụ 1: đổi địa chỉ IPv4 sang nhị phân

Xét địa chỉ 192.168.10.34.

$$192 = 11000000, \quad 168 = 10101000, \quad 10 = 00001010, \quad 34 = 00100010.$$

Do đó:

$$192.168.10.34 = 11000000.10101000.00001010.00100010.$$

Mỗi octet phải được viết đủ 8 bit; không được bỏ các số 0 ở đầu khi đang phân tích nhị phân.

Địa chỉ IPv4 được gán cho một giao diện mạng chứ không phải một “tên vĩnh viễn” của thiết bị. Một router có nhiều giao diện nên thường có nhiều địa chỉ IP. Một máy tính cũng có thể có đồng thời địa chỉ cho Ethernet, Wi-Fi, VPN và loopback.

4.2.2 Phần mạng và phần host

Địa chỉ IPv4 tự nó chưa cho biết ranh giới giữa phần mạng và phần host. Ranh giới được xác định bằng *mặt nạ mạng con* (subnet mask) hoặc *độ dài prefix* (prefix length).

Ví dụ, /24 nghĩa là 24 bit đầu là phần mạng và 8 bit cuối là phần host. Subnet mask tương ứng là:

$$255.255.255.0 = 11111111.11111111.11111111.00000000.$$

Ví dụ: khu phố và số nhà

Một địa chỉ “Khu A, nhà số 34” có hai phần: tên khu xác định phạm vi lớn hơn; số nhà xác định vị trí bên trong khu. Với 192.168.10.34/24, ba octet đầu đóng vai trò gần giống tên khu, còn octet cuối gần giống số nhà.

Giới hạn: prefix không nhất thiết dừng ở ranh giới octet. Ví dụ /27 chia ngay bên trong octet cuối, vì vậy không thể chỉ nhìn dấu chấm để xác định phần mạng.

4.2.3 Network address, host range và broadcast address

Trong một subnet IPv4 truyền thống:

- *Địa chỉ mạng* (network address): toàn bộ bit host bằng 0.
- *Địa chỉ broadcast* (broadcast address): toàn bộ bit host bằng 1.
- Các địa chỉ nằm giữa thường là địa chỉ host sử dụng được.

Với mạng 192.168.10.0/24:

- Network address: 192.168.10.0.
- Host đầu tiên: 192.168.10.1.
- Host cuối cùng: 192.168.10.254.
- Broadcast address: 192.168.10.255.

Quy tắc trừ hai địa chỉ để tính số host sử dụng được phù hợp với các subnet thông thường. Các prefix đặc biệt như /31 và /32 có cách sử dụng riêng và không nên áp dụng máy móc quy tắc đó.

4.2.4 Phép AND để xác định network address

Máy tính xác định network address bằng phép AND giữa địa chỉ IP và subnet mask.

Ví dụ 2: phép AND bit

Xét 192.168.10.34/27. Octet cuối:

$$34 = 00100010, \quad 224 = 11100000.$$

Phép AND:

$$00100010 \text{ AND } 11100000 = 00100000 = 32.$$

Network address là 192.168.10.32/27. Vì còn 5 bit host nên block có $2^5 = 32$ địa chỉ, từ 32 đến 63. Broadcast là 192.168.10.63; host dùng được từ 192.168.10.33 đến 192.168.10.62.

4.2.5 Các trường chính của IPv4 header

IPv4 header cơ bản thường dài 20 byte khi không có options. Một số trường quan trọng:

Trường	Độ dài	Vai trò
Version	4 bit	Giá trị 4 đối với IPv4
IHL	4 bit	Độ dài header theo đơn vị 32 bit
DSCP/ECN	8 bit	Hỗ trợ phân loại dịch vụ và báo hiệu tắc nghẽn
Total Length	16 bit	Tổng độ dài packet IPv4, gồm header và payload
Identification, Flags, Fragment Offset	32 bit tổng cộng	Liên quan fragmentation và reassembly
TTL	8 bit	Giới hạn số router packet có thể đi qua
Protocol	8 bit	Chỉ giao thức tầng trên, như ICMP=1, TCP=6, UDP=17
Header Checksum	16 bit	Kiểm tra lỗi riêng IPv4 header
Source Address	32 bit	Địa chỉ IPv4 nguồn
Destination Address	32 bit	Địa chỉ IPv4 đích

4.2.6 TTL và việc tránh packet đi vòng vô hạn

Mỗi router chuyển tiếp packet IPv4 sẽ giảm TTL ít nhất một đơn vị. Nếu TTL về 0, router loại packet và thường gửi ICMP Time Exceeded về nguồn.

Ví dụ: vé có số lượt chuyển tối đa

Hãy tưởng tượng một kiện hàng được dán phiếu “chỉ được qua tối đa 10 kho”. Mỗi kho xóa đi một lượt. Nếu phiếu về 0 mà hàng chưa tới đích, kho dừng chuyển để tránh kiện hàng đi vòng mãi do sai tuyến.

Giới hạn: TTL có tên lịch sử là “time”, nhưng trong hoạt động IPv4 hiện đại nó chủ yếu giảm theo hop, không phải đo số giây thực tế.

4.2.7 Fragmentation và MTU

Nếu packet IPv4 lớn hơn MTU của liên kết tiếp theo, nó có thể cần fragmentation, trừ khi cờ DF (Don't Fragment) được đặt. Fragmentation làm tăng xử lý, tạo nhiều mảnh phải ghép lại và khiến mất một mảnh có thể làm hỏng toàn bộ packet ban đầu.

Trong thực tế hiện đại, Path MTU Discovery và việc chọn kích thước phù hợp thường được ưu tiên hơn fragmentation giữa đường. Với IPv6, router không thực hiện fragmentation giữa đường như IPv4; nguồn phải điều chỉnh kích thước phù hợp.

Nhầm lẫn thường gặp

Sai lầm 1: cho rằng packet IP và Ethernet frame có cùng kích thước. Frame chứa packet cùng header/trailer của tầng liên kết.

Sai lầm 2: cho rằng TTL cho biết thời gian truyền tính bằng giây. TTL chủ yếu phản ánh giới hạn hop.

Sai lầm 3: cho rằng địa chỉ IP thuộc về toàn bộ máy tính theo nghĩa duy nhất. Địa chỉ được gán

cho giao diện và có thể thay đổi.

4.3 CIDR, chia mạng con và VLSM

4.3.1 Từ phân lớp cổ điển đến CIDR

Cách chia địa chỉ theo lớp A, B, C có giá trị lịch sử nhưng không còn đủ linh hoạt cho thiết kế mạng hiện đại. *định tuyến liên miền không phân lớp* (Classless Inter-Domain Routing, CIDR) sử dụng prefix length để biểu diễn mạng, ví dụ 10.20.0.0/16 hoặc 192.168.50.64/26.

CIDR giúp:

- Cấp phát địa chỉ sát nhu cầu hơn.
- Chia subnet linh hoạt.
- Tổng hợp route để giảm kích thước bảng định tuyến.

4.3.2 Kích thước block và bước nhảy

Với prefix /p, số bit host là $32 - p$. Số địa chỉ trong block:

$$N_{\text{address}} = 2^{32-p}.$$

Trong subnet thông thường, số host dùng được:

$$N_{\text{usable}} = 2^{32-p} - 2.$$

Khi prefix dùng trong octet cuối, bước nhảy có thể tính bằng:

$$\text{block size} = 256 - \text{giá trị mask ở octet đang xét}.$$

Prefix	Mask cuối	Số địa chỉ	Host thường dùng
/24	0	256	254
/25	128	128	126
/26	192	64	62
/27	224	32	30
/28	240	16	14
/29	248	8	6
/30	252	4	2

4.3.3 Quy trình xác định subnet của một địa chỉ

Một quy trình có thể kiểm tra được:

1. Viết prefix và xác định số bit host.

2. Đổi subnet mask ở octet liên quan.
3. Tính block size.
4. Tìm mốc block gần nhất không vượt quá giá trị octet của địa chỉ.
5. Xác định network, broadcast và host range.
6. Kiểm tra lại bằng phép AND hoặc Python.

Ví dụ 3: xác định subnet của 172.16.35.77/20

Dữ kiện: prefix /20; mask là 255.255.240.0. Octet thứ ba có block size $256 - 240 = 16$. Các mốc: 0, 16, 32, 48, ... Giá trị 35 nằm trong block 32–47.

- Network: 172.16.32.0/20.
- Broadcast: 172.16.47.255.
- Host đầu: 172.16.32.1.
- Host cuối: 172.16.47.254.
- Số địa chỉ: $2^{12} = 4096$; host thường dùng: 4094.

4.3.4 Chia mạng con kích thước đều

Giả sử cần chia 192.168.1.0/24 thành ít nhất 4 subnet bằng nhau. Cần mượn s bit sao cho $2^s \geq 4$, do đó $s = 2$. Prefix mới là /26.

Ví dụ 4: chia một /24 thành bốn /26

Mỗi /26 có 64 địa chỉ, bước nhảy 64:

Subnet	Network	Host đầu	Host cuối	Broadcast
1	192.168.1.0/26	.1	.62	.63
2	192.168.1.64/26	.65	.126	.127
3	192.168.1.128/26	.129	.190	.191
4	192.168.1.192/26	.193	.254	.255

Mỗi subnet có 62 địa chỉ host sử dụng được theo quy ước thông thường.

4.3.5 Chọn prefix theo số host

Nếu một LAN cần ít nhất H host, chọn số bit host h nhỏ nhất sao cho:

$$2^h - 2 \geq H.$$

Prefix là $32 - h$.

Ví dụ 5: LAN cần 50 host

Cần h sao cho $2^h - 2 \geq 50$.

$$2^5 - 2 = 30 < 50, \quad 2^6 - 2 = 62 \geq 50.$$

Vậy cần 6 bit host, prefix là /26. Một subnet /26 đáp ứng tối đa 62 host theo quy ước thông thường.

4.3.6 VLSM: cấp phát theo nhu cầu khác nhau

Mặt nạ mạng con độ dài thay đổi (Variable Length Subnet Mask, VLSM) cho phép dùng các prefix khác nhau trong cùng một khối địa chỉ. Quy tắc thực hành quan trọng: sắp xếp nhu cầu từ lớn đến nhỏ và cấp phát block lớn trước.

Ví dụ: chia khu đất thành các lô khác nhau

Một khu đất không nhất thiết chia thành các lô bằng nhau nếu bệnh viện cần diện tích lớn, trường học cần diện tích vừa và trạm bảo vệ cần diện tích nhỏ. VLSM cũng cấp block lớn cho mạng nhiều host và block nhỏ cho mạng ít host.

Giới hạn: lô đất có thể có hình dạng không đều; block CIDR phải có kích thước là lũy thừa của 2 và phải bắt đầu tại ranh giới phù hợp.

Ví dụ 6: VLSM cho ba LAN và một liên kết

Cho khối 192.168.100.0/24, nhu cầu: LAN A 100 host, LAN B 50 host, LAN C 20 host, liên kết point-to-point 2 host.

Mạng	Host	Prefix	Network	Host range	Broadcast
A	100	/25	192.168.100.0	.1–.126	.127
B	50	/26	192.168.100.128	.129–.190	.191
C	20	/27	192.168.100.192	.193–.222	.223
P2P	2	/30	192.168.100.224	.225–.226	.227

Phần còn lại bắt đầu từ 192.168.100.228, nhưng không phải mọi điểm bắt đầu đều tạo được block CIDR tùy ý. Khi cấp thêm subnet, phải chọn ranh giới đúng theo kích thước block.

4.3.7 Route summarization ở mức trực quan

Nếu nhiều mạng liên tiếp có phần bit đầu giống nhau, chúng có thể được biểu diễn bằng một prefix tổng quát hơn. Ví dụ bốn mạng 192.168.0.0/24 đến 192.168.3.0/24 có thể tổng hợp thành 192.168.0.0/22, nếu chúng thật sự được định tuyến theo cùng một hướng.

Ví dụ: biển chỉ dẫn theo khu vực

Thay vì đặt bốn biển riêng “phố 0”, “phố 1”, “phố 2”, “phố 3”, có thể đặt một biển “khu phố 0–3” nếu tất cả cùng một hướng. Tổng hợp route giảm số mục cần ghi nhớ.

Giới hạn: không được tổng hợp chỉ vì địa chỉ trông gần nhau. Các block phải liên tiếp, đúng ranh giới nhị phân và có cùng next hop phù hợp.

4.3.8 Các lỗi thường gặp khi chia subnet**Nhầm lẫn thường gặp**

- Dùng số host yêu cầu làm số địa chỉ block mà quên network và broadcast.
- Cho rằng mọi prefix đều kết thúc ở ranh giới octet.
- Dùng bước nhảy sai octet.
- Chọn network address không nằm trên ranh giới block.
- Cấp VLSM từ mạng nhỏ trước làm phân mảnh không gian địa chỉ.
- Nhầm broadcast của subnet với địa chỉ broadcast giới hạn 255.255.255.255.
- Áp dụng máy móc công thức $2^h - 2$ cho mọi trường hợp đặc biệt.

4.4 Đích cùng mạng và default gateway**4.4.1 Máy nguồn quyết định đích cùng subnet như thế nào?**

Máy nguồn tính network address của chính nó và của destination IP bằng cùng subnet mask. Nếu hai network address giống nhau, đích được coi là on-link; nếu khác, packet được gửi về một router, thường là default gateway.

Ví dụ 7: cùng subnet hay khác subnet?

Máy A: 192.168.10.34/27.

Subnet của A là 192.168.10.32/27, phạm vi host .33–62.

- Đích 192.168.10.50: cùng subnet, vì 50 nằm trong .32–63.
- Đích 192.168.10.80: khác subnet, vì 80 nằm trong block .64–95.

Trong trường hợp thứ hai, A không ARP trực tiếp cho MAC của .80; nó tìm MAC của default gateway trên subnet của mình.

4.4.2 Default gateway là cửa ra khỏi subnet

Default gateway là địa chỉ IP của giao diện router cùng subnet với host. Host dùng gateway khi không có route cụ thể hơn cho destination network.

Ví dụ: phòng chuyển phát của tòa nhà

Nếu người nhận ở cùng tòa nhà, nhân viên có thể giao trực tiếp đến phòng của họ. Nếu người nhận ở thành phố khác, kiện hàng được đưa tới phòng chuyển phát của tòa nhà. Phòng chuyển phát chọn tuyến tiếp theo.

Trong mạng, host gửi frame đến MAC của gateway khi destination IP ở mạng xa. Destination IP trong packet vẫn là địa chỉ máy đích cuối cùng.

Giới hạn: router không phải một “bưu điện duy nhất” cho toàn Internet. Packet có thể đi qua nhiều router và mỗi router chỉ chọn next hop dựa trên bảng định tuyến của mình.

4.4.3 Ba loại địa chỉ trong một lần gửi

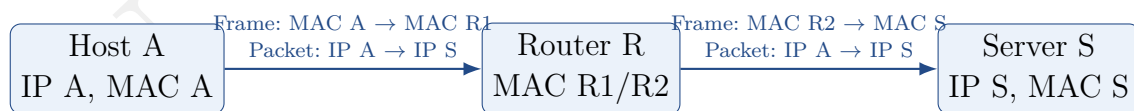
Khi trình duyệt gửi dữ liệu đến một máy chủ xa, có thể đồng thời tồn tại:

- Destination port: xác định dịch vụ hoặc tiến trình ở máy đích.
- Destination IP: xác định đích logic end-to-end.
- Destination MAC: xác định thiết bị nhận frame trên liên kết hiện tại.

Địa chỉ	Tầng	Phạm vi chính	Có thể đổi tại router?
Port	Transport	Tiến trình đầu cuối	Thường không, trừ cơ chế trung gian như NAT/PAT hoặc proxy
IP	Network	Đích logic qua nhiều mạng	Thường giữ nguyên; có thể đổi bởi NAT
MAC	Data Link	Một liên kết cục bộ	Có; frame mới được tạo ở mỗi chặng

4.4.4 Packet và frame thay đổi qua router

Giả sử A gửi đến server S qua router R:



Router loại header/trailer tầng liên kết của chặng vào, xử lý IPv4 header, giảm TTL, cập nhật IPv4 header checksum, chọn giao diện ra và đóng packet vào frame mới.

4.4.5 Loopback và các phạm vi địa chỉ quan trọng

Một số phạm vi thường gặp:

Phạm vi	Ví dụ	Ý nghĩa
Private IPv4	10.0.0.0/8; 172.16.0.0/12; 192.168.0.0/16	Dùng trong mạng riêng, không được định tuyến trực tiếp trên Internet công cộng
Loopback	127.0.0.0/8	Giao tiếp nội bộ trong chính host; thường gập 127.0.0.1
Link-local	169.254.0.0/16	Có thể tự gán khi không nhận được cấu hình phù hợp
Limited broadcast	255.255.255.255	Broadcast giới hạn trên liên kết cục bộ
Unspecified	0.0.0.0	Biểu diễn chưa có địa chỉ hoặc mọi địa chỉ cục bộ tùy ngữ cảnh
Default route	0.0.0.0/0	Route khớp mọi destination nếu không có route cụ thể hơn

4.4.6 Địa chỉ private không đồng nghĩa với an toàn

Địa chỉ private giúp tổ chức tái sử dụng không gian địa chỉ và thường đi cùng NAT. Tuy nhiên, một host dùng địa chỉ private vẫn có thể bị tấn công từ thiết bị khác trong mạng, từ VPN, từ phần mềm độc hại hoặc qua kết nối được cho phép từ bên ngoài.

Nguyên tắc cần nhớ

Không dùng tiêu chí “địa chỉ private” để kết luận hệ thống an toàn. Cần kết hợp segmentation, firewall, authentication, cập nhật, giám sát và mã hóa theo rủi ro thực tế.

4.5 ARP và ICMP

4.5.1 ARP giải quyết bài toán gì?

Trên Ethernet, host cần destination MAC để tạo frame. Nếu biết destination IPv4 on-link nhưng chưa biết MAC tương ứng, host sử dụng *giao thức phân giải địa chỉ* (Address Resolution Protocol, ARP).

Ví dụ: hỏi quây lễ tân

Người giao hàng đã đến đúng tòa nhà theo địa chỉ đường phố nhưng chưa biết phòng của người nhận. Họ hỏi quây lễ tân: “Ai phụ trách tên này và ở phòng nào?” Lễ tân hoặc người liên quan trả lời.

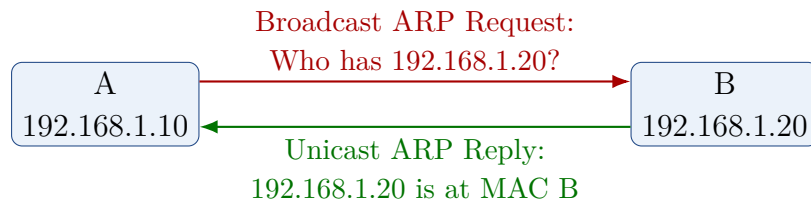
ARP Request gần với câu hỏi phát cho mọi thiết bị trong LAN; ARP Reply cung cấp ánh xạ IP-MAC.

Giới hạn: ARP không có một lễ tân trung tâm đáng tin cậy. Thiết bị có thể tự trả lời, vì vậy giao thức có nguy cơ bị giả mạo.

4.5.2 ARP Request và ARP Reply

Một quy trình đơn giản:

1. Host kiểm tra ARP cache.
2. Nếu chưa có ánh xạ, host gửi Ethernet broadcast với ARP Request: “Ai có IP X?”
3. Mọi thiết bị trong broadcast domain nhận frame; thiết bị có IP X trả ARP Reply, thường dưới dạng unicast.
4. Host lưu ánh xạ tạm thời trong ARP cache và tạo frame gửi dữ liệu.



4.5.3 ARP cache và thời gian tồn tại

ARP cache giảm việc phát broadcast lặp lại. Các entry thường có thời gian tồn tại và có thể được làm mới hoặc xóa. Lệnh quan sát tùy hệ điều hành, ví dụ `arp -a` hoặc `ip neigh`.

Không nên giả định mọi entry đều do một lần ARP Request vừa diễn ra. Hệ điều hành có thể học từ traffic khác, dùng entry tĩnh hoặc duy trì trạng thái theo thuật toán riêng.

4.5.4 ARP khi đích ở mạng xa

Nếu destination IP không cùng subnet, host không hỏi “ai có IP máy chủ xa?”. Nó ARP cho địa chỉ IP của default gateway, rồi gửi frame tới MAC của gateway. Packet bên trong vẫn mang destination IP xa.

Ví dụ 8: ARP cho gateway

Host A: 192.168.1.10/24; gateway: 192.168.1.1; server: 203.0.113.20.

A xác định server không cùng 192.168.1.0/24. A cần MAC của 192.168.1.1, không cần MAC của server. Frame đầu tiên:

- Source MAC: MAC của A.
- Destination MAC: MAC của gateway.
- Source IP: 192.168.1.10.
- Destination IP: 203.0.113.20.

4.5.5 ICMP và thông tin điều khiển

Giao thức thông báo điều khiển Internet (Internet Control Message Protocol, ICMP) được dùng để báo lỗi và cung cấp thông tin chẩn đoán liên quan đến IP. ICMP không phải giao thức “bảo đảm sửa lỗi”; nó thông báo một số trạng thái để nguồn hoặc công cụ quản trị xử lý.

Các thông điệp thường gặp:

- Echo Request và Echo Reply: dùng bởi ping.
- Destination Unreachable: đích hoặc dịch vụ không thể đạt theo một lý do cụ thể.

- Time Exceeded: TTL về 0 hoặc hết thời gian reassembly.
- Redirect: router thông báo một next hop phù hợp hơn trong một số tình huống.

4.5.6 Ping đo gì và không đo gì?

Ping thường đo RTT giữa lúc gửi ICMP Echo Request và nhận Echo Reply. Nó hữu ích để kiểm tra reachability và độ trễ ở mức sơ bộ.

Ví dụ 9: tính RTT trung bình

Bốn lần ping có RTT: 12 ms, 15 ms, 13 ms, 60 ms.

$$\bar{x} = \frac{12 + 15 + 13 + 60}{4} = 25 \text{ ms.}$$

Median là trung bình của 13 và 15, bằng 14 ms. Mean cao hơn nhiều vì một giá trị 60 ms. Đây là lý do cần xem cả mean, median và phân bố, không chỉ một con số.

Không nhận Echo Reply không chứng minh host đã tắt. ICMP có thể bị firewall lọc, rate-limit, đi theo đường khác hoặc mất trên mạng. Ngược lại, ping thành công không chứng minh mọi dịch vụ ứng dụng đều hoạt động.

4.5.7 Traceroute và ICMP Time Exceeded

Traceroute khai thác TTL tăng dần. Probe đầu có TTL nhỏ, router đầu làm TTL về 0 và trả ICMP Time Exceeded. Probe sau tăng TTL để khám phá router kế tiếp. Tùy hệ điều hành và công cụ, probe có thể dùng UDP, ICMP hoặc TCP.

Ví dụ: phiếu chỉ cho đi qua một số trạm

Gửi nhiều bưu kiện thử nghiệm, kiện đầu chỉ được qua một trạm, kiện sau hai trạm, rồi ba trạm. Trạm nơi “hết lượt” gửi thông báo về. Từ các phản hồi, người gửi suy ra chuỗi trạm trung gian.

Giới hạn: Internet có định tuyến bất đối xứng, load balancing và router không phản hồi ICMP. Traceroute không nhất thiết cho thấy một đường cố định và đầy đủ.

4.5.8 Các giới hạn khi diễn giải ICMP

Nhầm lẫn thường gặp

- “Ping timeout” không đồng nghĩa chắc chắn với “máy đích ngừng hoạt động”.
- RTT của ICMP không phải lúc nào cũng bằng RTT của TCP/HTTP vì đường đi và ưu tiên xử lý có thể khác.
- Một hop không hiện trong traceroute không có nghĩa hop đó không tồn tại.
- ARP Reply nhận được không chứng minh ánh xạ là đáng tin cậy.
- ICMP bị chặn hoàn toàn có thể làm giảm khả năng chẩn đoán và cản trở một số cơ chế như Path MTU Discovery.

4.6 IPv6 và chuyển tiếp từ IPv4

4.6.1 IPv6 giải quyết bài toán địa chỉ theo hướng khác

IPv6 dùng địa chỉ 128 bit, không cần dựa vào NAT để đối phó thiếu địa chỉ theo cách IPv4. IPv6 khôi phục khả năng cấp địa chỉ toàn cục rộng hơn, nhưng vẫn cần firewall và chính sách bảo vệ.

Một địa chỉ IPv6 được viết theo các nhóm hexadecimal, ví dụ 2001:db8:1:2::10. Dấu :: chỉ được dùng một lần để rút gọn một chuỗi nhóm 0 liên tiếp.

Chương này chỉ giới thiệu động lực chuyển tiếp; cấu hình và vận hành IPv6 chi tiết cần được phát triển trong phần chuyên sâu hoặc thực hành mở rộng.

4.6.2 Dual stack, tunneling và translation

Các mạng chuyển tiếp từ IPv4 sang IPv6 thường dùng một hoặc nhiều cách:

- *ngăn xếp kép* (dual stack): thiết bị chạy đồng thời IPv4 và IPv6.
- *đường hầm* (tunneling): mang traffic của một giao thức qua hạ tầng giao thức khác.
- *chuyển đổi giao thức* (translation): chuyển đổi giữa IPv4 và IPv6 trong một số kiến trúc.

Không có một phương án duy nhất phù hợp mọi tổ chức. Quyết định phụ thuộc ứng dụng, ISP, thiết bị, năng lực vận hành và yêu cầu an toàn.

4.7 Cơ sở khoa học dữ liệu 3: missing value, thống kê và outlier

4.7.1 Câu hỏi phân tích và data dictionary

Giả sử một file CSV ghi các phép ping theo thời gian:

Cột	Kiểu	Đơn vị	Ý nghĩa
timestamp	datetime/string	thời gian	Thời điểm gửi probe
destination	string	không có	IP hoặc tên đích
ttl	int/nullable	hop limit	TTL trong Echo Reply nếu có
rtt_ms	float/nullable	ms	Round-trip time
status	category/string	không có	reply hoặc timeout
packet_bytes	int	byte	Kích thước packet đo

Các câu hỏi phân tích:

- Tỷ lệ timeout là bao nhiêu?
- RTT mean và median khác nhau thế nào?
- Có thời điểm RTT tăng đột biến không?
- RTT có thay đổi theo destination hoặc packet size không?

4.7.2 Tạo DataFrame mẫu an toàn

CH04-CODE-03.

```
import numpy as np
import pandas as pd

ping_df = pd.DataFrame({
    "sequence": [1, 2, 3, 4, 5, 6, 7, 8],
    "destination": ["192.0.2.10"] * 8,
    "ttl": [57, 57, 57, 57, pd.NA, 57, 57, 57],
    "rtt_ms": [12.4, 13.1, 12.8, 48.6, np.nan,
              14.2, 13.5, 72.0],
    "status": ["reply", "reply", "reply", "reply",
              "timeout", "reply", "reply", "reply"]
})

ping_df["ttl"] = ping_df["ttl"].astype("Int64")
print(ping_df.shape)
print(ping_df.dtypes)
display(ping_df)
```

Mỗi hàng là một probe. `rtt_ms` thiếu khi timeout. Dtype `Int64` của pandas cho phép cột số nguyên chứa `pd.NA`.

4.7.3 Tính tỷ lệ timeout và thống kê RTT

CH04-CODE-04.

```
timeout_mask = ping_df["status"].eq("timeout")
timeout_rate = timeout_mask.mean()

rtt = ping_df.loc[~timeout_mask, "rtt_ms"]
summary = rtt.agg(["count", "mean", "median", "min", "max"])

print("Timeout rate:", timeout_rate)
print(summary)
```

Boolean có thể được xem như 1 cho True và 0 cho False khi tính mean. Vì vậy, lệnh `timeout_mask.mean()` cho tỷ lệ timeout. Dữ liệu RTT chỉ lấy các hàng có phản hồi.

4.7.4 Line plot theo sequence

CH04-CODE-05.

```
import matplotlib.pyplot as plt

fig, ax = plt.subplots(figsize=(8, 4))
ax.plot(
    ping_df["sequence"],
    ping_df["rtt_ms"],
```

```

    marker="o"
)
ax.set_title("RTT by ICMP sequence")
ax.set_xlabel("Sequence number")
ax.set_ylabel("RTT in milliseconds")
ax.grid(True, alpha=0.3)
plt.show()

```

Mỗi điểm là một probe có phản hồi. Khoảng trống ở sequence 5 phản ánh missing RTT do timeout, không nên tự động nối thành một giá trị giả.

4.7.5 Histogram và boxplot

CH04-CODE-06.

```

fig, ax = plt.subplots(figsize=(8, 4))
ax.hist(rtt.dropna(), bins=6, edgecolor="black")
ax.set_title("Distribution of RTT")
ax.set_xlabel("RTT in milliseconds")
ax.set_ylabel("Number of replies")
plt.show()

```

CH04-CODE-07.

```

fig, ax = plt.subplots(figsize=(7, 3.5))
ax.boxplot(rtt.dropna(), vert=False)
ax.set_title("Boxplot of RTT")
ax.set_xlabel("RTT in milliseconds")
plt.show()

```

Histogram cho thấy phân bố theo các khoảng; boxplot nhấn mạnh median, độ phân tán và các giá trị có thể là outlier. Với chỉ vài quan sát, hai biểu đồ chỉ mang tính minh họa, không đủ để suy rộng mạnh.

4.7.6 Kiểm tra kết luận bằng số liệu

CH04-CODE-08.

```

median_rtt = rtt.median()
high_mask = ping_df["rtt_ms"].gt(2 * median_rtt)
high_rows = ping_df.loc[
    high_mask,
    ["sequence", "rtt_ms", "status"]
]

print("Median RTT:", median_rtt)
display(high_rows)

```

Ngưỡng gấp hai median chỉ là quy tắc minh họa, không phải chuẩn phổ quát để kết luận bất thường. Cần baseline dài hơn, bối cảnh ứng dụng và nhiều biến khác.

4.8 Các tấn công liên quan đến IP

4.8.1 IP spoofing và giới hạn của địa chỉ nguồn

Trường source IP trong packet không tự chứng minh danh tính người gửi. Kẻ tấn công có thể tạo packet với source IP giả, đặc biệt trong các kiểu tấn công không cần nhận phản hồi trực tiếp hoặc lợi dụng phản xạ/khuếch đại.

Biện pháp giảm thiểu gồm ingress/egress filtering, xác thực ở tầng ứng dụng hoặc transport phù hợp, stateful firewall và giám sát bất thường. Không dùng IP address như bằng chứng duy nhất về người dùng.

4.8.2 ARP poisoning

ARP không có xác thực mật mã tích hợp. Kẻ tấn công trong cùng LAN có thể gửi ARP Reply giả để làm host ánh xạ IP gateway sang MAC của kẻ tấn công, từ đó gây man-in-the-middle hoặc denial of service.

Biện pháp có thể gồm:

- Dynamic ARP Inspection kết hợp DHCP snooping trên switch hỗ trợ.
- Port security và segmentation.
- Mã hóa end-to-end như TLS để giảm tác động nghe lén nội dung.
- Giám sát thay đổi ARP bất thường và ánh xạ trùng lặp.

4.8.3 ICMP abuse và chính sách lọc cân bằng

ICMP có thể bị dùng để reconnaissance, flood hoặc làm thành phần của tấn công phản xạ trong một số bối cảnh. Tuy nhiên, chặn toàn bộ ICMP có thể làm mất khả năng chẩn đoán và cản trở thông báo lỗi cần thiết.

Chính sách tốt thường lọc theo type/code, rate-limit, hướng lưu lượng và nhu cầu vận hành thay vì cấm tuyệt đối.

4.9 Tổng kết chương

4.9.1 Tóm tắt chương

- IPv4 là địa chỉ logic 32 bit; prefix xác định ranh giới giữa network và host.
- Network address được tính bằng phép AND giữa IP và subnet mask.
- CIDR biểu diễn block bằng prefix; subnetting chia block lớn thành các block nhỏ; VLSM cấp kích thước khác nhau theo nhu cầu.
- Host quyết định đích on-link bằng cách so sánh network address; đích off-link được gửi tới default gateway.
- Packet IP giữ destination IP end-to-end trong trường hợp không NAT, còn frame và MAC thay đổi theo từng liên kết.

- ARP ánh xạ IPv4 sang MAC trong cùng broadcast domain; ARP cache giảm broadcast nhưng giao thức thiếu xác thực tích hợp.
- ICMP cung cấp thông báo lỗi và chẩn đoán như Echo, Destination Unreachable và Time Exceeded.
- NAT/PAT thay đổi địa chỉ/port và duy trì trạng thái ánh xạ; NAT không thay thế firewall hoặc mã hóa.
- Python và dữ liệu giúp kiểm tra subnet, phân tích RTT và phát hiện các quan sát cần điều tra thêm, nhưng không tự tạo ra kết luận nguyên nhân.

4.9.2 Bài luyện tập

1. Đổi 10.12.5.200 sang nhị phân 32 bit.
2. Xác định network, broadcast và host range của 192.168.5.141/26.
3. Hai host 172.16.18.10/20 và 172.16.31.200/20 có cùng subnet không?
4. Một mạng cần 120 host. Prefix nhỏ nhất nào phù hợp theo quy ước thông thường?
5. Chia 10.0.0.0/24 thành 8 subnet bằng nhau. Nêu prefix mới và network của 8 subnet.
6. Từ 192.168.20.0/24, cấp VLSM cho các LAN cần 90, 40, 20 và 10 host.
7. Vì sao host gửi đến Internet phải biết MAC của gateway nhưng không cần biết MAC của server xa?
8. Trình bày source/destination IP và MAC ở chặng đầu khi A 192.168.1.10 gửi tới server 203.0.113.9, gateway 192.168.1.1.
9. TTL ban đầu là 64. Packet đi qua 9 router. TTL đến đích là bao nhiêu nếu không bị thay đổi theo cách khác?
10. Một IPv4 packet có Total Length 1500 byte và IHL=5. Payload IPv4 dài bao nhiêu byte?
11. Giải thích vì sao ARP Request thường dùng broadcast.
12. Nếu ARP cache của host ánh xạ IP gateway sang MAC sai, điều gì có thể xảy ra?
13. Phân biệt ICMP Echo Reply, Destination Unreachable và Time Exceeded.
14. Bốn RTT là 10, 11, 12 và 67 ms. Tính mean và median; chỉ ra đại lượng ổn định hơn trước outlier.
15. Ping timeout ba lần có đủ kết luận server dừng hoạt động không? Nêu ít nhất ba khả năng khác.
16. PAT phân biệt hai phiên nội bộ dùng cùng source port bằng cách nào?
17. Vì sao NAT không thay thế TLS?
18. Viết Python dùng `ipaddress` để kiểm tra 10.1.2.130/25 thuộc mạng nào.
19. Viết pandas code tính tỷ lệ timeout từ cột `status`.
20. Một boxplot có một RTT rất cao. Có đủ cơ sở gọi đó là tấn công DDoS không? Giải thích.

4.9.3 Lời giải bài luyện tập

Bài 1

$10 = 00001010$, $12 = 00001100$, $5 = 00000101$, $200 = 11001000$.

Kết quả: $00001010.00001100.00000101.11001000$.

Bài 2

/26 có block size 64. Các block: 0–63, 64–127, 128–191, 192–255. Giá trị 141 nằm trong block 128–191.

Network: 192.168.5.128/26; broadcast: 192.168.5.191. Host range là 192.168.5.129–192.168.5.190.

Bài 3

/20 có block size 16 ở octet thứ ba. Cả 18 và 31 đều nằm trong block 16–31. Hai host cùng mạng 172.16.16.0/20.

Bài 4

Cần $2^h - 2 \geq 120$. Với $h = 7$, $2^7 - 2 = 126$. Prefix là $32 - 7 = 25$, tức /25.

Bài 5

Cần 3 bit subnet vì $2^3 = 8$, prefix mới /27, bước nhảy 32. Các network: 10.0.0.0, .32, .64, .96, .128, .160, .192 và .224, đều /27.

Bài 6

Sắp xếp lớn đến nhỏ:

- 90 host: 192.168.20.0/25, host .1–.126, broadcast .127.
- 40 host: 192.168.20.128/26, host .129–.190, broadcast .191.
- 20 host: 192.168.20.192/27, host .193–.222, broadcast .223.
- 10 host: 192.168.20.224/28, host .225–.238, broadcast .239.

Phần .240–.255 còn lại là một block /28 nếu cần.

Bài 7

MAC chỉ dùng cho chặng cục bộ. Host phải tạo frame gửi tới thiết bị next hop là gateway. Router sau đó tạo frame mới trên liên kết kế tiếp. MAC của server xa không có ý nghĩa trực tiếp trong LAN của host.

Bài 8

Chặng đầu: source IP 192.168.1.10; destination IP 203.0.113.9; source MAC là MAC của A; destination MAC là MAC của giao diện gateway 192.168.1.1.

Bài 9

Mỗi router giảm TTL một đơn vị. TTL đến đích là $64 - 9 = 55$.

Bài 10

IHL=5 nghĩa header dài $5 \times 4 = 20$ byte. Payload IPv4 dài $1500 - 20 = 1480$ byte.

Bài 11

Người gửi biết target IP nhưng chưa biết target MAC, nên không thể gửi unicast Ethernet trực tiếp. Broadcast đưa câu hỏi tới mọi thiết bị trong broadcast domain; chỉ thiết bị có IP phù hợp cần trả lời.

Bài 12

Frame có thể được gửi sai thiết bị, bị chặn hoặc bị kẻ tấn công trung gian nhận. Kết quả có thể là mất kết nối, man-in-the-middle hoặc rò rỉ dữ liệu nếu không có mã hóa end-to-end.

Bài 13

Echo Reply là phản hồi cho Echo Request. Destination Unreachable báo một dạng không thể tới đích/dịch vụ. Time Exceeded thường xuất hiện khi TTL về 0. Type/code cụ thể cung cấp chi tiết hơn.

Bài 14

Mean = $(10 + 11 + 12 + 67)/4 = 25$ ms. Median = $(11 + 12)/2 = 11.5$ ms. Median ít bị giá trị 67 ms kéo lệch hơn.

Bài 15

Chưa đủ. ICMP có thể bị firewall chặn, rate-limit, packet có thể mất, route có thể lỗi, DNS có thể sai, hoặc server vẫn hoạt động nhưng không trả Echo. Cần kiểm tra dịch vụ ứng dụng và nhiều nguồn dữ liệu.

Bài 16

PAT có thể thay source port bên ngoài để mỗi phiên có một tuple duy nhất trong bảng ánh xạ. Ví dụ hai phiên cùng port 51000 nội bộ được ánh xạ thành public ports 40001 và 40002.

Bài 17

NAT chỉ thay đổi địa chỉ/port và duy trì ánh xạ; nó không mã hóa payload, không xác thực server và không bảo đảm toàn vẹn nội dung. TLS cung cấp các thuộc tính mật mã ở tầng ứng dụng/transport phù hợp.

Bài 18

```
from ipaddress import ip_interface

net = ip_interface("10.1.2.130/25").network
print(net.network_address)
```

```
print(net.broadcast_address)
```

Kết quả network là 10.1.2.128/25; broadcast 10.1.2.255.

Bài 19

```
timeout_rate = ping_df["status"].eq("timeout").mean()  
print(timeout_rate)
```

Nhân 100 nếu cần phần trăm.

Bài 20

Không. Một giá trị RTT cao có thể do queueing, thay đổi route, Wi-Fi, tải máy, xử lý ưu tiên thấp hoặc lỗi đo. DDoS là giả thuyết cần thêm bằng chứng như traffic volume, source diversity, packet rate, service impact và baseline.

4.9.4 Câu hỏi trắc nghiệm

Câu 1. Với prefix /27, một block có bao nhiêu địa chỉ?

- A. 16
- B. 30
- C. 32
- D. 64

Câu 2. Network address của 192.168.1.70/26 là gì?

- A. 192.168.1.0
- B. 192.168.1.64
- C. 192.168.1.70
- D. 192.168.1.127

Câu 3. Khi destination IP ở mạng xa, host thường ARP cho địa chỉ nào?

- A. Destination IP xa
- B. DNS server
- C. Default gateway cùng subnet
- D. Broadcast IP của mạng xa

Câu 4. Trường nào trong IPv4 header giúp ngăn packet đi vòng vô hạn?

- A. TTL
- B. Source Port
- C. Destination MAC
- D. FCS

Câu 5. ARP Request Ethernet thường được gửi như thế nào?

- A. Unicast tới MAC chưa biết
- B. Broadcast trong LAN
- C. Qua mọi router Internet
- D. Chỉ tới DNS server

Câu 6. ICMP Time Exceeded thường xuất hiện khi nào?

- A. TCP port đóng
- B. TTL về 0
- C. ARP cache đầy
- D. NAT table không có entry

Câu 7. PAT chủ yếu dùng thông tin nào để phân biệt nhiều phiên cùng chia sẻ public IP?

- A. Chỉ MAC address
- B. Port và protocol trong ánh xạ phiên
- C. Chỉ TTL
- D. Ethernet FCS

Câu 8. Phát biểu nào đúng về NAT?

- A. NAT tự mã hóa payload
- B. NAT thay thế mọi chức năng firewall
- C. NAT thay đổi địa chỉ hoặc port nhưng không tự xác thực người dùng
- D. NAT làm địa chỉ private được định tuyến công khai trực tiếp

Câu 9. Trong pandas, biểu thức nào tính tỷ lệ dòng có status bằng `timeout`?

- A. `df["status"].eq("timeout").mean()`
- B. `df.mean("timeout")`
- C. `df["timeout"].shape()`
- D. `df.status.sum("reply")`

Câu 10. Nhận định nào phù hợp nhất khi một ping bị timeout?

- A. Chắc chắn server đã tắt
- B. Chắc chắn có tấn công
- C. Chắc chắn DNS lỗi
- D. Cần thêm kiểm tra vì ICMP có thể bị lọc hoặc packet bị mất

4.9.5 Đáp án và giải thích

Câu 1. Đáp án đúng: C. /27 còn 5 bit host, nên có $2^5 = 32$ địa chỉ.

Câu 2. Đáp án đúng: B. /26 có block size 64; 70 nằm trong block 64–127.

Câu 3. Đáp án đúng: C. Host cần MAC của next hop là default gateway trong cùng subnet.

Câu 4. Đáp án đúng: A. Router giảm TTL; packet bị loại khi TTL về 0.

Câu 5. Đáp án đúng: B. Vì chưa biết target MAC, Request được broadcast trong broadcast domain.

Câu 6. Đáp án đúng: B. TTL về 0 là tình huống phổ biến tạo ICMP Time Exceeded.

Câu 7. Đáp án đúng: B. PAT dùng port/protocol và thông tin phiên để tạo ánh xạ phân biệt.

Câu 8. Đáp án đúng: C. NAT thay đổi địa chỉ/port nhưng không tự cung cấp mã hóa hay xác thực.

Câu 9. Đáp án đúng: A. Boolean mean cho tỷ lệ giá trị True.

Câu 10. Đáp án đúng: D. Timeout có nhiều nguyên nhân; cần kết hợp thêm phép đo và log.

Chương 5

Chuyển tiếp, định tuyến và NAT

5.1 Mục tiêu và câu hỏi mở đầu

5.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Một máy tính đã xác định rằng địa chỉ đích nằm ngoài subnet và gửi frame đầu tiên đến default gateway. Từ thời điểm router nhận được frame đó, router dựa vào thông tin nào để chọn cổng ra? Nếu bảng định tuyến có nhiều dòng đều phù hợp với địa chỉ đích, dòng nào được chọn? Bảng định tuyến được hình thành bằng cách nào, vì sao packet có thể đi qua nhiều router, và điều gì xảy ra khi một router không có đường đi thích hợp?

Ví dụ: bản đồ toàn tuyến và quyết định tại một ngã tư

Một người lái xe có thể dùng bản đồ để chọn tuyến từ Hà Nội đến một địa điểm ở Hải Phòng. Việc tìm tuyến tổng thể tương tự *định tuyến* (routing). Khi xe đến từng ngã tư, người lái chỉ cần quyết định rẽ trái, rẽ phải hay đi thẳng dựa trên tuyến đã chọn; quyết định cục bộ đó tương tự *chuyển tiếp* (forwarding).

Điểm cần nhớ: routing tạo hoặc cập nhật tri thức về đường đi; forwarding dùng tri thức đó để xử lý từng packet cụ thể.

Giới hạn của mạng: router không “nhìn” toàn bộ hành trình của từng packet theo cách con người nhìn bản đồ. Mỗi router chủ yếu thực hiện tra cứu cục bộ trong bảng chuyển tiếp của chính nó. Đường đi cũng có thể thay đổi khi mạng thay đổi.

5.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Phân biệt được forwarding, routing, data plane và control plane.
- Mô tả được các bước router xử lý một IPv4 packet từ cổng vào đến cổng ra.
- Đọc được các trường cơ bản trong bảng định tuyến: destination prefix, next hop, interface và metric.

- Thực hiện được longest-prefix matching bằng tay và bằng Python.
- Giải thích được connected route, static route, default route và dynamic route.
- Biểu diễn được mạng dưới dạng đồ thị gồm node, edge và cost.
- Thực hiện được thuật toán đường đi ngắn nhất trên một đồ thị nhỏ.
- Phân biệt được cách tiếp cận link-state và distance-vector ở mức nguyên lý.
- Nhận biết được vai trò khái quát của RIP, OSPF và BGP mà không nhầm lẫn phạm vi của chúng.
- Phân tích được dữ liệu routing table và traceroute bằng pandas, Matplotlib và thư viện chuẩn của Python.
- Giải thích được các rủi ro route poisoning, route hijacking, định tuyến vòng và các biện pháp giảm thiểu.

5.2 Chuyển tiếp gói tin và hoạt động của bộ định tuyến

5.2.1 Forwarding và routing

Chuyển tiếp (forwarding) là thao tác cục bộ: router nhận một packet ở cổng vào, tra cứu thông tin đích và đưa packet tới cổng ra thích hợp. *Định tuyến* (routing) là quá trình tạo ra hoặc cập nhật thông tin đường đi mà forwarding sử dụng.

Ví dụ: trung tâm phân loại bưu kiện

Tại một trung tâm phân loại, mỗi kiện hàng được đọc mã vùng và đưa lên chuyển xe tiếp theo. Đó là quyết định forwarding. Việc công ty vận chuyển thiết kế mạng lưới kho, xác định kho nào kết nối với kho nào và tính tuyến ưu tiên là routing.

Giới hạn: bưu kiện thường được nhận biết bằng nhãn dễ đọc, còn router xử lý header nhị phân với tốc độ cao. Một packet cũng không nhất thiết đi theo cùng đường với packet trước đó.

5.2.2 Data plane và control plane

Mặt phẳng dữ liệu (data plane) thực hiện forwarding với tốc độ cao. *Mặt phẳng điều khiển* (control plane) học, tính toán hoặc nhận thông tin định tuyến rồi cài đặt kết quả vào bảng chuyển tiếp.

Tiêu chí	Data plane	Control plane
Câu hỏi chính	Packet này đi ra cổng nào?	Có những đường nào và nên dùng đường nào?
Tần suất	Xử lý từng packet	Cập nhật khi topology hoặc chính sách thay đổi
Dữ liệu dùng	Forwarding table/FIB	Routing information/RIB, thông tin láng giềng
Yêu cầu nổi bật	Tốc độ, độ trễ thấp	Tính đúng, hội tụ, chính sách

Ví dụ: biển chỉ dẫn và phòng điều hành giao thông

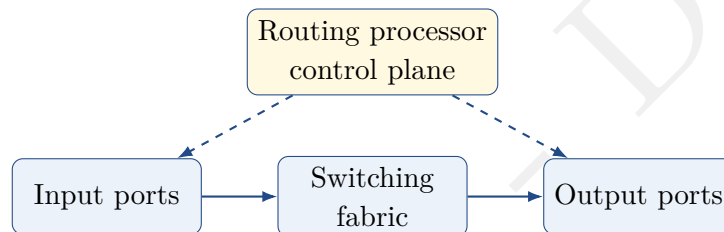
Biển chỉ dẫn tại ngã tư giúp xe rẽ ngay tại chỗ, tương tự data plane. Phòng điều hành thu thập tình trạng đường, quyết định phân luồng và cập nhật biển báo, tương tự control plane.

Giới hạn: trong mạng hiện đại, ranh giới có thể được triển khai theo nhiều kiến trúc khác nhau, nhưng cách phân biệt theo chức năng vẫn hữu ích.

5.2.3 Các thành phần của router

Một router có thể được mô tả bằng bốn nhóm thành phần:

- **Input ports:** nhận frame, kiểm tra tầng liên kết, tách packet và thực hiện tra cứu ban đầu.
- **Switching fabric:** chuyển dữ liệu từ cổng vào sang cổng ra bên trong thiết bị.
- **Output ports:** xếp hàng, tạo frame mới và phát lên liên kết kế tiếp.
- **Routing processor:** vận hành chức năng điều khiển, giao thức định tuyến và quản trị.



5.2.4 Các bước xử lý một IPv4 packet

Một mô hình đơn giản gồm các bước:

1. Router nhận một frame ở cổng vào và kiểm tra thông tin tầng Data Link.
2. Frame được tháo để lấy IPv4 packet.
3. Router kiểm tra header IPv4, bao gồm địa chỉ đích và TTL.
4. TTL giảm một đơn vị; header checksum được cập nhật.
5. Địa chỉ IP đích được tra cứu trong forwarding table.
6. Router chọn next hop và output interface.
7. Nếu cần, router tìm địa chỉ tầng liên kết của next hop, chẳng hạn qua ARP.
8. Packet được đóng trong một frame mới và đưa vào hàng đợi cổng ra.

Packet được giữ về mặt logic, frame thay đổi theo chặng

Địa chỉ IPv4 nguồn và đích thường không đổi khi packet đi qua router, ngoại trừ các cơ chế như NAT. Ngược lại, source MAC và destination MAC của frame thay đổi trên từng liên kết. TTL cũng thay đổi tại mỗi router.

5.2.5 Next hop và output interface

Nút kế tiếp (next hop) là router hoặc đích trực tiếp kế tiếp mà packet cần được chuyển đến. *giao diện đầu ra* (output interface) là giao diện cục bộ mà router dùng để gửi packet.

Một route có thể chỉ rõ:

- mạng đích;
- địa chỉ next hop;
- cổng ra;
- metric hoặc preference.

Với mạng kết nối trực tiếp, next hop có thể không cần là một router khác; router gửi trực tiếp tới host đích qua giao diện tương ứng.

5.2.6 TTL và định tuyến vòng

Nếu cấu hình sai hoặc quá trình hội tụ chưa hoàn tất, packet có thể đi vòng giữa các router. Trường TTL ngăn packet tồn tại vô hạn. Mỗi router giảm TTL; khi TTL về 0, router loại packet và thường gửi ICMP Time Exceeded về nguồn.

Ví dụ: tính toán TTL còn lại

Một packet rời máy nguồn với TTL bằng 64 và đi qua 11 router trước khi đến đích.

Kết quả: TTL khi đến đích là $64 - 11 = 53$.

Nếu có một vòng lặp và packet tiếp tục qua router, packet sẽ bị loại khi số lần giảm đủ làm TTL về 0. TTL không sửa lỗi định tuyến; nó chỉ giới hạn hậu quả của vòng lặp.

5.2.7 Hàng đợi tại cổng vào và cổng ra

Nếu nhiều packet cùng cần một cổng ra trong khi khả năng phát có hạn, packet phải chờ trong buffer. Khi buffer đầy, packet có thể bị drop. Vì vậy routing quyết định đường đi, nhưng hiệu năng thực tế còn phụ thuộc tải và hàng đợi trên đường.

Ví dụ: nhiều làn nhập vào một trạm thu phí

Nhiều làn xe có thể cùng nhập vào ít làn phía trước. Dù biển chỉ dẫn đúng, xe vẫn phải xếp hàng nếu năng lực phục vụ thấp hơn tốc độ xe đến. Tương tự, một output port có thể tắc dù bảng định tuyến hoàn toàn đúng.

Giới hạn: packet có kích thước khác nhau và cơ chế lập lịch mạng phức tạp hơn một hàng xe đơn giản.

5.2.8 Điều gì xảy ra khi không có route?

Nếu không có route phù hợp và cũng không có default route, router loại packet. Tùy chính sách, router có thể gửi ICMP Destination Unreachable. Tuy nhiên, firewall hoặc cấu hình bảo mật có thể làm thông báo không được gửi hoặc không đến được nguồn.

5.3 Bảng định tuyến và longest-prefix matching

5.3.1 Các trường cơ bản trong bảng định tuyến

Một cách biểu diễn tối giản:

Destination prefix	Next hop	Interface	Ý nghĩa
10.10.0.0/16	192.0.2.2	eth1	Đường tới mạng 10.10.0.0/16
10.10.20.0/24	192.0.2.6	eth2	Đường cụ thể hơn tới subnet 10.10.20.0/24
192.168.1.0/24	directly connected	eth0	Mạng kết nối trực tiếp
0.0.0.0/0	203.0.113.1	wan0	Default route

Trong thiết bị thực tế còn có nguồn route, metric, preference, tuổi route và nhiều thuộc tính khác.

5.3.2 Connected, static, default và dynamic route

- *tuyến kết nối trực tiếp* (connected route): xuất hiện vì một giao diện được cấu hình địa chỉ thuộc mạng đó và đang hoạt động.
- *tuyến tĩnh* (static route): do quản trị viên cấu hình thủ công.
- *tuyến mặc định* (default route): dùng khi không có route cụ thể hơn; IPv4 biểu diễn bằng 0.0.0.0/0.
- *tuyến động* (dynamic route): học qua giao thức định tuyến.

Ví dụ: lối đi riêng và biển “các hướng khác”

Một tòa nhà có biển riêng cho “Phòng A”, “Phòng B”, và một biển “Các phòng khác”. Biển cụ thể được ưu tiên khi phù hợp; biển chung chỉ dùng khi không có chỉ dẫn cụ thể hơn. Đây là trực giác của longest-prefix matching và default route.

5.3.3 Longest-prefix matching

Một địa chỉ đích có thể khớp nhiều prefix. Router chọn route có số bit prefix khớp dài nhất, tức route cụ thể nhất.

Ví dụ: phân tích chọn route cụ thể nhất

Giả sử bảng có:

- 10.0.0.0/8 qua R2;
- 10.20.0.0/16 qua R3;
- 10.20.30.0/24 qua R4;
- 0.0.0.0/0 qua ISP.

Với đích 10.20.30.77, cả bốn route đều có thể được xem xét, nhưng /24 dài nhất nên packet đi qua R4. Với 10.20.80.9, route /16 được chọn. Với 10.99.1.1, route /8 được chọn. Với 8.8.8.8,

default route được dùng.

5.3.4 Thực hiện LPM bằng phép toán bit

Một route P/n phù hợp với địa chỉ đích D nếu n bit đầu của D giống n bit đầu của prefix P . Có thể kiểm tra bằng:

$$D \text{ AND } M_n = P,$$

trong đó M_n là subnet mask tương ứng với prefix length n .

Sau khi tìm tất cả route phù hợp, chọn route có n lớn nhất.

5.3.5 Metric và preference không thay thế LPM

Trước hết router xét mức độ cụ thể của prefix. Metric thường dùng để chọn giữa các route tới **cùng prefix** hoặc theo quy tắc của hệ thống định tuyến. Không được lấy route /8 có metric nhỏ hơn để thay route /24 đang phù hợp, nếu bảng chuyển tiếp áp dụng longest-prefix matching thông thường.

Nhầm lẫn thường gặp

Sai lầm phổ biến là chọn “metric nhỏ nhất trong toàn bảng”. Quy trình đúng là:

1. tìm các prefix khớp địa chỉ đích;
2. chọn prefix dài nhất;
3. nếu còn nhiều route tương đương tới prefix đó, mới xét preference, metric hoặc cơ chế cân bằng tải.

5.3.6 Recursive next-hop lookup

Một static route có thể chỉ nêu địa chỉ next hop mà chưa nêu rõ cổng ra. Router phải tra cứu tiếp để biết next hop đó reachable qua interface nào. Đây là *tra cứu đệ quy* (recursive lookup).

Ví dụ, route tới 10.50.0.0/16 có next hop 192.0.2.9; một connected route 192.0.2.0/24 cho biết next hop này nằm trên eth1. Router từ đó chọn eth1.

5.3.7 Equal-cost multipat

Nếu có nhiều đường tới cùng prefix với chi phí tương đương, thiết bị có thể dùng *đa đường chi phí bằng nhau* (equal-cost multipath, ECMP). Việc phân phối thường dựa trên hash của các trường flow để các packet trong cùng flow có xu hướng đi cùng đường, tránh đảo lộn thứ tự quá mức.

ECMP không bảo đảm tải luôn chia đều tuyệt đối và không đồng nghĩa với việc gửi một packet thành nhiều bản sao.

5.3.8 Route aggregation

Nhiều mạng liên tiếp có thể được quảng bá bằng một prefix tổng quát nếu chúng có chung các bit đầu phù hợp. Aggregation làm bảng định tuyến nhỏ hơn và giảm số cập nhật.

Ví dụ: mã bưu chính theo vùng

Thay vì ghi riêng từng con phố trong bảng tuyến liên tỉnh, hệ thống có thể dùng một mã vùng chung để đưa thư đến trung tâm khu vực, sau đó trung tâm khu vực dùng chỉ dẫn chi tiết hơn. Route aggregation hoạt động tương tự.

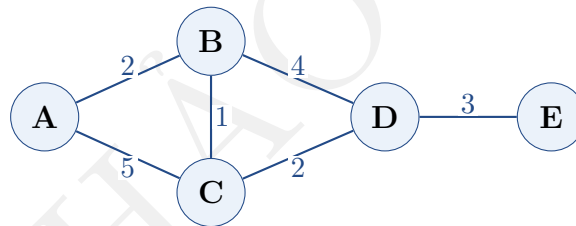
Giới hạn: chỉ được tổng hợp các prefix phù hợp về ranh giới nhị phân; tổng hợp sai có thể thu hút packet tới mạng không tồn tại hoặc tạo black hole.

5.4 Đồ thị, chi phí đường đi và Dijkstra

5.4.1 Node, edge và cost

Một mạng có thể được mô hình hóa bằng đồ thị $G = (V, E)$:

- V là tập node, thường đại diện router;
- E là tập liên kết;
- mỗi liên kết có cost, có thể phản ánh hop count, bandwidth, delay hoặc chính sách.



5.4.2 Đường đi và tổng chi phí

Một path từ A đến E là dãy node nối tiếp nhau. Tổng cost thường là tổng cost các edge trên path, nếu metric có tính cộng được.

Trong đồ thị trên:

- A-B-D-E có cost $2 + 4 + 3 = 9$;
- A-C-D-E có cost $5 + 2 + 3 = 10$;
- A-B-C-D-E có cost $2 + 1 + 2 + 3 = 8$.

Do đó đường thứ ba có cost nhỏ nhất theo metric đã cho.

5.4.3 Shortest path không luôn đồng nghĩa với ít hop nhất

Nếu cost là 1 cho mọi liên kết, shortest path tương ứng đường ít hop nhất. Nếu cost phản ánh thuộc tính khác, đường nhiều hop có thể có tổng cost thấp hơn.

Ví dụ: đường gần nhưng chậm

Hai tuyến đường: tuyến thứ nhất dài 8 km qua khu đông xe; tuyến thứ hai dài 11 km nhưng là đường cao tốc. “Ngắn nhất” phụ thuộc tiêu chí: khoảng cách, thời gian hay chi phí. Routing metric cũng phải được hiểu theo cách tương tự.

5.4.4 Thuật toán Dijkstra

Từ node nguồn, thuật toán Dijkstra lặp lại:

1. chọn node chưa cố định có khoảng cách tạm thời nhỏ nhất;
2. cố định khoảng cách tới node đó;
3. thử cải thiện khoảng cách tới các node láng giềng;
4. tiếp tục cho đến khi đủ node được xử lý.

Thuật toán áp dụng trực tiếp khi edge cost không âm.

Ví dụ từng bước

Với nguồn A trong đồ thị trên:

1. Ban đầu: $d(A) = 0$, các node khác là vô cùng.
2. Từ A: cập nhật $d(B) = 2$, $d(C) = 5$.
3. Chọn B: cập nhật $d(C) = 3$, $d(D) = 6$.
4. Chọn C: cập nhật $d(D) = 5$.
5. Chọn D: cập nhật $d(E) = 8$.

Đường A–B–C–D–E có cost 8.

5.4.5 Link-state: mỗi router xây dựng bản đồ topology

Trong cách tiếp cận *trạng thái liên kết* (link-state), router thu thập thông tin về topology trong một vùng, xây dựng cơ sở dữ liệu trạng thái liên kết và tính đường đi ngắn nhất. Trực giác gần với việc mỗi điểm điều hành có một bản đồ tương đối đầy đủ của khu vực.

Ưu điểm là có cái nhìn topology rõ; đổi lại cần cơ chế quảng bá trạng thái, đồng bộ cơ sở dữ liệu và tính toán.

5.4.6 Hội tụ và thông tin tạm thời không nhất quán

Hội tụ (convergence) là quá trình các router cập nhật để đạt trạng thái nhất quán sau thay đổi. Trong thời gian hội tụ có thể xảy ra:

- packet đi đường chưa tối ưu;
- black hole;
- routing loop;

- cập nhật dao động.

Thời gian hội tụ là một thuộc tính quan trọng nhưng không phải metric duy nhất để đánh giá giao thức.

5.5 Định tuyến tĩnh và động

5.5.1 Static route

Static route được cấu hình thủ công. Nó phù hợp khi:

- topology nhỏ và ổn định;
- chỉ có một đường ra;
- cần đường dự phòng có kiểm soát;
- cần route cụ thể cho mục đích quản trị.

Ưu điểm là đơn giản, dự đoán được và không phát sinh cập nhật định tuyến. Nhược điểm là khó mở rộng và không tự thích ứng nếu liên kết thay đổi, trừ khi có cơ chế theo dõi bổ sung.

5.5.2 Default route

Default route thường xuất hiện ở mạng nhánh hoặc host có một hướng ra chính. Nó trả lời: “Nếu không biết đích cụ thể, gửi về đâu?”

Ví dụ: quầy tiếp nhận chung

Một cơ quan có biển riêng cho một số phòng, nhưng tất cả yêu cầu còn lại được chuyển tới quầy tiếp nhận chung. Quầy này tương tự default gateway/default route.

Giới hạn: quầy tiếp nhận có thể hỏi lại người dùng; router chỉ xử lý theo bảng và chính sách đã cấu hình.

5.5.3 Dynamic routing

Dynamic routing cho phép router trao đổi thông tin và thích ứng với thay đổi. Điều này không loại bỏ vai trò quản trị viên: vẫn phải thiết kế metric, phạm vi quảng bá, xác thực, lọc route, summarization và chính sách.

5.5.4 IGP và EGP

Tiêu chí	IGP	EGP/inter-domain
Phạm vi điển hình	Bên trong một AS	Giữa các AS
Mục tiêu nổi bật	Reachability và đường nội bộ hiệu quả	Reachability liên miền và chính sách
Ví dụ	RIP, OSPF, IS-IS	BGP
Cách hiểu	Tối ưu vận hành trong một tổ chức	Lựa chọn đường theo thuộc tính và chính sách giữa tổ chức

5.5.5 RIP (Routing Information Protocol)

RIP là ví dụ điển hình của distance-vector và dùng hop count làm metric. Cách hiểu đơn giản, nhưng khả năng mở rộng và tốc độ hội tụ có giới hạn. Người học cần nhớ RIP để hiểu nguyên lý, không nên suy ra rằng mọi mạng hiện đại đều dùng hop count.

5.5.6 OSPF (Open Shortest Path First)

OSPF là giao thức link-state dùng trong một AS. Router trao đổi thông tin trạng thái liên kết, xây dựng cơ sở dữ liệu topology trong phạm vi thích hợp và tính đường đi. Khái niệm area giúp tổ chức phân cấp. Không nên đồng nhất OSPF cost với delay thực tế; cost phụ thuộc cách cấu hình và triển khai.

5.5.7 BGP (Border Gateway Protocol)

BGP trao đổi khả năng reachability giữa các AS và mang nhiều thuộc tính đường đi. Việc chọn route chịu ảnh hưởng mạnh của chính sách, không chỉ “đường ngắn nhất” theo khoảng cách vật lý.

Ví dụ: doanh nghiệp chọn đối tác vận chuyển

Một doanh nghiệp có thể không chọn tuyến ngắn nhất nếu tuyến đó qua đối tác đắt, rủi ro hoặc vi phạm thỏa thuận. BGP cũng cho phép chính sách kinh doanh và quản trị ảnh hưởng lựa chọn đường.

Giới hạn: chính sách BGP phức tạp hơn nhiều và không thể suy ra chỉ từ một tiêu chí đơn giản.

5.6 NAT, PAT và port mapping

5.6.1 Vì sao NAT được sử dụng rộng rãi?

dịch địa chỉ mạng (Network Address Translation, NAT) thay đổi địa chỉ IP trong packet khi packet đi qua thiết bị biên. Một động lực phổ biến là cho phép nhiều host dùng địa chỉ private chia sẻ một hoặc một số địa chỉ public.

NAT cũng được dùng trong các tình huống tổ chức, kết nối mạng chồng lấn hoặc xuất bản dịch vụ, nhưng nó tạo trạng thái và làm thay đổi mô hình end-to-end ban đầu của Internet.

5.6.2 Static NAT, dynamic NAT và PAT

Cơ chế	Ánh xạ	Đặc điểm
Static NAT	Một private IP với một public IP cố định	Dễ dự đoán, tốn địa chỉ public nếu nhiều host
Dynamic NAT	Private IP với một địa chỉ trong pool public	Ánh xạ tạo khi cần, phụ thuộc pool
PAT/NAPT	Nhiều phiên chia sẻ public IP, phân biệt bằng port	Rất phổ biến ở router gia đình và doanh nghiệp

Trong thực tế, thuật ngữ “NAT” thường được dùng rộng để chỉ cả PAT.

5.6.3 Bảng ánh xạ PAT

Ví dụ: tổng đài và số máy lẻ

Một cơ quan có một số điện thoại công cộng nhưng nhiều máy lẻ. Khi nhân viên gọi ra, tổng đài ghi máy lẻ nào đang dùng một phiên gọi và gắn thông tin phân biệt. Khi phản hồi quay lại, tổng đài chuyển đúng máy lẻ.

PAT gần với cơ chế này: nhiều địa chỉ private dùng chung một địa chỉ public, còn port giúp phân biệt các phiên.

Giới hạn: phiên mạng phức tạp hơn cuộc gọi; ánh xạ còn phụ thuộc protocol, source/destination tuple, timeout và chính sách thiết bị.

Ví dụ 10: hai host chia sẻ một public IP

Trước NAT:

- Host A: 192.168.1.10:51000 → 198.51.100.20:443.
- Host B: 192.168.1.11:51000 → 198.51.100.20:443.

Router có public IP 203.0.113.5, có thể tạo:

- A ↔ 203.0.113.5:40001.
- B ↔ 203.0.113.5:40002.

Port ngoài khác nhau cho phép router chuyển phản hồi về đúng host nội bộ.

5.6.4 NAT thay đổi checksum và trạng thái phiên

Khi thay địa chỉ IP hoặc port, thiết bị NAT phải cập nhật các trường checksum liên quan. Nó cũng duy trì bảng trạng thái có timeout. Nếu entry hết hạn hoặc không có ánh xạ phù hợp, packet từ bên ngoài thường không biết phải chuyển đến host nào.

Điều này giải thích vì sao một số ứng dụng peer-to-peer, VoIP hoặc giao thức nhúng địa chỉ vào payload cần cơ chế NAT traversal hoặc gateway ứng dụng.

5.6.5 Port forwarding

chuyển tiếp cổng (port forwarding) cấu hình ánh xạ lưu lượng đến một public IP/port vào một host/port nội bộ. Ví dụ public :8443 có thể được chuyển vào server private 192.168.1.50:443.

Port forwarding làm dịch vụ nội bộ có thể được truy cập từ bên ngoài và do đó làm tăng bề mặt tấn công. Chỉ nên mở dịch vụ cần thiết, áp dụng authentication, cập nhật, logging và giới hạn nguồn khi phù hợp.

5.6.6 NAT không phải firewall và không phải mã hóa

NAT có thể vô tình làm giảm kết nối từ ngoài vào vì không có ánh xạ, nhưng mục tiêu chính của nó không phải là chính sách bảo mật hoàn chỉnh.

Ba điều NAT không cung cấp

- NAT không mã hóa nội dung packet.
- NAT không xác thực người dùng hoặc thiết bị.
- NAT không phát hiện malware trong lưu lượng được phép.

Firewall quyết định cho phép/từ chối theo chính sách; NAT thay đổi địa chỉ/port. Hai chức năng thường nằm cùng thiết bị nhưng không đồng nhất.

5.7 Dữ liệu định tuyến và trực quan hóa tuyến

5.7.1 Câu hỏi phân tích và data dictionary

Các câu hỏi mẫu:

- Route nào sẽ được chọn cho một địa chỉ đích?
- Có bao nhiêu route connected, static và dynamic?
- Hop nào trong traceroute có RTT tăng đáng kể?
- Có route nào thiếu next hop hoặc interface không?
- Sau thay đổi topology, đường đi có đổi không?

Cột	Kiểu	Đơn vị	Ý nghĩa
prefix	string	–	Mạng đích dạng CIDR
next_hop	string	–	Địa chỉ router kế tiếp hoặc direct
interface	category	–	Cổng ra
source	category	–	connected, static, OSPF, RIP, BGP
metric	float/int	tùy giao thức	Chi phí trong phạm vi phù hợp
hop	int	hop	Thứ tự hop trong traceroute
rtt_ms	float	ms	RTT quan sát tới hop

5.7.2 Tạo DataFrame routing table mẫu

```
# CH05-CODE-01
import pandas as pd

routes = pd.DataFrame({
    "prefix": ["10.0.0.0/8", "10.20.0.0/16",
              "10.20.30.0/24", "0.0.0.0/0"],
    "next_hop": ["192.0.2.2", "192.0.2.3",
                "192.0.2.4", "203.0.113.1"],
    "interface": ["eth1", "eth2", "eth3", "wan0"],
    "source": ["OSPF", "static", "connected", "static"],
    "metric": [20, 5, 0, 100]
})

print(type(routes))
print(routes.shape)
print(routes.dtypes)
print(routes)
```

Kết quả là DataFrame có shape (4, 5). Mỗi hàng là một route, không phải một packet.

5.7.3 Hàm longest-prefix matching bằng ipaddress

```
# CH05-CODE-02
from ipaddress import ip_address, ip_network

def lookup_route(destination, route_table):
    dst = ip_address(destination)
    candidates = []

    for row in route_table.to_dict("records"):
        network = ip_network(row["prefix"])
        if dst in network:
            candidates.append((network.prefixlen, row))
```

```

    if not candidates:
        return None

    _, best_row = max(candidates, key=lambda item: item[0])
    return best_row

result = lookup_route("10.20.30.77", routes)
print(result)

```

Hàm chuyển địa chỉ đích thành đối tượng IP, kiểm tra membership trong từng network, rồi chọn prefix length lớn nhất. Với dữ liệu trên, route 10.20.30.0/24 được chọn.

5.7.4 Biểu diễn đồ thị và Dijkstra bằng Python

```

# CH05-CODE-04
import heapq

graph = {
    "A": {"B": 2, "C": 5},
    "B": {"A": 2, "C": 1, "D": 4},
    "C": {"A": 5, "B": 1, "D": 2},
    "D": {"B": 4, "C": 2, "E": 3},
    "E": {"D": 3}
}

def dijkstra(graph, source):
    distance = {node: float("inf") for node in graph}
    previous = {node: None for node in graph}
    distance[source] = 0
    queue = [(0, source)]

    while queue:
        current_dist, node = heapq.heappop(queue)
        if current_dist != distance[node]:
            continue

        for neighbor, cost in graph[node].items():
            new_dist = current_dist + cost
            if new_dist < distance[neighbor]:
                distance[neighbor] = new_dist
                previous[neighbor] = node
                heapq.heappush(queue, (new_dist, neighbor))

    return distance, previous

print(dijkstra(graph, "A")[0])

```

Output dự kiến cho E là cost 8. Dictionary `previous` được dùng để phục hồi path.

5.7.5 Dữ liệu traceroute mẫu

```
# CH05-CODE-06
trace = pd.DataFrame({
    "hop": [1, 2, 3, 4, 5, 6],
    "router": ["192.168.1.1", "10.0.0.1", "198.51.100.9",
               "203.0.113.6", "203.0.113.10", "203.0.113.20"],
    "rtt_ms": [1.2, 3.8, 9.5, 18.2, 20.1, 22.4]
})

print(trace.shape)
print(trace.dtypes)
print(trace[["hop", "rtt_ms"]].describe())
```

Mỗi hàng là một hop quan sát được trong một lần đo mẫu. Đây không phải routing table và cũng không chứng minh tuyến hai chiều giống nhau.

5.7.6 Vẽ RTT theo hop

```
# CH05-CODE-07
import matplotlib.pyplot as plt

fig, ax = plt.subplots(figsize=(8, 4))
ax.plot(trace["hop"], trace["rtt_ms"], marker="o")
ax.set_title("RTT observed along a sample path")
ax.set_xlabel("Hop number")
ax.set_ylabel("RTT in milliseconds")
ax.set_xticks(trace["hop"])
ax.grid(True, alpha=0.3)
plt.show()
```

Một điểm biểu diễn RTT quan sát tới một hop, không phải delay riêng của liên kết vừa đi qua. Chênh lệch giữa hai điểm chỉ là dấu hiệu để điều tra, không phải phép đo chính xác delay của một router.

5.8 An toàn định tuyến

5.8.1 Route poisoning và thông tin sai lệch

Nếu router nhận và tin thông tin route sai, traffic có thể bị chuyển sai hướng, black hole hoặc đi qua thiết bị không mong muốn. Nguồn sai có thể là lỗi cấu hình, giao thức không được bảo vệ hoặc hành vi cố ý.

5.8.2 Route hijacking

chiếm đoạt tuyến (route hijacking) là tình huống một mạng quảng bá reachability không đúng hoặc không được ủy quyền, làm traffic bị thu hút về phía nó. Ở quy mô inter-domain, hậu quả có thể lớn vì route lan truyền qua nhiều AS.

Không phải mọi route leak hoặc hijack đều là tấn công cố ý; lỗi cấu hình cũng có thể tạo hiện tượng tương tự. Phân tích phải dựa trên bằng chứng.

5.8.3 Rogue router và neighbor giả mạo

Một thiết bị trái phép có thể cố gắng tham gia miền định tuyến hoặc gửi thông tin điều khiển giả. Biện pháp giảm thiểu gồm:

- xác thực neighbor khi giao thức hỗ trợ;
- giới hạn giao diện được phép hình thành adjacency;
- ACL/control-plane policing;
- phân đoạn mạng quản trị;
- giám sát thay đổi neighbor và route.

5.8.4 Prefix filtering và nguyên tắc ít đặc quyền

Router chỉ nên chấp nhận hoặc quảng bá các prefix được phép. Prefix list, route policy và giới hạn số lượng route giúp giảm lỗi lan truyền. Nguyên tắc là không tin mọi thông tin chỉ vì nó đến qua một phiên định tuyến hợp lệ.

5.8.5 Xác thực và bảo vệ control plane

Mục tiêu gồm:

- xác định đúng neighbor;
- bảo vệ tính toàn vẹn thông điệp;
- giới hạn lưu lượng điều khiển;
- tách truy cập quản trị khỏi dữ liệu người dùng;
- ghi nhật ký và đồng bộ thời gian.

Mã hóa đường quản trị không đồng nghĩa mọi update định tuyến tự động được xác thực; cần phân biệt kênh quản trị và kênh giao thức.

5.8.6 Kiểm chứng nguồn gốc route

Trong định tuyến liên miền, có thể dùng dữ liệu ủy quyền và cơ chế xác thực nguồn gốc để kiểm tra một AS có được phép công bố một prefix hay không. Cơ chế này giảm một loại sai lệch nhưng không chứng minh toàn bộ đường AS là an toàn và không thay thế lọc chính sách.

5.9 Tổng kết chương

5.9.1 Tóm tắt chương

- Forwarding xử lý từng packet; routing xây dựng tri thức đường đi.
- Data plane ưu tiên tốc độ; control plane ưu tiên tính đúng, hội tụ và chính sách.
- Router tháo frame cũ, giảm TTL, tra cứu IP đích và tạo frame mới cho chặng kế tiếp.
- Longest-prefix matching chọn route cụ thể nhất trong số các route phù hợp.
- Metric thường được xét sau khi đã xác định prefix phù hợp nhất.
- Mạng có thể biểu diễn bằng đồ thị; shortest path phụ thuộc định nghĩa cost.
- Link-state xây dựng cái nhìn topology; distance-vector trao đổi khoảng cách với láng giềng.
- Static route phù hợp mạng nhỏ, còn dynamic routing hỗ trợ thích ứng và mở rộng.
- RIP, OSPF và BGP thuộc các phạm vi và nguyên lý khác nhau.
- Route sai có thể gây loop, black hole hoặc hijacking; cần xác thực, lọc, giám sát và kiểm soát thay đổi.

5.9.2 Bài luyện tập

Bài 1. Phân biệt forwarding và routing bằng một ví dụ không sử dụng giao thông hoặc bưu kiện.

Bài 2. Giải thích vì sao router phải thay frame nhưng thường giữ địa chỉ IP nguồn và đích.

Bài 3. Một packet có TTL 32 đi qua 7 router. TTL khi đến đích bằng bao nhiêu?

Bài 4. Cho các route 192.168.0.0/16, 192.168.10.0/24, 192.168.10.128/25 và default. Chọn route cho 192.168.10.200.

Bài 5. Với cùng bảng trên, chọn route cho 192.168.11.8.

Bài 6. Vì sao metric nhỏ nhất không được xét trước longest-prefix matching?

Bài 7. Route 10.0.0.0/8 có next hop 172.16.1.2; connected route là 172.16.1.0/24 trên eth2. Cổng ra nào được dùng?

Bài 8. Tính cost của path A-B-C-D-E trong đồ thị của chương.

Bài 9. Nếu cost B-C tăng từ 1 lên 10, tìm path tốt hơn từ A tới E.

Bài 10. Nêu hai điểm khác nhau giữa link-state và distance-vector.

Bài 11. Khi nào static route là lựa chọn hợp lý?

Bài 12. Vì sao BGP không thể chỉ được mô tả là thuật toán tìm đường ngắn nhất?

Bài 13. Giải thích một nguyên nhân khiến traceroute có dấu * nhưng traffic ứng dụng vẫn hoạt động.

Bài 14. Nêu hai rủi ro trong thời gian hội tụ.

Bài 15. Viết điều kiện để route 172.16.0.0/12 khớp một địa chỉ đích bằng phép AND.

- Bài 16.** Một routing table có 100 route OSPF và 3 static route. Có thể kết luận static route luôn được chọn không? Giải thích.
- Bài 17.** Đề xuất ba cột cần có để lưu route trong DataFrame.
- Bài 18.** Giải thích vì sao chênh lệch RTT giữa hop 4 và hop 5 không phải delay chính xác của liên kết 4–5.
- Bài 19.** Nêu ba biện pháp giảm nguy cơ nhận route trái phép.
- Bài 20.** Phân biệt route aggregation đúng với việc dùng một default route.

5.9.3 Lời giải bài luyện tập

Lời giải Bài 1

Ví dụ nhà hàng: quy trình quản lý quyết định món nào do bếp nào phụ trách tương tự routing; nhân viên chuyển từng phiếu gọi món tới đúng bếp tương tự forwarding. Ví dụ cần nêu rằng router xử lý theo bảng, không suy nghĩ linh hoạt như con người.

Lời giải Bài 2

Frame chỉ phục vụ một liên kết. Khi sang liên kết mới, router cần source MAC và destination MAC mới. IPv4 packet đại diện truyền logic nguồn–đích qua nhiều mạng nên địa chỉ IP thường giữ nguyên, trừ NAT hoặc cơ chế đặc biệt. TTL và checksum header thay đổi.

Lời giải Bài 3

TTL còn lại là $32 - 7 = 25$.

Lời giải Bài 4

Đích 192.168.10.200 thuộc cả /16, /24 và /25 bắt đầu tại 128. Chọn 192.168.10.128/25 vì prefix dài nhất.

Lời giải Bài 5

192.168.11.8 thuộc 192.168.0.0/16 nhưng không thuộc 192.168.10.0/24; chọn /16.

Lời giải Bài 6

LPM xác định route cụ thể nhất cho không gian địa chỉ đích. Metric chỉ có ý nghĩa khi so sánh các route phù hợp trong cùng bối cảnh. Nếu chọn metric toàn cục trước, một route tổng quát có thể lấn route chi tiết và làm sai mục tiêu phân cấp.

Lời giải Bài 7

Next hop 172.16.1.2 thuộc connected network 172.16.1.0/24; recursive lookup cho biết dùng eth2.

Lời giải Bài 8

A–B–C–D–E có cost $2 + 1 + 2 + 3 = 8$.

Lời giải Bài 9

Khi B-C bằng 10, A-B-D-E có cost $2 + 4 + 3 = 9$; A-C-D-E có cost $5 + 2 + 3 = 10$. Chọn A-B-D-E với cost 9.

Lời giải Bài 10

Link-state quảng bá trạng thái liên kết và mỗi router tính trên cơ sở topology; distance-vector trao đổi khoảng cách tới đích với láng giềng. Link-state có cơ sở dữ liệu topology rõ hơn, còn distance-vector dựa nhiều hơn vào thông tin tổng hợp từ neighbor.

Lời giải Bài 11

Static route hợp lý trong mạng nhỏ ổn định, stub network chỉ có một đường ra, route quản trị đặc biệt hoặc đường dự phòng được kiểm soát. Nó không phù hợp khi topology lớn và thay đổi thường xuyên nếu không có cơ chế tự động bổ sung.

Lời giải Bài 12

BGP chọn đường theo nhiều thuộc tính và chính sách giữa các AS. Quan hệ kinh doanh, lọc, preference và quy định quản trị có thể quan trọng hơn khoảng cách vật lý hoặc số AS đơn thuần.

Lời giải Bài 13

Router trung gian có thể chuyển tiếp packet nhưng không gửi ICMP Time Exceeded, hoặc phản hồi bị firewall lọc/rate-limit. Vì vậy ứng dụng vẫn hoạt động dù traceroute có dấu sao.

Lời giải Bài 14

Hai rủi ro: routing loop làm packet đi vòng và black hole làm packet bị loại ở một điểm không có route đúng. Ngoài ra còn có đường tạm thời không tối ưu hoặc cập nhật dao động.

Lời giải Bài 15

Với mask 255.240.0.0, route khớp nếu destination AND 255.240.0.0 = 172.16.0.0.

Lời giải Bài 16

Không. Việc chọn còn phụ thuộc prefix nào khớp, preference/administrative rule và metric. Số lượng route mỗi loại không quyết định route cho một đích cụ thể.

Lời giải Bài 17

Tối thiểu gồm prefix, next_hop, interface. Có thể thêm source, metric, age và trạng thái.

Lời giải Bài 18

Mỗi RTT là thời gian khứ hồi tới một hop, chịu ảnh hưởng đường về, queueing và cách router ưu tiên ICMP. Hiệu hai RTT không tách riêng chính xác delay của một liên kết.

Lời giải Bài 19

Ví dụ: xác thực neighbor, chỉ cho phép adjacency trên interface cần thiết, prefix filtering/route policy, control-plane ACL, giám sát thay đổi và phân đoạn mạng quản trị.

Lời giải Bài 20

Aggregation tạo một prefix chung đại diện có chủ đích cho nhiều prefix cụ thể và vẫn mang thông tin vùng đích. Default route khớp mọi địa chỉ khi không có route cụ thể hơn; nó không chứng minh các mạng đích thuộc cùng một khối tổng hợp.

5.9.4 Câu hỏi trắc nghiệm

Câu 1. Chức năng nào xử lý quyết định cổng ra cho từng packet?

- A. Forwarding
- B. Route aggregation
- C. Name resolution
- D. Application multiplexing

Câu 2. Khi nhiều route cùng khớp địa chỉ đích, nguyên tắc cơ bản nào được dùng trước?

- A. Chọn route có prefix dài nhất
- B. Chọn route được tạo sớm nhất
- C. Chọn cổng có tên ngắn nhất
- D. Chọn route có next hop lớn nhất

Câu 3. Route 0.0.0.0/0 thường có vai trò gì?

- A. Default route
- B. Loopback route
- C. Broadcast route
- D. Host route

Câu 4. Khi router chuyển một IPv4 packet thông thường sang liên kết kế tiếp, yếu tố nào chắc chắn thay đổi?

- A. TTL giảm
- B. IP đích trở thành IP của router
- C. Transport port bị xóa
- D. Payload ứng dụng bị mã hóa

Câu 5. Cách tiếp cận nào thường xây dựng cơ sở dữ liệu topology để tính đường đi?

- A. Link-state
- B. ARP
- C. NAT

D. DNS caching

Câu 6. RIP dùng metric nổi bật nào ở mức cơ bản?

- A. Hop count
- B. Giá điện năng
- C. Kích thước payload
- D. Số port TCP

Câu 7. Giao thức nào gắn chủ yếu với định tuyến giữa các AS?

- A. BGP
- B. ARP
- C. DHCP
- D. Ethernet

Câu 8. Dấu sao trong traceroute cho phép kết luận chắc chắn điều gì?

- A. Chỉ rằng phép đo không nhận được phản hồi dự kiến tại probe đó
- B. Router chắc chắn đã hỏng
- C. Không có route tới đích
- D. Packet ứng dụng luôn bị chặn

Câu 9. Rủi ro nào mô tả packet đi lặp qua một nhóm router?

- A. Routing loop
- B. Port multiplexing
- C. Frame padding
- D. DNS delegation

Câu 10. Biện pháp nào phù hợp để giảm việc nhận route ngoài ý muốn?

- A. Prefix filtering và route policy
- B. Tăng kích thước application message
- C. Tắt mọi checksum
- D. Đổi port HTTP

5.9.5 Đáp án và giải thích

Câu 1. Đáp án đúng: A. Forwarding là quyết định cục bộ cho từng packet tại data plane.

Câu 2. Đáp án đúng: A. Longest-prefix matching chọn route cụ thể nhất trước khi xét các tiêu chí tiếp theo trong cùng bối cảnh.

Câu 3. Đáp án đúng: A. 0.0.0.0/0 khớp mọi IPv4 address và được dùng khi không có route cụ thể hơn.

Câu 4. Đáp án đúng: A. Mỗi router giảm TTL; frame và header checksum cũng được cập nhật theo xử lý.

Câu 5. Đáp án đúng: A. Link-state quảng bá trạng thái liên kết và hỗ trợ xây dựng cái nhìn topology.

Câu 6. Đáp án đúng: A. RIP dùng hop count ở mức nguyên lý cơ bản.

Câu 7. Đáp án đúng: A. BGP là giao thức chủ đạo cho trao đổi reachability giữa các AS.

Câu 8. Đáp án đúng: A. Dấu sao chỉ nói rằng phản hồi dự kiến không được quan sát; không đủ để kết luận router hỏng.

Câu 9. Đáp án đúng: A. Routing loop làm packet đi vòng cho tới khi TTL hoặc cơ chế khác dừng nó.

Câu 10. Đáp án đúng: A. Prefix filtering và route policy giới hạn route được chấp nhận hoặc quảng bá.

Chương 6

UDP, TCP và truyền dữ liệu đầu cuối

6.1 Mục tiêu và câu hỏi mở đầu

Câu hỏi mở đầu

Hai ứng dụng trên cùng một máy cùng gửi dữ liệu qua IP. Làm thế nào hệ điều hành biết dữ liệu nhận được phải chuyển cho tiến trình nào? Vì sao một ứng dụng truyền file thường cần TCP trong khi một ứng dụng thời gian thực có thể chấp nhận UDP? Khi một TCP segment bị mất, những field nào giúp hai đầu phát hiện và phục hồi?

Ví dụ: tòa nhà, phòng và cuộc hội thoại có đánh số

Địa chỉ IP giống địa chỉ một tòa nhà; port giống số phòng giúp chuyển thư tới đúng dịch vụ. Với TCP, có thể hình dung một bộ tài liệu được đánh số theo byte và bên nhận thường xuyên báo “tôi đã nhận liên tục đến vị trí N”. Nếu một đoạn bị thiếu, bên gửi có cơ sở để truyền lại.

Giới hạn: TCP không gửi từng “trang” độc lập; nó cung cấp một byte stream. ACK của TCP cũng không chứng minh ứng dụng đã xử lý dữ liệu thành công.

Sau khi hoàn thành phần này, người học có thể

- Phân biệt host-to-host và process-to-process, port, socket và socket pair.
- Đọc được các field chính của UDP header và TCP header.
- Giải thích được three-way handshake, sequence number, acknowledgment, retransmission và termination.
- Giải thích được flow control, congestion control, MSS, RTT, window và BDP ở mức cần cho phân tích mạng.
- Tính được sequence/ACK tiếp theo và giới hạn throughput đơn giản từ window/RTT.
- Chuyển được tư duy từ packet sang flow: xác định flow key, aggregation và một số flow feature có ý nghĩa mạng.

Thực hành liên quan

Thực hành liên quan nằm trong Module 04. Các đoạn code trong chương chỉ nhằm làm rõ cấu trúc dữ liệu và ý nghĩa của feature; phần quan sát packet bằng Wireshark được trình bày riêng trong phụ lục bổ trợ.

6.2 Port, socket và truyền dữ liệu liên tiến trình

6.2.1 Từ host-to-host đến process-to-process

Tầng Network đưa packet đến đúng host. Tuy nhiên, một host có thể chạy nhiều tiến trình mạng cùng lúc. Tầng Transport bổ sung khả năng nhận diện tiến trình bằng port và cung cấp giao tiếp logic từ tiến trình nguồn đến tiến trình đích.

Ví dụ: trung tâm tiếp nhận có nhiều quầy

Một bưu kiện được giao đến đúng trụ sở nhưng vẫn cần chuyển đến quầy kế toán, phòng đào tạo hoặc bộ phận kỹ thuật. Địa chỉ trụ sở tương tự địa chỉ IP; mã quầy tương tự port.

Giới hạn: trong hệ điều hành, việc chuyển dữ liệu không chỉ dựa vào một số port riêng lẻ. Với TCP, hệ điều hành thường phân biệt kết nối bằng nhiều trường, trong đó có địa chỉ IP nguồn, port nguồn, địa chỉ IP đích và port đích.

6.2.2 Port và không gian số port

Port là số nguyên 16 bit, vì vậy về lý thuyết có các giá trị từ 0 đến 65535. Ba vùng thường được dùng để tổ chức việc cấp phát:

Vùng	Khoảng	Ý nghĩa khái quát
Well-known	0–1023	Dịch vụ chuẩn hoặc phổ biến, thường cần quyền cao hơn để lắng nghe trên nhiều hệ điều hành.
Registered	1024–49151	Dịch vụ, sản phẩm hoặc ứng dụng đã đăng ký hay sử dụng theo quy ước.
Dynamic/private	49152–65535	Thường dùng làm ephemeral port cho phía khởi tạo kết nối.

Các khoảng này hỗ trợ tổ chức và khả năng tương tác, nhưng không bảo đảm rằng mọi ứng dụng luôn tuân thủ đúng port thường dùng. Vì vậy, chỉ dựa vào port để kết luận loại ứng dụng có thể dẫn đến sai sót.

6.2.3 Socket và socket pair

Một *socket* (điểm cuối giao tiếp) là giao diện phần mềm giữa tiến trình và tầng Transport. Có thể xem một endpoint được nhận diện bởi:

(protocol, IP address, port)

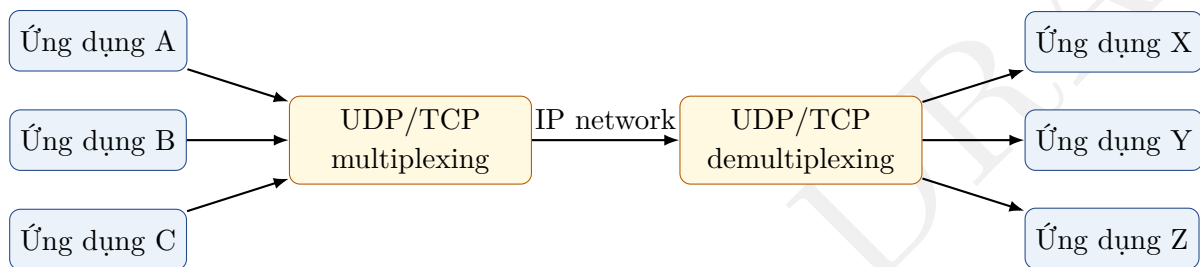
Một TCP connection thường được phân biệt bằng bộ bốn:

(source IP, source port, destination IP, destination port)

Cùng một web server có thể phục vụ nhiều client trên port 443 vì mỗi connection có source IP hoặc source port khác nhau.

6.2.4 Ghép kênh và phân kênh logic

Ghép kênh logic (multiplexing) ở phía gửi là quá trình nhận dữ liệu từ nhiều socket, bổ sung header transport và chuyển xuống tầng Network. *phân kênh logic* (demultiplexing) ở phía nhận là quá trình đọc header để chuyển dữ liệu đến đúng socket hoặc tiến trình.



6.2.5 Server port và ephemeral port

Server thường lắng nghe trên một port đã biết hoặc được cấu hình trước. Client thường được hệ điều hành cấp một ephemeral port tạm thời. Ví dụ:

Client socket	192.0.2.10:53124
Server socket	198.51.100.20:443
Protocol	TCP

Khi kết nối kết thúc, ephemeral port có thể được tái sử dụng sau khi các điều kiện của hệ điều hành cho phép.

6.2.6 Connection và flow không hoàn toàn đồng nghĩa

Trong TCP, connection là trạng thái giao tiếp được hai endpoint duy trì. Trong phân tích dữ liệu, flow thường là nhóm packet có cùng các trường nhận diện trong một khoảng thời gian, chẳng hạn bộ năm:

(src IP, dst IP, src port, dst port, protocol)

Một flow record là bản tóm tắt quan sát, không nhất thiết chứa đầy đủ trạng thái nội bộ của TCP. Hai hệ thống giám sát có thể dùng timeout khác nhau và tạo ra số flow khác nhau từ cùng một traffic trace.

6.2.7 Port không phải là bằng chứng duy nhất về ứng dụng

HTTPS thường dùng TCP port 443, DNS thường dùng UDP hoặc TCP port 53. Tuy nhiên:

- Ứng dụng có thể dùng port không chuẩn.
- Nhiều ứng dụng khác nhau có thể đi qua cùng port 443.
- Tunneling và proxy có thể làm mờ quan hệ giữa port và ứng dụng cuối.
- Mã hóa làm giảm khả năng quan sát payload nhưng metadata vẫn còn giá trị.

6.2.8 Ví dụ phân tích socket pair

Ví dụ: Xác định endpoint

Một packet TCP có source IP 10.0.0.8, source port 52000, destination IP 203.0.113.5, destination port 443.

Phân tích:

- Endpoint phía client: 10.0.0.8:52000.
- Endpoint phía server: 203.0.113.5:443.
- Bộ bốn nhận diện chiều đang quan sát: (10.0.0.8, 52000, 203.0.113.5, 443).
- Port 443 gợi ý HTTPS nhưng chưa đủ để khẳng định nội dung ứng dụng.

6.3 UDP và truyền datagram không hướng-kết nối

6.3.1 Đặc điểm cơ bản của UDP

UDP cung cấp dịch vụ datagram đơn giản cho ứng dụng. Các đặc điểm chính:

- Không thiết lập connection trước khi gửi.
- Giữ ranh giới message: một lần gửi tạo một UDP datagram ở tầng Transport.
- Không tự bảo đảm giao đúng, đúng thứ tự hoặc không trùng lặp.
- Header nhỏ và xử lý đơn giản.
- Ứng dụng có thể tự bổ sung cơ chế reliability, timing hoặc congestion control nếu cần.

Ví dụ: thông báo qua loa

Một thông báo công cộng được phát ngay mà không đợi từng người xác nhận. Cách làm này ít thủ tục và phù hợp khi thông tin cần truyền nhanh hoặc được lặp lại định kỳ.

Giới hạn: UDP không phải là “phát thanh” theo nghĩa mạng và vẫn có source/destination cụ thể trong nhiều trường hợp. Một ứng dụng UDP cũng có thể xây dựng acknowledgment riêng; khi đó độ tin cậy đến từ ứng dụng, không phải từ UDP header.

6.3.2 Cấu trúc UDP header

UDP header có độ dài 8 byte, gồm bốn trường 16 bit:

Source Port 16 bit	Destination Port 16 bit
Length 16 bit	Checksum 16 bit
Application data	

Trường Length tính tổng UDP header và payload. Checksum giúp phát hiện một số lỗi truyền dẫn; phát hiện lỗi không đồng nghĩa với tự sửa lỗi hay tự truyền lại.

6.3.3 Message boundary và kích thước datagram

UDP giữ ranh giới message. Nếu ứng dụng gửi ba message riêng, phía nhận đọc các datagram riêng. Tuy nhiên, datagram quá lớn có thể dẫn đến IP fragmentation hoặc bị loại bỏ trên đường đi. Trong thực hành, ứng dụng nên cân nhắc MTU và overhead của IP/UDP.

Ví dụ: Hiệu suất payload của UDP

Một ứng dụng gửi payload 1200 byte qua IPv4 không có option và UDP.

Dữ kiện: IPv4 header 20 byte, UDP header 8 byte.

$$\text{Tổng kích thước IP packet} = 1200 + 8 + 20 = 1228 \text{ byte}$$

$$\text{Payload efficiency} = \frac{1200}{1228} \times 100\% \approx 97.72\%$$

Ý nghĩa: với payload lớn, tỷ lệ overhead của IP/UDP tương đối nhỏ. Với payload rất nhỏ, tỷ lệ overhead tăng đáng kể.

6.3.4 Checksum và giới hạn của phát hiện lỗi

Checksum được tính trên UDP header, data và một pseudo-header lấy thông tin từ IP. Mục tiêu là phát hiện sai lệch. Nếu checksum không hợp lệ, datagram thường bị loại bỏ. UDP không gửi thông báo yêu cầu truyền lại; ứng dụng phải quyết định cách xử lý mất mát.

6.3.5 Các tình huống sử dụng UDP

UDP phù hợp khi một hoặc nhiều đặc điểm sau quan trọng:

- Giảm thủ tục thiết lập connection.
- Ứng dụng quan tâm dữ liệu mới hơn dữ liệu cũ.
- Ứng dụng có cơ chế điều khiển riêng.
- Một request và một response nhỏ có thể hoàn thành nhanh.
- Hỗ trợ multicast hoặc broadcast trong phạm vi thích hợp.

Ví dụ thường gặp gồm DNS query, DHCP, một số luồng thoại/video thời gian thực và giao thức được thiết kế riêng trên UDP. Không nên kết luận rằng mọi ứng dụng thời gian thực đều dùng UDP hoặc UDP luôn nhanh hơn TCP.

6.3.6 UDP và DNS: đơn giản nhưng không tuyệt đối

DNS query thông thường thường dùng UDP vì request/response nhỏ và không cần connection kéo dài. Tuy nhiên, DNS cũng dùng TCP trong nhiều tình huống, chẳng hạn response lớn, zone transfer hoặc khi cơ chế ứng dụng yêu cầu. Vì vậy, quy tắc “DNS bằng UDP” chỉ là cách nhớ ban đầu, không phải khẳng định tuyệt đối.

6.3.7 Mất, trễ, trùng và đảo thứ tự

Từ góc nhìn ứng dụng UDP, datagram có thể:

- Không đến đích;
- Đến muộn;
- Đến trùng;
- Đến khác thứ tự gửi.

Ứng dụng có thể gắn sequence number, timestamp hoặc acknowledgment trong payload nếu cần phát hiện các tình huống này.

6.3.8 Khi nào không nên chọn UDP chỉ vì “nhẹ”

UDP không tự động giải quyết congestion. Một ứng dụng gửi UDP không kiểm soát có thể chiếm bandwidth, tăng packet loss và gây hại cho các flow khác. Thiết kế ứng dụng phải xem xét rate control, backoff, giới hạn kích thước, timeout và khả năng thích ứng.

6.4 TCP: connection và truyền byte tin cậy

6.4.1 TCP cung cấp những gì?

TCP cung cấp một reliable byte stream luồng byte tin cậy giữa hai endpoint. Các chức năng quan trọng gồm:

- Thiết lập và kết thúc connection;
- Đánh số byte;
- Acknowledgment tích lũy;
- Retransmission khi cần;
- Kiểm soát luồng;
- Kiểm soát tắc nghẽn;
- Phát hiện lỗi bằng checksum.

TCP không giữ ranh giới message của ứng dụng. Hai lần gọi gửi của ứng dụng có thể được ghép hoặc chia thành các TCP segment khác nhau.

Ví dụ: gửi bộ hồ sơ nhiều trang có đánh số

Một bộ hồ sơ được chia thành nhiều phần, mỗi phần có số thứ tự. Bên nhận thông báo phần tiếp theo đang chờ; nếu quá lâu không nhận được xác nhận, bên gửi gửi lại phần cần thiết. Phép so sánh giúp hình dung sequence number, acknowledgment và retransmission.

Giới hạn: TCP đánh số byte, không nhất thiết đánh số “gói tài liệu”. Acknowledgment thường tích lũy và các thuật toán thực tế phức tạp hơn việc xác nhận từng segment một.

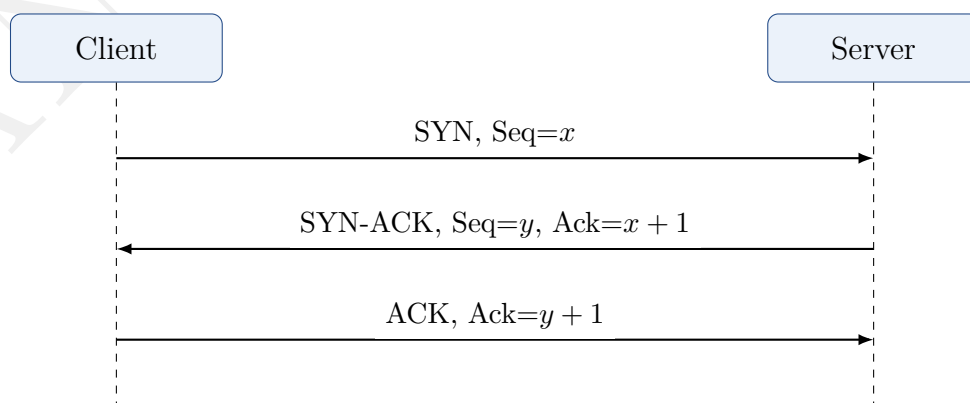
6.4.2 Cấu trúc TCP header ở mức cần thiết

TCP header tối thiểu 20 byte. Các trường quan trọng:

Trường	Kích thước	Vai trò
Source/Destination Port	16 bit mỗi trường	Nhận diện endpoint ứng dụng.
Sequence Number	32 bit	Số thứ tự byte đầu tiên trong segment, hoặc initial sequence number trong SYN.
Acknowledgment Number	32 bit	Số thứ tự byte tiếp theo phía nhận đang chờ khi ACK hợp lệ.
Data Offset	4 bit	Độ dài TCP header theo đơn vị 32 bit word.
Flags	Nhiều bit cờ	SYN, ACK, FIN, RST, PSH và các cờ khác.
Window Size	16 bit	Thông tin receiver window cơ bản.
Checksum	16 bit	Phát hiện lỗi trên header và data.
Options	Biến đổi	MSS, window scaling, timestamp và các tùy chọn khác.

6.4.3 Three-way handshake

TCP thiết lập connection bằng ba bước cơ bản:



Handshake xác nhận hai chiều giao tiếp, trao đổi initial sequence number và một số option. SYN tiêu thụ một vị trí trong không gian sequence number.

6.4.4 Sequence number và acknowledgment number

Nếu một segment có $\text{Seq} = 1001$ và mang 500 byte data, các byte được đánh số từ 1001 đến 1500. Phía nhận nhận đủ có thể gửi $\text{Ack} = 1501$, nghĩa là byte tiếp theo đang chờ là 1501.

Ví dụ: Tính acknowledgment

Một TCP segment bắt đầu tại $\text{Seq} = 7000$ và mang 1460 byte payload.

$$\text{Ack tiếp theo} = 7000 + 1460 = 8460$$

Nếu segment đến đầy đủ và đúng thứ tự, phía nhận có thể báo $\text{Ack} = 8460$. Kết quả không cộng thêm độ dài TCP/IP header vì sequence number đánh số byte của TCP stream, không đánh số toàn bộ packet.

6.4.5 Cumulative acknowledgment

ACK tích lũy cho biết mọi byte trước acknowledgment number đã được nhận liên tục. Nếu phía nhận có byte 1–1000 và 2001–3000 nhưng thiếu 1001–2000, ACK cơ bản vẫn phản ánh byte đầu tiên còn thiếu. Các cơ chế option như selective acknowledgment có thể cung cấp thêm thông tin về các khối đã nhận.

6.4.6 Retransmission và timeout

TCP có thể retransmit khi:

- Retransmission timer hết hạn;
- Nhận các duplicate ACK cho thấy có khả năng mất segment;
- Thuật toán phát hiện mất mát hiện đại đưa ra quyết định phù hợp.

Timeout phải thích nghi với RTT. Nếu quá ngắn, segment có thể bị truyền lại không cần thiết; nếu quá dài, phản ứng với mất mát chậm.

6.4.7 Duplicate segment và loại bỏ trùng

Retransmission có thể làm phía nhận nhận cùng dải byte nhiều lần. Sequence number giúp phát hiện dữ liệu trùng và chỉ giao byte stream đúng thứ tự cho ứng dụng. Tuy nhiên, điều này không tự làm cho hành động ở tầng ứng dụng trở nên idempotent; ứng dụng vẫn cần thiết kế giao dịch phù hợp.

6.4.8 Kết thúc connection

TCP hỗ trợ đóng từng chiều bằng FIN. Một quá trình đóng thông thường có thể cần bốn segment vì mỗi phía đóng chiều gửi riêng. RST dùng để hủy hoặc từ chối connection trong một số tình huống. Trạng thái TIME-WAIT giúp giảm nguy cơ segment cũ bị nhầm với connection mới có cùng bộ bốn.

6.4.9 MSS, MTU và segmentation

kích thước segment tối đa (Maximum Segment Size, MSS) là lượng TCP payload tối đa mà endpoint quảng bá cho segment. Với Ethernet MTU 1500 byte, IPv4 header 20 byte và TCP header 20 byte không option, MSS thường được minh họa là:

$$1500 - 20 - 20 = 1460 \text{ byte}$$

MSS không phải MTU. MTU giới hạn kích thước packet trên một liên kết; MSS liên quan TCP payload và thường được chọn để tránh fragmentation.

Đọc TCP header theo câu hỏi chức năng. Thay vì học thuộc vị trí bit, nên liên hệ mỗi nhóm field với một câu hỏi:

Field/nhóm field	Câu hỏi chức năng
Source/Destination Port	Segment thuộc hai endpoint ứng dụng nào?
Sequence Number	Byte đầu tiên của dữ liệu trong segment đang mang số thứ tự nào?
Acknowledgment Number	Bên nhận đang chờ byte kế tiếp nào từ phía đối diện?
Data Offset	TCP header dài bao nhiêu, payload bắt đầu ở đâu?
Flags SYN/ACK-/FIN/RST	Connection đang được thiết lập, xác nhận, kết thúc hay reset?
Window	Bên nhận hiện quảng bá khả năng tiếp nhận thêm bao nhiêu dữ liệu?
Checksum	Header và dữ liệu có dấu hiệu lỗi bit trong phạm vi kiểm tra hay không?
Options	Có các tham số bổ sung như MSS, window scale hoặc timestamp hay không?

Ví dụ sequence và ACK

Giả sử client bắt đầu với ISN 1000. SYN tiêu thụ một sequence number nên ACK hợp lệ tiếp theo từ server là 1001. Nếu client sau đó gửi 500 byte dữ liệu bắt đầu ở sequence 1001 và toàn bộ dữ liệu đến liên tục, phía nhận có thể ACK 1501. Điều này minh họa rằng ACK thường chỉ ra *byte kế tiếp đang chờ*, không phải “số segment đã nhận”.

6.5 Flow control, congestion control và hiệu năng TCP

6.5.1 Flow control bảo vệ phía nhận

Phía nhận có buffer hữu hạn và tốc độ xử lý hữu hạn. TCP dùng receiver window (rwnd) để thông báo lượng dữ liệu phía nhận sẵn sàng tiếp nhận thêm.

Ví dụ: kho tiếp nhận có sức chứa giới hạn

Một kho chỉ còn chỗ cho 30 thùng thì thông báo cho bên gửi không đưa vào quá lượng đó trước khi kho giải phóng thêm không gian. Đây là trực giác của flow control.

Giới hạn: TCP window được đo theo byte và thay đổi động. Hệ điều hành còn dùng window scaling, buffer management và các tối ưu khác; không nên hiểu rwnd là số segment cố định.

6.5.2 Sliding window

Thay vì gửi một segment rồi chờ một ACK, TCP có thể cho phép nhiều byte chưa được xác nhận cùng tồn tại trên đường truyền. Cửa sổ “trượt” khi ACK mới đến. Cách này khai thác tốt đường truyền có RTT lớn hơn.

6.5.3 Tích băng thông–độ trễ

Tích băng thông–độ trễ (bandwidth-delay product, BDP) ước lượng lượng bit có thể “đang trên đường” khi đường truyền hoạt động đầy tải:

$$\text{BDP} = \text{bandwidth} \times \text{RTT}$$

Ví dụ: Tính BDP

Một đường truyền có bandwidth 100 Mbps và RTT 40 ms.

$$100 \times 10^6 \text{ bit/s} \times 0.040 \text{ s} = 4 \times 10^6 \text{ bit}$$

$$4 \times 10^6 / 8 = 500000 \text{ byte} \approx 488.3 \text{ KiB}$$

Để khai thác gần đầy bandwidth trong mô hình đơn giản, lượng dữ liệu chưa được ACK cần có thể đạt khoảng 500000 byte. Đây là ước lượng; throughput thực tế còn phụ thuộc loss, protocol overhead, congestion control, hệ điều hành và ứng dụng.

6.5.4 Congestion control bảo vệ mạng

Flow control trả lời: “phía nhận còn tiếp nhận được bao nhiêu?” Congestion control trả lời: “mạng hiện có thể chịu thêm bao nhiêu lưu lượng?” TCP duy trì congestion window (cwnd) và điều chỉnh tốc độ dựa trên dấu hiệu như ACK, loss và đo lường thời gian.

Ví dụ: đường vào hầm

Dù bãi đỗ phía cuối còn nhiều chỗ, nếu cửa hầm đang ùn tắc thì không nên cho quá nhiều xe đi vào cùng lúc. Bãi đỗ tương tự khả năng phía nhận; hầm và các đoạn đường trung gian tương tự tài nguyên mạng.

Giới hạn: congestion control không quan sát trực tiếp toàn bộ mạng. TCP suy luận từ tín hiệu nhận được và thuật toán cụ thể có thể khác nhau giữa các hệ điều hành.

6.5.5 Cửa sổ gửi hữu hiệu

Ở mức khái niệm, lượng dữ liệu chưa được xác nhận mà sender có thể gửi thường bị giới hạn bởi:

$$\text{send window} \approx \min(\text{rwnd}, \text{cwnd})$$

Nếu rwnd nhỏ, phía nhận là nút hạn chế. Nếu cwnd nhỏ, tình trạng hoặc thuật toán congestion control là nút hạn chế. Công thức trên là mô hình hóa đơn giản, chưa phản ánh mọi chi tiết triển khai.

6.5.6 Slow start và tăng dần khả năng gửi

Khi bắt đầu connection hoặc sau một số sự kiện, sender không biết chính xác năng lực mạng. Slow start tăng lượng dữ liệu đang truyền theo phản hồi ACK để nhanh chóng thăm dò khả năng. Khi có dấu hiệu congestion, sender giảm tốc độ và chuyển sang cơ chế thận trọng hơn.

Tên “slow start” dễ gây hiểu lầm: tốc độ tăng của cửa sổ trong giai đoạn này có thể khá nhanh theo RTT; “slow” chủ yếu đối chiếu với việc gửi ngay một lượng cực lớn mà không thăm dò.

6.5.7 Loss không phải lúc nào cũng có cùng nguyên nhân

Packet loss có thể do queue overflow, lỗi liên kết, thay đổi đường đi, chính sách hoặc sự cố thiết bị. TCP truyền thống thường xem loss là dấu hiệu congestion, nhưng trong mạng không dây loss cũng có thể đến từ lỗi kênh. Cách suy luận này ảnh hưởng đến throughput.

6.5.8 Throughput, goodput và overhead

Throughput có thể tính trên toàn bộ dữ liệu truyền, trong khi goodput chỉ tính dữ liệu ứng dụng hữu ích. Retransmission và header làm throughput trên liên kết cao hơn goodput ứng dụng.

Ví dụ: Tính goodput

Trong 10 giây, một flow truyền tổng cộng 12 MB TCP payload trên mạng, trong đó 2 MB là payload retransmission. Dữ liệu ứng dụng hữu ích là 10 MB.

$$\text{Goodput} = \frac{10 \times 8}{10} = 8 \text{ Mb/s}$$

Nếu tính toàn bộ TCP payload đã truyền, tốc độ là 9.6 Mb/s. Hai đại lượng trả lời hai câu hỏi khác nhau.

6.5.9 RTT, window và giới hạn tốc độ đơn giản

Trong một mô hình không loss và bỏ qua overhead, throughput có thể bị giới hạn gần đúng bởi:

$$\text{throughput} \leq \frac{\text{window}}{\text{RTT}}$$

Ví dụ, window 256 KiB và RTT 100 ms cho giới hạn gần đúng:

$$\frac{256 \times 1024 \times 8}{0.1} \approx 20.97 \text{ Mb/s}$$

Đây không phải công thức dự đoán đầy đủ TCP hiện đại; nó giúp thấy vì sao đường truyền bandwidth cao, RTT lớn cần window đủ lớn.

Công bằng và cạnh tranh tài nguyên. Nhiều TCP flow cùng chia sẻ bottleneck thường điều chỉnh tốc độ theo phản hồi mạng, nhưng công bằng tuyệt đối không được bảo đảm. RTT khác nhau, thuật toán congestion control khác nhau, số connection khác nhau và traffic UDP có thể làm phân bổ bandwidth thay đổi.

6.6 Phân tích và trực quan hóa dữ liệu tầng Transport

6.6.1 Đơn vị quan sát và data dictionary

Trong phần này, mỗi hàng biểu diễn một flow được tóm tắt trong một time window. Không được diễn giải mỗi hàng như một packet.

Cột	Kiểu	Đơn vị	Ý nghĩa
protocol	category	–	TCP hoặc UDP
src_port	int	–	Port nguồn
dst_port	int	–	Port đích
packets	int	packet	Số packet trong flow
bytes	int	byte	Tổng byte quan sát
duration_s	float	s	Thời lượng flow
rtt_ms	float	ms	RTT ước lượng; có thể thiếu với UDP
retransmissions	int	packet	Số TCP retransmission quan sát
syn_count	int	packet	Số packet có SYN
rst_count	int	packet	Số packet có RST

6.6.2 Tạo DataFrame flow mẫu

```
import pandas as pd

flows = pd.DataFrame({
    "protocol": ["TCP", "TCP", "UDP", "TCP", "UDP", "TCP"],
    "src_port": [53124, 53125, 54000, 53126, 55000, 53127],
    "dst_port": [443, 80, 53, 443, 5004, 22],
    "packets": [120, 85, 10, 210, 340, 75],
    "bytes": [180000, 92000, 1800, 430000, 510000, 64000],
    "duration_s": [3.2, 2.5, 0.08, 8.0, 5.0, 4.1],
    "rtt_ms": [35.0, 48.0, None, 92.0, None, 41.0],
```

```

    "retransmissions": [1, 0, 0, 8, 0, 2],
    "syn_count": [1, 1, 0, 1, 0, 1],
    "rst_count": [0, 0, 0, 0, 0, 1]
})

print(type(flows))
print(flows.shape)
print(flows.dtypes)
print(flows.head())

```

Kết quả là một DataFrame có shape (6, 10). Giá trị thiếu ở `rtt_ms` không nên tự động thay bằng 0 vì 0 ms mang ý nghĩa đo lường khác với “không có phép đo”.

6.6.3 Tạo đặc trưng throughput và kích thước packet trung bình

```

flows = flows.assign(
    throughput_mbps=(flows["bytes"] * 8) /
                    flows["duration_s"] / 1_000_000,
    avg_packet_size=flows["bytes"] / flows["packets"]
)

print(flows[["protocol", "throughput_mbps",
             "avg_packet_size"]])

```

`assign()` tạo các cột mới theo cách rõ ràng, tránh sửa lỗi khó kiểm soát. Cần kiểm tra `duration_s > 0` và `packets > 0` trước khi chia.

6.6.4 Kiểm tra dữ liệu và lỗi thân thiện

```

required = {
    "protocol", "packets", "bytes", "duration_s"
}
missing = required.difference(flows.columns)

assert not missing, (
    "Thieu cot bat buoc: " + ", ".join(sorted(missing))
)
assert (flows["packets"] > 0).all(), (
    "packets phai lon hon 0 cho moi flow."
)
assert (flows["duration_s"] > 0).all(), (
    "duration_s phai lon hon 0 de tinh throughput."
)

```

Trong notebook chính thức, thông báo lỗi có thể viết tiếng Việt có dấu. Ở đây chuỗi không dấu giúp hạn chế lỗi khi sao chép sang một số terminal cấu hình cũ.

6.6.5 So sánh TCP và UDP bằng thống kê nhóm

```
summary = (
    flows.groupby("protocol", as_index=False)
        .agg(
            flow_count=("protocol", "size"),
            total_bytes=("bytes", "sum"),
            mean_packets=("packets", "mean"),
            mean_throughput_mbps=("throughput_mbps", "mean")
        )
)

print(summary)
```

Kết quả chỉ mô tả dataset nhỏ đang xét. Không được suy rộng rằng TCP hoặc UDP nói chung có throughput cao hơn chỉ từ sáu flow mẫu.

6.6.6 Vẽ throughput theo flow

```
import matplotlib.pyplot as plt

fig, ax = plt.subplots(figsize=(8, 4))
ax.bar(flows.index.astype(str), flows["throughput_mbps"])
ax.set_title("Throughput uoc luong theo flow")
ax.set_xlabel("Chi so flow")
ax.set_ylabel("Throughput (Mb/s)")
plt.show()
```

Mỗi cột biểu diễn throughput trung bình của một flow trong toàn bộ duration. Biểu đồ không cho biết throughput thay đổi theo từng thời điểm bên trong flow.

6.6.7 Quan hệ quan sát giữa RTT và retransmission

```
tcp_flows = flows.loc[flows["protocol"] == "TCP"].dropna(
    subset=["rtt_ms"]
)

fig, ax = plt.subplots(figsize=(7, 4))
ax.scatter(tcp_flows["rtt_ms"],
           tcp_flows["retransmissions"])
ax.set_xlabel("RTT (ms)")
ax.set_ylabel("So retransmission")
ax.set_title("RTT va retransmission cua cac TCP flow")
plt.show()
```

Một điểm là một TCP flow. Nếu các flow RTT cao có nhiều retransmission hơn, đó mới là quan sát trong mẫu; chưa chứng minh RTT gây retransmission hoặc ngược lại.

6.6.8 Tạo chỉ báo tỷ lệ retransmission đơn giản

```
tcp_flows = tcp_flows.assign(
    retransmission_ratio=(
        tcp_flows["retransmissions"] /
        tcp_flows["packets"]
    )
)

print(tcp_flows[["dst_port", "packets",
                  "retransmissions",
                  "retransmission_ratio"]])
```

Tỷ lệ này chỉ là proxy đơn giản vì mẫu số gồm nhiều loại packet, bao gồm ACK không mang payload. Phân tích chính xác hơn cần định nghĩa rõ retransmission và số TCP data segment đủ điều kiện.

6.6.9 Từ packet đến flow feature

Các feature tầng Transport thường được tổng hợp từ packet:

- Số SYN, FIN, RST và ACK;
- Tổng byte, packet và duration;
- Khoảng thời gian giữa các packet;
- Tỷ lệ packet theo chiều;
- RTT ước lượng;
- Retransmission, out-of-order và duplicate ACK;
- Distribution của packet size.

Feature phải đi kèm định nghĩa và quy tắc tổng hợp. Cùng tên “duration” nhưng cách chọn packet đầu/cuối khác nhau có thể tạo kết quả khác nhau.

Viên gạch dữ liệu: từ packet đến flow

Một packet table có thể có hàng triệu hàng, trong khi nhiều câu hỏi vận hành cần đơn vị quan sát là **flow**. Việc chuyển packet thành flow không phải thao tác “làm nhỏ dữ liệu” tùy ý; đó là quyết định về đơn vị phân tích.

Một khóa flow cơ bản thường dùng 5-tuple: source IP, destination IP, source port, destination port và transport protocol. Khi hướng truyền quan trọng, cần quy ước chiều; khi muốn coi hai chiều là một cuộc trao đổi, cần chuẩn hóa cặp endpoint trước khi groupby.

DataFrame.groupby() lần đầu được dùng như phép tổng hợp flow

Mục đích: gom các packet có cùng khóa và tính các thống kê theo nhóm.

Input: DataFrame packet, mỗi hàng là một packet.

Output: bảng flow, mỗi hàng là một flow sau aggregation.

Điểm phải kiểm tra: cột dùng làm khóa, hướng của flow, kiểu dữ liệu, số hàng trước/sau và ý nghĩa của từng phép tổng hợp.

Lỗi thường gặp: groupby theo thiếu một thành phần của 5-tuple, trộn hai hướng không có chủ đích, hoặc tính trung bình một field không có ý nghĩa định lượng.

Flow control và congestion control không giải quyết cùng một vấn đề.

	Flow control	Congestion control
Mục tiêu	Không làm tràn khả năng nhận của peer	Không bơm quá nhiều dữ liệu vào mạng
Tín hiệu điển hình	receiver advertised window	loss, ECN, ACK/RTT và thuật toán sender
Phạm vi	quan hệ giữa hai endpoint	trạng thái/khả năng của path và các flow cạnh tranh
Nhằm lẫn cần tránh	rwnd lớn không bảo đảm mạng không congestion	congestion window không phải buffer của application

Cửa sổ gửi hữu hiệu thường bị giới hạn bởi cả hai phía, về trực giác có thể xem như phụ thuộc vào $\min(rwnd, cwnd)$ cùng các giới hạn khác của sender/application.

Đọc type và shape trước khi phân tích flow. Sau khi tạo DataFrame, luôn kiểm tra cấu trúc trước khi vẽ hoặc tính thống kê:

```
print(type(flows))
print(flows.shape)
print(flows.dtypes)
print(flows.isna().sum())
```

Nếu `flows.shape == (6, 10)`, cần đọc thành lời: sáu observations (sáu flow) và mười columns. Không được hiểu “10” là mười packet hay mười class nếu schema không nói như vậy.

Packet count không phải packet rate

`packet_count` là số packet trong đơn vị quan sát; `packet_rate` cần chia cho duration hoặc một cửa sổ thời gian đã định nghĩa. Hai flow có cùng 100 packet nhưng duration 0.1 s và 10 s có hành vi hoàn toàn khác nhau.

6.7 An toàn, độ tin cậy ở tầng Transport

6.7.1 Port scanning và nhận diện dịch vụ

Port scanning gửi traffic đến nhiều port để suy đoán dịch vụ đang lắng nghe. Dấu hiệu có thể gồm một nguồn kết nối đến nhiều destination port trong thời gian ngắn, nhiều SYN không hoàn tất hoặc nhiều response RST. Tuy nhiên, phần mềm quản trị và giám sát hợp lệ cũng có thể tạo mẫu tương tự.

6.7.2 SYN flood

SYN flood cố tạo nhiều trạng thái half-open bằng cách gửi SYN nhưng không hoàn tất handshake. Server tiêu tốn băng trạng thái và tài nguyên. Biện pháp giảm thiểu có thể gồm SYN cookies, rate limiting, backlog tuning, filtering và dịch vụ chống DDoS phù hợp.

Dấu hiệu không phải bằng chứng tuyệt đối

Tỷ lệ SYN cao và handshake không hoàn tất có thể do tấn công, nhưng cũng có thể do packet loss, client lỗi, routing bất ổn hoặc capture chỉ quan sát một chiều. Phân tích cần kết hợp nhiều nguồn và bối cảnh.

6.7.3 UDP amplification và spoofing

Một số dịch vụ UDP có response lớn hơn request. Nếu kẻ tấn công giả mạo source IP của nạn nhân, server trung gian có thể gửi response về nạn nhân và khuếch đại lưu lượng. Phòng vệ gồm vô hiệu hóa dịch vụ không cần thiết, rate limiting, cấu hình chống open resolver/amplifier và lọc địa chỉ nguồn giả mạo tại biên mạng.

6.7.4 RST injection và session disruption

Packet RST giả có thể cố làm gián đoạn TCP connection nếu thông tin bộ bốn và sequence number phù hợp. Mã hóa ở tầng ứng dụng bảo vệ nội dung nhưng không nhất thiết ngăn mọi hành vi gây gián đoạn transport. Các triển khai hiện đại kiểm tra sequence window và có biện pháp chống packet bất thường.

6.7.5 Mã hóa vẫn để lộ metadata

TLS có thể mã hóa payload ứng dụng nhưng các quan sát như địa chỉ IP, port, thời gian, kích thước packet, hướng traffic và duration vẫn có thể hiện diện. Metadata hỗ trợ vận hành và phát hiện bất thường nhưng cũng đặt ra yêu cầu bảo vệ quyền riêng tư.

6.7.6 Firewall stateful và bảng trạng thái

Stateful firewall theo dõi trạng thái connection để cho phép traffic phản hồi phù hợp. Bảng trạng thái là tài nguyên hữu hạn và có thể trở thành mục tiêu exhaustion. Timeout, connection limit và monitoring cần được cấu hình theo đặc điểm hệ thống.

6.7.7 Thực hành an toàn và hợp pháp

Chỉ phân tích traffic do người học tạo trên máy của mình, file capture được cung cấp hoặc môi trường được phép. Không quét port, tạo SYN flood, giả mạo địa chỉ hay gửi datagram khuếch đại đến hệ thống bên ngoài. Mục tiêu của chương là hiểu dấu hiệu và phòng vệ, không thực hiện tấn công thật.

6.8 Ví dụ tổng hợp từ header đến dữ liệu

6.8.1 Ví dụ 1: tính sequence và acknowledgment

Client có sequence hiện tại 20,001 và gửi 1,200 byte payload. Bỏ qua SYN/FIN, nếu toàn bộ dữ liệu đến liên tục thì ACK kế tiếp là

$$20,001 + 1,200 = 21,201.$$

Nếu ACK vẫn dừng ở 20,001 sau khi phía nhận đã thấy các byte phía sau, cần nghĩ đến dữ liệu bị thiếu, reorder hoặc capture không đầy đủ trước khi kết luận retransmission.

6.8.2 Ví dụ 2: window, RTT và giới hạn throughput

Nếu cửa sổ hữu hiệu là 256 KiB và RTT là 40 ms, giới hạn đơn giản do cửa sổ là

$$\frac{256 \times 1024 \times 8}{0.040} \approx 52.4 \text{ Mb/s.}$$

Đây là giới hạn lý tưởng theo window/RTT, chưa tính congestion, loss, ACK behavior, application pacing và overhead.

6.8.3 Ví dụ 3: từ packet thành flow feature

Giả sử một flow có 20 packet, tổng 18,000 byte, duration 0.9 s và 2 retransmission. Khi đó có thể tạo:

$$\text{throughput} = \frac{18,000 \times 8}{0.9} = 160 \text{ kb/s,} \quad \text{retransmission rate} = \frac{2}{20} = 0.10.$$

Các feature này chỉ có ý nghĩa khi cách đếm packet, byte và retransmission được định nghĩa nhất quán.

6.9 Tổng kết chương

6.9.1 Tóm tắt chương

- Tầng Transport mở rộng giao tiếp host-to-host thành process-to-process bằng port và socket.
- UDP cung cấp datagram đơn giản, giữ message boundary nhưng không tự bảo đảm giao đúng hoặc đúng thứ tự.
- TCP cung cấp reliable byte stream với connection, sequence number, acknowledgment và retransmission.
- Three-way handshake trao đổi trạng thái ban đầu và xác nhận khả năng giao tiếp hai chiều.
- Flow control bảo vệ receiver; congestion control điều chỉnh theo khả năng của mạng.
- BDP cho thấy bandwidth và RTT cùng quyết định lượng dữ liệu cần tồn tại trên đường để khai thác đường truyền.
- Flow record là dữ liệu tổng hợp, không đồng nhất với trạng thái TCP nội bộ.

- Port, flags, RTT, retransmission và byte count là những feature quan trọng nhưng phải được diễn giải trong bối cảnh.
- TCP reliability không thay thế TLS, xác thực ứng dụng hoặc kiểm soát giao dịch.
- Phân tích an ninh phải kết hợp nhiều dấu hiệu; một mẫu SYN hoặc RST bất thường chưa đủ kết luận tấn công.

6.9.2 Bài luyện tập

1. Một client dùng TCP socket 10.1.1.5:55010 kết nối đến 198.51.100.8:443. Hãy ghi bộ bốn của connection theo chiều client gửi.
2. Vì sao hai client khác nhau có thể cùng kết nối đến port 443 của một server?
3. UDP header có bao nhiêu byte và gồm những trường nào?
4. Một UDP payload 32 byte đi qua IPv4 header 20 byte. Tính tỷ lệ payload trên tổng IP packet, bỏ qua Data Link overhead.
5. Nêu hai tình huống trong đó UDP phù hợp hơn một giao thức transport có connection.
6. Một TCP segment có Seq = 15000 và payload 1200 byte. ACK tiếp theo là bao nhiêu nếu nhận đủ?
7. Một SYN có Seq = 900. SYN-ACK hợp lệ thường dùng Ack bao nhiêu?
8. Các segment có Seq/Payload lần lượt là 1000/500, 1500/500 và 2000/500. Nếu segment thứ hai mất nhưng thứ ba đến, ACK tích lũy cơ bản là bao nhiêu?
9. Phân biệt flow control và congestion control bằng một câu hỏi mà mỗi cơ chế trả lời.
10. Tính BDP cho đường truyền 50 Mbps, RTT 80 ms, biểu diễn theo byte.
11. Window 128 KiB và RTT 50 ms. Tính giới hạn throughput gần đúng theo công thức window/RTT.
12. Trong 20 giây, ứng dụng nhận hữu ích 30 MB nhưng mạng đã truyền 36 MB TCP payload do retransmission. Tính goodput ứng dụng.
13. Vì sao không nên thay mọi giá trị RTT thiếu trong flow table bằng 0?
14. Viết biểu thức pandas lọc các TCP flow có `retransmissions > 0`.
15. Một nguồn gửi SYN đến 100 port khác nhau trong 2 giây. Đây có thể là dấu hiệu gì và vì sao chưa đủ để kết luận?
16. Giải thích vì sao TCP connection thành công không chứng minh nội dung được mã hóa.
17. Vì sao ACK của TCP không chứng minh giao dịch cơ sở dữ liệu đã hoàn tất?
18. So sánh message boundary của UDP với byte stream của TCP.
19. Nêu hai giới hạn của việc suy đoán ứng dụng chỉ từ destination port.
20. Đề xuất ba cột dữ liệu để hỗ trợ phát hiện SYN flood và giải thích ý nghĩa.

6.9.3 Lời giải bài luyện tập

Bài 1–5

1. Bộ bốn: (10.1.1.5, 55010, 198.51.100.8, 443).
2. Mỗi connection được phân biệt bằng bộ bốn; source IP hoặc source port của các client khác nhau.
3. UDP header 8 byte: source port, destination port, length và checksum, mỗi trường 16 bit.
4. Tổng IP packet: $32 + 8 + 20 = 60$ byte. Tỷ lệ payload: $32/60 \times 100\% \approx 53.33\%$.
5. Ví dụ: DNS query nhỏ; truyền media quan tâm dữ liệu mới và chấp nhận mất nhẹ; ứng dụng có reliability riêng. Cần nêu điều kiện cụ thể, không chỉ nói “UDP nhanh”.

Bài 6–10

6. $15000 + 1200 = 16200$.
7. SYN tiêu thụ một sequence number nên Ack thường là 901.
8. Sau segment đầu, byte tiếp theo cần là 1500. Dù segment 2000 đến, vẫn thiếu dải bắt đầu 1500 nên ACK tích lũy cơ bản là 1500.
9. Flow control: receiver còn nhận được bao nhiêu? Congestion control: mạng hiện chịu được bao nhiêu lưu lượng?
10. $50 \times 10^6 \times 0.08 = 4 \times 10^6$ bit = 500000 byte.

Bài 11–15

11. $128 \times 1024 \times 8/0.05 = 20,971,520$ bit/s, xấp xỉ 20.97 Mb/s.
12. $30 \times 8/20 = 12$ Mb/s nếu MB dùng theo 10^6 byte trong cách tính mạng. Cần ghi rõ quy ước MB/MiB khi đo chính xác.
13. Missing RTT nghĩa là không có phép đo hoặc không áp dụng; 0 ms là một giá trị đo cụ thể và có thể làm sai mean, histogram và mô hình.
14. `flows.loc[(flows["protocol"] == "TCP") & (flows["retransmissions"] > 0)].`
15. Có thể là port scan hoặc reconnaissance. Chưa đủ kết luận vì có thể là scanner quản trị hợp lệ, phần mềm kiểm kê, lỗi cấu hình hoặc dữ liệu capture không đầy đủ.

Bài 16–20

16. TCP chỉ bảo đảm byte stream theo cơ chế transport; confidentiality cần TLS hoặc cơ chế mã hóa khác.
17. TCP ACK chỉ phản ánh TCP phía nhận đã nhận byte; ứng dụng có thể chưa đọc hoặc chưa commit giao dịch.
18. UDP giữ ranh giới datagram; TCP cung cấp dòng byte liên tục, ứng dụng phải tự đánh dấu message.
19. Ứng dụng có thể dùng port không chuẩn; nhiều ứng dụng có thể dùng chung port qua

TLS/proxy; tunneling làm port không phản ánh ứng dụng cuối.

20. Ví dụ: `syn_count`, `ack_count`, `unique_dst_ports` hoặc số handshake hoàn tất. Cần thêm time window và source IP để diễn giải tốc độ và phạm vi.

6.9.4 Câu hỏi trắc nghiệm

1. Chức năng chính của port ở tầng Transport là gì?
 - A. Chuyển dữ liệu đến đúng tiến trình trên host.
 - B. Chọn đường đi qua router.
 - C. Xác định địa chỉ MAC của gateway.
 - D. Mã hóa payload ứng dụng.
2. Đặc điểm nào đúng với UDP?
 - A. UDP giữ ranh giới datagram nhưng không tự bảo đảm giao đúng thứ tự.
 - B. UDP luôn nhanh hơn TCP trong mọi mạng.
 - C. UDP dùng three-way handshake.
 - D. UDP tự truyền lại mọi datagram bị mất.
3. TCP acknowledgment number thường biểu diễn gì?
 - A. Số thứ tự byte tiếp theo phía nhận đang chờ.
 - B. Số segment đã đi qua router.
 - C. Tổng số byte của IP header.
 - D. Port của ứng dụng nguồn.
4. Mục đích chính của three-way handshake là gì?
 - A. Thiết lập trạng thái và xác nhận giao tiếp hai chiều.
 - B. Tìm địa chỉ MAC của server.
 - C. Chọn shortest path trong mạng.
 - D. Mã hóa toàn bộ TCP header.
5. Flow control chủ yếu bảo vệ đối tượng nào?
 - A. Buffer và khả năng xử lý của receiver.
 - B. Bảng định tuyến của router.
 - C. DNS cache của client.
 - D. Khóa riêng của server.
6. Bandwidth-delay product cho biết trực giác nào?
 - A. Lượng dữ liệu có thể đang trên đường khi liên kết hoạt động đầy tải.
 - B. Số port mở trên server.

- C. Số hop tối đa của packet.
 - D. Số retransmission chắc chắn xảy ra.
7. Vì sao destination port 443 chưa đủ chứng minh traffic là HTTPS hợp lệ?
- A. Nhiều ứng dụng có thể dùng port đó và port có thể bị sử dụng không theo quy ước.
 - B. Port 443 chỉ tồn tại trong UDP.
 - C. Router luôn xóa port trước khi chuyển tiếp.
 - D. TCP không có trường destination port.
8. Dấu hiệu nào phù hợp nhất với khả năng SYN flood?
- A. Nhiều SYN nhưng ít handshake hoàn tất trong cùng time window.
 - B. Một flow có đúng một SYN và một SYN-ACK.
 - C. UDP checksum hợp lệ.
 - D. RTT ổn định và không có loss.
9. Phát biểu nào đúng về TCP ACK?
- A. ACK transport không chứng minh ứng dụng đã hoàn tất xử lý nghiệp vụ.
 - B. ACK luôn xác nhận từng message ứng dụng riêng biệt.
 - C. ACK mã hóa payload đã nhận.
 - D. ACK chỉ xuất hiện khi connection kết thúc.
10. Khi phân tích DataFrame flow, mỗi hàng nên được hiểu thế nào?
- A. Theo schema đã định nghĩa, chẳng hạn một flow trong một time window.
 - B. Luôn là một packet bất kể nguồn dữ liệu.
 - C. Luôn là một người dùng.
 - D. Luôn là một cuộc tấn công.

6.9.5 Đáp án và giải thích

- 1. **Đáp án đúng:**A. IP đưa dữ liệu đến host; port hỗ trợ demultiplexing đến đúng tiến trình.
- 2. **Đáp án đúng:**A. UDP giữ datagram boundary nhưng không cung cấp reliability và ordering như TCP.
- 3. **Đáp án đúng:**A. ACK number chỉ byte tiếp theo đang chờ trong byte stream.
- 4. **Đáp án đúng:**A. Handshake thiết lập trạng thái, sequence number ban đầu và xác nhận hai chiều.
- 5. **Đáp án đúng:**A. Receiver window phản ánh khả năng tiếp nhận của phía nhận.
- 6. **Đáp án đúng:**A. BDP là bandwidth nhân RTT, biểu diễn lượng bit có thể tồn tại trên đường.
- 7. **Đáp án đúng:**A. Port là dấu hiệu gợi ý, không phải bằng chứng đầy đủ về ứng dụng hoặc tính hợp lệ.
- 8. **Đáp án đúng:**A. Nhiều half-open connection là mẫu thường được xem xét khi phát hiện SYN flood.

9. **Đáp án đúng:**A. TCP chỉ xác nhận ở tầng Transport; ứng dụng cần cơ chế xác nhận nghiệp vụ riêng.
10. **Đáp án đúng:**A. Ý nghĩa một hàng phải được xác định bởi schema và quy trình tạo dữ liệu.

Chương 7

DNS, DHCP, HTTP, HTTPS và các giao thức ứng dụng

7.1 Mục tiêu và câu hỏi mở đầu

7.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Khi người dùng nhập một địa chỉ như `https://www.example.edu.vn` vào trình duyệt, máy tính chưa thể gửi ngay nội dung trang web. Nó cần biết địa chỉ IP của tên miền, cần có cấu hình mạng hợp lệ, cần thiết lập giao tiếp với máy chủ và cần xác minh rằng đầu bên kia thực sự là máy chủ mong muốn. Những giao thức nào tham gia vào chuỗi công việc này? Dữ liệu nào được trao đổi ở mỗi bước? Vì sao trang web có thể tải chậm ngay cả khi đường truyền có bandwidth cao?

Ví dụ: tìm địa chỉ, xin quyền sử dụng phương tiện và đến nơi làm việc

Một người muốn đến một cơ quan mới có thể phải thực hiện ba việc: tra danh bạ để biết địa chỉ, nhận phương tiện cùng giấy phép sử dụng, rồi đến quầy tiếp nhận để yêu cầu dịch vụ. Trong phép so sánh này:

- tra tên cơ quan để tìm địa chỉ gần với *hệ thống tên miền* (Domain Name System, DNS);
- nhận địa chỉ và thông số kết nối gần với *giao thức cấu hình host động* (Dynamic Host Configuration Protocol, DHCP);
- gửi yêu cầu và nhận tài liệu gần với *giao thức truyền siêu văn bản* (Hypertext Transfer Protocol, HTTP);
- kiểm tra giấy tờ và tạo kênh bảo mật gần với TLS trong HTTPS.

Điểm cần nhớ: một hoạt động đơn giản đối với người dùng thường là kết quả phối hợp của nhiều giao thức ứng dụng.

Giới hạn của mạng: DNS, DHCP và HTTP không nhất thiết diễn ra theo một chuỗi cứng nhắc cho từng lần truy cập. Kết quả DNS có thể đã được cache; địa chỉ DHCP có thể còn thời hạn; kết nối HTTP có thể được tái sử dụng.

7.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Giải thích được vai trò của tầng Application và mô hình client-server.
- Phân biệt được tên miền, địa chỉ IP, URL, URI, resource và service.
- Mô tả được cấu trúc phân cấp DNS, các loại resource record và quá trình phân giải tên.
- Phân tích được DNS caching, TTL, recursive query và iterative query.
- Giải thích được quá trình DHCP Discover–Offer–Request–Acknowledgment và thời hạn thuê địa chỉ.
- Đọc được HTTP request, HTTP response, method, status code, header và message body.
- Giải thích được quan hệ giữa HTTP, TLS và HTTPS; hiểu vai trò của certificate.
- Trình bày được nguyên lý cơ bản của thư điện tử, truyền file, đăng nhập từ xa, đồng bộ thời gian và quản trị mạng.
- Phân tích được dữ liệu DNS/HTTP bằng Wireshark, pandas và Matplotlib.
- Nhận biết được DNS spoofing, DNS tunneling, rogue DHCP, HTTP injection, certificate warning và các biện pháp giảm thiểu.

7.2 Nguyên lý tầng Application

7.2.1 Tiến trình ứng dụng và message

Ứng dụng mạng gồm các tiến trình chạy trên các host và trao đổi *thông điệp* (message). Tùy giao thức, message có thể là:

- DNS query hoặc DNS response;
- DHCP Discover hoặc DHCP Offer;
- HTTP request hoặc HTTP response;
- thư điện tử, lệnh quản trị, file hoặc bản ghi thời gian.

Một giao thức ứng dụng thường xác định:

- loại message;
- cú pháp và tên trường;
- ý nghĩa của từng trường;
- thứ tự trao đổi;
- trạng thái và mã lỗi;
- cách hai phía phản ứng khi timeout hoặc dữ liệu không hợp lệ.

7.2.2 Mô hình client–server

Trong mô hình client–server:

- *máy chủ/dịch vụ phục vụ* (server) chờ request tại một địa chỉ và port;
- *máy khách* (client) chủ động gửi request;
- server xử lý request và tạo response;
- một server có thể phục vụ nhiều client đồng thời.

Ví dụ: quầy dịch vụ công

Người dân chủ động đến quầy và yêu cầu một thủ tục; quầy tiếp nhận chờ yêu cầu, kiểm tra hồ sơ rồi trả kết quả. Client gần với người gửi yêu cầu; server gần với quầy dịch vụ; request là hồ sơ; response là kết quả hoặc thông báo lỗi.

Giới hạn: server không nhất thiết là một máy vật lý duy nhất. Một tên dịch vụ có thể được thực hiện bởi nhiều máy chủ, container, reverse proxy hoặc dịch vụ đám mây.

7.2.3 Peer-to-peer và mô hình lai

Trong mô hình *ngang hàng* (peer-to-peer), một nút có thể vừa yêu cầu vừa cung cấp tài nguyên. Mô hình này có thể giảm phụ thuộc vào một server trung tâm nhưng làm quản lý định danh, khả dụng, bảo mật và nhất quán phức tạp hơn.

Nhiều hệ thống là mô hình lai: server trung tâm hỗ trợ đăng nhập, tìm peer hoặc phân phối metadata; dữ liệu lớn được trao đổi trực tiếp giữa peer.

7.2.4 Request–response và publish–subscribe

yêu cầu–phản hồi (request–response) phù hợp khi client cần một kết quả cụ thể. *xuất bản–đăng ký* (publish–subscribe) phù hợp khi producer công bố sự kiện và subscriber nhận những chủ đề đã đăng ký.

Tiêu chí	Request–response	Publish–subscribe
Khởi tạo trao đổi	Client gửi request	Publisher phát sự kiện
Quan hệ hai phía	Thường trực tiếp	Có thể qua broker
Phản hồi tức thời	Thường mong đợi	Không nhất thiết
Ví dụ	HTTP API, DNS query	Hệ thống cảnh báo, message broker

7.2.5 Tên, địa chỉ, URL và resource

Khái niệm	Vai trò	Ví dụ
Tên miền	Tên có ý nghĩa đối với con người và tổ chức	<code>www.example.edu.vn</code>
Địa chỉ IP	Định danh logic dùng để chuyển packet	<code>203.0.113.20</code>
URL	Mô tả cách và nơi truy cập resource	<code>https://example.org/docs/a.pdf</code>
Scheme	Cơ chế truy cập	<code>https</code>
Host	Tên hoặc địa chỉ của endpoint	<code>example.org</code>
Path	Vị trí logic của resource	<code>/docs/a.pdf</code>
Query string	Tham số bổ sung	<code>?page=2&sort=date</code>

7.2.6 Hồ sơ giao thức ứng dụng

Để hiểu giao thức, người học có thể lập bảng để trả lời các câu hỏi kiểu như sau:

Thuộc tính	Câu hỏi cần trả lời
Mục đích	Giao thức giải quyết vấn đề nào?
Đơn vị message	Request, response, command, record hay event?
Transport	UDP, TCP, QUIC hay cơ chế khác?
Port thường dùng	Port mặc định hoặc port theo cấu hình?
State	Có duy trì phiên không?
Trường quan trọng	Tên trường, kiểu, ý nghĩa và đơn vị?
Lỗi/timeout	Hai phía phản ứng như thế nào?
An toàn	Có xác thực, mã hóa, integrity hay không?
Wireshark filter	Bộ lọc nào hỗ trợ quan sát?

7.3 DNS

7.3.1 DNS giải quyết vấn đề gì?

Con người thường nhớ tên tốt hơn địa chỉ số. DNS cung cấp cơ chế ánh xạ tên miền đến dữ liệu cần thiết, phổ biến nhất là địa chỉ IP. DNS là hệ thống phân tán và phân cấp, không phải một danh bạ duy nhất đặt ở một nơi.

Ví dụ: danh bạ nhiều cấp

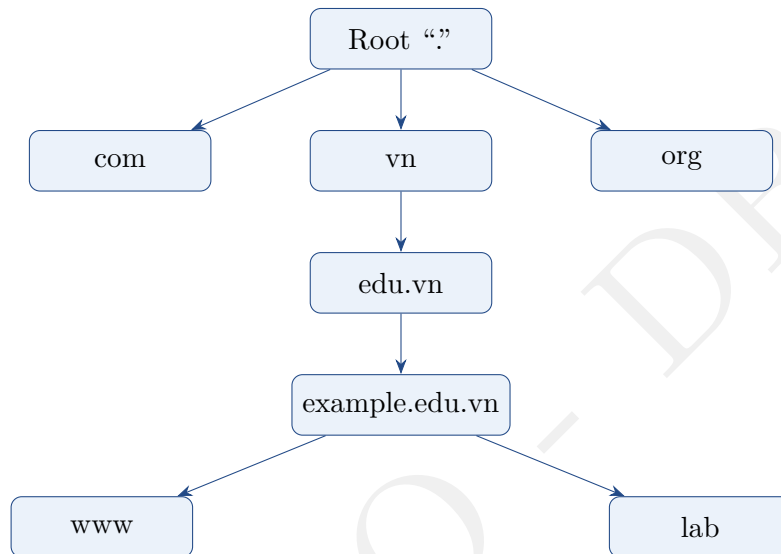
Một tổ chức lớn có danh bạ toàn cơ quan, danh bạ theo đơn vị và danh bạ theo phòng. Khi cần tìm một người, ta có thể đi từ cấp tổng quát đến cấp cụ thể. DNS cũng tổ chức tên theo không gian phân cấp: root, top-level domain, domain và subdomain.

Giới hạn: DNS không chỉ lưu số “điện thoại”. Nó có nhiều loại record, cơ chế cache, delegation, load distribution và chính sách vận hành.

7.3.2 Không gian tên và phân cấp DNS

Tên đầy đủ có thể được đọc từ phải sang trái theo mức phân cấp. Ví dụ `lab.example.edu.vn` gồm:

- root ngầm định ở cuối;
- top-level domain `vn`;
- domain cấp dưới `edu.vn`;
- domain tổ chức `example.edu.vn`;
- host hoặc subdomain `lab`.



7.3.3 Resolver, recursive server và authoritative server

Các vai trò chính:

- *bộ phân giải tại host* (stub resolver): nhận yêu cầu từ ứng dụng và gửi query đến DNS server cấu hình;
- *máy chủ phân giải đệ quy* (recursive resolver): thay client tìm câu trả lời, dùng cache nếu có;
- *máy chủ có thẩm quyền* (authoritative server): cung cấp record chính thức cho zone;
- root và TLD server: hỗ trợ delegation đến cấp dưới.

Recursive không đồng nghĩa với authoritative

Một DNS server có thể làm recursive resolver cho client nhưng không có thẩm quyền đối với domain đang hỏi. Ngược lại, authoritative server có thể trả lời record của zone nhưng không cung cấp recursion cho client ngoài phạm vi cho phép.

7.3.4 Recursive query, iterative query và caching

Trong recursive query, phía nhận có trách nhiệm trả câu trả lời cuối hoặc lỗi. Trong iterative query, server có thể trả referral đến server gần hơn với câu trả lời.

Cache giảm số query và độ trễ, nhưng làm dữ liệu thay đổi không xuất hiện ngay ở mọi nơi. *thời gian sống* (Time To Live, TTL) của record cho biết thời gian cache có thể giữ bản ghi trước khi cần làm mới.

Ví dụ: hỏi người đã biết đường

Nếu người được hỏi đã biết địa chỉ, ta nhận câu trả lời ngay. Nếu chưa biết, họ có thể chỉ sang một đầu mối khác. Nếu từng tra địa chỉ gần đây và còn tin cậy, ta dùng ghi chú cũ thay vì hỏi lại.

Giới hạn: DNS cache có nhiều cấp và chính sách; TTL không bảo đảm mọi cache xóa record đúng cùng một thời điểm tuyệt đối.

7.3.5 Các resource record thường gặp

Type	Vai trò	Ví dụ ý nghĩa
A	Tên đến IPv4	<code>www.example.org</code> đến <code>203.0.113.10</code>
AAAA	Tên đến IPv6	Host đến địa chỉ IPv6
CNAME	Bí danh đến canonical name	<code>portal</code> là alias của tên khác
MX	Mail exchanger	Máy chủ nhận thư cho domain
NS	Name server	Server có thẩm quyền cho zone
PTR	Reverse lookup	Địa chỉ đến tên trong reverse zone
TXT	Văn bản/chính sách	SPF, xác minh domain và metadata
SOA	Thông tin zone	Primary server, serial và timer

Nhầm lẫn thường gặp

CNAME không phải là một địa chỉ IP. MX không trực tiếp là hộp thư người dùng. PTR không phải lúc nào cũng tồn tại hoặc khớp hoàn toàn với forward lookup.

7.3.6 Cấu trúc message DNS và transport

DNS message gồm header và các vùng question, answer, authority, additional. Các trường header đáng chú ý:

- transaction ID để ghép query với response;
- QR để phân biệt query/response;
- opcode, response code;
- các cờ recursion desired, recursion available, authoritative answer;
- số lượng record ở từng vùng.

DNS thường dùng UDP cho query nhỏ và dùng TCP trong một số trường hợp như response lớn, zone transfer hoặc khi cơ chế yêu cầu. Các triển khai hiện đại còn có DNS over TLS và DNS over HTTPS nhằm bảo vệ đường truyền giữa client và resolver, nhưng điều này không tự bảo đảm resolver là đáng tin cậy.

7.4 DHCP

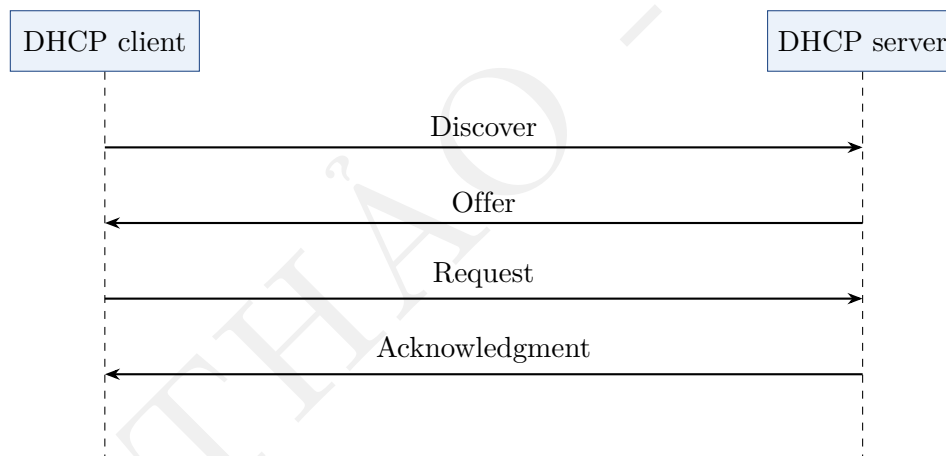
7.4.1 DHCP và quá trình cấp cấu hình

DHCP giúp host nhận các tham số như:

- địa chỉ IP;
- subnet mask hoặc prefix;
- default gateway;
- DNS server;
- lease time và các option khác.

Quá trình cơ bản thường được nhớ bằng DORA:

1. **Discover**: client tìm DHCP server;
2. **Offer**: server đề nghị cấu hình;
3. **Request**: client yêu cầu dùng offer đã chọn;
4. **Acknowledgment**: server xác nhận lease.



7.4.2 Lease, renewal và DHCP relay

Địa chỉ DHCP được cấp theo thời hạn. Client cố gắng renew trước khi lease hết hạn. Nếu không thể liên hệ server cũ, nó có thể chuyển sang trạng thái rebinding để tìm server phù hợp.

DHCP broadcast ban đầu không đi qua router theo cách thông thường. *bộ chuyển tiếp DHCP* (DHCP relay) nhận request ở subnet client và chuyển đến server ở mạng khác, đồng thời cung cấp thông tin giúp server chọn đúng pool.

Ví dụ: thẻ gửi xe có thời hạn

Một thẻ gửi xe được cấp cho một khoảng thời gian và có thể gia hạn. Hết hạn mà không gia hạn, chỗ đỗ có thể được cấp cho người khác. DHCP lease cũng giúp tái sử dụng địa chỉ trong pool.

Giới hạn: địa chỉ IP không hoàn toàn giống chỗ đỗ vật lý; client có thể có reservation, nhiều interface hoặc cơ chế cấu hình khác ngoài DHCP.

7.5 HTTP

7.5.1 HTTP request và HTTP response

HTTP tổ chức trao đổi theo request và response. Một request cơ bản gồm request line, header và có thể có body. Một response gồm status line, header và có thể có body.

Ví dụ HTTP tối giản

```
GET /courses/networks HTTP/1.1
Host: www.example.edu.vn
Accept: text/html
User-Agent: ExampleBrowser/1.0

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8
Content-Length: 1250
Cache-Control: max-age=300

<html>...</html>
```

Dòng trống phân cách header với body. Trong capture thực tế, nội dung có thể bị chia trên nhiều TCP segment và không xuất hiện trọn vẹn trong một packet.

7.5.2 Method và ý nghĩa nghiệp vụ

Các method phổ biến:

- GET: lấy biểu diễn của resource;
- HEAD: lấy header mà không cần response body;
- POST: gửi dữ liệu để xử lý hoặc tạo resource theo ngữ nghĩa ứng dụng;
- PUT: thay thế hoặc tạo resource tại URI xác định;
- PATCH: cập nhật một phần;
- DELETE: yêu cầu xóa resource;
- OPTIONS: hỏi khả năng giao tiếp.

Method không tự tạo quyền truy cập. Server vẫn phải xác thực, phân quyền, kiểm tra dữ liệu và ghi nhật ký phù hợp.

7.5.3 Status code

Nhóm	Ý nghĩa tổng quát	Ví dụ
1xx	Thông tin tạm thời	100 Continue
2xx	Thành công	200 OK, 201 Created, 204 No Content
3xx	Chuyển hướng/cache	301 Moved Permanently, 302 Found, 304 Not Modified
4xx	Vấn đề phía request/-client	400 Bad Request, 401 Unauthorized, 403 Forbidden, 404 Not Found
5xx	Lỗi phía server/gateway	500 Internal Server Error, 502 Bad Gateway, 503 Service Unavailable

401 và 403

Trong thực tế API, 401 thường chỉ rằng request thiếu hoặc có credential không hợp lệ; 403 thường chỉ rằng server hiểu danh tính/yêu cầu nhưng không cho phép hành động. Tên “Unauthorized” của 401 dễ làm người học nhầm với authorization.

7.5.4 Header, content type và message body

Header mang metadata như host, content type, độ dài, cache policy, cookie, authorization, compression và negotiation. Content-Type cho biết cách diễn giải body. Các giá trị thường gặp gồm text/html, application/json và image/png.

Body có thể chứa HTML, JSON, file, form data hoặc dữ liệu nhị phân. Không nên suy đoán kiểu dữ liệu chỉ từ đuôi URL; cần xem header và ngữ cảnh.

7.5.5 Persistent connection, pipelining và multiplexing

HTTP/1.1 thường tái sử dụng TCP connection để giảm chi phí tạo kết nối. HTTP/2 cho phép nhiều stream logic trên một connection và nén header. HTTP/3 chạy trên QUIC, hỗ trợ multiplexing ở transport hiện đại và giảm một số dạng head-of-line blocking giữa stream.

Ví dụ: giao nhiều hồ sơ qua một chuyến xe

Nếu mỗi tài liệu cần một chuyến xe riêng, chi phí khởi hành lớn. Tái sử dụng connection giống dùng một chuyến cho nhiều tài liệu. Multiplexing giống xếp nhiều luồng hồ sơ có nhãn riêng trên cùng hệ thống vận chuyển.

Giới hạn: HTTP version, TCP/QUIC, proxy, browser và server quyết định cách thực hiện thực tế; ví dụ chuyến xe không thể hiện đầy đủ kiểm soát tắc nghẽn và trạng thái stream.

7.5.6 Cookie, session và cache

Cookie là dữ liệu nhỏ do server yêu cầu client lưu và gửi lại theo phạm vi phù hợp. Cookie có thể hỗ trợ session, preference hoặc tracking. Các thuộc tính như Secure, HttpOnly, SameSite, domain, path và expiry ảnh hưởng đến hành vi và an toàn.

Cache lưu response để giảm độ trễ và lưu lượng. Server điều khiển bằng các header như **Cache-Control**, **ETag**, **Last-Modified**. Response 304 Not Modified cho phép client dùng bản đã cache.

7.5.7 Thời gian tải trang và các thành phần độ trễ

Thời gian người dùng cảm nhận có thể gồm:

- DNS lookup time;
- thời gian thiết lập transport;
- TLS handshake;
- server processing time;
- time to first byte;
- thời gian tải resource;
- thời gian parse, render và chạy script ở client;
- queueing, loss và retransmission trong mạng.

Do đó, bandwidth cao không bảo đảm trang luôn phản hồi nhanh. Một request nhỏ có thể bị chi phối bởi RTT, handshake và xử lý server.

7.5.8 TLS và HTTPS

HTTPS là HTTP được bảo vệ bởi TLS. Mục tiêu chính:

- confidentiality: hạn chế bên thứ ba đọc nội dung;
- integrity: phát hiện dữ liệu bị thay đổi;
- authentication: thường xác thực server bằng certificate;
- tạo khóa phiên để mã hóa hiệu quả.

TLS handshake ở mức khái quát:

1. client gửi khả năng hỗ trợ và dữ liệu khởi tạo;
2. server chọn tham số và gửi certificate;
3. client kiểm tra chuỗi tin cậy, tên miền, thời hạn và chính sách;
4. hai phía tạo shared secret và session keys;
5. dữ liệu ứng dụng được bảo vệ bằng khóa phiên.

Certificate warning không nên bị bỏ qua theo thói quen

Cảnh báo có thể do sai thời gian hệ thống, certificate hết hạn, tên miền không khớp, CA không tin cậy, captive portal hoặc tấn công trung gian. Người dùng cần xác định nguyên nhân thay vì bấm tiếp tục một cách máy móc.

7.6 Các giao thức ứng dụng khác

7.6.1 Thư điện tử: SMTP, IMAP và POP3

Hệ thống thư điện tử có nhiều thành phần: mail user agent, mail submission agent, mail transfer agent và mailbox server. SMTP chủ yếu dùng để gửi/chuyển thư; IMAP và POP3 hỗ trợ client truy cập hộp thư theo các mô hình khác nhau.

Giao thức	Vai trò chính	Ghi nhớ
SMTP	Gửi và chuyển thư	Store-and-forward; cần cơ chế chống relay trái phép
IMAP	Đồng bộ và quản lý hộp thư trên server	Giữ cấu trúc folder, trạng thái đọc và nhiều thiết bị
POP3	Tải thư theo mô hình đơn giản	Có thể tải về và tùy cấu hình giữ/xóa bản trên server

MX record trong DNS chỉ đến mail exchanger của domain. SPF, DKIM và DMARC hỗ trợ kiểm tra nguồn gửi và chính sách, nhưng không loại bỏ hoàn toàn phishing.

7.6.2 Truyền file: FTP, FTPS, SFTP và HTTP

FTP truyền thống dùng connection điều khiển và connection dữ liệu riêng, có active/passive mode. FTPS là FTP được bảo vệ bằng TLS. SFTP là giao thức truyền file chạy trên SSH và không phải “FTP qua SSL”.

Trong nhiều hệ thống hiện đại, file được tải qua HTTP/HTTPS hoặc object storage API. Lựa chọn phụ thuộc xác thực, phân quyền, tự động hóa, firewall/NAT, logging và yêu cầu tích hợp.

7.6.3 Đăng nhập từ xa: Telnet và SSH

Telnet cung cấp terminal từ xa nhưng không bảo vệ credential và nội dung theo mặc định. SSH cung cấp kênh mã hóa, xác thực server và nhiều cơ chế xác thực client như password hoặc public key.

Góc nhìn an toàn, an ninh mạng

SSH an toàn hơn Telnet nhưng vẫn cần quản trị khóa, tắt account không dùng, giới hạn nguồn truy cập, chống brute force, cập nhật phần mềm và theo dõi log. Không nên coi “dùng SSH” là đủ cho toàn bộ an toàn hệ thống.

7.6.4 Đồng bộ thời gian: NTP

NTP giúp thiết bị đồng bộ thời gian. Thời gian đúng quan trọng đối với:

- đối chiếu log và điều tra sự cố;
- certificate validation;
- token và cơ chế hết hạn;

- hệ thống phân tán và thứ tự sự kiện;
- đo latency.

NTP tổ chức nguồn thời gian theo stratum, nhưng stratum thấp không tự bảo đảm nguồn là chính xác hoặc đáng tin trong mọi tình huống.

7.6.5 Quản trị mạng: SNMP

SNMP hỗ trợ đọc/ghi đối tượng quản trị và nhận notification. Các khái niệm:

- manager và agent;
- MIB và object identifier;
- polling, trap và inform;
- counter, gauge và trạng thái.

SNMPv1/v2c dùng community string với hạn chế bảo mật; SNMPv3 bổ sung xác thực và bảo vệ nội dung. Quyền write cần được kiểm soát đặc biệt.

7.6.6 API, JSON và dữ liệu có cấu trúc

API web thường trao đổi JSON. Ví dụ:

```
{
  "device_id": "router-01",
  "status": "up",
  "latency_ms": 12.5,
  "interfaces": 4
}
```

JSON có object, array, string, number, Boolean và null. Schema và validation vẫn cần thiết vì dữ liệu hợp cú pháp chưa chắc hợp nghiệp vụ.

7.6.7 MQTT và giao tiếp publish–subscribe

MQTT thường dùng mô hình broker, topic, publisher và subscriber. Nó phù hợp với nhiều kịch bản IoT nhờ message nhỏ và các mức QoS, nhưng cần thiết kế xác thực, TLS, authorization theo topic, session và giới hạn tài nguyên.

Ví dụ: bảng thông báo theo chủ đề

Người quan tâm đăng ký bảng “nhiệt độ phòng máy”. Cảm biến đăng thông báo lên bảng; broker chuyển thông báo đến người đã đăng ký. Publisher không cần biết trực tiếp từng subscriber.

Giới hạn: broker có thể là cụm dịch vụ, message có QoS và trạng thái; bảng thông báo không thể hiện đầy đủ retained message, session hoặc duplicate delivery.

7.6.8 Bảng ghi nhớ nhanh

Giao thức	Mục đích	Port thường gặp	Wireshark filter
DNS	Phân giải tên	53	dns
DHCP	Cấp cấu hình	UDP 67/68	dhcp hoặc bootp
HTTP	Web/API	80	http
HTTPS	HTTP qua TLS	443	tls hoặc tcp.port==443
SMTP	Gửi/chuyển thư	25, 587, 465	smtp
IMAP	Truy cập hộp thư	143, 993	imap
SSH	Đăng nhập/kênh bảo mật	22	ssh
NTP	Đồng bộ thời gian	UDP 123	ntp
SNMP	Quản trị mạng	UDP 161/162	snmp

7.7 Cơ sở khoa học dữ liệu 4: numerical và categorical data

7.7.1 Ví dụ: ước lượng thời gian phân giải DNS

Bài toán

Một recursive resolver chưa có cache. Giả sử nó cần lần lượt hỏi root server, TLD server và authoritative server. RTT đến ba server lần lượt là 20 ms, 35 ms và 45 ms. Bỏ qua processing time và transmission delay của các message nhỏ. Ước lượng thời gian phân giải.

Dữ kiện:

$$RTT_{root} = 20 \text{ ms}, \quad RTT_{TLD} = 35 \text{ ms}, \quad RTT_{auth} = 45 \text{ ms}.$$

Cách tính:

$$T_{DNS} \approx RTT_{root} + RTT_{TLD} + RTT_{auth} = 20 + 35 + 45 = 100 \text{ ms}.$$

Ý nghĩa: dù query/response DNS nhỏ, nhiều lượt trao đổi nối tiếp có thể tạo độ trễ đáng kể.

Kiểm tra tính hợp lý: kết quả không bao gồm RTT từ client đến resolver, queueing, retransmission hoặc cache trung gian.

7.7.2 Ví dụ: thời gian truy cập web đơn giản

Giả sử:

<https://play.google.com/store/apps/developer?id=Ngô+Hai+Anh>

- DNS lookup mất 40 ms;
- RTT đến web server là 60 ms;
- thiết lập TCP cần khoảng 1 RTT;
- TLS handshake cần thêm 1 RTT trong mô hình đơn giản;
- HTTP request đến khi nhận byte đầu tiên cần 1 RTT;
- thời gian truyền nội dung là 120 ms.

Ước lượng:

$$T \approx 40 + 3 \times 60 + 120 = 340 \text{ ms.}$$

Ghi chú

Mô hình này nhằm hình thành trực giác, không phải công thức cố định. TLS version, session resumption, QUIC, connection reuse, server processing, browser scheduling và nhiều resource có thể làm kết quả khác.

7.7.3 Tạo bảng transaction bằng pandas

Một hàng trong bảng dưới đây biểu diễn một HTTP transaction đã được tổng hợp:

```
import pandas as pd

transactions = pd.DataFrame({
    "host": ["portal.edu.vn", "api.edu.vn", "portal.edu.vn",
            "cdn.example.net", "api.edu.vn"],
    "method": ["GET", "GET", "POST", "GET", "GET"],
    "status_code": [200, 200, 201, 304, 503],
    "dns_ms": [12.0, 18.5, 0.0, 22.1, 16.4],
    "ttfb_ms": [85.2, 120.4, 180.5, 40.8, 650.2],
    "response_bytes": [14500, 3200, 850, 0, 120]
})

print(type(transactions))
print(transactions.shape)
print(transactions.dtypes)
print(transactions.head())
```

Giải thích:

- kiểu của transactions là DataFrame;
- shape dự kiến là (5, 6): 5 transaction và 6 cột;
- dns_ms bằng 0 chỉ hợp lệ nếu quy trình tạo dữ liệu quy ước rằng cache hit không phát sinh lookup đo được; nếu 0 dùng thay missing value thì kết luận sẽ sai;
- status 304 có thể có body bằng 0 vì client dùng bản cache.

7.7.4 Lọc lỗi và tổng hợp theo host

```

server_errors = transactions.loc[
    transactions["status_code"].between(500, 599)
]

host_summary = (
    transactions.groupby("host", as_index=False)
    .agg(
        requests=("status_code", "size"),
        mean_ttfb_ms=("ttfb_ms", "mean"),
        total_bytes=("response_bytes", "sum")
    )
    .sort_values("mean_ttfb_ms", ascending=False)
)

print(server_errors)
print(host_summary)

```

Không nên kết luận server chậm chỉ từ một transaction 503. Cần xem số lượng quan sát, time window, percentile, route, DNS, retransmission và dữ liệu phía server.

7.7.5 Trực quan hóa status code và TTFB

```

import matplotlib.pyplot as plt

status_counts = transactions["status_code"].value_counts().sort_index()

fig, ax = plt.subplots(figsize=(8, 4))
ax.bar(status_counts.index.astype(str), status_counts.values)
ax.set_title("Số lượng HTTP transaction theo status code")
ax.set_xlabel("HTTP status code")
ax.set_ylabel("Số transaction")
plt.show()

```

Cách đọc:

- trục x là status code;
- trục y là số transaction trong dữ liệu;
- mỗi cột biểu diễn tần suất một status code;
- biểu đồ không cho biết nguyên nhân của lỗi và không tự chứng minh có tấn công.

```

fig, ax = plt.subplots(figsize=(8, 4))
ax.scatter(transactions["response_bytes"], transactions["ttfb_ms"])
ax.set_title("Quan hệ giữa kích thước response và TTFB")
ax.set_xlabel("Response bytes")
ax.set_ylabel("TTFB in milliseconds")
plt.show()

```

TTFB đo thời gian đến byte đầu tiên, nên không nhất thiết tăng theo kích thước toàn bộ response.

Scatter plot có thể giúp phát hiện mẫu nhưng không chứng minh quan hệ nhân quả.

7.7.6 Đo percentile thay vì chỉ dùng mean

Dữ liệu latency thường lệch phải và có outlier. Có thể tính:

```
summary = transactions["ttfb_ms"].agg(  
    count="count",  
    mean="mean",  
    median="median",  
    min="min",  
    max="max"  
)  
  
p95 = transactions["ttfb_ms"].quantile(0.95)  
print(summary)  
print("P95 TTFB:", p95)
```

Mean mô tả mức trung bình nhưng nhạy với giá trị lớn; median mô tả vị trí trung tâm bền vững hơn; P95 cho biết khoảng 95% quan sát không vượt giá trị đó trong tập dữ liệu đang xét. P95 không phải là “trường hợp xấu nhất”.

7.8 An toàn tầng Application

7.8.1 Bề mặt tấn công tầng ứng dụng

Tầng Application xử lý dữ liệu có ngữ nghĩa phong phú và thường gần người dùng, cơ sở dữ liệu, tài khoản và nghiệp vụ. Bề mặt tấn công có thể gồm:

- parser của protocol/message;
- authentication và session;
- input validation;
- API endpoint;
- DNS/DHCP infrastructure;
- browser, mail client, plugin và script;
- log chứa dữ liệu nhạy cảm;
- cấu hình TLS, certificate và secret.

7.8.2 DNS spoofing, cache poisoning và hijacking

Kẻ tấn công có thể cố làm client nhận record sai bằng response giả, đầu độc cache, chiếm quyền quản trị domain hoặc thay đổi cấu hình resolver. Hậu quả có thể là chuyển người dùng đến server giả, chặn dịch vụ hoặc hỗ trợ phishing.

Biện pháp:

- bảo vệ registrar account và DNS management;
- cập nhật resolver, randomization và kiểm tra transaction;
- DNSSEC khi phù hợp để xác minh tính toàn vẹn/xác thực dữ liệu DNS;
- giám sát thay đổi record và certificate transparency;
- giới hạn recursion và chống open resolver.

Ghi chú

DNSSEC không mã hóa query và không bảo vệ nội dung ứng dụng. DNS over HTTPS/TLS bảo vệ kênh đến resolver nhưng không chứng minh record gốc đúng nếu resolver hoặc quản trị domain bị xâm phạm.

7.8.3 Rogue DHCP và DHCP starvation

Rogue DHCP server có thể cấp gateway hoặc DNS server độc hại. DHCP starvation cố làm cạn pool bằng nhiều request/identity giả.

Biện pháp trong mạng quản trị:

- DHCP snooping trên switch hỗ trợ;
- trusted/untrusted port;
- port security, rate limit và access control;
- giám sát nhiều offer hoặc thay đổi gateway/DNS bất thường;
- phân vùng mạng và 802.1X khi phù hợp.

7.8.4 HTTP input, authentication và session

Các nguy cơ phổ biến gồm injection, broken access control, session fixation/hijacking, cross-site scripting, cross-site request forgery, insecure direct object reference và upload không kiểm soát.

Nguyên tắc phòng vệ:

- kiểm tra và chuẩn hóa input theo ngữ cảnh;
- parameterized query thay cho ghép chuỗi SQL;
- output encoding;
- kiểm tra authorization ở server cho từng hành động;
- cookie Secure, HttpOnly, SameSite;
- token ngắn hạn, rotation và thu hồi;
- rate limit, audit log và phát hiện bất thường.

7.8.5 TLS, certificate và lỗi cấu hình

TLS có thể bị suy yếu bởi:

- certificate hết hạn hoặc tên không khớp;
- private key bị lộ;
- hỗ trợ protocol/cipher lỗi thời;
- không kiểm tra certificate ở client;
- mixed content;
- reverse proxy cấu hình sai;
- secret được ghi vào source code hoặc log.

HTTPS bảo vệ dữ liệu trên đường truyền, nhưng server vẫn có thể bị xâm nhập, ứng dụng vẫn có thể có lỗ hổng, người dùng vẫn có thể bị phishing và endpoint vẫn nhìn thấy plaintext sau giải mã.

7.8.6 Thu thập dữ liệu ứng dụng và quyền riêng tư

DNS query, URL, HTTP header, email metadata và API log có thể tiết lộ:

- dịch vụ người dùng truy cập;
- tài khoản, token hoặc session identifier;
- từ khóa tìm kiếm và path;
- thiết bị, phần mềm và thói quen;
- nội dung nghiệp vụ nếu không mã hóa.

Khi thực hành và nghiên cứu cần:

- thu thập tối thiểu;
- loại bỏ credential, cookie và token;
- ẩn danh hóa/pseudonymize khi phù hợp;
- giới hạn thời gian lưu;
- phân quyền truy cập;
- chỉ dùng dữ liệu được phép.

7.9 Tổng kết chương

7.9.1 Tóm tắt chương

- Tầng Application quy định ý nghĩa và quy tắc trao đổi message giữa tiến trình.
- Client-server, peer-to-peer, request-response và publish-subscribe là các mô hình giao tiếp khác nhau.
- DNS là hệ thống phân tán, phân cấp; resolver dùng cache và truy vấn các server để tìm resource record.
- DHCP cấp địa chỉ và tham số mạng theo lease; DORA mô tả chuỗi trao đổi cơ bản.

- HTTP dùng request/response, method, status code, header và body để truy cập resource.
- HTTPS là HTTP qua TLS; certificate hỗ trợ xác thực endpoint và TLS bảo vệ confidentiality/integrity trên đường truyền.
- SMTP, IMAP, SSH, NTP, SNMP, MQTT và các giao thức khác giải quyết những nhu cầu ứng dụng riêng.
- Độ trễ ứng dụng có thể gồm DNS, transport, TLS, server processing, tải resource và xử lý phía client.
- Dữ liệu ứng dụng cần schema rõ ràng, kiểm tra missing value, metric phù hợp và diễn giải theo ngữ cảnh.
- An toàn tầng ứng dụng cần defense in depth; không một giao thức hay công nghệ đơn lẻ giải quyết mọi rủi ro.

7.9.2 Bài luyện tập

1. Phân biệt tên miền, địa chỉ IP và URL bằng một ví dụ.
2. Giải thích vì sao DNS được thiết kế phân tán và phân cấp thay vì một file trung tâm duy nhất.
3. Nêu vai trò của recursive resolver và authoritative server.
4. Một record có TTL 600 giây. Resolver cache lúc 09:00:00. Theo mô hình đơn giản, đến thời điểm nào record hết TTL?
5. Phân biệt A, AAAA, CNAME và MX.
6. Một resolver cần ba lượt hỏi nối tiếp với RTT 15 ms, 25 ms và 40 ms. Bỏ qua yếu tố khác, tính thời gian.
7. Trình bày bốn message DORA và ý nghĩa từng message.
8. Vì sao DHCP relay cần thiết khi server không cùng subnet với client?
9. Phân biệt HTTP method với HTTP status code.
10. Giải thích ý nghĩa của 200, 304, 404 và 503.
11. Một response gồm 800 byte header và 7,200 byte body. Tính tỷ lệ header.
12. Trang web cần DNS 30 ms, 2 RTT thiết lập/handshake mỗi RTT 50 ms, 1 RTT request-response và 100 ms truyền body. Ước lượng tổng thời gian theo mô hình đơn giản.
13. Vì sao status 304 có thể đi với response body rất nhỏ hoặc không có body?
14. Phân biệt cookie, cache và server-side session.
15. Nêu ba việc client cần kiểm tra khi xác minh certificate.
16. Vì sao HTTPS không chứng minh website là trung thực?
17. So sánh SMTP và IMAP về vai trò.
18. Vì sao NTP quan trọng đối với điều tra sự cố và certificate?
19. Viết biểu thức pandas lọc transaction có status code từ 500 đến 599.
20. Đề xuất bốn feature để khảo sát DNS tunneling và nêu giới hạn của kết luận.

7.9.3 Lời giải bài luyện tập

Bài 1–5

1. Tên miền: `www.example.org`; IP: `203.0.113.10`; URL: `https://www.example.org/docs/a.pdf`. Tên miền dùng cho định danh để nhớ; IP hỗ trợ chuyển packet; URL mô tả cơ chế và resource.
2. Phân tán và phân cấp giúp mở rộng, phân quyền quản trị, giảm single point of failure và cho phép cache. Một file trung tâm khổng lồ khó cập nhật, khó chịu tải và dễ trở thành điểm lỗi duy nhất.
3. Recursive resolver thay client tìm câu trả lời và dùng cache; authoritative server cung cấp record chính thức của zone mà nó quản lý.
4. 600 giây = 10 phút; theo mô hình đơn giản record hết TTL vào 09:10:00. Thực tế thời điểm quan sát và chính sách cache cần được xem xét.
5. A ánh xạ tên đến IPv4; AAAA đến IPv6; CNAME tạo bí danh đến canonical name; MX chỉ mail exchanger của domain.

Bài 6–10

6. $15 + 25 + 40 = 80$ ms.
7. Discover tìm server; Offer đề nghị cấu hình; Request chọn/yêu cầu offer; Acknowledgment xác nhận lease và option.
8. Broadcast DHCP ban đầu không được router chuyển tiếp thông thường. Relay nhận message tại subnet client và gửi đến server, kèm thông tin subnet để chọn pool.
9. Method mô tả hành động request như GET/POST; status code mô tả kết quả server trả như 200/404.
10. 200 thành công; 304 dùng bản cache vì chưa thay đổi; 404 không tìm thấy resource theo request; 503 dịch vụ tạm không sẵn sàng.

Bài 11–15

11. Tổng 8,000 byte; tỷ lệ header $800/8000 \times 100\% = 10\%$.
12. $30 + 2 \times 50 + 50 + 100 = 280$ ms. Công thức đơn giản không gồm render, nhiều resource, server processing hoặc loss.
13. 304 thông báo resource chưa thay đổi, client dùng bản cache nên server không cần gửi lại body đầy đủ.
14. Cookie là dữ liệu client lưu/gửi lại; cache lưu response/resource; server-side session lưu trạng thái ở server và thường được tham chiếu bằng identifier.
15. Kiểm tra chuỗi tin cậy/issuer, tên domain trong certificate, thời hạn hiệu lực; có thể thêm revocation/policy theo hệ thống.

Bài 16–20

16. HTTPS bảo vệ kênh đến domain đã xác minh, nhưng domain đó vẫn có thể thuộc kẻ lừa đảo hoặc ứng dụng có mã độc/lỗi nghiệp vụ.
17. SMTP dùng gửi/chuyển thư giữa client/server hoặc server/server; IMAP dùng truy cập và đồng bộ hộp thư trên server.
18. Thời gian đúng giúp xếp thứ tự log, đối chiếu nhiều thiết bị và kiểm tra thời hạn certificate/token. Lệnh thời gian gây sai phân tích và lỗi xác thực.
19. `transactions.loc[transactions["status_code"].between(500, 599)]`.
20. Ví dụ: độ dài qname, entropy ký tự, số subdomain duy nhất theo time window, tỷ lệ TX-T/NXDOMAIN, query rate. Giới hạn: CDN, telemetry và phần mềm hợp lệ có thể tạo mẫu tương tự; cần ngữ cảnh và nhiều nguồn dữ liệu.

7.9.4 Câu hỏi trắc nghiệm

1. Vai trò phổ biến nhất của DNS là gì?
 - A. Ánh xạ tên miền đến resource record như địa chỉ IP.
 - B. Mã hóa toàn bộ dữ liệu web.
 - C. Cấp địa chỉ MAC cho switch.
 - D. Tính shortest path cho router.
2. Authoritative DNS server là server nào?
 - A. Server cung cấp dữ liệu chính thức cho zone mà nó quản lý.
 - B. Mọi server đang có một bản cache.
 - C. Chỉ server đặt trên máy client.
 - D. Server luôn cấp địa chỉ bằng DHCP.
3. TTL của DNS record chủ yếu liên quan đến điều gì?
 - A. Khoảng thời gian record có thể được giữ trong cache.
 - B. Số hop tối đa của IP packet.
 - C. Độ dài TCP header.
 - D. Số user truy cập website.
4. Thứ tự đúng của DORA là gì?
 - A. Discover, Offer, Request, Acknowledgment.
 - B. Data, Open, Route, Address.
 - C. Discover, Request, Offer, Acknowledgment.
 - D. Download, Observe, Reply, Authenticate.
5. HTTP status code 304 thường cho biết điều gì?
 - A. Resource chưa thay đổi và client có thể dùng bản cache phù hợp.

- B. Server đã xóa resource.
 - C. Client chưa có địa chỉ IP.
 - D. TLS certificate chắc chắn hết hạn.
6. Phát biểu nào đúng về HTTPS?
- A. HTTPS là HTTP được bảo vệ bằng TLS.
 - B. HTTPS tự loại bỏ mọi lỗ hổng ứng dụng.
 - C. HTTPS không cần certificate trong mọi cấu hình.
 - D. HTTPS chỉ hoạt động với UDP port 53.
7. TTFB đo đại lượng nào?
- A. Thời gian từ khi bắt đầu request đến khi nhận byte đầu response theo điểm đo.
 - B. Tổng thời gian người dùng đọc trang.
 - C. Số byte của DNS header.
 - D. Thời hạn của DHCP lease.
8. Giao thức nào chủ yếu dùng để đồng bộ và quản lý hộp thư trên server?
- A. IMAP.
 - B. ARP.
 - C. ICMP.
 - D. OSPF.
9. Dấu hiệu nào có thể gợi ý DNS tunneling nhưng chưa đủ kết luận?
- A. Nhiều qname dài, entropy cao và subdomain duy nhất tăng.
 - B. Một A query hợp lệ đến domain phổ biến.
 - C. Một DHCP Acknowledgment.
 - D. Một HTTP 200 response nhỏ.
10. Vì sao port 443 chưa đủ chứng minh traffic an toàn?
- A. Port chỉ là dấu hiệu; ứng dụng và nội dung có thể không đúng quy ước hoặc vẫn độc hại.
 - B. Router luôn xóa port 443.
 - C. TCP không có destination port.
 - D. Port 443 chỉ dùng cho DHCP.

7.9.5 Đáp án và giải thích

1. **Đáp án đúng:**A. DNS lưu và phân phối nhiều loại resource record; ánh xạ tên đến IP là chức năng phổ biến.
2. **Đáp án đúng:**A. Authoritative server là nguồn có thẩm quyền cho zone, khác với resolver chỉ đang cache dữ liệu.

3. **Đáp án đúng:**A. TTL điều khiển thời gian cache record trước khi cần làm mới.
4. **Đáp án đúng:**A. DORA là Discover–Offer–Request–Acknowledgment.
5. **Đáp án đúng:**A. 304 cho phép dùng bản cache khi điều kiện xác nhận cho thấy resource chưa đổi.
6. **Đáp án đúng:**A. HTTPS kết hợp HTTP và TLS; nó không thay thế an toàn ứng dụng tổng thể.
7. **Đáp án đúng:**A. TTFB tập trung vào byte đầu response, không phải toàn bộ tải/render.
8. **Đáp án đúng:**A. IMAP hỗ trợ truy cập và đồng bộ trạng thái hộp thư trên server.
9. **Đáp án đúng:**A. Đây là các feature thường được xem xét, nhưng dịch vụ hợp lệ cũng có thể tạo mẫu tương tự.
10. **Đáp án đúng:**A. Port không phải bằng chứng đầy đủ về protocol, identity, encryption hoặc tính lành tính.

Chương 8

Mạng không dây và mạng di động

8.1 Mục tiêu và câu hỏi mở đầu

8.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Một máy tính xách tay đang tải tệp qua Wi-Fi. Khi người dùng rời phòng làm việc, tín hiệu yếu dần, thiết bị chuyển sang access point khác rồi tiếp tục truy cập Internet. Nếu người dùng ra khỏi tòa nhà, điện thoại có thể chuyển từ Wi-Fi sang mạng di động. Dữ liệu có thực sự “bay” nguyên vẹn trong không khí không? Vì sao tốc độ hiển thị 1.2 Gb/s nhưng tốc độ tải thực tế thấp hơn nhiều? Thiết bị, địa chỉ, kênh vô tuyến và đường đi của packet thay đổi như thế nào khi người dùng di chuyển?

Ví dụ: cuộc trò chuyện trong một căn phòng đông người

Trong một phòng họp, mọi người dùng chung không gian âm thanh. Trước khi nói, một người thường lắng nghe xem có ai đang nói hay không. Nếu phòng đang ồn, người đó chờ; nếu hai người cùng bắt đầu, câu nói có thể bị che lấp và phải nói lại. Người ngồi gần nghe rõ hơn người ở xa; bức tường làm âm thanh suy giảm.

Phép so sánh này giúp hình dung môi trường vô tuyến dùng chung, cơ chế nghe trước khi truyền, thời gian chờ ngẫu nhiên, nhiễu và suy hao theo khoảng cách.

Giới hạn của mạng: Wi-Fi không truyền bằng âm thanh; tín hiệu vô tuyến được điều chế, mã hóa và xử lý bằng các cơ chế vật lý phức tạp. Thiết bị cũng không “hiểu” nội dung như con người mà chỉ tuân theo quy tắc giao thức.

8.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Phân biệt được mạng có dây, mạng không dây cục bộ và mạng di động.
- Giải thích được tần số, kênh, băng thông kênh, công suất, nhiễu, suy hao và tỷ số tín hiệu trên nhiễu.
- Trình bày được kiến trúc WLAN gồm station, access point, BSS, ESS và distribution system.

- Giải thích được beacon, scanning, authentication, association và roaming.
- Mô tả được CSMA/CA, interframe space, random backoff, acknowledgment và hidden node.
- Phân biệt được PHY rate, throughput, goodput; giải thích ảnh hưởng của khoảng cách, contention và retransmission.
- Trình bày được kiến trúc khái quát của mạng di động gồm UE, trạm truy nhập vô tuyến và core network.
- Giải thích được cell, handover, mobility management, control plane và user plane.
- Phân tích được dữ liệu RSSI, channel utilization, retry rate, throughput và handover bằng pandas và Matplotlib.
- Nhận biết được rogue AP, evil twin, deauthentication, weak encryption, IMSI catcher và các biện pháp giảm thiểu.

8.2 Nền tảng của truyền thông không dây

8.2.1 Tín hiệu vô tuyến và phổ tần số

Mạng không dây truyền thông tin bằng cách làm thay đổi có kiểm soát một sóng điện từ. Các thay đổi đó biểu diễn bit hoặc symbol. Tần số f đo số chu kỳ trong một giây, đơn vị hertz (Hz). Bước sóng λ có quan hệ gần đúng:

$$\lambda = \frac{c}{f},$$

trong đó c là vận tốc lan truyền của sóng điện từ trong chân không, xấp xỉ 3×10^8 m/s.

Ví dụ tính bước sóng

Với tín hiệu 2.4 GHz:

$$\lambda \approx \frac{3 \times 10^8}{2.4 \times 10^9} = 0.125 \text{ m} = 12.5 \text{ cm}.$$

Với tín hiệu 5 GHz, bước sóng xấp xỉ 6 cm. Đây chỉ là giá trị gần đúng; môi trường thực tế ảnh hưởng đến tốc độ lan truyền và đặc tính antenna.

8.2.2 Kênh và băng thông kênh

Một dải tần được chia thành các kênh. *Băng thông kênh* (channel width) là độ rộng phổ mà một truyền dẫn sử dụng, thường biểu diễn bằng MHz. Kênh rộng hơn có thể mang nhiều symbol đồng thời hơn, nhưng cũng chiếm nhiều phổ hơn và dễ chồng lấn với hệ thống lân cận.

Ví dụ: làn đường trên một cây cầu

Kênh vô tuyến giống một phần làn đường được dành cho luồng xe. Mở rộng số làn có thể tăng lượng xe đi qua, nhưng nếu cây cầu và đường dẫn phải chia sẻ với nhiều đơn vị khác, việc chiếm quá nhiều làn làm giảm không gian của người khác.

Giới hạn: phổ tần không phải đường vật lý; các tín hiệu có thể chồng lấn, bị suy hao hoặc được tách bằng kỹ thuật tín hiệu số.

8.2.3 Công suất, RSSI và SNR

chỉ báo cường độ tín hiệu thu (Received Signal Strength Indicator, RSSI) là chỉ báo cường độ tín hiệu thu; cách biểu diễn cụ thể phụ thuộc thiết bị. Nhiều hệ thống hiển thị theo dBm. Giá trị dBm âm ít hơn về độ lớn thường biểu diễn tín hiệu mạnh hơn, ví dụ -45 dBm mạnh hơn -75 dBm.

tỷ số tín hiệu trên nhiễu (Signal-to-Noise Ratio, SNR) so sánh công suất tín hiệu có ích với nền nhiễu:

$$\text{SNR}_{dB} = P_{\text{signal},dBm} - P_{\text{noise},dBm}.$$

Ví dụ tính SNR

Nếu tín hiệu thu là -58 dBm và nền nhiễu là -92 dBm thì:

$$\text{SNR} = (-58) - (-92) = 34 \text{ dB}.$$

SNR cao thường tạo điều kiện dùng mức điều chế và mã hóa hiệu quả hơn, nhưng không bảo đảm throughput cao nếu kênh đang đông hoặc có nhiều retransmission.

8.2.4 Suy hao, che khuất, phản xạ và đa đường

Công suất thu giảm khi khoảng cách tăng. Tường, cửa kim loại, kính phủ, cơ thể người và vật cản làm tín hiệu suy hao hoặc che khuất. Sóng còn có thể phản xạ và tới antenna theo nhiều đường khác nhau, tạo hiện tượng *đa đường* (multipath). Các phiên bản Wi-Fi hiện đại khai thác đa đường bằng OFDM và MIMO, nhưng môi trường phức tạp vẫn làm chất lượng thay đổi theo vị trí và thời gian.

Ví dụ: ánh sáng trong hành lang

Một bóng đèn chiếu sáng tốt khi nhìn trực tiếp, yếu hơn sau nhiều lớp cửa, và có thể tạo vùng sáng tối do phản xạ. Sóng vô tuyến cũng chịu khoảng cách, vật cản và phản xạ, dù quy luật chi tiết khác ánh sáng nhìn thấy.

8.2.5 Nhiễu và tranh chấp

Cần phân biệt:

- *Nhiễu vô tuyến* (radio interference): năng lượng ngoài ý muốn làm giảm khả năng giải mã tín hiệu.
- *Tranh chấp kênh* (contention): nhiều station hợp lệ cùng muốn truyền trên môi trường dùng chung.
- *Tải mạng cao* (high load): nhiều dữ liệu cần truyền; có thể dẫn tới tranh chấp, hàng đợi và độ trễ.

Một mạng có tín hiệu mạnh vẫn có thể chậm vì nhiều thiết bị tranh chấp cùng kênh.

8.2.6 Tốc độ PHY, throughput và goodput

tốc độ *PHY* (physical-layer data rate) là tốc độ mã hóa tín hiệu ở tầng vật lý. Throughput là tốc độ dữ liệu thực tế qua một phạm vi đo. Goodput chỉ tính payload hữu ích của ứng dụng. Quan hệ khái quát:

$$\text{goodput} \leq \text{throughput} \leq \text{PHY rate}.$$

Khoảng cách giữa các đại lượng do preamble, header, acknowledgment, thời gian chờ, backoff, retransmission và lưu lượng của thiết bị khác.

Ví dụ tính hiệu suất quan sát

Một client hiển thị PHY rate 866 Mb/s nhưng đo TCP throughput 420 Mb/s và application goodput 390 Mb/s.

$$\eta_{PHY \rightarrow \text{throughput}} = \frac{420}{866} \times 100\% \approx 48.5\%.$$

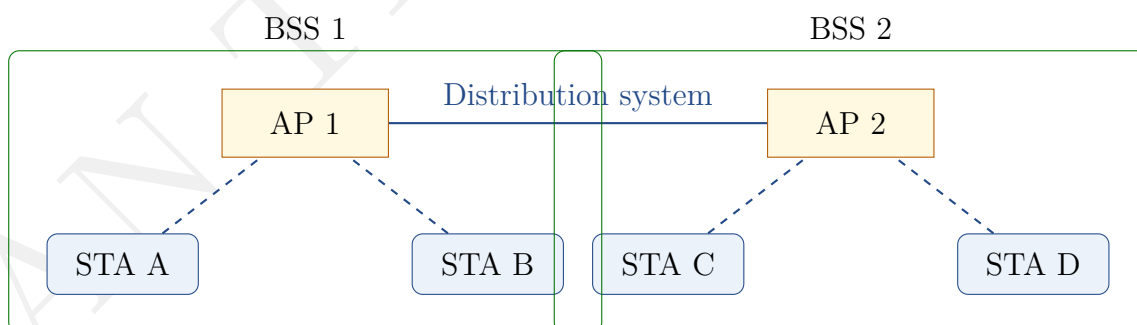
$$\eta_{\text{throughput} \rightarrow \text{goodput}} = \frac{390}{420} \times 100\% \approx 92.9\%.$$

Không nên kết luận phần còn lại là “mất”; phần đó gồm overhead, thời gian môi trường bận và giới hạn của toàn bộ đường truyền.

8.3 Wi-Fi và kiến trúc IEEE 802.11

8.3.1 Station, access point, BSS và ESS

trạm (station, STA) là thiết bị tham gia WLAN. *điểm truy nhập* (access point, AP) cung cấp truy nhập vô tuyến và thường cầu nối lưu lượng vào distribution system. Một AP cùng các station liên kết tạo thành *tập dịch vụ cơ bản* (Basic Service Set, BSS). Nhiều BSS được kết nối và dùng chung chính sách có thể tạo thành *tập dịch vụ mở rộng* (Extended Service Set, ESS).



8.3.2 SSID và BSSID

định danh tập dịch vụ (Service Set Identifier, SSID) là tên logic giúp người dùng nhận biết mạng. *định danh BSS* (Basic Service Set Identifier, BSSID) thường nhận dạng một BSS cụ thể và thường liên quan đến địa chỉ MAC của radio interface. Nhiều AP có thể phát cùng SSID nhưng có BSSID khác nhau.

Ví dụ: chuỗi thư viện và từng chi nhánh

SSID giống tên của một hệ thống thư viện; BSSID giống mã của từng chi nhánh. Người dùng nhớ tên hệ thống, còn thiết bị cần biết đang kết nối với chi nhánh cụ thể nào.

Giới hạn: SSID không chứng minh AP là hợp lệ; kẻ tấn công có thể phát cùng tên để tạo evil twin.

8.3.3 Beacon và scanning

AP định kỳ phát *khung beacon* (beacon frame) để quảng bá thông tin như SSID, khả năng hỗ trợ, kênh và thông số bảo mật. Client có thể:

- *quét thụ động* (passive scanning): nghe beacon trên các kênh;
- *quét chủ động* (active scanning): gửi probe request và nhận probe response.

Scanning tiêu tốn thời gian vì radio phải quan sát nhiều kênh. Kết quả scanning là ảnh chụp tại một thời điểm; môi trường có thể thay đổi ngay sau đó.

8.3.4 Authentication và association

Trong WLAN hạ tầng, client thường đi qua các bước:

1. phát hiện AP;
2. 802.11 authentication ở mức MAC;
3. association để AP ghi nhận station;
4. thực hiện cơ chế bảo mật như WPA2/WPA3 và EAP khi áp dụng;
5. nhận cấu hình IP, thường qua DHCP;
6. trao đổi dữ liệu ứng dụng.

Không nên đồng nhất 802.11 association với xác thực người dùng hoàn chỉnh hoặc với cấp địa chỉ IP.

8.3.5 Các loại frame quản lý, điều khiển và dữ liệu

IEEE 802.11 có ba nhóm frame lớn:

- *khung quản lý* (management frame): beacon, probe, xác thực, liên kết và hủy liên kết;
- *khung điều khiển* (control frame): ACK, RTS, CTS và các frame điều phối;
- *khung dữ liệu* (data frame): mang dữ liệu tầng trên hoặc thông tin liên quan QoS.

Nhóm	Chức năng	Ví dụ
Management	Khám phá, tham gia, duy trì hoặc rời BSS	Beacon, Probe, Association, Deauthentication
Control	Điều phối truy nhập và xác nhận	RTS, CTS, ACK
Data	Mang payload và thông tin dữ liệu	Data, QoS Data, Null Data

8.3.6 Địa chỉ trong frame 802.11

Frame 802.11 có thể chứa nhiều trường địa chỉ hơn Ethernet vì cần phân biệt transmitter, receiver, nguồn logic, đích logic và distribution system. Ý nghĩa phụ thuộc các bit To DS và From DS. Vì vậy không được mặc định “Address 1 luôn là destination” trong mọi frame.

Nguyên tắc đọc frame

Khi đọc một frame Wi-Fi, trước hết xác định loại frame và các bit điều khiển, sau đó mới diễn giải Address 1–4. Wireshark thường hiển thị thêm nhãn Receiver, Transmitter, Source, Destination và BSSID để hỗ trợ.

8.3.7 Từ 802.11 frame sang Ethernet frame

AP có thể cầu nối dữ liệu giữa WLAN và LAN có dây. IP packet không nhất thiết thay đổi, nhưng lớp liên kết được thay thế:

802.11 frame → IP packet → Ethernet frame.

Ví dụ: đổi phương tiện tại điểm trung chuyển

Một kiện hàng đến ga bằng xe máy rồi được đưa lên xe tải. Nội dung và địa chỉ giao cuối cùng có thể giữ nguyên, nhưng chứng từ và bao gói dùng cho từng chặng thay đổi. Tương tự, IP packet có thể được đóng trong frame 802.11 ở chặng vô tuyến và Ethernet frame ở chặng có dây.

8.4 CSMA/CA, roaming và hiệu năng Wi-Fi

8.4.1 Vì sao Wi-Fi dùng CSMA/CA

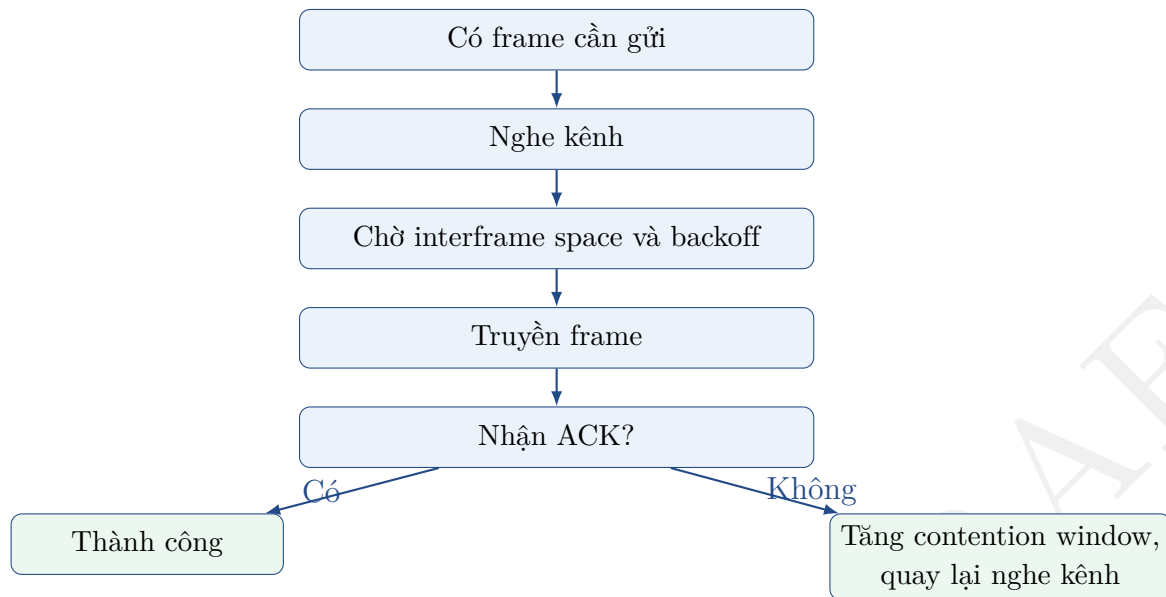
Trong Ethernet cổ điển dùng môi trường chia sẻ, thiết bị có thể phát hiện collision trong khi truyền. Trong radio, một thiết bị phát thường khó đồng thời nghe tín hiệu yếu từ thiết bị khác. WLAN vì thế dùng *đa truy nhập cảm nhận sóng mang tránh va chạm* (Carrier Sense Multiple Access with Collision Avoidance, CSMA/CA): nghe trước, chờ, chọn backoff và dựa vào ACK để suy luận việc truyền thành công. Đây là cơ chế nền tảng của IEEE 802.11 [?].

8.4.2 Quy trình truy nhập cơ bản

Một quy trình khái quát:

1. station có frame cần gửi;
2. cảm nhận kênh;
3. nếu kênh bận, tiếp tục chờ;
4. khi kênh rỗi đủ thời gian, chọn bộ đếm backoff ngẫu nhiên;
5. giảm bộ đếm khi kênh rỗi, đóng băng khi kênh bận;
6. khi bộ đếm về 0, truyền frame;

7. chờ ACK; nếu không nhận ACK, tăng cửa sổ tranh chấp và thử lại.



8.4.3 ACK và retransmission ở tầng liên kết

802.11 thường xác nhận unicast frame ở tầng liên kết. Nếu transmitter không nhận ACK, nó có thể retransmit. Cơ chế này độc lập với TCP retransmission. Một TCP segment có thể được đặt trong một 802.11 frame bị gửi lại nhiều lần mà TCP vẫn chưa biết có lỗi.

Nhầm lẫn thường gặp

Sai: thấy TCP không retransmit nên kết luận liên kết vô tuyến không có lỗi.

Đúng: link-layer retransmission có thể che giấu nhiều lỗi khỏi TCP, nhưng làm tăng airtime và latency.

8.4.4 Hidden node và RTS/CTS

Hai station có thể cùng nghe được AP nhưng không nghe được nhau do khoảng cách hoặc vật cản. Cả hai tưởng kênh rỗi và truyền đồng thời tại AP. Đây là *bài toán nút ẩn* (hidden node problem). RTS/CTS có thể giúp đặt trước môi trường bằng các frame điều khiển, nhưng tạo overhead và không phải lúc nào cũng được dùng.

Ví dụ: hai người ở hai phòng

Hai người ở hai phòng khác nhau không nghe thấy nhau, nhưng cùng gọi vào một phòng điều phối. Họ có thể nói đồng thời và làm người điều phối không nghe rõ. Một thủ tục “xin nói–được phép nói” gần với RTS/CTS.

8.4.5 Băng tần 2.4, 5 và 6 GHz

Các băng tần có đặc điểm triển khai khác nhau:

- 2.4 GHz thường có phạm vi tương đối tốt nhưng ít phổ không chồng lấn và dễ đông;

- 5 GHz có nhiều lựa chọn kênh hơn, thường cho hiệu năng cao trong phạm vi phù hợp;
- 6 GHz mở thêm phổ cho thiết bị và quy định hỗ trợ tương ứng, giảm gánh nặng từ thiết bị cũ nhưng có đặc tính truyền lan cần xem xét.

Quy định kênh và công suất phụ thuộc quốc gia. Không nên đưa một danh sách kênh cố định vào cấu hình mà không kiểm tra regulatory domain.

8.4.6 Các thể hệ Wi-Fi và cơ chế nâng cao hiệu quả

Tên thương mại giúp người dùng nhận biết một số thể hệ chính: Wi-Fi 4 gắn với IEEE 802.11n, Wi-Fi 5 với 802.11ac, Wi-Fi 6/6E với 802.11ax và Wi-Fi 7 với 802.11be. Các thể hệ mới không chỉ tăng PHY rate mà còn cải thiện hiệu quả sử dụng phổ và khả năng phục vụ nhiều thiết bị, thông qua những cơ chế như OFDM/OFDMA, nhiều antenna, lập lịch tài nguyên và phối hợp nhiều liên kết tùy thể hệ.

Không suy luận chỉ từ tên thể hệ

Một client và AP cùng hỗ trợ thể hệ mới chưa bảo đảm goodput cao. Kết quả còn phụ thuộc số spatial stream, channel width, regulatory domain, mức tín hiệu, nhiễu, contention, driver và backhaul. Thiết bị cũng phải thương lượng một tập khả năng chung.

8.4.7 Channel planning và channel utilization

Hai AP gần nhau dùng cùng kênh có thể phải chia sẻ airtime. AP dùng kênh chồng lấn còn có thể gây nhiễu khó điều phối. *mức sử dụng kênh* (channel utilization) ước lượng tỷ lệ thời gian kênh được quan sát là bận. Giá trị cao có thể do mạng của mình, mạng lân cận hoặc nguồn nhiễu khác.

Ví dụ tính airtime đơn giản

Giả sử một frame cần 1.2 ms để truyền kể cả overhead, ACK và khoảng chờ. Nếu trong một giây có 500 lần truyền tương đương:

$$\text{airtime demand} = 500 \times 1.2 \text{ ms} = 600 \text{ ms},$$

tức khoảng 60% thời gian kênh. Đây là mô hình đơn giản, chưa tính collision, retransmission và tốc độ thay đổi theo từng client.

8.4.8 Roaming trong WLAN

Khi client di chuyển trong ESS, nó có thể đổi association từ AP cũ sang AP mới. Quá trình gồm phát hiện ứng viên, quyết định chuyển, authentication/association và cập nhật đường chuyển tiếp. Quyết định roaming thường thuộc client, dù hạ tầng có thể cung cấp thông tin hỗ trợ.

Ví dụ: chuyển quây trong cùng hệ thống

Một người đang được phục vụ tại chi nhánh A rồi chuyển sang chi nhánh B của cùng hệ thống. Hồ sơ cần được nhận diện và tuyến phục vụ cần cập nhật. Nếu chuyển quá sớm hoặc quá muộn, trải nghiệm đều kém.

Giới hạn: roaming không nhất thiết giữ nguyên mọi session nếu địa chỉ IP, chính sách hoặc đường đi thay đổi.

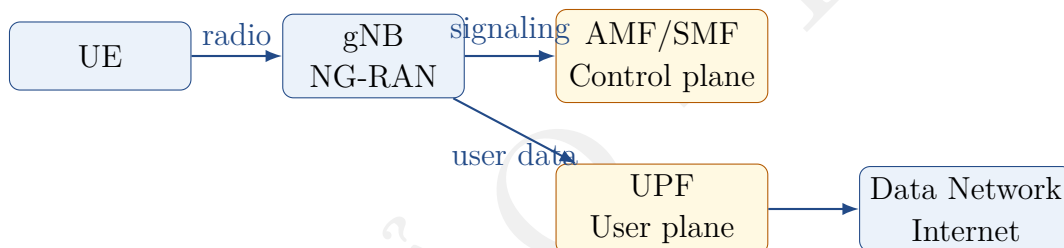
8.4.9 Các yếu tố làm roaming gián đoạn

Độ trễ roaming có thể đến từ scanning, xác thực, trao đổi khóa, DHCP, cập nhật switch table và ứng dụng. Các kỹ thuật tối ưu có thể giảm thời gian, nhưng không thể chỉ nhìn RSSI để kết luận nguyên nhân.

8.5 Mạng di động 4G/5G

8.5.1 Cell, UE và radio access network

Mạng di động chia vùng phủ thành các *ô phủ sóng* (cell). Thiết bị người dùng là *thiết bị người dùng* (User Equipment, UE). UE liên lạc với radio access network qua trạm gốc; trong 5G NR, node chính là *trạm gốc 5G* (next generation Node B, gNB). RAN kết nối UE với core network.



8.5.2 Control plane và user plane

mặt phẳng điều khiển (control plane) thực hiện đăng ký, xác thực, quản lý di động, thiết lập session và chính sách. *mặt phẳng người dùng* (user plane) chuyển dữ liệu của ứng dụng. Trong kiến trúc 5G, AMF xử lý truy nhập và di động; SMF quản lý session; UPF xử lý user data [?].

Ví dụ: quầy điều hành và tuyến xe

Quầy điều hành xác minh vé, chọn tuyến và ghi nhận hành khách; xe buýt thực sự chở hành khách. Control plane gần với phần điều hành, user plane gần với phương tiện chuyển dữ liệu.

Giới hạn: các chức năng mạng là phần mềm và giao thức phân tán, không phải một quầy và một xe duy nhất.

8.5.3 Đăng ký và thiết lập kết nối dữ liệu

Một chuỗi khái quát có thể gồm:

1. UE tìm và chọn mạng phù hợp;
2. thực hiện registration và authentication;
3. thiết lập security context;

4. tạo PDU session và chọn UPF;
5. UE nhận thông tin địa chỉ hoặc định danh cần thiết;
6. packet ứng dụng được chuyển qua RAN và user plane.

Chi tiết phụ thuộc thể hệ mạng, chế độ triển khai và chính sách nhà mạng.

8.5.4 Handover giữa các cell

Khi UE di chuyển hoặc điều kiện radio thay đổi, mạng có thể chuyển kết nối sang cell khác. Handover cần phối hợp đo lường, quyết định, chuẩn bị tài nguyên, chuyển đường dữ liệu và xác nhận. Mục tiêu là duy trì dịch vụ, nhưng một số packet có thể trễ, mất hoặc đi lại đường.

Ví dụ: đoàn tàu đổi khu điều hành

Một đoàn tàu đi từ khu điều hành A sang B. Trước khi rời A, hai bên trao đổi vị trí và quyền kiểm soát để B tiếp tục điều hành. Nếu bàn giao chậm hoặc thông tin không đầy đủ, đoàn tàu phải giảm tốc hoặc dừng.

8.5.5 Mobility và địa chỉ IP

Di chuyển ở tầng radio không nhất thiết làm ứng dụng thấy địa chỉ IP thay đổi. Core network có thể duy trì anchor và tunnel để giữ PDU session. Tuy nhiên, khi chuyển giữa Wi-Fi và mạng di động, giữa nhà mạng hoặc khi session được tạo lại, địa chỉ và đường đi có thể thay đổi.

8.5.6 Roaming giữa các nhà mạng

chuyển vùng (roaming) trong mạng di động là việc thuê bao sử dụng mạng phục vụ không phải mạng nhà. Xác thực, chính sách, định tuyến và tính cước có thể liên quan cả mạng home và visited. Không nên nhầm với Wi-Fi roaming giữa các AP trong một ESS.

8.5.7 Độ trễ và hiệu năng mạng di động

Độ trễ đầu cuối có thể gồm:

$$D_{total} = D_{radio} + D_{RAN} + D_{core} + D_{transport} + D_{server}.$$

Tín hiệu radio tốt chỉ làm giảm một phần; server xa hoặc core route dài vẫn có thể tạo RTT lớn.

Ví dụ tính độ trễ tổng

Một phép đo ước lượng: radio 8 ms, xử lý RAN 4 ms, core 12 ms, Internet 28 ms và server 6 ms:

$$D_{one-way} = 8 + 4 + 12 + 28 + 6 = 58 \text{ ms.}$$

Nếu đường về tương tự, RTT gần 116 ms. Kết quả thực tế có thể không đối xứng.

8.6 Cơ sở khoa học dữ liệu 5: time series và line plot

8.6.1 Nguồn dữ liệu

Có thể thu thập:

- packet capture ở chế độ monitor khi phần cứng và quyền cho phép;
- log của AP, controller hoặc RADIUS;
- số liệu client như RSSI, SNR, PHY rate và retry;
- active measurement như ping, throughput test và roaming test;
- log mạng di động từ thiết bị hoặc hệ thống nhà mạng trong phạm vi được phép.

Mỗi nguồn chỉ phản ánh một phần. Một capture trên một kênh không nhìn thấy traffic ở kênh khác.

8.6.2 Đơn vị quan sát và data dictionary

Giả sử mỗi hàng là một phép đo client trong một khoảng thời gian:

Cột	Kiểu	Đơn vị	Ý nghĩa
timestamp	datetime	–	Thời điểm đo
client_id	string	–	Định danh đã ẩn danh
ap_id	category	–	AP phục vụ
rss_i_dbm	float	dBm	Cường độ tín hiệu thu
snr_db	float	dB	Tỷ số tín hiệu trên nhiễu
retry_rate	float	ratio	Tỷ lệ frame retry
throughput_mbps	float	Mb/s	Throughput đo được
channel_util	float	percent	Tỷ lệ kênh bận

8.6.3 Tạo dữ liệu minh họa bằng pandas

```
import pandas as pd

records = [
    {"minute": 1, "ap_id": "AP-A", "rss_i_dbm": -48,
     "retry_rate": 0.03, "throughput_mbps": 180},
    {"minute": 2, "ap_id": "AP-A", "rss_i_dbm": -58,
     "retry_rate": 0.08, "throughput_mbps": 142},
    {"minute": 3, "ap_id": "AP-A", "rss_i_dbm": -69,
     "retry_rate": 0.19, "throughput_mbps": 78},
    {"minute": 4, "ap_id": "AP-B", "rss_i_dbm": -54,
     "retry_rate": 0.05, "throughput_mbps": 155},
]

df = pd.DataFrame(records)
print(type(df))
```



```
print(df.shape)
print(df.dtypes)
print(df)
```

Giải thích: mỗi dictionary là một phép đo theo phút. Sau phút 3, client chuyển từ AP-A sang AP-B. shape dự kiến là (4, 5).

8.6.4 Kiểm tra kiểu và giá trị thiếu

```
print(df.isna().sum())
print(df[["rssi_dbm", "retry_rate", "throughput_mbps"]].describe())
```

Không nên tự động điền mọi giá trị thiếu bằng 0. RSSI thiếu không có nghĩa là 0 dBm; có thể do client mất liên lạc hoặc hệ thống không thu được phép đo.

8.6.5 Quan hệ RSSI, retry và throughput

```
correlation = df[[
    "rssi_dbm", "retry_rate", "throughput_mbps"
]].corr(numeric_only=True)
print(correlation)
```

Correlation chỉ mô tả quan hệ tuyến tính trong dữ liệu quan sát. Với bốn hàng, không đủ để kết luận tổng quát. Retry có thể tăng do contention dù RSSI không đổi.

8.6.6 Vẽ chuỗi thời gian roaming

```
import matplotlib.pyplot as plt

fig, ax = plt.subplots(figsize=(8, 4))
ax.plot(df["minute"], df["throughput_mbps"], marker="o")
ax.set_xlabel("Minute")
ax.set_ylabel("Throughput in Mb/s")
ax.set_title("Throughput before and after AP transition")
ax.grid(True, alpha=0.3)
plt.show()
```

Cần đọc biểu đồ cùng cột `ap_id`; nếu chỉ nhìn đường throughput, không biết thời điểm association đổi AP.

8.6.7 Nhóm theo AP

```
summary = (
    df.groupby("ap_id", as_index=False)
    .agg(
        samples=("minute", "count"),
        mean_rssi=("rssi_dbm", "mean"),
    )
)
```

```

        mean_retry=("retry_rate", "mean"),
        mean_throughput=("throughput_mbps", "mean"),
    )
)
print(summary)

```

AP-B chỉ có một sample nên mean của nó không đại diện ổn định. Luôn đọc cả số sample.

8.6.8 Bài toán phát hiện giai đoạn chất lượng kém

```

poor = df.loc[
    (df["rssi_dbm"] < -65) |
    (df["retry_rate"] > 0.15) |
    (df["throughput_mbps"] < 100)
]
print(poor)

```

Đây là rule minh họa, không phải chuẩn chung. Threshold phải phù hợp thiết bị, ứng dụng và môi trường.

8.7 An toàn không dây và di động

8.7.1 Đặc điểm bề mặt tấn công

Tín hiệu vô tuyến vượt ra ngoài ranh giới vật lý của phòng và tòa nhà. Kẻ tấn công không nhất thiết cần vào switch để quan sát hoặc phát tín hiệu. Tuy nhiên, mã hóa và xác thực đúng có thể làm giảm đáng kể rủi ro.

8.7.2 Open Wi-Fi, WPA2 và WPA3

Open Wi-Fi không cung cấp bảo vệ liên kết tương đương một mạng được mã hóa và xác thực. WPA2 và WPA3 là các họ cơ chế bảo mật Wi-Fi; mức bảo vệ thực tế còn phụ thuộc mật khẩu, chế độ enterprise/personal, cấu hình, thiết bị và việc người dùng kiểm tra certificate trong 802.1X.

Không đồng nhất Wi-Fi encryption với bảo mật đầu cuối

Mã hóa Wi-Fi bảo vệ chặng radio giữa client và AP. HTTPS bảo vệ dữ liệu giữa ứng dụng và server theo phạm vi của TLS. Một cơ chế không thay thế hoàn toàn cơ chế kia.

8.7.3 Rogue AP và evil twin

điểm truy cập trái phép (rogue AP) là AP không được phép kết nối vào hạ tầng hoặc phát trong phạm vi tổ chức. *điểm truy cập song sinh giả mạo* (evil twin) giả mạo tên và đặc điểm của mạng hợp lệ để dụ client kết nối. SSID giống nhau không chứng minh tính hợp lệ.

Biện pháp gồm inventory, wireless monitoring, certificate-based authentication, không tự động kết nối mạng lạ và xác minh cảnh báo certificate.

8.7.4 Deauthentication và management frame protection

Một số management frame truyền thống có thể bị giả mạo để làm client rời AP. Protected Management Frames giúp bảo vệ một số frame quản lý quan trọng. Dù vậy, jamming vật lý hoặc nhiễu vẫn có thể làm gián đoạn dịch vụ.

8.7.5 Theo dõi định danh và quyền riêng tư

MAC address, probe behavior, vị trí AP và timestamp có thể hỗ trợ theo dõi thiết bị. Nhiều hệ điều hành dùng MAC randomization trong một số giai đoạn, nhưng không nên giả định mọi định danh đã được ẩn danh hoàn toàn.

Dữ liệu nghiên cứu cần giảm định danh, giới hạn thời gian lưu, kiểm soát truy cập và nêu rõ mục đích.

8.7.6 Nguy cơ trong mạng di động

Các nguy cơ có thể gồm giả mạo trạm gốc, hạ cấp thể hệ, theo dõi định danh, signaling attack, cấu hình sai core network và lộ dữ liệu vị trí. 5G có kiến trúc bảo mật được mô tả trong bộ tiêu chuẩn 3GPP, nhưng an toàn vẫn phụ thuộc triển khai, thiết bị và liên kết với hệ thống cũ [?].

8.7.7 Phòng vệ nhiều lớp

Lớp	Biện pháp
Radio và WLAN	WPA2/WPA3, PMF, channel planning, phát hiện rogue AP
Danh tính	802.1X/EAP, certificate, MFA cho hệ thống quản trị
Mạng	VLAN, firewall, client isolation, network access control
Ứng dụng	TLS, xác thực ứng dụng, cập nhật phần mềm
Giám sát	AP/controller log, RADIUS log, anomaly detection, spectrum analysis
Quản trị	Inventory, cấu hình chuẩn, backup, phân quyền, xử lý sự cố

8.8 Tổng kết chương

8.8.1 Tóm tắt chương

- Truyền thông không dây dùng tín hiệu vô tuyến trên môi trường dùng chung; chất lượng phụ thuộc công suất, nhiễu, vật cản và tranh chấp.
- RSSI, SNR, PHY rate, throughput và goodput là các đại lượng khác nhau.
- WLAN gồm station, AP, BSS, ESS và distribution system; SSID là tên logic, BSSID nhận dạng BSS cụ thể.
- Beacon, scanning, authentication và association là các bước khác với DHCP và truy cập ứng dụng.
- Wi-Fi dùng CSMA/CA, backoff, ACK và retransmission để giảm xác suất collision và xử lý lỗi tăng liên kết.

- Roaming Wi-Fi là đổi AP trong ESS; handover mạng di động là bàn giao giữa các cell/RAN node.
- Mạng di động tách control plane và user plane; 5G dùng UE, NG-RAN và 5G Core.
- Phân tích chất lượng cần kết hợp RSSI/SNR, retry, channel utilization, throughput, latency và bối cảnh.
- Không dây mở rộng bề mặt tấn công; cần mã hóa, xác thực, segmentation, giám sát và bảo vệ quyền riêng tư.

8.8.2 Bài tập tự học

Các nhầm lẫn cần tránh

Nhầm lẫn thường gặp

1. AP không đồng nghĩa router; một hộp gia đình có thể tích hợp nhiều chức năng.
2. RSSI không phải throughput và không phải SNR.
3. Association không đồng nghĩa đã có IP hoặc đã truy cập Internet.
4. Wi-Fi roaming khác roaming giữa các nhà mạng di động.
5. Link-layer retry khác TCP retransmission.
6. Kênh rộng hơn không luôn tạo goodput cao hơn.
7. Một SSID giống tên mạng hợp lệ không chứng minh AP đáng tin cậy.
8. “5G” trên giao diện thiết bị không bảo đảm một mức latency cố định.

Bài tập 1

Bài 1. Tín hiệu thu là -64 dBm, noise floor là -91 dBm. Tính SNR.

Bài 2. PHY rate là 600 Mb/s, throughput là 270 Mb/s. Tính hiệu suất throughput trên PHY rate.

Bài 3. Phân biệt SSID và BSSID.

Bài 4. Xếp beacon, ACK và QoS Data vào ba nhóm frame.

Bài 5. Vì sao AP gửi beacon nhưng client vẫn có thể active scan?

Lời giải 1

Lời giải

Bài 1: $\text{SNR} = (-64) - (-91) = 27$ dB.

Bài 2:

$$\eta = \frac{270}{600} \times 100\% = 45\%.$$

Bài 3: SSID là tên logic của mạng; BSSID nhận dạng một BSS cụ thể, thường gắn với radio/MAC của AP.

Bài 4: Beacon là management; ACK là control; QoS Data là data.

Bài 5: Active scan giúp client chủ động hỏi và có thể phát hiện nhanh hơn, đặc biệt khi chưa chờ đủ beacon trên từng kênh.

Bài tập 2

Bài 6. Một kênh có 800 frame/s. Mỗi lần truyền trung bình chiếm 0.7 ms kể cả overhead. Ước lượng airtime demand. Kết quả có hợp lý không?

Bài 7. Client có RSSI -50 dBm, retry 22% và throughput thấp. Nêu ít nhất ba giả thuyết.

Bài 8. Giải thích vì sao TCP không retransmit không chứng minh Wi-Fi không retransmit.

Bài 9. So sánh control plane và user plane của mạng di động.

Bài 10. Một phép đo one-way gồm radio 6 ms, RAN 5 ms, core 14 ms, Internet 20 ms và server 5 ms. Tính one-way delay và RTT gần đúng.

Lời giải 2

Lời giải

Bài 6: $800 \times 0.7 = 560$ ms/s, tức khoảng 56% airtime. Đây là ước lượng; nếu có retransmission, collision hoặc frame tốc độ khác nhau thì airtime thực thay đổi.

Bài 7: Có thể do channel utilization cao, hidden node, nguồn nhiễu gần client/AP, uplink yếu, thiết bị khác dùng tốc độ thấp chiếm airtime hoặc backhaul bị nghẽn.

Bài 8: 802.11 có link-layer ACK và retry trước khi TCP phát hiện mất segment. Retry thành công che giấu lỗi khỏi TCP nhưng làm tăng delay.

Bài 9: Control plane quản lý registration, authentication, mobility, session và policy; user plane chuyển packet ứng dụng qua RAN, UPF và data network.

Bài 10: One-way = $6 + 5 + 14 + 20 + 5 = 50$ ms. RTT gần đúng 100 ms nếu hai chiều tương tự.

Bài tập 3

Bài 11. Một log có các dòng AP-A, AP-A, AP-B, AP-B. Có thể khẳng định đã roaming thành công không? Cần thêm gì?

Bài 12. Phân tích lỗi trong kết luận: “AP-B có throughput trung bình cao hơn AP-A nên AP-B luôn tốt hơn.”

Bài 13. Thiết kế schema tối thiểu để nghiên cứu quan hệ giữa RSSI, retry và throughput.

Bài 14. Vì sao mở rộng channel width trong khu chung cư có thể làm hiệu năng giảm?

Bài 15. Một sinh viên thu thập MAC address và vị trí thiết bị của toàn trường rồi đăng công khai. Nêu các vấn đề và phương án sửa.

Lời giải 3

Lời giải

Bài 11: Chưa đủ. Cần timestamp, trạng thái association, khoảng mất kết nối, BSSID, SSID, IP/session continuity và có thể packet/log authentication.

Bài 12: Có thể số sample khác nhau, thời điểm tải khác nhau, client khác nhau hoặc AP-B chỉ được đo trong điều kiện thuận lợi. Cần kiểm soát biến và báo confidence/variation.

Bài 13: Tối thiểu: timestamp, anonymized client ID, AP/BSSID, channel, RSSI dBm, noise hoặc SNR, data frame count, retry frame count, throughput Mb/s, test duration và vị trí/điều kiện đo.

Bài 14: Kênh rộng chiếm nhiều phổ, tăng khả năng chồng lấn và giảm số kênh độc lập; các AP phải chia sẻ hoặc gây nhiễu nhiều hơn.

Bài 15: MAC và vị trí có thể là dữ liệu nhận dạng hoặc hỗ trợ theo dõi. Cần có mục đích và quyền thu thập, giảm dữ liệu, pseudonymization, giới hạn truy cập/thời gian lưu và không công khai dữ liệu thô.

8.8.3 Câu hỏi trắc nghiệm

Câu 1. Đại lượng nào so sánh công suất tín hiệu có ích với nền nhiễu?

- A. SSID.
- B. SNR.
- C. BSSID.
- D. MTU.

Câu 2. Thành phần nào thường nhận dạng một BSS cụ thể?

- A. SSID.
- B. BSSID.
- C. URL.
- D. ASN.

Câu 3. Vì sao Wi-Fi dùng CSMA/CA thay vì dựa vào collision detection khi đang phát?

- A. Thiết bị radio khó đồng thời phát và phát hiện tín hiệu yếu khác.
- B. Wi-Fi không có địa chỉ MAC.
- C. Wi-Fi không dùng frame.
- D. AP luôn cấp lịch truyền cố định cho mọi station.

Câu 4. Frame nào thuộc nhóm management?

- A. TCP ACK.
- B. 802.11 Beacon.
- C. IPv4 packet.
- D. Ethernet FCS.

Câu 5. Nhận định nào đúng về link-layer retry và TCP retransmission?

- A. Hai cơ chế luôn xảy ra đồng thời.
- B. Retry tầng liên kết có thể che giấu lỗi khỏi TCP.
- C. TCP retransmission diễn ra trước khi Wi-Fi retry.
- D. Wi-Fi không có acknowledgment.

Câu 6. Thiết bị nào là node truy nhập vô tuyến chính trong 5G NR?

- A. gNB.
- B. DNS resolver.
- C. Ethernet switch.
- D. SMTP server.

Câu 7. Chức năng nào thuộc user plane của 5G Core?

- A. AMF.
- B. UPF.
- C. UDM.
- D. AUSF.

Câu 8. Điều nào có thể làm throughput thấp dù RSSI mạnh?

- A. Channel utilization cao.
- B. Bước sóng tồn tại.
- C. SSID có tên ngắn.
- D. Client có địa chỉ IP.

Câu 9. Evil twin là gì?

- A. AP giả mạo đặc điểm của mạng hợp lệ.
- B. Hai AP hợp lệ cùng thuộc một ESS.
- C. Hai client dùng cùng ứng dụng.
- D. Một router có hai default route.

Câu 10. Khi phân tích roaming từ log AP, thông tin nào cần thiết nhất để xác định trình tự?

- A. Timestamp.
- B. Màu giao diện AP.
- C. Tên người sản xuất laptop.
- D. Kích thước màn hình client.

8.8.4 Đáp án và giải thích

Lời giải

Câu 1: B. SNR là tỷ số tín hiệu trên nhiễu; theo dB có thể tính từ chênh lệch signal và noise cùng đơn vị dBm.

Câu 2: B. BSSID nhận dạng BSS cụ thể; nhiều BSSID có thể quảng bá cùng SSID.

Câu 3: A. Trên radio, collision detection trong khi phát không thực tế như Ethernet có dây; Wi-Fi dùng nghe trước và backoff.

Câu 4: B. Beacon là management frame dùng để quảng bá BSS.

Câu 5: B. Wi-Fi có thể retry frame ở tầng liên kết trước khi TCP nhận thấy segment bị mất.

Câu 6: A. gNB là node chính của NG-RAN trong 5G NR.

Câu 7: B. UPF xử lý dữ liệu người dùng; AMF, UDM và AUSF chủ yếu thuộc control plane.

Câu 8: A. Khi kênh bận, client phải chờ đủ tín hiệu mạnh, làm throughput giảm.

Câu 9: A. Evil twin dùng SSID và đặc điểm tương tự mạng hợp lệ để đánh lừa người dùng hoặc thiết bị.

Câu 10: A. Timestamp cho phép sắp xếp sự kiện và đo khoảng gián đoạn; vẫn cần thêm trạng thái association để kết luận chắc chắn.

Tài liệu tham khảo chọn lọc

Chương 9

Hiệu năng mạng và phân tích bằng hồi quy

9.1 Mục tiêu của chương

Câu hỏi mở đầu

Một dịch vụ web chậm vào giờ cao điểm. Nhóm vận hành đo được RTT, packet loss, mức sử dụng liên kết, số flow đồng thời và response time. Những đại lượng nào mô tả đúng hiện tượng mạng? Có thể dùng các phép đo này để dự đoán response time của một khoảng thời gian mới hay không, và làm thế nào biết mô hình thực sự tốt hơn một dự đoán đơn giản?

Ví dụ: thời gian giao hàng

Muốn dự đoán thời gian giao hàng, ta có thể dùng quãng đường, số điểm trung chuyển và mức tắc đường. Trước khi dùng mô hình phức tạp, cần hiểu từng đại lượng đo gì và có một mốc so sánh đơn giản, chẳng hạn luôn dự đoán thời gian trung bình.

Liên hệ sang mạng: quãng đường tương tự thành phần propagation/path; tắc đường tương tự utilization/queue; số lần phải xử lý lại tương tự retransmission; thời gian giao hàng tương tự response time. **Giới hạn:** quan hệ trong mạng có thể thay đổi theo topology, ứng dụng và thời gian; mô hình dự đoán không tự chứng minh quan hệ nhân quả.

Sau khi hoàn thành phần này, người học có thể

- Phân biệt bandwidth, throughput, goodput, utilization, delay, RTT, jitter, loss và percentile.
- Tính được transmission delay, propagation delay, BDP và một số giới hạn throughput đơn giản.
- Giải thích được queue, congestion, bufferbloat, QoS/QoE/SLA và giới hạn của đo lường.
- Xác định đúng observation, feature, target, ma trận X và vector y cho một bài toán hồi quy mạng.
- Chia train-test đúng nguyên tắc, xây baseline, huấn luyện `LinearRegression` và tạo prediction.
- Đánh giá bằng MAE, RMSE và residual, đồng thời diễn giải kết quả bằng đơn vị mạng và nhận biết leakage/extrapolation.

Thực hành liên quan

Chương này giải thích các đoạn code then chốt theo mạch input–type–shape–output. Thực hành liên quan nằm trong Module 07, với dữ liệu và quy trình chạy đầy đủ.

9.2 Các đại lượng mô tả hiệu năng mạng

9.2.1 Băng thông, tốc độ bit và dung lượng

băng thông (bandwidth) trong ngữ cảnh vận hành mạng thường được dùng để chỉ năng lực truyền tối đa danh nghĩa của một liên kết hoặc dịch vụ, ví dụ 100 Mb/s hoặc 1 Gb/s. Trong vật lý tín hiệu, bandwidth còn có nghĩa là độ rộng dải tần. Vì vậy, khi dùng từ này phải nêu rõ ngữ cảnh.

tốc độ bit (bit rate) là số bit được truyền trong một đơn vị thời gian. *dung lượng* (capacity) là giới hạn năng lực mà hệ thống có thể cung cấp trong điều kiện xác định. Các đại lượng này không đồng nghĩa với tốc độ ứng dụng thực nhận.

Ví dụ: sức chứa của đường và số xe thực đi qua

Một con đường thiết kế cho 2.000 xe mỗi giờ là năng lực danh nghĩa. Nếu đang sửa đường, có nút giao hoặc xe đi không đều, số xe thực đi qua có thể chỉ là 1.300 xe mỗi giờ. Tương tự, liên kết 100 Mb/s không bảo đảm ứng dụng luôn nhận đủ 100 Mb/s.

9.2.2 Thông lượng và thông lượng hữu ích

thông lượng (throughput) là tốc độ dữ liệu thực tế đi qua một điểm quan sát, thường tính cả header và có thể tính cả dữ liệu được truyền lại tùy cách đo. *thông lượng hữu ích* (goodput) là tốc độ dữ liệu hữu ích của ứng dụng đến được đích, không tính protocol overhead và dữ liệu truyền lại.

Nếu trong thời gian T giây, ứng dụng nhận được D byte hữu ích:

$$G = \frac{8D}{T} \quad \text{bit/s.}$$

Ví dụ tính goodput

Một ứng dụng nhận tệp 120 MB trong 16 s. Dùng quy ước thập phân $1 \text{ MB} = 10^6 \text{ byte}$:

$$G = \frac{8 \times 120 \times 10^6}{16} = 60 \times 10^6 \text{ bit/s} = 60 \text{ Mb/s.}$$

Nếu packet capture cho thấy 1.08 Gbit đã đi qua liên kết trong thời gian đó, throughput quan sát là 67.5 Mb/s. Chênh lệch phản ánh header, retransmission hoặc lưu lượng điều khiển.

9.2.3 Tốc độ packet và tốc độ frame

Ngoài bit/s, thiết bị còn bị giới hạn bởi số packet hoặc frame xử lý mỗi giây, ký hiệu pps hoặc fps. Hai luồng có cùng throughput nhưng packet size khác nhau có thể tạo tải xử lý rất khác.

Ví dụ packet nhỏ và packet lớn

Một luồng 80 Mb/s dùng packet 1.000 byte tạo xấp xỉ:

$$\frac{80 \times 10^6}{8 \times 1000} = 10,000 \text{ packet/s.}$$

Nếu dùng packet 100 byte, packet rate tăng lên khoảng 100.000 packet/s. Thiết bị phải thực hiện nhiều lookup, cập nhật counter và thao tác queue hơn.

9.2.4 Mức sử dụng và tải đầu vào

tải đầu vào (offered load) là lượng lưu lượng muốn đi vào tài nguyên. *mức sử dụng* (utilization) là tỷ lệ tài nguyên bận trong khoảng quan sát. Với link capacity C và throughput R :

$$U = \frac{R}{C} \times 100\%.$$

Utilization cao không tự động là xấu. Một liên kết hoạt động 80% có thể hoàn toàn bình thường nếu lưu lượng đều và queue nhỏ. Vấn đề xuất hiện khi tải đến theo burst, nhiều lớp lưu lượng tranh chấp hoặc capacity thực thấp hơn con số cấu hình.

9.2.5 Độ trễ và thời gian đáp ứng

độ trễ (delay/latency) mô tả thời gian dữ liệu đi từ điểm này tới điểm khác. *thời gian đáp ứng* (response time) ở tầng ứng dụng thường bao gồm cả thời gian mạng, thời gian server xử lý và thời gian client hiển thị.

Cần nêu rõ đại lượng là:

- one-way delay hay round-trip time;
- đo ở packet, flow hay transaction;
- giá trị trung bình, trung vị, percentile hay cực đại;
- thời gian mạng thuần túy hay thời gian đầu cuối của ứng dụng.

9.2.6 Packet loss

Với N_s packet được gửi và N_r packet nhận được:

$$\text{Loss rate} = \frac{N_s - N_r}{N_s} \times 100\%.$$

Packet có thể mất do queue đầy, lỗi đường truyền, chính sách drop, TTL hết, filter hoặc do công cụ đo bị giới hạn. Không nhận được ICMP Echo Reply không chứng minh packet dữ liệu ứng dụng cũng bị mất.

9.2.7 Dao động và biến thiên độ trễ packet

Trong cách nói thông dụng, *dao động độ trễ* (jitter) là mức biến động của delay theo thời gian. RFC 3393 định nghĩa metric IP packet delay variation từ chênh lệch one-way delay giữa các packet được chọn [?]. Có nhiều cách tính jitter; tài liệu và công cụ phải ghi rõ công thức.

Một cách đơn giản cho dãy delay $d_1, d_2, \dots, d_n$ là trung bình độ lệch tuyệt đối liên tiếp:

$$J = \frac{1}{n-1} \sum_{i=2}^n |d_i - d_{i-1}|.$$

Ví dụ cuộc gọi có cùng delay trung bình nhưng trải nghiệm khác

Dãy A: 40, 41, 39, 40, 40 ms. Dãy B: 10, 70, 20, 60, 30 ms. Cả hai có trung bình 40 ms, nhưng dãy B biến động mạnh. Ứng dụng thoại phải dùng jitter buffer lớn hơn hoặc chấp nhận mất/đến muộn.

9.2.8 Percentile và tail latency

Giá trị trung bình có thể che giấu các lần chậm bất thường. Percentile thứ 95, ký hiệu p95, là mức mà khoảng 95% quan sát không vượt quá. p99 mô tả phần đuôi nghiêm trọng hơn.

Nhầm lẫn thường gặp

Nói “p95 bằng 120 ms” không có nghĩa 95% packet có delay đúng 120 ms. Nó có nghĩa khoảng 95% quan sát có delay nhỏ hơn hoặc bằng ngưỡng đó theo cách tính percentile đã chọn.

9.3 Các thành phần độ trễ và BDP

9.3.1 Độ trễ truyền

Với packet dài L bit và tốc độ liên kết R bit/s:

$$d_{trans} = \frac{L}{R}.$$

Đây là thời gian cần để đẩy toàn bộ bit của packet lên liên kết, không phải thời gian tín hiệu đi hết khoảng cách.

Ví dụ xếp một đoàn tàu qua cổng

Một đoàn tàu có 100 toa. Nếu cổng cho mỗi giây 10 toa đi qua, cần 10 giây để toàn bộ đoàn tàu qua cổng. Thời gian này tương tự transmission delay. Việc toa đầu tiên chạy tới ga kế tiếp mất bao lâu lại tương tự propagation delay.

9.3.2 Độ trễ lan truyền

Với khoảng cách d và tốc độ lan truyền v :

$$d_{prop} = \frac{d}{v}.$$

Ví dụ tính propagation delay

Một tuyến cáp dài 1.800 km, tốc độ lan truyền gần 2×10^8 m/s:

$$d_{prop} = \frac{1.8 \times 10^6}{2 \times 10^8} = 0.009 \text{ s} = 9 \text{ ms}.$$

Giá trị này chưa gồm đường vòng thực tế, bộ khuếch đại, router và queue.

9.3.3 Độ trễ xử lý

độ trễ xử lý (processing delay) là thời gian thiết bị đọc header, kiểm tra lỗi, lookup route, áp policy, mã hóa/giải mã hoặc thực hiện chức năng khác. Giá trị phụ thuộc phần cứng, software path, tính năng bật và tải CPU.

Một firewall kiểm tra sâu nội dung có thể tạo processing delay lớn hơn router chỉ chuyển tiếp IP. Tuy nhiên, không nên suy luận chỉ từ tên thiết bị; cần đo trong điều kiện cụ thể.

9.3.4 Độ trễ hàng đợi

độ trễ hàng đợi (queueing delay) là thời gian packet chờ trước khi được phục vụ. Đây thường là thành phần biến động nhất. Khi offered load thấp, queue có thể gần bằng không; khi tải tiến sát hoặc vượt capacity, delay tăng nhanh và packet có thể bị drop.

Ví dụ: quầy thanh toán

Thời gian nhân viên quét hàng tương tự service time. Thời gian khách đứng chờ phía trước là queueing delay. Nếu nhiều khách đến cùng lúc, hàng đợi tăng dù tốc độ phục vụ của quầy không đổi.

Giới hạn: packet có thể thuộc nhiều class và được lập lịch khác FIFO; một số packet có thể bị drop hoặc đánh dấu trước khi queue đầy.

9.3.5 Độ trễ đầu cuối

Với đường đi qua nhiều liên kết và router, one-way delay gần đúng:

$$d_{e2e} = \sum d_{trans} + \sum d_{prop} + \sum d_{proc} + \sum d_{queue}.$$

Ví dụ tổng hợp độ trễ

Một packet đi qua ba liên kết. Tổng transmission delay là 1.8 ms, propagation delay 24 ms, processing delay 1.2 ms và queueing delay 8 ms:

$$d_{e2e} = 1.8 + 24 + 1.2 + 8 = 35 \text{ ms.}$$

Nếu chiều về tương tự và server xử lý 10 ms, response time gần đúng là $35 + 10 + 35 = 80 \text{ ms}$.

9.3.6 Store-and-forward và pipeline

Trong store-and-forward, router phải nhận đủ frame hoặc packet trước khi chuyển tiếp. Với N liên kết cùng tốc độ R , một packet dài L bit, bỏ qua các delay khác, thời gian packet đầu tới đích xấp xỉ NL/R .

Khi có nhiều packet, pipeline cho phép packet sau được truyền trên liên kết đầu trong khi packet trước đã sang liên kết kế tiếp. Vì vậy, thời gian gửi P packet không đơn giản bằng $P \times NL/R$ mà gần:

$$(N + P - 1) \frac{L}{R}$$

trong mô hình lý tưởng, cùng tốc độ và không queue.

9.3.7 Thời gian khứ hồi

RTT là thời gian từ khi gửi một thông điệp tới khi nhận phản hồi tương ứng. Ping thường đo RTT của ICMP Echo, còn TCP có thể ước lượng RTT từ segment và acknowledgment.

RTT không nhất thiết bằng hai lần one-way delay vì đường đi, queue và processing hai chiều có thể khác nhau. Đo one-way chính xác còn cần đồng bộ clock giữa hai đầu.

9.3.8 Tích băng thông–độ trễ

tích băng thông–độ trễ (bandwidth-delay product, BDP) là lượng dữ liệu có thể đang “trên đường” khi truyền ở tốc độ C trong một RTT:

$$BDP = C \times RTT.$$

Ví dụ đường ống dài

Một đường ống có thể bơm 100 lít mỗi giây và nước mất 5 giây để đi hết ống. Khi hệ thống ổn định, có thể có khoảng 500 lít đang nằm trong ống. Tương tự, mạng có capacity cao và RTT lớn cần window đủ lớn để giữ nhiều dữ liệu đang bay.

Ví dụ tính BDP và window

Liên kết 200 Mb/s, RTT 50 ms:

$$BDP = 200 \times 10^6 \times 0.05 = 10^7 \text{ bit} = 1.25 \text{ MB.}$$

Muốn tận dụng gần hết capacity, sender cần có khả năng giữ xấp xỉ 1.25 MB dữ liệu chưa được xác nhận, chưa tính overhead và biến động.

9.3.9 Hàng đợi, tắc nghẽn, mất packet và điểm nghẽn

Từ tải thấp tới tắc nghẽn. *tắc nghẽn* (congestion) xảy ra khi nhu cầu sử dụng tài nguyên vượt khả năng phục vụ trong một khoảng đủ dài hoặc theo burst. Khi đó:

1. packet đến nhanh hơn tốc độ truyền ra;
2. queue tăng;
3. queueing delay tăng;
4. buffer đầy dẫn tới drop;
5. transport hoặc ứng dụng có thể retransmit, làm tải tăng thêm.

Congestion khác lỗi vật lý. Packet loss do queue đầy có thể xảy ra trên đường truyền hoàn toàn không có bit error.

Burst traffic. Lưu lượng mạng thường đến theo burst chứ không đều. Trung bình 40% capacity không loại trừ việc trong một khoảng ngắn lưu lượng đạt 150% capacity và tạo queue.

Ví dụ: học sinh ra khỏi hội trường

Trong cả giờ, số người đi qua cửa không nhiều; nhưng khi buổi học kết thúc, hàng trăm người tới cửa trong vài phút. Trung bình theo một giờ che giấu đỉnh tải ngắn. Vì vậy, cần xem time series và percentile thay vì chỉ giá trị trung bình.

Buffer, drop-tail và bufferbloat. Buffer hấp thụ burst tạm thời. Nếu quá nhỏ, packet bị drop sớm; nếu quá lớn, packet có thể chờ rất lâu. *hiện tượng phình bộ đệm* (bufferbloat) là hiện tượng buffer lớn hoặc được quản lý không phù hợp tạo latency cao dưới tải.

Drop-tail loại bỏ packet mới khi queue đầy. Active Queue Management có thể drop hoặc đánh dấu trước khi buffer đầy để báo congestion sớm hơn. Chương này tập trung nguyên lý, không đi sâu cấu hình từng thuật toán.

Retransmission và congestion collapse. Retransmission cần thiết khi dữ liệu mất, nhưng truyền lại quá nhiều trong mạng đã nghẽn có thể làm tình hình xấu hơn. Congestion control của TCP cố gắng điều chỉnh sending rate dựa trên tín hiệu loss, delay hoặc explicit marking tùy cơ chế.

Không được kết luận mọi retransmission là do congestion: lỗi Wi-Fi, reordering, timeout quá ngắn hoặc receiver behavior cũng có thể liên quan.

Tính công bằng. *tính công bằng* (fairness) mô tả cách tài nguyên được chia giữa các flow hoặc class. Chia đều bit rate không phải lúc nào cũng là chính sách phù hợp: thoại cần ít bandwidth nhưng nhạy delay; backup cần nhiều bandwidth nhưng có thể chờ.

Một chỉ số thường dùng để mô tả công bằng giữa n luồng có throughput x_i là Jain's fairness index:

$$J = \frac{(\sum_{i=1}^n x_i)^2}{n \sum_{i=1}^n x_i^2}, \quad \frac{1}{n} \leq J \leq 1.$$

Ví dụ tính công bằng

Ba flow đạt 30, 30 và 30 Mb/s:

$$J = \frac{90^2}{3(30^2 + 30^2 + 30^2)} = 1.$$

Nếu đạt 80, 5 và 5 Mb/s:

$$J = \frac{90^2}{3(80^2 + 5^2 + 5^2)} \approx 0.419.$$

Chỉ số thấp hơn phản ánh phân chia không đều, nhưng không tự kết luận chính sách là sai vì có thể tồn tại ưu tiên hợp lệ.

Điểm nghẽn. *điểm nghẽn* (bottleneck) là tài nguyên giới hạn throughput hoặc gây queue đáng kể trên một đường đi. Bottleneck có thể là:

- liên kết có capacity thấp;
- Wi-Fi airtime bị tranh chấp;
- CPU của firewall;
- storage của server;
- receiver window;
- ứng dụng đọc dữ liệu chậm.

Nhầm lẫn thường gặp

Tuyến có các liên kết 1 Gb/s, 100 Mb/s và 500 Mb/s thường bị giới hạn gần 100 Mb/s, nhưng throughput ứng dụng còn có thể thấp hơn do overhead, RTT, loss, window, server và lưu lượng khác.

Little's Law ở mức trực giác. Trong hệ ổn định, Little's Law liên hệ số phần tử trung bình trong hệ L , tốc độ đến λ và thời gian trung bình W :

$$L = \lambda W.$$

Nếu một link xử lý trung bình 2.000 packet/s và packet ở trong queue trung bình 5 ms, số packet trung bình trong queue xấp xỉ $2,000 \times 0.005 = 10$ packet. Công thức cần các điều kiện ổn định và cách xác định phạm vi hệ nhất quán.

9.4 QoS và phân bổ tài nguyên

9.4.1 QoS, QoE và SLA

chất lượng dịch vụ (Quality of Service, QoS) là tập hợp chỉ số và cơ chế kỹ thuật nhằm cung cấp mức phục vụ có thể phân biệt hoặc kiểm soát. *chất lượng trải nghiệm* (Quality of Experience, QoE) phản ánh trải nghiệm người dùng, chịu ảnh hưởng của mạng, ứng dụng, thiết bị và kỳ vọng. *thỏa thuận mức dịch vụ* (Service Level Agreement, SLA) là thỏa thuận về mức dịch vụ, phạm vi đo, thời gian, ngoại lệ và trách nhiệm.

Ví dụ nhà hàng

QoS giống quy trình bảo đảm món nóng được phục vụ sớm và món nguội có thể chờ hơn. QoE là cảm nhận của khách, còn SLA giống cam kết “phục vụ trong 15 phút” với điều kiện và phạm vi cụ thể.

Giới hạn: QoE không chỉ do delay; nội dung, giao diện, thiết bị và tâm lý người dùng cũng ảnh hưởng.

9.4.2 Yêu cầu của các nhóm ứng dụng

Ứng dụng	Bandwidth	Delay	Jitter/loss	Nhận xét
Thoại tương tác	Thấp-vừa	Rất nhạy	Nhạy	Đến muộn có thể vô ích
Hội nghị video	Vừa-cao	Nhạy	Nhạy	Có thể thích nghi bitrate
Web tương tác	Theo burst	Nhạy vừa	Mất gây chậm	Nhiều request nhỏ
Tải tệp/backup	Cao	Ít nhạy	TCP khắc phục	Ưu tiên hoàn tất chính xác
Telemetry	Thấp	Tùy ứng dụng	Tùy	Có thể cần độ tin cậy cao
Game trực tuyến	Thấp-vừa	Rất nhạy	Nhạy	Cần độ ổn định

Bảng chỉ mang tính định hướng. Yêu cầu cụ thể phụ thuộc codec, thiết kế ứng dụng, số người dùng và môi trường.

9.4.3 Phân loại và đánh dấu

phân loại (classification) xác định packet thuộc class nào dựa trên trường header, interface, ứng dụng, policy hoặc thông tin khác. *đánh dấu* (marking) ghi một giá trị để thiết bị sau có thể áp hành vi phù hợp.

Kiến trúc Differentiated Services dùng DS field trong IP header và các per-hop behavior để cung cấp phân biệt dịch vụ có khả năng mở rộng [?]. Marking chỉ có ý nghĩa khi các thiết bị trong miền tin cậy thống nhất policy.

9.4.4 Hàng đợi và lập lịch

Sau classification, packet thường được đưa vào queue. Scheduler chọn queue nào được phục vụ tiếp.

Cơ chế	Ý tưởng	Điểm cần lưu ý
FIFO	Packet đến trước phục vụ trước	Đơn giản, không phân biệt class
Strict priority	Luôn phục vụ queue ưu tiên cao trước	Có thể làm queue thấp bị starvation
Round robin	Luân phiên giữa các queue	Không xét packet size hoặc trọng số
Weighted round robin	Mỗi queue có phần phục vụ theo trọng số	Cần chọn trọng số phù hợp
Fair queuing	Xấp xỉ chia công bằng giữa flow/class	Phức tạp hơn FIFO

Ví dụ: nhiều quầy ở sân bay

Khách hạng ưu tiên được phục vụ trước, nhưng nếu quầy luôn chỉ nhận khách ưu tiên thì khách thường có thể chờ vô hạn. Scheduler hợp lý phải vừa bảo vệ lưu lượng nhạy cảm vừa tránh starvation.

9.4.5 Định hình và kiểm soát lưu lượng

định hình lưu lượng (traffic shaping) làm chậm hoặc giữ packet trong buffer để lưu lượng đầu ra phù hợp profile. *kiểm soát lưu lượng* (policing) kiểm tra lưu lượng so với profile và thường drop hoặc remark phần vượt mức.

Ví dụ bể chứa nước

Shaping giống bể chứa nhận nước theo đợt nhưng xả ra đều. Policing giống cổng kiểm tra: phần vượt hạn mức bị từ chối hoặc gắn nhãn khác. Bể hữu hạn nên shaping vẫn có thể drop khi burst quá lớn.

9.4.6 DiffServ và per-hop behavior

DiffServ tập trung phân loại và đánh dấu tại biên, sau đó các router lõi áp per-hop behavior theo class thay vì giữ trạng thái từng flow. Kiến trúc này cung cấp *service differentiation*, không tự bảo đảm end-to-end SLA nếu các miền không phối hợp hoặc capacity không đủ [?].

9.4.7 Giới hạn của QoS

QoS không:

- tạo thêm bandwidth vật lý;
- sửa được server chậm;
- bảo đảm Internet công cộng tôn trọng marking;
- thay thế capacity planning;

- tự động xác định ứng dụng nào quan trọng;
- ngăn mọi tấn công gây nghẽn.

9.4.8 Đo lường hiệu năng trước khi dùng ML

Đo chủ động và đo thụ động. *đo chủ động* (active measurement) tạo traffic kiểm thử, ví dụ ping, HTTP probe hoặc throughput test. *đo thụ động* (passive measurement) quan sát traffic thật qua packet capture, flow, counter và log.

Đo chủ động dễ kiểm soát nhưng có thể không đại diện traffic thật và tự tạo tải. Đo thụ động phản ánh hoạt động thật nhưng có vấn đề quyền riêng tư, sampling và giới hạn điểm quan sát.

Thiết kế phép đo. Trước khi đo cần xác định:

1. câu hỏi cần trả lời;
2. điểm đo và hướng traffic;
3. khoảng thời gian và tần suất lấy mẫu;
4. clock và timezone;
5. kích thước packet, protocol và tải nền;
6. metric, đơn vị và công thức;
7. điều kiện loại trừ và giới hạn.

RFC 2544 mô tả phương pháp benchmark thiết bị liên mạng trong môi trường kiểm thử có kiểm soát [?]. Không nên dùng traffic RFC 2544 không kiểm soát trên mạng sản xuất vì có thể gây ảnh hưởng dịch vụ.

Lược đồ dữ liệu hiệu năng. Một bảng theo time window có thể dùng schema:

Cột	Kiểu	Đơn vị	Ý nghĩa
timestamp	datetime	–	Thời điểm bắt đầu cửa sổ
link	category	–	Liên kết hoặc interface
capacity_mbps	float	Mb/s	Năng lực danh nghĩa
throughput_mbps	float	Mb/s	Tốc độ quan sát
rtt_ms	float	ms	Round-trip time
jitter_ms	float	ms	Biến động delay theo công thức đã chọn
loss_pct	float	%	Tỷ lệ mất
queue_packets	int	packet	Độ dài queue

Sai số và giới hạn đo. Các nguồn sai lệch thường gặp:

- clock không đồng bộ;

- sampling làm mất burst ngắn;
- counter wrap hoặc reset;
- đo tại một điểm nhưng suy luận toàn đường;
- ICMP bị xử lý ưu tiên thấp;
- tải do chính công cụ đo tạo ra;
- thiếu dữ liệu khi thiết bị quá tải;
- so sánh các khoảng thời gian có tải nền khác nhau.

Đo được không có nghĩa là đo đúng

RTT từ một probe, response time của ứng dụng và queueing delay là ba đại lượng khác nhau. Một mô hình ML chỉ học quan hệ trong các cột được đưa vào; nếu định nghĩa cột hoặc điểm đo sai, mô hình có thể rất “chính xác” đối với một đại lượng không trả lời câu hỏi vận hành.

9.5 Từ dữ liệu hiệu năng đến observation, feature, target và X/y

9.5.1 Một hàng phải có nghĩa trước khi có mô hình

Giả sử hệ thống tổng hợp telemetry theo cửa sổ 10 giây. Mỗi hàng sau đây đại diện cho **một time window**, không phải một packet riêng lẻ:

RTT (ms)	Loss	Utilization	Concurrent flows	Response time (ms)
21.4	0.001	0.42	53	47.8
35.2	0.012	0.76	132	96.1
48.9	0.028	0.91	211	178.4

đơn vị quan sát (observation/sample) là một đơn vị quan sát nhất quán. *đặc trưng* (feature) là thông tin có sẵn tại thời điểm cần dự đoán. *biến mục tiêu* (target) là đại lượng mô hình cần dự đoán.

Viên gạch ML 1: không chọn feature bằng cách nhìn tên cột

Một cột identifier, timestamp sau tương lai, hoặc giá trị được tạo sau khi sự kiện đã kết thúc có thể gây leakage dù kiểu dữ liệu là số. Feature phải được chọn theo **ý nghĩa thời gian và cơ chế mạng**, không chỉ theo dtype.

9.5.2 Tạo một tập dữ liệu nhỏ bằng API NumPy hiện hành

```
import numpy as np
import pandas as pd

rng = np.random.default_rng(42)
```

```

n = 600

rtt_ms = np.clip(rng.normal(32, 11, n), 5, None)
loss_rate = np.clip(rng.beta(1.2, 35, n), 0, 0.20)
link_utilization = np.clip(rng.normal(0.62, 0.18, n), 0.05, 0.98)
concurrent_flows = rng.integers(15, 240, n)

response_time_ms = (
    12
    + 1.35 * rtt_ms
    + 210 * loss_rate
    + 0.18 * concurrent_flows
    + np.where(link_utilization > 0.75,
               120 * (link_utilization - 0.75), 0)
    + rng.normal(0, 7, n)
)

df = pd.DataFrame({
    "rtt_ms": rtt_ms,
    "loss_rate": loss_rate,
    "link_utilization": link_utilization,
    "concurrent_flows": concurrent_flows,
    "response_time_ms": response_time_ms,
})

```

np.random.default_rng()

Mục đích: tạo một Generator cho mô phỏng/thử nghiệm tái lập.

Input chính: seed, ở đây là 42.

Output: object Generator; các phương thức như `normal()`, `beta()` và `integers()` sinh array.

Lưu ý: RNG này dùng cho mô phỏng/thống kê, không dùng cho mục đích mật mã.

9.5.3 Tạo X và y : type và shape phải được đọc thành lời

```

feature_columns = [
    "rtt_ms", "loss_rate",
    "link_utilization", "concurrent_flows"
]

X = df[feature_columns]
y = df["response_time_ms"]

print(type(X), X.shape)
print(type(y), y.shape)

```

Với 600 hàng, kết quả điển hình là `X.shape == (600, 4)` và `y.shape == (600,)`. Điều đó phải được đọc thành lời: có 600 observations, bốn features cho mỗi observation và một target cho mỗi observation. Vector shape (600,) không giống ma trận một cột shape (600, 1).

9.5.4 Vẽ scatter plot: trước hết phải có câu hỏi

Câu hỏi: RTT lớn hơn có thường đi cùng response time lớn hơn hay không?

```
import matplotlib.pyplot as plt

fig, ax = plt.subplots()
ax.scatter(df["rtt_ms"], df["response_time_ms"], alpha=0.55)
ax.set_xlabel("RTT (ms)")
ax.set_ylabel("Response time (ms)")
ax.set_title("RTT va response time")
plt.show()
```

fig là Figure; ax là Axes. Mỗi điểm tương ứng một observation. Trục X là RTT, trục Y là target response time. Một xu hướng đi lên gợi ý association nhưng **không chứng minh RTT gây ra toàn bộ biến động response time**.

9.5.5 Đọc đoạn code tạo dữ liệu theo từng lớp ý nghĩa

Đoạn code mô phỏng ở trên nên được đọc theo bốn lớp, thay vì nhìn như một khối lệnh dài:

1. **Tạo Generator:** rng là object chịu trách nhiệm sinh số giả ngẫu nhiên có thể tái lập khi dùng cùng seed.
2. **Tạo từng feature:** mỗi lời gọi trả về array độ dài n ; vì vậy mọi cột phải có cùng số observations.
3. **Tạo target:** công thức mô phỏng chỉ tạo quan hệ phức vụ học tập; không được trình bày như định luật mạng.
4. **Ghép thành DataFrame:** tên cột, kiểu, đơn vị và phạm vi giá trị biến các array thành một schema có thể phân tích.

9.5.6 Kiểm tra dữ liệu trước ML

```
print(type(df))
print(df.shape)
print(df.dtypes)
print(df.isna().sum())
print(df.head())
```

DataFrame.shape và DataFrame.dtypes

shape là tuple (n_rows, n_columns); nó giúp phát hiện sai đơn vị quan sát hoặc mất/thừa cột. **dtypes** cho biết kiểu lưu trữ của từng cột; kiểu lưu trữ phải được đối chiếu với **ý nghĩa đo lường**. Một status code lưu dạng integer vẫn có thể mang ý nghĩa category, trong khi RTT là biến định lượng.

9.5.7 Giá trị thiếu: không tự động thay bằng 0

Để minh họa, có thể cố ý làm thiếu một số RTT:

```
missing_idx = rng.choice(df.index, size=18, replace=False)
df.loc[missing_idx, "rtt_ms"] = np.nan
```

Cách gán bằng `.loc` làm rõ đối tượng đang được sửa và phù hợp với semantics Copy-on-Write hiện hành của pandas. Ở đây NaN nghĩa là “không có phép đo RTT”, khác với RTT bằng 0 ms. Vì vậy cách xử lý missing phải dựa trên ý nghĩa cột.

9.6 Chia train–test, baseline và tiền xử lý đúng nguyên tắc

9.6.1 Chia dữ liệu trước khi học từ dữ liệu

```
from sklearn.model_selection import train_test_split

X_train, X_test, y_train, y_test = train_test_split(
    X, y,
    test_size=0.25,
    random_state=42
)

print(X_train.shape, X_test.shape)
print(y_train.shape, y_test.shape)
```

train_test_split()

Module: sklearn.model_selection.

Purpose: tách các indexable objects có cùng số mẫu thành train/test subsets.

Input: ở đây là DataFrame X và Series y .

Output: bốn object tương ứng train/test.

Tham số cần hiểu: `test_size`, `random_state`; `stratify` quan trọng hơn ở bài toán phân loại và sẽ học ở Chương 11.

9.6.2 Baseline: mô hình phải vượt qua một mốc đơn giản

Với hồi quy, một baseline dễ hiểu là luôn dự đoán mean của target training. Baseline không dùng feature nhưng trả lời câu hỏi: “Mô hình học từ feature có thực sự tốt hơn một chiến lược ngây thơ không?”

```
from sklearn.dummy import DummyRegressor

baseline = DummyRegressor(strategy="mean")
baseline.fit(X_train, y_train)
baseline_pred = baseline.predict(X_test)
```

9.6.3 Giá trị thiếu và rò rỉ dữ liệu

Nếu dữ liệu có missing value, giá trị dùng để impute phải được học từ train, không phải toàn bộ tập dữ liệu. Ví dụ sau là **sai về thiết kế**:

```
# SAI: học median từ cả dữ liệu trước khi split
# X_filled = imputer.fit_transform(X)
# X_train, X_test = train_test_split(X_filled, ...)
```

Quy trình đúng là split trước, rồi để preprocessing được fit trên train và chỉ transform test bằng trạng thái đã học. Pipeline giúp đóng gói quy tắc này.

9.6.4 Đọc shape sau split như một phép kiểm tra tính toàn vẹn

Với 600 observations và `test_size=0.25`, kỳ vọng xấp xỉ:

Object	Shape	Ý nghĩa
<code>X_train</code>	(450, 4)	450 observations, 4 features
<code>X_test</code>	(150, 4)	150 observations chưa dùng để fit
<code>y_train</code>	(450,)	target cho train
<code>y_test</code>	(150,)	target để đánh giá

Nếu số hàng của X và y không khớp, không nên cố “reshape cho chạy” trước khi tìm nguyên nhân; lỗi có thể do lọc hàng ở một object nhưng không lọc object còn lại.

9.6.5 Đánh giá baseline bằng cùng metric

```
from sklearn.metrics import (
    mean_absolute_error,
    root_mean_squared_error
)

baseline_mae = mean_absolute_error(y_test, baseline_pred)
baseline_rmse = root_mean_squared_error(y_test, baseline_pred)
print(baseline_mae, baseline_rmse)
```

Đây là kết quả cần lưu lại trước khi huấn luyện model chính. Mọi so sánh sau phải dùng cùng test set và cùng định nghĩa metric.

9.7 Hồi quy tuyến tính: từ đường thẳng đến estimator

9.7.1 Trực giác trước công thức

Với một feature, hồi quy tuyến tính tìm quan hệ dạng

$$\hat{y} = b_0 + b_1 x.$$

Với nhiều feature,

$$\hat{y} = b_0 + b_1 x_1 + \dots + b_p x_p.$$

Mục tiêu của ordinary least squares là chọn các hệ số để giảm tổng bình phương residual trên dữ liệu train. Công thức không nói rằng mọi quan hệ mạng là tuyến tính; nó tạo một mô hình cơ sở để kiểm tra và diễn giải.

9.7.2 Xây pipeline tối thiểu

```
from sklearn.impute import SimpleImputer
from sklearn.linear_model import LinearRegression
from sklearn.pipeline import Pipeline

model = Pipeline([
    ("imputer", SimpleImputer(strategy="median")),
    ("regressor", LinearRegression())
])
```

Pipeline

Input khi fit: X_{train} và y_{train} .

Bước 1: `SimpleImputer.fit()` học median trên train rồi biến đổi feature.

Bước 2: `LinearRegression.fit()` học coefficient/intercept từ feature đã xử lý.

Lợi ích: cùng một quy trình preprocessing được áp dụng nhất quán khi predict và giảm nguy cơ leakage do thao tác thủ công.

9.7.3 Fit không phải là predict

```
model.fit(X_train, y_train)
y_pred = model.predict(X_test)

print(type(y_pred))
print(y_pred.shape)
```

`fit()` học trạng thái mô hình từ train. `predict()` dùng trạng thái đã học để tạo một giá trị dự đoán cho mỗi hàng test; nó không huấn luyện lại estimator. Nếu test có 150 observations thì `y_pred.shape` thường là (150,).

Nhầm lẫn thường gặp

Không đánh giá bằng cách gọi `fit()` trên test set. Test chỉ đóng vai trò dữ liệu chưa thấy để ước lượng khả năng khái quát trong phạm vi thiết kế đánh giá.

9.7.4 Đọc coefficient mà không biến nó thành kết luận nhân quả

Sau khi fit, estimator cuối trong pipeline có thể được truy cập để xem hệ số:

```
reg = model.named_steps["regressor"]
coef_table = pd.DataFrame({
    "feature": feature_columns,
    "coefficient": reg.coef_
```

```
}
print("intercept:", reg.intercept_)
print(coef_table)
```

Với các feature đang dùng ở đơn vị gốc và chỉ impute missing, coefficient cho biết mức thay đổi tuyến tính ước lượng của target khi một feature tăng một đơn vị trong khi các feature khác giữ cố định *trong mô hình*. Ví dụ hệ số RTT có đơn vị gần “ms response time trên mỗi ms RTT”. Đây vẫn là mô tả của model, không tự chứng minh quan hệ nguyên nhân.

Đừng so độ lớn coefficient khi đơn vị rất khác nhau

Một feature nằm trong khoảng 0–1 và một feature nằm trong hàng trăm có thang đo khác nhau. So sánh trực tiếp trị tuyệt đối coefficient để kết luận feature nào “quan trọng hơn” thường không hợp lý nếu chưa xét scale và cấu trúc dữ liệu.

9.8 Đánh giá, phần dư và diễn giải dưới góc độ mạng

9.8.1 MAE và RMSE

```
from sklearn.metrics import (
    mean_absolute_error,
    root_mean_squared_error
)

mae = mean_absolute_error(y_test, y_pred)
rmse = root_mean_squared_error(y_test, y_pred)
print("MAE :", mae)
print("RMSE:", rmse)
```

Nếu target có đơn vị ms thì MAE và RMSE cũng có đơn vị ms. RMSE phạt các lỗi lớn mạnh hơn MAE do bình phương residual trước khi lấy trung bình/căn.

9.8.2 So sánh với baseline

Cùng metric phải được tính cho baseline và model. Một mô hình có RMSE 12 ms chưa thể gọi là “tốt” nếu baseline chỉ 11 ms; ngược lại mức 12 ms có thể rất hữu ích nếu baseline là 40 ms và yêu cầu vận hành chấp nhận sai số đó.

9.8.3 Phần dư là dữ liệu để chẩn đoán

Residual thường viết

$$e_i = y_i - \hat{y}_i.$$

Nếu residual tăng mạnh khi utilization vượt 0.8, mô hình tuyến tính có thể bỏ sót threshold hoặc interaction. Nếu residual lớn tập trung ở một site, có thể có khác biệt topology, đo lường hoặc population chưa được mô hình hóa.

9.8.4 Giá trị thực, giá trị dự đoán và đồ thị phần dư

```
residual = y_test.to_numpy() - y_pred

fig, ax = plt.subplots()
ax.scatter(y_pred, residual, alpha=0.55)
ax.axhline(0, linewidth=1)
ax.set_xlabel("Predicted response time (ms)")
ax.set_ylabel("Residual (ms)")
ax.set_title("Residual diagnostic")
plt.show()
```

Đây là biểu đồ chẩn đoán model, không phải bằng chứng nguyên nhân. Cần đọc pattern, outlier và phạm vi dữ liệu.

9.8.5 Ba giới hạn phải luôn ghi trong kết luận

1. **Prediction không phải causality:** coefficient/association không tự chứng minh cơ chế nguyên nhân.
2. **Extrapolation nguy hiểm:** test trong cùng miền không bảo đảm model đúng ở utilization hoặc topology chưa từng thấy.
3. **Drift:** khi workload, route hoặc ứng dụng thay đổi, phân bố và hiệu năng model có thể thay đổi.

9.8.6 Giá trị thực và dự đoán: biểu đồ phải có đường tham chiếu

```
fig, ax = plt.subplots()
ax.scatter(y_test, y_pred, alpha=0.55)
low = min(y_test.min(), y_pred.min())
high = max(y_test.max(), y_pred.max())
ax.plot([low, high], [low, high], linestyle="--")
ax.set_xlabel("Actual response time (ms)")
ax.set_ylabel("Predicted response time (ms)")
ax.set_title("Actual vs predicted")
plt.show()
```

Đường chéo $y = x$ là tham chiếu cho prediction hoàn hảo. Điểm nằm trên đường có prediction cao hơn actual; điểm dưới đường có prediction thấp hơn actual. Cần xem cả pattern và miền giá trị, không chỉ “các điểm trông gần đường”.

9.8.7 Các lỗi thường gặp khi sinh viên tự làm

Nhầm lẫn thường gặp

- Gọi `predict()` trước `fit()`.
- Đưa target vào danh sách feature gây leakage.
- Lọc missing ở X nhưng quên lọc y , làm lệch hàng.

- Fit preprocessing trên cả train và test.
- Đọc (600,) như “600 cột” thay vì vector 600 phần tử.
- Diễn giải RMSE không kèm đơn vị target.
- Kết luận causality từ scatter plot hoặc coefficient.

Khi gặp lỗi, thứ tự kiểm tra nên là: tên biến → type → shape → dtypes/missing → thời điểm tạo feature → pipeline → metric.

9.9 Tổng kết chương

9.9.1 Tóm tắt chương

1. Capacity/bandwidth không đồng nghĩa throughput; throughput không đồng nghĩa goodput.
2. End-to-end delay gồm nhiều thành phần; queueing thay đổi mạnh theo tải và burst.
3. RTT, loss, jitter và percentile phải gắn với câu hỏi ứng dụng; một con số trung bình thường không đủ.
4. BDP liên hệ bandwidth và RTT với lượng dữ liệu có thể “đang trên đường”.
5. QoS phân bổ tài nguyên có giới hạn; không tạo ra capacity mới.
6. Trước ML phải định nghĩa observation, feature và target có nghĩa về mặt mạng.
7. X chứa features, y chứa target; shape phải được kiểm tra và đọc thành lời.
8. Split phải xảy ra trước các phép học thống kê từ dữ liệu để hạn chế leakage.
9. Baseline là mốc tối thiểu; `fit()` học, `predict()` dự đoán.
10. MAE/RMSE/residual phải được diễn giải bằng đơn vị và yêu cầu kỹ thuật của mạng.

9.9.2 Bài luyện tập

1. Một link 100 Mb/s truyền frame có 1,200 byte dữ liệu hữu ích trong 1,300 byte on-wire. Nếu throughput on-wire đạt 80 Mb/s, goodput xấp xỉ bao nhiêu?
2. Link 200 Mb/s có RTT 40 ms. Tính BDP theo byte và MiB.
3. Một bảng có 600 hàng, bốn cột feature và một target. Viết shape hợp lý của X và y .
4. Giải thích vì sao cột `response_time_after_recovery` không thể dùng để dự đoán sự cố tại thời điểm trước recovery.
5. Model có MAE 9 ms, baseline có MAE 8 ms. Có đủ lý do để dùng model không? Giải thích.
6. Với một nhóm traffic, residual chủ yếu dương và lớn. Điều đó nói gì về khuynh hướng dự đoán của model trên nhóm này?

9.9.3 Lời giải bài luyện tập

Bài 1

Tỷ lệ payload là $1200/1300 \approx 0.923$. Goodput xấp xỉ $80 \times 0.923 \approx 73.8$ Mb/s, nếu bỏ qua các overhead khác ngoài giả định đã cho.

Bài 2

$BDP = 200 \times 10^6 \times 0.040 = 8 \times 10^6$ bit = 1,000,000 byte ≈ 0.954 MiB.

Bài 3

$X.shape = (600, 4)$ và $y.shape = (600,)$. Hàng của hai object phải tương ứng cùng 600 observations.

Bài 4

Đó là thông tin của tương lai so với thời điểm dự đoán, gây target/future leakage. Model có thể đạt metric đẹp nhưng không triển khai được đúng thời điểm thực tế.

Bài 5

Chưa. Model tệ hơn baseline theo metric đã chọn. Cần kiểm tra thiết kế feature, metric, split hoặc lý do nghiệp vụ khác trước khi biện minh cho độ phức tạp tăng thêm.

Bài 6

Với $e = y - \hat{y}$, residual dương nghĩa là giá trị thật lớn hơn prediction: model có khuynh hướng dự đoán thấp trên nhóm đó.

9.9.4 Câu hỏi trắc nghiệm

- Goodput khác throughput chủ yếu ở điểm nào?
 - Goodput chỉ tính dữ liệu ứng dụng hữu ích.
 - Goodput luôn lớn hơn capacity.
 - Goodput chỉ dùng cho UDP.
 - Goodput không phụ thuộc thời gian.
- Đại lượng nào liên hệ trực tiếp bandwidth và RTT?
 - Bandwidth-delay product.
 - MAC address.
 - DNS TTL.
 - HTTP status code.
- Nếu $X.shape == (600, 4)$, cách hiểu phù hợp là gì?
 - 600 observations và 4 features.
 - 600 features và 4 models.
 - 600 labels và 4 classes.
 - 4 observations và 600 targets.
- Trong supervised regression, y thường biểu diễn gì?
 - Target cần dự đoán.

- B. Tên cột identifier.
 - C. Số lượng feature.
 - D. Random seed.
5. Vì sao cần baseline?
 - A. Để biết model có vượt chiến lược đơn giản hay không.
 - B. Để thay thế test set.
 - C. Để tạo thêm feature.
 - D. Để làm RMSE bằng 0.
 6. Thao tác nào dễ gây leakage?
 - A. Fit imputer trên toàn bộ dữ liệu trước khi split.
 - B. Chỉ fit model trên train.
 - C. Tính metric trên test sau predict.
 - D. Kiểm tra shape sau split.
 7. `model.fit(X_train, y_train)` chủ yếu làm gì?
 - A. Học trạng thái/parameter từ train.
 - B. Tạo test set.
 - C. Vẽ scatter plot.
 - D. Xóa missing khỏi file gốc.
 8. $MAE = 8$ ms có nghĩa trực tiếp nhất là gì?
 - A. Sai số tuyệt đối trung bình khoảng 8 ms trên tập đánh giá.
 - B. Mọi dự đoán sai đúng 8 ms.
 - C. Model giải thích 92 phần trăm biến thiên.
 - D. RTT trung bình là 8 ms.
 9. Nếu residual $e = y - \hat{y}$ dương lớn, model đã làm gì?
 - A. Dự đoán thấp hơn giá trị thật.
 - B. Dự đoán đúng hoàn toàn.
 - C. Dự đoán cao hơn giá trị thật.
 - D. Không tạo prediction.
 10. Scatter plot cho thấy RTT và response time tăng cùng nhau. Kết luận an toàn nhất là gì?
 - A. Có association quan sát được; chưa đủ chứng minh causality.
 - B. RTT chắc chắn là nguyên nhân duy nhất.
 - C. Không cần feature khác.
 - D. Model tuyến tính chắc chắn tối ưu.

9.9.5 Đáp án và giải thích

1. **Đáp án đúng:** A. Goodput loại overhead/retransmission không tạo dữ liệu ứng dụng hữu ích theo định nghĩa đang dùng.
2. **Đáp án đúng:** A. $BDP = B \times RTT$.
3. **Đáp án đúng:** A. Shape của ma trận feature được đọc theo (samples, features).
4. **Đáp án đúng:** A. y là target trong bài toán supervised đang xét.
5. **Đáp án đúng:** A. Baseline là mốc so sánh tối thiểu.

6. **Đáp án đúng:**A. Imputer đã học thông tin từ test trước đánh giá.
7. **Đáp án đúng:**A. `fit()` học từ training data.
8. **Đáp án đúng:**A. MAE là mean absolute error; không nói mọi lỗi bằng nhau.
9. **Đáp án đúng:**A. Với định nghĩa residual đã cho, $y > \hat{y}$.
10. **Đáp án đúng:**A. Association không tự chứng minh quan hệ nhân quả.

Phần III

An toàn và phân tích mạng

Chương 10

Các nguyên lý bảo vệ hệ thống mạng

10.1 Mục tiêu và câu hỏi mở đầu

10.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Một cơ quan đã lắp firewall ở cổng Internet và yêu cầu người dùng đặt mật khẩu mạnh. Tuy nhiên, một máy tính xách tay bị đánh cắp vẫn chứa dữ liệu chưa mã hóa; một tài khoản quản trị dùng chung không xác định được ai đã thay đổi cấu hình; và một dịch vụ nội bộ ngừng hoạt động do lỗi thiết bị. Hệ thống này có thể được coi là an toàn chỉ vì đã có firewall và mật khẩu hay không? Cần bảo vệ những gì, trước ai, bằng các lớp kiểm soát nào và làm thế nào để biết kiểm soát đang hoạt động?

Ví dụ: bảo vệ một bảo tàng

Một bảo tàng không chỉ khóa cửa chính. Tài sản quý được đặt trong tủ kính; nhân viên và khách đi qua các khu vực khác nhau; camera ghi lại hoạt động; hệ thống báo cháy bảo vệ tính sẵn sàng; danh sách kiểm kê giúp phát hiện mất mát; và quy trình ứng phó được chuẩn bị cho từng tình huống.

Phép so sánh giúp hình dung rằng bảo vệ mạng cần nhiều lớp: kiểm soát truy cập, phân vùng, giám sát, sao lưu, khả năng phục hồi và con người.

Giới hạn của mạng: dữ liệu có thể bị sao chép mà bản gốc vẫn còn; tấn công mạng có thể diễn ra từ xa, tự động và ở tốc độ rất cao. Vì vậy, các biện pháp vật lý chỉ gọi mở nguyên lý, không thay thế kiểm soát kỹ thuật.

10.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Phân biệt được tài sản, mối đe dọa, lỗ hổng, rủi ro và kiểm soát.
- Giải thích được các mục tiêu confidentiality, integrity, availability cùng authenticity, accountability và privacy.
- Trình bày được chu trình quản trị rủi ro và sáu chức năng của NIST CSF 2.0.

- Phân biệt được identification, authentication, authorization và accounting.
- Giải thích được least privilege, separation of duties, default deny và defense in depth.
- Thiết kế được phân vùng mạng cơ bản gồm vùng người dùng, server, quản trị, khách và DMZ.
- Phân biệt được ACL, stateless firewall, stateful firewall, proxy, IDS, IPS và WAF.
- Giải thích được vai trò của mã hóa đối xứng, khóa công khai, hash, MAC, chữ ký số, certificate, TLS và VPN.
- Phân tích được log kiểm soát truy cập và dữ liệu sự kiện bằng pandas.
- Nhận biết được giới hạn của kiểm soát, false positive, false negative và các yêu cầu bảo vệ dữ liệu giám sát.

10.2 Tài sản, rủi ro và mục tiêu bảo vệ

10.2.1 Tài sản và giá trị cần bảo vệ

Tài sản (asset) là bất cứ thứ gì có giá trị đối với cá nhân hoặc tổ chức. Trong mạng máy tính, tài sản không chỉ là server hoặc dữ liệu. Nó còn gồm:

- danh tính, tài khoản và quyền truy cập;
- cấu hình router, firewall, DNS, cloud và ứng dụng;
- khóa mật mã, certificate và secret;
- dịch vụ kinh doanh, thời gian hoạt động và uy tín;
- log, bằng chứng và khả năng điều tra;
- tri thức, quy trình và nhân lực vận hành.

Ví dụ: tài sản không chỉ là vật trong két

Một ngân hàng phải bảo vệ tiền, nhưng cũng phải bảo vệ chữ ký, hồ sơ giao dịch, quyền truy cập kho tiền, hệ thống điện, camera và khả năng chứng minh ai đã thực hiện một thao tác. Tương tự, một hệ thống mạng phải bảo vệ cả dữ liệu, danh tính, cấu hình và bằng chứng.

10.2.2 Mối đe dọa, lỗ hổng và sự kiện

Mối đe dọa (threat) là nguyên nhân tiềm tàng có thể gây hại. *Lỗ hổng* (vulnerability) là điểm yếu có thể bị khai thác. *Sự kiện* (event) là điều đã xảy ra và được quan sát; sự kiện không nhất thiết là sự cố.

Khái niệm	Ví dụ mạng	Điều cần tránh
Threat	kẻ tấn công, mã độc, mất điện, lỗi thao tác	chỉ nghĩ đến tấn công cố ý
Vulnerability	mật khẩu yếu, dịch vụ lỗi thời, ACL quá rộng	đồng nhất lỗ hổng với hậu quả
Event	đăng nhập, thay đổi rule, packet bị drop	coi mọi event là incident
Incident	truy cập trái phép hoặc gián đoạn đáng kể	kết luận khi chưa xác minh

10.2.3 Rủi ro và tác động

Rủi ro (risk) thể hiện khả năng một mối đe dọa khai thác lỗ hổng và gây tác động. Có thể dùng mô hình định tính:

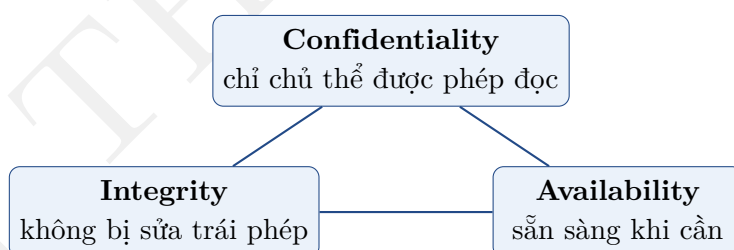
$$\text{Risk level} \approx \text{Likelihood} \times \text{Impact}$$

Đây không phải công thức vật lý. Các thang thấp–trung bình–cao cần được định nghĩa nhất quán và dựa trên bối cảnh.

Ví dụ: cùng một lỗ hổng, rủi ro khác nhau

Một dịch vụ thử nghiệm không chứa dữ liệu thật và bị cô lập có thể có tác động thấp. Cùng lỗi đó trên hệ thống thanh toán Internet-facing có thể có tác động rất cao. Mức nghiêm trọng kỹ thuật không tự động bằng mức rủi ro kinh doanh.

10.2.4 Bộ ba CIA



- *Tính bí mật* (confidentiality): ngăn tiết lộ trái phép.
- *Tính toàn vẹn* (integrity): ngăn hoặc phát hiện thay đổi trái phép.
- *Tính sẵn sàng* (availability): duy trì dịch vụ và dữ liệu đúng lúc.

Nhầm lẫn thường gặp

Mã hóa chủ yếu hỗ trợ confidentiality. Nó không tự đảm bảo server luôn hoạt động, dữ liệu không bị xóa, người dùng đã được phân quyền đúng hoặc endpoint không bị chiếm quyền.

10.2.5 Các mục tiêu bổ sung

- *Tính xác thực* (authenticity): chủ thể hoặc dữ liệu đúng nguồn tuyên bố.
- *Khả năng quy trách nhiệm* (accountability): hành động có thể gắn với chủ thể.
- *Không thể phủ nhận* (non-repudiation): cung cấp bằng chứng để hạn chế phủ nhận hành động.
- *Quyền riêng tư* (privacy): xử lý dữ liệu cá nhân đúng mục đích và phạm vi.
- *An toàn* (safety): tránh gây hại vật lý hoặc vận hành, đặc biệt trong hệ thống điều khiển.

10.2.6 Kiểm soát phòng ngừa, phát hiện và khắc phục

Nhóm	Mục đích	Ví dụ
Preventive	giảm khả năng xảy ra	MFA, patch, ACL, hardening
Detective	phát hiện sớm	log, IDS, integrity monitoring
Corrective	hạn chế và sửa hậu quả	isolate host, restore backup
Deterrent	làm giảm động cơ vi phạm	cảnh báo, chế tài, giám sát
Compensating	thay thế khi chưa thể áp dụng kiểm soát chuẩn	segmentation tạm thời, giám sát tăng cường

10.3 Định danh, xác thực và phân quyền

10.3.1 Bốn câu hỏi của AAA mở rộng

Identification	Chủ thể tuyên bố mình là ai?
Authentication	Có bằng chứng đủ tin cậy để xác minh tuyên bố không?
Authorization	Chủ thể đã xác thực được phép làm gì?
Accounting/- Auditing	Hành động nào đã xảy ra, khi nào và dưới danh tính nào?

Ví dụ: vào khu vực hạn chế

Một người nói tên tại cổng là identification. Xuất trình thẻ và sinh trắc học là authentication. Quy định thẻ đó chỉ mở được tầng 2 là authorization. Log cửa ghi thời gian ra vào là accounting.

Giới hạn: thẻ vật lý có thể bị mượn; trong hệ thống số, session, token và thiết bị cũng phải được bảo vệ sau khi đăng nhập.

10.3.2 Yếu tố xác thực và MFA

Ba nhóm phổ biến:

- điều người dùng biết: mật khẩu, PIN;
- điều người dùng sở hữu: token, điện thoại, khóa bảo mật;

- đặc trưng của người dùng: sinh trắc học.

Xác thực đa yếu tố (multi-factor authentication, MFA) phải kết hợp các yếu tố độc lập. Hai mật khẩu không tạo thành hai yếu tố.

MFA không phải lớp bảo vệ tuyệt đối

MFA giảm rủi ro từ mật khẩu bị lộ, nhưng vẫn có thể bị ảnh hưởng bởi phishing thời gian thực, đánh cắp session, fatigue attack, quy trình khôi phục yếu hoặc endpoint bị kiểm soát. Cần kết hợp với kiểm tra ngữ cảnh và giám sát.

10.3.3 Mật khẩu và vòng đời thông tin xác thực

Nguyên tắc:

- không dùng credential mặc định hoặc dùng chung;
- hỗ trợ password manager và passphrase dài;
- lưu mật khẩu bằng hàm dẫn xuất khóa có salt, không lưu plaintext;
- thay đổi khi có dấu hiệu lộ, không thay định kỳ máy móc nếu làm giảm chất lượng;
- bảo vệ reset, recovery code và tài khoản break-glass;
- thu hồi ngay khi nhân sự hoặc thiết bị thay đổi trạng thái.

10.3.4 Authorization và các mô hình truy cập

Mô hình	Ý tưởng	Ví dụ
DAC	chủ sở hữu quyết định quyền	chia sẻ file cá nhân
MAC	nhân và chính sách trung tâm	hệ thống phân loại mức độ mật
RBAC	quyền gắn với vai trò	sinh viên, giảng viên, quản trị
ABAC	quyết định từ thuộc tính và ngữ cảnh	vai trò + thiết bị + thời gian + vị trí

10.3.5 Least privilege và need to know

Đặc quyền tối thiểu (least privilege) cấp đúng quyền cần thiết, trong thời gian cần thiết và cho phạm vi cần thiết. Need to know (n)hấn mạnh rằng có clearance hoặc vai trò rộng không đồng nghĩa được đọc mọi dữ liệu.

Ví dụ: chìa khóa tổng và chìa khóa phòng

Nhân viên vệ sinh chỉ cần chìa khóa các phòng trong ca làm việc; không cần chìa khóa kết hoặc phòng máy. Cấp chìa khóa tổng thuận tiện nhưng làm tăng tác động nếu bị mất.

10.3.6 Separation of duties và dual control

Phân tách nhiệm vụ (separation of duties) tránh để một người tự tạo, phê duyệt và che giấu cùng một giao dịch. *Kiểm soát kép* (dual control) yêu cầu hai chủ thể độc lập cùng tham gia thao tác nhạy cảm.

Ví dụ:

- thay đổi firewall quan trọng cần người đề xuất và người phê duyệt;
- khôi phục khóa gốc cần hai người giữ hai phần thông tin;
- tài khoản vận hành không đồng thời là tài khoản kiểm toán.

10.3.7 Accounting, audit trail và đồng bộ thời gian

Log hữu ích cần có:

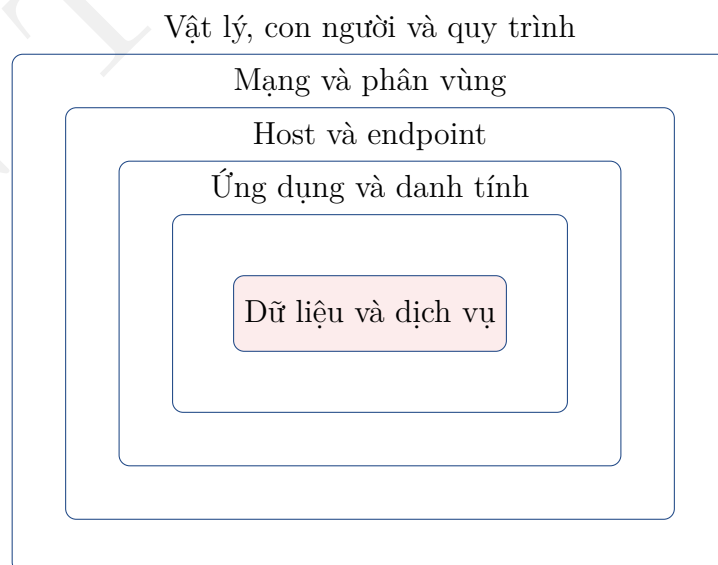
- thời gian tin cậy và timezone rõ;
- subject, source, target, action, result;
- request ID hoặc session ID để liên kết sự kiện;
- bảo vệ integrity và quyền truy cập;
- retention phù hợp mục đích, pháp lý và dung lượng.

Không nên ghi secret, mật khẩu hoặc dữ liệu nhạy cảm đầy đủ vào log.

10.4 Phòng vệ nhiều lớp, phân vùng và Zero Trust

10.4.1 Defense in depth

phòng vệ nhiều lớp (defense in depth) phối hợp nhiều lớp độc lập tương đối. Khi một lớp thất bại, lớp khác vẫn giảm khả năng hoặc tác động.



Nhiều lớp giống hệt nhau không nhất thiết tạo chiều sâu. Ví dụ, hai firewall cùng cấu hình sai có thể cùng thất bại.

10.4.2 Attack surface và trust boundary

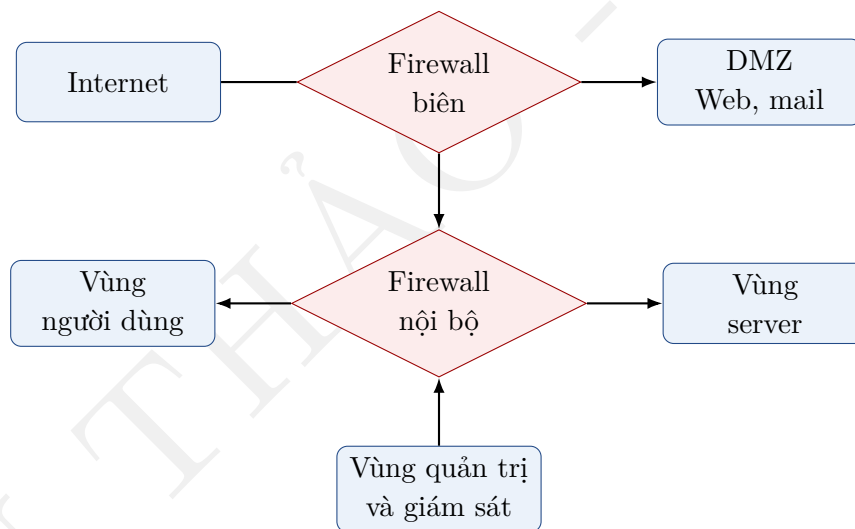
Bề mặt tấn công (attack surface) gồm các điểm mà đối tượng không tin cậy có thể tương tác: service, port, API, tài khoản, thiết bị, chuỗi cung ứng và quy trình.

Ranh giới tin cậy (trust boundary) là nơi mức tin cậy hoặc cơ chế kiểm soát thay đổi. Mọi dữ liệu đi qua ranh giới cần được xác minh phù hợp.

10.4.3 Phân vùng và vùng an ninh

Một kiến trúc cơ bản có thể gồm:

- vùng người dùng;
- vùng server nội bộ;
- vùng quản trị;
- vùng khách hoặc BYOD;
- vùng IoT;
- DMZ cho dịch vụ công khai;
- vùng sao lưu và hệ thống giám sát.



10.4.4 DMZ và dịch vụ công khai

DMZ đặt dịch vụ cần truy cập từ Internet vào vùng tách biệt. Mục tiêu không phải làm server DMZ “an toàn tuyệt đối”, mà hạn chế đường đi tiếp nếu server bị xâm nhập.

Nguyên tắc:

- chỉ mở flow cần thiết từ Internet tới DMZ;
- từ DMZ vào nội bộ phải chặt hơn;
- quản trị qua vùng quản trị, không từ Internet trực tiếp;
- log và giám sát các kết nối xuyên vùng;
- tách secret và dữ liệu quan trọng khỏi frontend.

10.4.5 Secure baseline, hardening và patching

Hardening (g)ảm chức năng và cấu hình không cần thiết:

- tắt service, account và protocol không dùng;
- đổi credential mặc định;
- giới hạn giao diện quản trị;
- cập nhật bản vá theo rủi ro và kiểm thử;
- dùng cấu hình chuẩn có version;
- phát hiện configuration drift.

Ví dụ: căn phòng mới bàn giao

Một căn phòng có nhiều cửa phụ và chìa khóa mặc định sẽ khó kiểm soát. Hardening giống việc khóa cửa không dùng, thay khóa mặc định, lập danh sách chìa và kiểm tra định kỳ.

10.4.6 Zero Trust ở mức nguyên lý

Zero Trust không coi vị trí mạng nội bộ là bằng chứng đủ để tin cậy. Các nguyên lý cốt lõi:

- xác minh rõ ràng subject, device, resource và ngữ cảnh;
- cấp quyền tối thiểu cho từng request;
- giả định vi phạm có thể đã xảy ra;
- giám sát liên tục và cập nhật quyết định;
- bảo vệ resource thay vì chỉ bảo vệ perimeter.

Nhầm lẫn thường gặp

Zero Trust không có nghĩa “không tin ai” theo nghĩa xã hội và cũng không phải một sản phẩm duy nhất. Đây là tập nguyên lý kiến trúc, chính sách và vận hành.

10.4.7 Trade-off giữa an toàn, khả dụng và vận hành

Kiểm soát quá chặt có thể làm gián đoạn công việc; kiểm soát quá rộng làm tăng rủi ro. Thiết kế cân bằng:

- rủi ro và giá trị tài sản;
- trải nghiệm người dùng;
- khả năng hỗ trợ và giám sát;
- chi phí, độ phức tạp và năng lực nhân sự;
- phương án ngoại lệ, break-glass và phục hồi.

10.5 Firewall, ACL và IDS/IPS

10.5.1 ACL và packet filtering

ACL thường kiểm tra các thuộc tính:

- source/destination IP hoặc prefix;
- protocol;
- source/destination port;
- hướng và interface;
- một số cờ hoặc trạng thái.

Quy tắc thường được xử lý theo thứ tự. Quy tắc đầu tiên phù hợp quyết định hành động; cuối danh sách thường có implicit deny tùy nền tảng.

Ví dụ: danh sách kiểm soát tại cổng

Bảo vệ xem người đến từ đơn vị nào, muốn vào khu vực nào và vào bằng loại phương tiện nào. Nếu quy tắc “cho tất cả nhân viên vào” đặt trước quy tắc “cấm vào phòng máy”, quy tắc rộng có thể làm mất tác dụng của quy tắc hẹp.

10.5.2 Stateless và stateful firewall

Đặc điểm	Stateless	Stateful
Đơn vị quyết định	từng packet	packet trong trạng thái connection/flow
Thông tin	header hiện tại	header + state table
Return traffic	cần rule rõ	có thể cho phép theo state hợp lệ
Chi phí	đơn giản hơn	cần bộ nhớ và bảo vệ state table
Giới hạn	ít ngữ cảnh	không hiểu toàn bộ logic ứng dụng

10.5.3 Default deny và thiết kế rule

Quy trình thiết kế:

1. xác định flow kinh doanh cần thiết;
2. mô tả source, destination, service, direction và owner;
3. viết rule hẹp nhất phù hợp;
4. đặt rule theo thứ tự từ cụ thể tới tổng quát;
5. ghi nhật ký có chọn lọc;
6. kiểm thử cho phép và từ chối;
7. đặt ngày review, hết hạn và người chịu trách nhiệm.

10.5.4 Proxy và application gateway

Proxy kết thúc một kết nối và tạo kết nối khác thay mặt client hoặc server. Nó có thể:

- xác thực người dùng;
- kiểm tra protocol và nội dung;
- áp dụng policy URL hoặc file;
- che giấu cấu trúc phía trong;
- ghi nhật ký ở mức transaction.

Nhưng proxy làm tăng độ phức tạp và không tự bảo vệ ứng dụng khỏi mọi lỗi logic.

10.5.5 IDS và IPS

Hệ thống phát hiện xâm nhập (IDS) cảnh báo; hệ thống ngăn chặn xâm nhập (IPS) nằm trên đường truyền hoặc có khả năng chặn.

Phương pháp	Ưu điểm	Hạn chế
Signature	chính xác với mẫu đã biết	khó với biến thể mới
Anomaly	phát hiện khác biệt chưa biết	dễ false positive
Policy	phát hiện vi phạm quy định	phụ thuộc policy đầy đủ

10.5.6 NAT không phải firewall

NAT chuyển đổi địa chỉ và thường cả port. Việc kết nối từ ngoài khó đi vào nếu không có state hoặc port forwarding có thể tạo tác dụng phụ giống lọc, nhưng:

- NAT không đánh giá danh tính hoặc nội dung;
- lưu lượng đi ra vẫn có thể nguy hiểm;
- port forwarding có thể phơi bày service;
- IPv6 không yêu cầu NAT để có địa chỉ riêng tư.

10.5.7 Giới hạn của kiểm soát tại cổng

Firewall không thay thế:

- vá lỗi và hardening endpoint;
- xác thực và phân quyền ứng dụng;
- mã hóa dữ liệu;
- giám sát nội bộ;
- sao lưu và phục hồi;
- đào tạo và quy trình.

10.6 Mật mã, PKI, TLS và VPN

10.6.1 Mã hóa đối xứng

Mã hóa đối xứng (symmetric encryption) dùng cùng secret key để mã hóa và giải mã. Nó hiệu quả với lượng dữ liệu lớn, nhưng cần phân phối và bảo vệ khóa.

$$C = E_K(P), \quad P = D_K(C)$$

Trong đó P là plaintext, C là ciphertext và K là khóa.

Ví dụ: hộp có khóa chung

Hai bên có bản sao cùng một chìa khóa. Hộp khóa nhanh và thuận tiện, nhưng nếu chìa bị sao chép, người khác có thể mở hộp. Phép so sánh không thể hiện nonce, mode, authentication tag hoặc quản lý khóa tự động.

10.6.2 Mật mã khóa công khai

Một key pair gồm public key và private key. Tùy thuật toán và giao thức, nó hỗ trợ:

- thiết lập bí mật chung;
- mã hóa một lượng dữ liệu nhỏ;
- chữ ký số;
- xác thực chữ ký.

Public key có thể công bố; private key phải được bảo vệ. Không nên mô tả đơn giản rằng “mã hóa bằng private key” là chữ ký số vì thuật toán chữ ký có quy trình riêng.

10.6.3 Hash, MAC và chữ ký số

Cơ chế	Cung cấp chính	Cần secret/private key
Hash	fingerprint, phát hiện thay đổi khi có giá trị tham chiếu tin cậy	không
MAC/HMAC	integrity và authenticity giữa các bên chia sẻ secret	secret chung
Digital signature	integrity, authenticity và bằng chứng từ private key	private key người ký

Hash không mã hóa và không che nội dung.

10.6.4 Certificate và PKI

Certificate liên kết public key với subject và được issuer ký. Khi kiểm tra certificate, client cần xem:

- chuỗi tin cậy tới trust anchor;
- chữ ký của issuer;
- thời hạn;
- hostname hoặc identity;
- key usage và policy;
- trạng thái thu hồi khi phù hợp.

Ví dụ: giấy tờ có cơ quan cấp

Một thẻ nhân viên không đáng tin chỉ vì có ảnh đẹp. Người kiểm tra cần biết cơ quan cấp có được tin cậy, thẻ còn hạn và tên có khớp người sử dụng. Certificate tương tự ở ý tưởng liên kết danh tính với khóa, nhưng việc xác minh diễn ra bằng chữ ký số và chuỗi tin cậy.

10.6.5 TLS và HTTPS

TLS thường cung cấp:

- bảo mật kênh giữa hai endpoint;
- integrity và phát hiện sửa đổi;
- xác thực server bằng certificate;
- tùy chọn xác thực client bằng certificate;
- thiết lập khóa phiên cho mã hóa đối xứng.

HTTPS là HTTP chạy trên TLS. TLS không tự bảo đảm ứng dụng không có lỗi, server không bị xâm nhập hoặc dữ liệu không bị lộ tại endpoint.

10.6.6 VPN và IPsec

Mạng riêng ảo (virtual private network, VPN) tạo kênh bảo vệ qua mạng không tin cậy.

Hai tình huống:

- remote-access VPN: người dùng tới mạng tổ chức;
- site-to-site VPN: nối hai mạng.

IPsec hoạt động ở tầng Network, có thể bảo vệ packet IP theo transport mode hoặc tunnel mode. VPN không biến endpoint không an toàn thành endpoint an toàn.

10.6.7 Quản lý khóa và secret

Các câu hỏi quan trọng:

- khóa được tạo ở đâu và bằng nguồn ngẫu nhiên nào;
- lưu ở đâu, ai có quyền đọc hoặc sử dụng;

- rotation, expiration và revocation ra sao;
- backup hoặc recovery có bảo vệ không;
- secret có bị ghi vào source code, image hoặc log không;
- khi nghi lộ, phạm vi thay thế và ảnh hưởng là gì.

10.7 Security telemetry và giám sát có trách nhiệm

10.7.1 Nguồn dữ liệu bảo vệ mạng

- authentication và identity log;
- firewall, proxy, DNS, DHCP và VPN log;
- NetFlow/IPFIX hoặc connection record;
- endpoint detection event;
- application và database audit;
- configuration change;
- vulnerability và asset inventory;
- alert từ IDS/IPS, WAF và cloud control.

10.7.2 Schema sự kiện tối thiểu

Cột	Kiểu	Ví dụ	Ý nghĩa
timestamp	datetime	2026-08-06 09:15	thời gian sự kiện
source_ip	string	10.10.5.24	nguồn quan sát
user	string	sv023	danh tính nếu có
action	category	login	loại thao tác
result	category	fail	thành công/thất bại
resource	string	vpn- gateway	đối tượng
severity	category	medium	mức ưu tiên ban đầu

10.7.3 False positive và false negative

- True positive: cảnh báo đúng về hoạt động cần xử lý.
- False positive: cảnh báo nhưng hoạt động hợp lệ.
- True negative: không cảnh báo và thực sự bình thường.
- False negative: bỏ sót hoạt động nguy hiểm.

Giảm false positive quá mức có thể tăng false negative. Ngưỡng phải dựa trên tác động và năng lực xử lý.

10.7.4 Bảo vệ telemetry và quyền riêng tư

Dữ liệu giám sát có thể tiết lộ:

- người dùng, vị trí và lịch làm việc;
- domain, dịch vụ và quan hệ giao tiếp;
- cấu trúc mạng và tài khoản đặc quyền;
- nội dung lỗi hoặc token vô tình ghi vào log.

Cần thu thập tối thiểu, phân quyền, mã hóa, retention phù hợp, masking và kiểm toán truy cập log.

10.7.5 Từ cảnh báo tới xử lý

Một playbook cơ bản:

1. xác minh dữ liệu và thời gian;
2. đánh giá asset, subject, source và phạm vi;
3. thu thập bằng chứng bổ sung;
4. phân loại mức độ và quyết định cô lập;
5. khắc phục nguyên nhân, không chỉ xóa dấu hiệu;
6. khôi phục, theo dõi tái diễn và ghi bài học.

10.8 Tổng kết chương

10.8.1 Tóm tắt chương

- Bảo vệ mạng bắt đầu từ tài sản, bối cảnh và rủi ro, không bắt đầu từ việc mua thiết bị.
- CIA là nền tảng nhưng cần bổ sung authenticity, accountability, privacy và resilience.
- Identification, authentication, authorization và accounting trả lời bốn câu hỏi khác nhau.
- Least privilege, separation of duties, default deny và defense in depth giảm tác động khi một kiểm soát thất bại.
- Segmentation và DMZ giới hạn đường đi; Zero Trust yêu cầu xác minh theo resource và request.
- ACL, firewall, proxy, IDS/IPS và WAF có phạm vi khác nhau; không công cụ nào quan sát toàn bộ.
- Mã hóa đối xứng, khóa công khai, hash, HMAC và chữ ký số giải quyết các mục tiêu khác nhau.
- Certificate và PKI tạo chuỗi tin cậy; TLS và VPN bảo vệ kênh nhưng không làm endpoint tự động an toàn.
- Log và telemetry cần được bảo vệ như tài sản nhạy cảm.
- Kiểm soát chỉ có giá trị khi được cấu hình, kiểm thử, giám sát và cải tiến.

10.8.2 Bài tập tự học

Bài tập 1

1. Phân biệt threat và vulnerability bằng một ví dụ.
2. Một file đã mã hóa nhưng bị xóa. Mục tiêu CIA nào bị ảnh hưởng trực tiếp?
3. Hai mật khẩu có được coi là MFA không?
4. Vì sao NAT không phải firewall?
5. Hash có che giấu nội dung không?
6. Default deny có ý nghĩa gì?

Lời giải bài tập 1

1. Threat là tác nhân hoặc nguyên nhân, ví dụ kẻ tấn công; vulnerability là điểm yếu, ví dụ mật khẩu mặc định.
2. Availability bị ảnh hưởng trực tiếp; có thể cả integrity nếu việc xóa trái phép.
3. Không. Chúng cùng thuộc yếu tố “điều biết”.
4. NAT chuyển đổi địa chỉ/port, không đánh giá đầy đủ policy, identity hoặc nội dung.
5. Không. Hash tạo fingerprint một chiều, không phải mã hóa.
6. Chỉ cho phép những flow được xác định rõ; phần còn lại bị từ chối.

Bài tập 2

1. Một tài khoản quản trị dùng chung cho năm người. Phân tích ảnh hưởng tới khả năng quy trách nhiệm.
2. Rule 1 cho phép any tới TCP 22; rule 2 từ chối Internet tới TCP 22. Điều gì có thể xảy ra?
3. Vì sao cần bảo vệ backup khỏi quyền xóa của tài khoản vận hành thông thường?
4. So sánh HMAC và digital signature về khóa và khả năng xác minh.
5. Một IDS phát 1000 alert/ngày nhưng nhóm chỉ xử lý 20. Nêu ba hướng cải thiện.

Lời giải bài tập mức 2

1. Không thể gán hành động chắc chắn với cá nhân; điều tra và quy trách nhiệm suy giảm. Cần tài khoản riêng, MFA và audit.
2. Rule rộng đứng trước có thể shadow rule 2, làm Internet vẫn được phép. Cần sắp xếp rule cụ thể và kiểm thử negative.
3. Nếu cùng tài khoản có thể xóa dữ liệu gốc và backup, ransomware hoặc sai thao tác sẽ phá cả khả năng phục hồi.
4. HMAC dùng secret chung; hai bên đều có thể tạo tag. Digital signature dùng private key để ký và public key để xác minh.

5. Tuning theo context; loại hoặc gộp alert trùng; thêm asset criticality; tự động enrichment; ưu tiên theo risk; cải thiện rule và coverage.

Bài tập 3

1. Thiết kế defense in depth cho dịch vụ học trực tuyến gồm web, database, tài khoản sinh viên và giảng viên.
2. Phân tích tuyên bố: “Đã dùng HTTPS nên dữ liệu người dùng hoàn toàn an toàn”.
3. Một nguồn có 50 lần đăng nhập thất bại trong 10 phút rồi một lần thành công. Đưa ra quy trình điều tra an toàn.
4. So sánh perimeter security và Zero Trust mà không biến chúng thành hai lựa chọn loại trừ.

Lời giải bài tập 3

1. Lớp đề xuất: DNS/TLS; reverse proxy/WAF ở DMZ; tách application và database; MFA cho giảng viên/quản trị; RBAC; least privilege; patch; endpoint protection; logging; backup bất biến; giám sát và playbook.
2. HTTPS bảo vệ kênh và xác thực server nếu validation đúng. Nó không ngăn credential phishing, lỗi authorization, database leak, endpoint malware, logging secret hoặc server bị chiếm quyền.
3. Xác minh timestamp và nguồn; kiểm tra user, device, MFA, IP reputation nội bộ, location, session sau đăng nhập; liên hệ chủ tài khoản qua kênh độc lập; thu hồi session/credential nếu cần; bảo toàn log; tìm lateral movement; khắc phục nguyên nhân.
4. Perimeter vẫn hữu ích để giảm exposure và phân vùng. Zero Trust bổ sung xác minh theo request, identity, device và context; không nên tin cậy chỉ vì đang ở mạng trong. Hai cách có thể phối hợp.

10.8.3 Câu hỏi trắc nghiệm

1. Thành phần nào mô tả điểm yếu có thể bị khai thác?
A. Vulnerability B. Asset C. Impact D. Control
2. Mục tiêu nào bị ảnh hưởng trực tiếp khi dịch vụ không truy cập được?
A. Availability B. Confidentiality C. Authenticity D. Privacy
3. Hành động người dùng tuyên bố tên tài khoản thuộc bước nào?
A. Identification B. Authorization C. Accounting D. Encryption
4. Hai mật khẩu khác nhau có tạo MFA không?
A. Không, vì cùng một loại yếu tố B. Có, vì có hai bí mật
C. Có nếu đủ dài D. Có nếu đổi định kỳ
5. Nguyên tắc nào yêu cầu chỉ cấp đúng quyền cần thiết?
A. Least privilege B. Availability C. Load balancing D. NAT
6. Vì sao đặt database sau application server tốt hơn cho Internet-facing service?
A. Giảm đường truy cập trực tiếp và hỗ trợ segmentation

- B. Làm database không cần xác thực
 - C. Thay thế backup
 - D. Loại bỏ mọi lỗ hổng ứng dụng
7. Khác biệt chính của stateful firewall là gì?
- A. Theo dõi trạng thái connection/flow
 - B. Chỉ dùng địa chỉ MAC
 - C. Luôn giải mã TLS
 - D. Không cần rule
8. Hash chủ yếu cung cấp điều gì?
- A. Fingerprint để kiểm tra thay đổi
 - B. Che giấu nội dung như mã hóa
 - C. Tính sẵn sàng
 - D. Cấp địa chỉ IP
9. Certificate server trong TLS chủ yếu giúp client làm gì?
- A. Liên kết public key với identity được xác minh
 - B. Tăng bandwidth
 - C. Thay thế DNS
 - D. Xóa log
10. False negative trong giám sát nghĩa là gì?
- A. Hoạt động nguy hiểm xảy ra nhưng không được cảnh báo
 - B. Hoạt động hợp lệ bị cảnh báo
 - C. Alert được xử lý đúng
 - D. Không có event và không có alert

10.8.4 Đáp án và giải thích

- 1. **Đáp án đúng:** A. Vulnerability là điểm yếu có thể bị threat khai thác.
- 2. **Đáp án đúng:** A. Availability mô tả khả năng dịch vụ và dữ liệu sẵn sàng khi cần.
- 3. **Đáp án đúng:** A. Identification là tuyên bố danh tính; authentication là xác minh.
- 4. **Đáp án đúng:** A. Hai mật khẩu cùng thuộc yếu tố “điều biết”, nên không phải MFA thực sự.
- 5. **Đáp án đúng:** A. Least privilege giới hạn quyền theo nhiệm vụ, thời gian và phạm vi.
- 6. **Đáp án đúng:** A. Phân tầng dịch vụ hạn chế exposure và tạo điểm kiểm soát giữa các vùng.
- 7. **Đáp án đúng:** A. Stateful firewall dùng state table để hiểu packet trong connection đã quan sát.
- 8. **Đáp án đúng:** A. Hash tạo digest; nó không mã hóa và không che plaintext.
- 9. **Đáp án đúng:** A. Certificate được issuer ký, giúp kiểm tra identity và public key của server.
- 10. **Đáp án đúng:** A. False negative là bỏ sót trường hợp thực sự nguy hiểm.

Chương 11

Tấn công mạng, giám sát và phát hiện bất thường

11.1 Mục tiêu và câu hỏi mở đầu

11.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Trong một buổi sáng, hệ thống giám sát ghi nhận hàng nghìn kết nối thất bại đến nhiều port, một tài khoản đăng nhập thành công sau nhiều lần sai mật khẩu, lượng DNS tăng đột biến và một máy trạm bắt đầu gửi dữ liệu ra ngoài vào ban đêm. Từng dấu hiệu riêng lẻ có thể có nguyên nhân hợp lệ. Làm thế nào để phân biệt hoạt động bình thường, cấu hình sai và tấn công; cần quan sát dữ liệu nào; khi nào một cảnh báo trở thành sự cố; và phải xử lý thế nào để không phá hủy bằng chứng?

Ví dụ: nhân viên trực an ninh của một tòa nhà

Nhân viên trực không chỉ nhìn một người đi qua cửa. Họ kết hợp camera, thẻ ra vào, thời gian, vị trí, danh sách khách và lịch làm việc. Một người mở cửa lúc 10 giờ sáng có thể bình thường; cùng hành động lúc 2 giờ sáng, bằng thẻ vừa bị báo mất và sau nhiều lần quẹt sai lại có ý nghĩa khác. Phép so sánh giúp hình dung rằng phát hiện sự cố cần **ngữ cảnh** và **tương quan nhiều dấu hiệu**, không chỉ một giá trị đơn lẻ.

Giới hạn của mạng: hoạt động mạng diễn ra với khối lượng và tốc độ rất lớn; dữ liệu có thể bị mã hóa, giả mạo hoặc thiếu; người dùng hợp lệ cũng có thể gây hành vi bất thường. Vì vậy, cảnh báo là điểm bắt đầu của quá trình xác minh, không phải bằng chứng tự động về tấn công.

11.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Phân biệt được threat, attack, event, alert, incident và compromise.
- Mô tả được các giai đoạn thường gặp của một cuộc tấn công mà không coi mọi cuộc tấn công đều theo một chuỗi cố định.
- Nhận biết được dấu hiệu của scanning, spoofing, man-in-the-middle, credential attack, malware,

lateral movement, command and control, data exfiltration và DoS/DDoS.

- Phân biệt được IOC, IOA, baseline, deviation và context.
- Giải thích được nguồn dữ liệu packet, flow, DNS, authentication, endpoint, application, cloud và threat intelligence.
- Phân biệt được NIDS, NIPS, HIDS, HIPS, signature-based, anomaly-based và stateful protocol analysis.
- Tính và diễn giải được precision, recall, false-positive rate và các chi phí vận hành của hệ thống phát hiện.
- Giải thích được vai trò của SIEM, correlation rule, triage, case và playbook.
- Trình bày được các bước xác minh, giới hạn ảnh hưởng, bảo toàn bằng chứng, phục hồi và rút kinh nghiệm.
- Phân tích được tập sự kiện an toàn mạng bằng pandas và Matplotlib trong môi trường thực hành an toàn.

11.2 Tấn công và dấu hiệu quan sát

11.2.1 Threat, attack, event, alert và incident

Tấn công (attack) là hành động nhằm vi phạm mục tiêu an toàn hoặc khai thác điểm yếu. *Sự kiện* (event) là một thay đổi hay hoạt động được quan sát. *Cảnh báo* (alert) là event hoặc tập event được cơ chế phát hiện đánh dấu cần chú ý. *Sự cố an toàn mạng* (cybersecurity incident) là sự kiện thực tế gây nguy hại hoặc đe dọa đáng kể đến confidentiality, integrity, availability hay chính sách an toàn.

Đối tượng	Ví dụ	Nhận xét
Event	một lần đăng nhập sai	có thể do gõ nhầm
Alert	100 lần sai từ một IP trong 2 phút	cần xác minh
Incident	tài khoản bị chiếm và truy cập dữ liệu trái phép	đã có tác động hoặc nguy cơ rõ ràng
Compromise	attacker giành quyền trên hệ thống hoặc tài khoản	một dạng kết quả nghiêm trọng

Nhầm lẫn thường gặp

Không nên dùng các từ *event*, *alert*, *incident* và *attack* như đồng nghĩa. Một công cụ có thể tạo alert sai; ngược lại, incident có thể không tạo alert nếu telemetry thiếu hoặc detection rule chưa phù hợp.

11.2.2 Hành vi của tấn công

Một packet hiếm khi đủ để mô tả toàn bộ cuộc tấn công. Hành vi có thể gồm:

1. Thu thập thông tin;
2. Tìm điểm vào;
3. Thực thi hoặc lạm dụng quyền;
4. Duy trì truy cập;
5. Khám phá tài nguyên;
6. Di chuyển sang hệ thống khác;
7. Điều khiển từ xa;
8. Thu thập, phá hoại hoặc đưa dữ liệu ra ngoài.

Trình tự thực tế có thể lặp lại, bỏ qua hoặc diễn ra đồng thời. Người phòng vệ dùng chuỗi này để đặt câu hỏi quan sát, không phải để ép mọi incident vào một kịch bản duy nhất.

11.2.3 IOC và IOA

Chỉ dấu xâm nhập (Indicator of Compromise, IOC) là dấu vết có liên hệ với compromise, chẳng hạn hash file độc hại, domain hoặc IP đã biết, tên file hay registry key. *Chỉ dấu tấn công* (Indicator of Attack, IOA) tập trung vào hành vi và ý định đang diễn ra, chẳng hạn một tài khoản truy cập nhiều máy trong thời gian ngắn rồi chạy công cụ từ xa.

IOC thường cụ thể và dễ đối chiếu nhưng có thể nhanh lỗi thời. IOA có khả năng khái quát tốt hơn nhưng cần ngữ cảnh và dễ tạo false positive.

11.2.4 Baseline và deviation

đường cơ sở (baseline) mô tả hành vi bình thường theo hệ thống, nhóm người dùng, thời điểm và chức năng. *độ lệch* (deviation) là khác biệt so với baseline.

Ví dụ: 500 truy vấn DNS/phút có thể bất thường với máy in nhưng bình thường với recursive resolver. Vì vậy, threshold phải đặt trong ngữ cảnh tài sản và vai trò.

11.2.5 Từ giả thuyết tới bằng chứng

Một quy trình phân tích tốt thường gồm:

1. Phát biểu giả thuyết: “có thể đang xảy ra password spraying”;
2. Xác định dữ liệu cần kiểm tra;
3. Tìm bằng chứng ủng hộ và phản bác;
4. Kiểm tra chất lượng timestamp, identity và source;
5. Đánh giá tác động;
6. Ghi rõ mức độ chắc chắn và giả định.

11.2.6 Reconnaissance và scanning

Trình sát và dò quét nhằm xác định host, port, service hoặc version. Dấu hiệu thường gặp:

- một source kết nối tới nhiều destination port;
- một source truy cập nhiều host trong subnet;
- tỷ lệ SYN cao nhưng connection hoàn chỉnh thấp;
- nhiều ICMP Echo hoặc phản hồi unreachable;
- truy vấn DNS hoặc HTTP nhằm thu thập thông tin.

Ví dụ: thử nhiều tay nắm cửa

Một người đi dọc hành lang và thử từng tay nắm không chứng minh chắc chắn ý định trộm, nhưng khác với người đi thẳng tới phòng làm việc của mình. Tương tự, một chuỗi kết nối rộng có thể là scan, song cũng có thể do hệ thống inventory hoặc monitoring được phép.

11.2.7 Spoofing và giả mạo nguồn

Spoofing làm thông tin nhận dạng hoặc nguồn trông giống đối tượng khác. Ví dụ:

- IP spoofing trong packet không cần nhận phản hồi;
- ARP poisoning ánh xạ IP với MAC sai;
- DNS spoofing trả lời ánh xạ giả;
- Email display name hoặc domain gần giống;
- Giả mạo user-agent hay header ứng dụng.

Dấu hiệu cần kết hợp nhiều lớp: bất thường ARP, xung đột địa chỉ, TTL khác biệt, authentication context, certificate, DNS log và đường đi.

11.2.8 Credential attack

Các dạng phổ biến:

- *brute force* (:): thử nhiều mật khẩu cho một hoặc vài tài khoản;
- *password spraying* (:): thử ít mật khẩu phổ biến trên nhiều tài khoản;
- *credential stuffing* (:): dùng cặp tài khoản/mật khẩu đã rò rỉ;
- phishing hoặc social engineering để lấy thông tin xác thực;
- session/token theft để tránh nhập mật khẩu.

Dấu hiệu gồm failure burst, nhiều account từ một source, nhiều source cho một account, impossible travel, login time lạ, MFA fatigue và đăng nhập thành công sau chuỗi thất bại.

11.2.9 Malware, command and control và beaconing

Malware có thể liên lạc với hạ tầng điều khiển qua HTTP(S), DNS hoặc giao thức tùy chỉnh. Dấu hiệu khả dĩ:

- Connection định kỳ với khoảng thời gian gần đều;
- Domain mới, hiếm hoặc có chuỗi bất thường;
- Outbound traffic từ process không phù hợp;
- Certificate, SNI hoặc destination chưa từng thấy;
- Lưu lượng nhỏ lặp lại rồi tải lượng lớn sau đó.

Không nên kết luận chỉ từ “định kỳ”: agent cập nhật, backup và monitoring cũng có beacon hợp lệ.

11.3 Nguồn dữ liệu, IDS/IPS, SIEM và triage

11.3.1 Packet capture

Packet capture cung cấp header và có thể có payload. Ưu điểm: chi tiết, hỗ trợ tái dựng protocol. Hạn chế: khối lượng lớn, cần vị trí thu phù hợp, payload có thể mã hóa và có rủi ro quyền riêng tư.

Các trường thường dùng: timestamp, source/destination, protocol, ports, TCP flags, length, DNS fields, HTTP metadata và TLS handshake metadata.

11.3.2 Flow record

Flow tóm tắt giao tiếp theo các thuộc tính như 5-tuple, thời gian, packet count, byte count và flags. Flow tiết kiệm hơn packet capture, phù hợp phân tích phạm vi rộng nhưng không giữ toàn bộ nội dung từng packet.

Nguồn	Điểm mạnh	Điểm hạn chế
Packet	chi tiết protocol, có thể thấy payload	dung lượng lớn, privacy, mã hóa
Flow	bao phủ rộng, lưu lâu hơn	ít chi tiết, phụ thuộc exporter
Log	có ngữ nghĩa ứng dụng và identity	schema khác nhau, có thể thiếu hoặc bị tắt
Endpoint	process, file, user context	cần agent, tải vận hành

11.3.3 DNS, DHCP và proxy log

DNS log cho biết query, response, type, resolver và client. DHCP giúp ánh xạ IP động với MAC hoặc device identity theo thời gian. Proxy hoặc secure web gateway cung cấp URL/category, user, action và byte count.

Khi điều tra địa chỉ IP nội bộ, phải dùng đúng lease và timestamp; nếu không, có thể quy nhầm thiết bị.

11.3.4 Authentication và identity log

Các trường quan trọng:

- User hoặc service account;
- Source IP/device;
- Authentication method và MFA result;
- Success/failure và reason;
- Target application;
- Session/token identifier;
- Timestamp chuẩn hóa.

Identity log thường là chìa khóa để phân biệt “máy nào kết nối” với “ai hoặc service nào thực hiện”.

11.3.5 Endpoint và application telemetry

Endpoint telemetry có thể ghi process creation, parent-child relationship, command line, file hash, registry/service change và network connection. Application log ghi transaction, authorization decision, error và business context.

Kết hợp network với endpoint giúp trả lời: connection nào do process nào tạo, dưới user nào, tới mục đích gì.

11.3.6 Intrusion detection và intrusion prevention

Hệ thống phát hiện xâm nhập (Intrusion Detection System, IDS) giám sát và tạo cảnh báo. *Hệ thống ngăn chặn xâm nhập* (Intrusion Prevention System, IPS) có thể thực hiện hành động ngăn chặn, thường đặt inline hoặc tích hợp với control khác.

Prevention giảm thời gian phản ứng nhưng có nguy cơ chặn nhầm. Vì vậy, rule inline cần kiểm thử, staged deployment và cơ chế rollback.

11.3.7 Signature-based detection

Signature khớp mẫu đã biết: byte pattern, rule field, hash, domain hoặc chuỗi event. Ưu điểm là dễ giải thích và thường có precision tốt khi mẫu đặc trưng. Hạn chế:

- khó phát hiện biến thể mới;
- attacker có thể thay đổi encoding hoặc hạ tầng;
- signature lỗi thời tạo khoảng trống;
- mẫu quá rộng tạo false positive.

11.3.8 Anomaly-based detection

Anomaly detection tìm độ lệch so với baseline hoặc mô hình. Có thể dùng threshold, thống kê hoặc ML. Ưu điểm: phát hiện hành vi chưa có signature. Hạn chế: baseline thay đổi, seasonality, concept drift và khó giải thích.

Ví dụ: hóa đơn điện bất thường

Một hóa đơn cao gấp năm lần mức thông thường đáng kiểm tra, nhưng có thể do mùa nóng hoặc thêm thiết bị mới. Giá trị khác thường là tín hiệu để hỏi tiếp, không tự chứng minh hành vi sai trái.

11.3.9 Rule, threshold và correlation

Một rule có thể dựa trên:

- Điều kiện đơn: destination nằm trong blocklist;
- Threshold: hơn 50 failures trong 5 phút;
- Sequence: failure burst rồi success rồi privilege change;
- Correlation nhiều nguồn: network connection + process + identity;
- Suppression: bỏ qua scanner được phê duyệt.

11.4 Cơ sở máy học 1: phân loại, nhãn, X/y và baseline

11.4.1 Khi nào một bài toán mạng là phân loại

Một bài toán là *phân loại* (classification) khi target nhận một số hữu hạn giá trị rời rạc. Ví dụ:

- Flow bình thường hoặc cần điều tra;
- Trạng thái liên kết bình thường, suy giảm hoặc gián đoạn;
- Loại ứng dụng: web, DNS, video, voice hoặc file transfer;
- Sự kiện xác thực thành công, thất bại hoặc bị khóa;
- Packet thuộc TCP, UDP, ICMP hoặc giao thức khác.

Phân loại nhị phân (binary classification) có hai class. *Phân loại đa lớp* (multiclass classification) có từ ba class trở lên và mỗi sample thuộc đúng một class. *Phân loại đa nhãn* (multilabel classification) cho phép một sample đồng thời có nhiều label, chẳng hạn một flow vừa “encrypted” vừa “interactive”.

Nhầm lẫn thường gặp

Một cột được lưu bằng số 0, 1, 2 chưa chắc là target số liên tục. Nếu 0, 1 và 2 chỉ là mã của ba trạng thái, bài toán vẫn là classification. Ngược lại, packet count có giá trị nguyên nhưng vẫn là đại lượng số và có thể là target hồi quy.

11.4.2 Class, label và positive class

Lớp (class) là một nhóm kết quả có ý nghĩa. *nhãn* (label) là giá trị class được gán cho từng sample. Trong bài toán nhị phân, một class thường được chọn làm *lớp dương* (positive class); đây là lớp mà hệ thống đặc biệt quan tâm.

Trong chương này:

- label 1: flow cần điều tra;
- label 0: flow chưa cần điều tra;
- positive class: label 1.

Việc chọn positive class ảnh hưởng trực tiếp tới cách đọc precision, recall và F1. Positive không có nghĩa là “tốt”; nó chỉ là class được đặt ở vị trí quan tâm.

11.4.3 Nhãn phải phản ánh tiêu chí nghiệp vụ

Label không nên được tạo chỉ vì một feature vượt ngưỡng tùy ý rồi sau đó dùng chính feature đó để “chứng minh” mô hình tốt. Trong dữ liệu thực tế, label có thể đến từ:

- kết luận xử lý sự cố;
- xác minh của chuyên gia;
- trạng thái thiết bị được ghi nhận từ hệ thống quản trị;
- kết quả kiểm tra dịch vụ độc lập;
- luật nghiệp vụ đã được phê duyệt và kiểm định.

Nhãn “tấn công” cần bằng chứng

Không nên gán nhãn “tấn công” chỉ vì flow có nhiều packet, nhiều port hoặc lưu lượng lớn. Backup, kiểm kê tài sản, cập nhật phần mềm và kiểm thử được phép có thể tạo đặc trưng tương tự. Label an ninh mạng cần bối cảnh, thời gian, tài sản liên quan và bằng chứng bổ sung.

11.4.4 Tạo DataFrame flow minh họa

Đoạn code sau tạo 800 flow tổng hợp. Mỗi hàng là một flow; dữ liệu chỉ dùng để minh họa quy trình.

```
import numpy as np
import pandas as pd

RANDOM_STATE = 42
rng = np.random.default_rng(RANDOM_STATE)
n = 800

protocol = rng.choice(
    ["HTTP", "HTTPS", "DNS", "SSH"],
    size=n,
    p=[0.28, 0.42, 0.20, 0.10]
)
```

```
df = pd.DataFrame({
    "duration_s": rng.gamma(2.0, 1.8, n),
    "packet_count": rng.poisson(45, n) + 1,
    "retransmission_rate": rng.beta(1.3, 15.0, n),
    "syn_ratio": rng.beta(1.2, 8.0, n),
    "unique_dst_ports": rng.poisson(2.0, n) + 1,
    "dns_query_rate": rng.gamma(1.2, 1.8, n),
    "link_utilization": rng.uniform(0.15, 0.95, n),
    "protocol": protocol,
})

print(type(df))
print(df.shape)
print(df.head())
```

Kết quả dự kiến:

- `type(df)` là `pandas.DataFrame`;
- `shape` là `(800, 8)`;
- mỗi hàng là một flow;
- `protocol` là feature phân loại, các cột còn lại là feature số.

11.4.5 Tạo nhãn và kiểm tra class balance

Để mô phỏng kết quả xác minh của nhóm vận hành, ta tạo một điểm tiềm ẩn từ nhiều dấu hiệu và thêm nhiễu. Label không được dùng ngoài mục đích học tập.

```
protocol_effect = pd.Series(protocol).map({
    "HTTP": 0.10,
    "HTTPS": 0.00,
    "DNS": 0.35,
    "SSH": 0.20,
}).to_numpy()

latent_score = (
    4.2 * df["retransmission_rate"].to_numpy()
    + 2.4 * df["syn_ratio"].to_numpy()
    + 0.11 * df["unique_dst_ports"].to_numpy()
    + 0.08 * df["dns_query_rate"].to_numpy()
    + 1.5 * df["link_utilization"].to_numpy()
    + protocol_effect
    + rng.normal(0, 0.45, n)
)

threshold_for_label = np.quantile(latent_score, 0.82)
df["needs_investigation"] = (
    latent_score >= threshold_for_label
).astype("int8")
```

```
print(df["needs_investigation"].value_counts())
print(df["needs_investigation"].value_counts(normalize=True))
```

Do ngưỡng được chọn tại phân vị 82%, positive class chiếm xấp xỉ 18%. Đây là một tập dữ liệu mất cân bằng ở mức vừa phải.

11.4.6 Tách X , y và chia train-test

```
from sklearn.model_selection import train_test_split

X = df.drop(columns="needs_investigation")
y = df["needs_investigation"]

X_train, X_test, y_train, y_test = train_test_split(
    X,
    y,
    test_size=0.25,
    stratify=y,
    random_state=RANDOM_STATE,
)

print(X_train.shape, X_test.shape)
print(y_train.value_counts(normalize=True))
print(y_test.value_counts(normalize=True))
```

`stratify=y` giúp giữ tỷ lệ class gần tương đương giữa train và test. Tuy nhiên, nếu dữ liệu có nhiều flow từ cùng host hoặc có phụ thuộc thời gian, cần cân nhắc `group split` hoặc `temporal split` để tránh đánh giá quá lạc quan.

11.4.7 Baseline bằng DummyClassifier

Một classifier chỉ có ý nghĩa khi vượt qua một mốc đơn giản. Với dữ liệu mất cân bằng, baseline “luôn dự đoán lớp phổ biến nhất” có thể đạt accuracy khá cao mà vẫn bỏ sót toàn bộ positive class.

```
from sklearn.dummy import DummyClassifier

baseline = DummyClassifier(strategy="most_frequent")
baseline.fit(X_train, y_train)
y_pred_base = baseline.predict(X_test)

print(y_pred_base.shape)
print(pd.Series(y_pred_base).value_counts())
```

DummyClassifier cố ý bỏ qua cấu trúc feature. Vì vậy ở bước này chưa cần preprocessing. Vai trò của baseline là tạo một mốc tối thiểu để kiểm tra xem mô hình học máy thực sự có tạo thêm giá trị hay không.

11.4.8 Ví dụ: bác sĩ và bệnh hiểm

Giả sử 99 trong 100 người không mắc một bệnh hiểm. Một hệ thống luôn kết luận “không mắc” có accuracy 99%, nhưng bỏ sót toàn bộ người mắc bệnh. Trong giám sát mạng, một classifier luôn dự đoán “bình thường” cũng có thể đạt accuracy cao nếu sự cố hiếm.

Giới hạn của mạng: chi phí, bằng chứng và quy trình trong y tế khác an ninh mạng. Phép so sánh chỉ giúp hiểu vì sao tỷ lệ lớp ảnh hưởng tới ý nghĩa của accuracy.

11.5 Tiền xử lý dữ liệu và Pipeline

11.5.1 Fit, transform và fit_transform

Phương thức	Ý nghĩa
<code>fit(X)</code>	Học tham số từ dữ liệu, ví dụ median, mean, standard deviation hoặc danh sách category
<code>transform(X)</code>	Dùng tham số đã học để biến đổi dữ liệu mới
<code>fit_transform(X)</code>	Gọi fit rồi transform trên cùng dữ liệu, thường dùng cho train

Không gọi fit hoặc fit_transform trên test.

11.5.2 Imputation cho dữ liệu số

Trước hết khai báo rõ các cột số. Danh sách này được dùng lại trong toàn bộ pipeline để tránh chọn cột theo cảm tính.

```
from sklearn.impute import SimpleImputer

numeric_features = [
    "duration_s",
    "packet_count",
    "retransmission_rate",
    "syn_ratio",
    "unique_dst_ports",
    "dns_query_rate",
    "link_utilization",
]

num_imputer = SimpleImputer(strategy="median")
X_train_num = X_train[numeric_features]
X_train_num_imputed = num_imputer.fit_transform(X_train_num)

print(type(X_train_num_imputed))
print(X_train_num_imputed.shape)
print(num_imputer.statistics_)
```

`fit()` học median từ tập train; `transform()` dùng các median đó để thay missing value. Không được học median mới từ test set.

11.5.3 Standardization

Sau imputation, các feature số có thang đo rất khác nhau. `StandardScaler` học mean và standard deviation trên train rồi dùng chúng để biến đổi dữ liệu.

```
from sklearn.preprocessing import StandardScaler

scaler = StandardScaler()
X_train_scaled = scaler.fit_transform(X_train_num_imputed)

print(X_train_scaled.shape)
print(scaler.mean_)
print(scaler.scale_)
```

Scaling đặc biệt quan trọng đối với các phương pháp dựa trên khoảng cách; với Logistic Regression, nó còn giúp các hệ số và quá trình tối ưu ít bị chi phối bởi chênh lệch đơn vị đo.

11.5.4 Imputation cho dữ liệu phân loại

Dữ liệu phân loại cần chiến lược riêng. Trong ví dụ này chỉ có cột `protocol`.

```
from sklearn.impute import SimpleImputer

categorical_features = ["protocol"]
cat_imputer = SimpleImputer(
    strategy="most_frequent"
)
```

Nếu missing mang ý nghĩa nghiệp vụ riêng, có thể dùng một category như `"missing"`; không nên mặc định coi mọi missing value là cùng một nguyên nhân.

11.5.5 One-hot encoding

Các chuỗi như `"HTTP"`, `"DNS"` không thể được đưa vào mô hình tuyến tính như những con số có thứ tự. One-hot encoding tạo một cột chỉ báo cho từng category.

```
from sklearn.preprocessing import OneHotEncoder

encoder = OneHotEncoder(
    handle_unknown="ignore",
    sparse_output=False,
)

X_train_cat = X_train[categorical_features]
X_train_encoded = encoder.fit_transform(X_train_cat)

print(X_train_encoded.shape)
print(encoder.get_feature_names_out())
```

`handle_unknown="ignore"` giúp pipeline vẫn xử lý được category mới ở test hoặc dữ liệu tương lai.

`sparse_output=False` được dùng ở đây để sinh viên dễ quan sát ma trận biến đổi; với dữ liệu rất lớn có thể cần `sparse output` để tiết kiệm bộ nhớ.

11.5.6 Vì sao cần nhiều nhánh tiền xử lý

Một `DataFrame` mạng thường chứa nhiều loại cột:

- số liên tục: `duration`, `bytes`;
- số đếm: `packets`;
- category: `protocol`, `service`;
- Boolean: `has_syn`;
- metadata: `flow_id`, `host_id`.

Không thể áp dụng cùng một phép biến đổi cho tất cả. `ColumnTransformer` cho phép chọn cột và pipeline tương ứng.

11.5.7 Ghép các nhánh bằng `ColumnTransformer`

Ta đóng gói hai nhóm tiền xử lý thành hai nhánh: một nhánh cho dữ liệu số và một nhánh cho dữ liệu phân loại. Sau đó, `ColumnTransformer` ghép các kết quả thành cùng một ma trận đặc trưng.

```
from sklearn.compose import ColumnTransformer
from sklearn.pipeline import Pipeline

numeric_pipeline = Pipeline([
    ("imputer", SimpleImputer(strategy="median")),
    ("scaler", StandardScaler()),
])

categorical_pipeline = Pipeline([
    ("imputer", SimpleImputer(strategy="most_frequent")),
    ("encoder", OneHotEncoder(
        handle_unknown="ignore",
        sparse_output=False,
    )),
])

preprocessor = ColumnTransformer(
    transformers=[
        ("num", numeric_pipeline, numeric_features),
        ("cat", categorical_pipeline, categorical_features),
    ],
    remainder="drop",
    verbose_feature_names_out=False,
)
```

`remainder="drop"` loại các cột không được liệt kê. Điều này giúp kiểm soát chính xác feature nào thực sự đi vào mô hình.

11.5.8 Đầu ra pandas và tên feature

Để sinh viên quan sát được feature sau preprocessing, cấu hình transformer trả về DataFrame pandas.

```
from sklearn import set_config

set_config(transform_output="pandas")

X_train_ready = preprocessor.fit_transform(X_train)
X_test_ready = preprocessor.transform(X_test)

print(type(X_train_ready))
print(X_train_ready.shape)
print(X_train_ready.columns.tolist())
```

Điểm quan trọng là `fit_transform()` chỉ dùng trên train. Test chỉ được `transform()` bằng đúng tham số đã học từ train.

11.5.9 Kết hợp tiền xử lý với mô hình

Sau khi hiểu từng bước riêng, có thể ghép preprocessor và estimator thành một pipeline duy nhất.

```
from sklearn.linear_model import LogisticRegression
from sklearn.pipeline import Pipeline

model_pipeline = Pipeline(steps=[
    ("preprocess", preprocessor),
    ("model", LogisticRegression(max_iter=1000)),
])

model_pipeline.fit(X_train, y_train)
pred = model_pipeline.predict(X_test)

print(pred.shape)
print(pred[:10])
```

Lợi ích của pipeline không chỉ là code ngắn hơn. Quan trọng hơn, cùng một preprocessing được áp dụng nhất quán khi `fit()`, `predict()` và đánh giá dữ liệu mới, giúp giảm nguy cơ leakage và sai khác thủ công.

11.6 Logistic Regression, metric, threshold và Decision Tree

11.6.1 Từ điểm tuyến tính đến xác suất

Mặc dù có chữ “regression”, *hồi quy logistic* (logistic regression) thường được dùng cho classification. Mô hình tạo điểm tuyến tính:

$$z = b_0 + b_1x_1 + \dots + b_px_p, \quad (11.1)$$

rồi biến đổi điểm thành xác suất bằng hàm sigmoid:

$$P(y = 1 | X) = \frac{1}{1 + e^{-z}}. \quad (11.2)$$

Xác suất nằm trong khoảng từ 0 đến 1. Mô hình mặc định chuyển xác suất thành class bằng một threshold, thường là 0.5 trong bài toán nhị phân.

Ví dụ: điểm ưu tiên kiểm tra

Một trung tâm hỗ trợ chấm điểm từng yêu cầu dựa trên mức độ khẩn cấp, người dùng bị ảnh hưởng và thời gian chờ. Điểm được chuyển thành xác suất cần xử lý ưu tiên. Sau đó trung tâm chọn ngưỡng phù hợp với số nhân viên trực.

Giới hạn: xác suất do mô hình đưa ra không tự động là xác suất được hiệu chỉnh hoàn hảo. Cần đánh giá calibration nếu giá trị xác suất được dùng trực tiếp để phân bổ nguồn lực.

11.6.2 Xây dựng pipeline LogisticRegression

Ta dùng lại đúng `preprocessor` vừa xây dựng để tạo mô hình Logistic Regression hoàn chỉnh.

```
from sklearn.linear_model import LogisticRegression

logistic_model = Pipeline([
    ("preprocessor", preprocessor),
    ("classifier", LogisticRegression(
        max_iter=1000,
        random_state=RANDOM_STATE,
    )),
])

logistic_model.fit(X_train, y_train)
y_pred_log = logistic_model.predict(X_test)
y_prob_log = logistic_model.predict_proba(X_test)[: , 1]

print(y_pred_log.shape)
print(y_prob_log.shape)
print(y_prob_log[:5])
```

`predict()` trả về nhãn dự đoán; `predict_proba()` trả về xác suất ước lượng cho từng lớp. Cột `[: , 1]` là xác suất của positive class trong bài toán nhị phân này.

11.6.3 Bốn kết quả của phân loại nhị phân

Với positive class là “cần điều tra”, mỗi prediction thuộc một trong bốn trường hợp:

	Dự đoán 0	Dự đoán 1
Thực tế 0	True Negative (TN)	False Positive (FP)
Thực tế 1	False Negative (FN)	True Positive (TP)

- TP: flow cần điều tra và được phát hiện;
- FP: flow bình thường nhưng bị cảnh báo;
- TN: flow bình thường và được bỏ qua đúng;
- FN: flow cần điều tra nhưng bị bỏ sót.

11.6.4 Confusion matrix

Confusion matrix phải được tính riêng cho baseline và mô hình chính. Baseline cho thấy một mô hình “luôn đoán lớp phổ biến” có thể đạt accuracy cao nhưng không phát hiện positive case.

```
from sklearn.metrics import confusion_matrix

cm_base = confusion_matrix(y_test, y_pred_base)
cm_log = confusion_matrix(y_test, y_pred_log)

print("Baseline:\n", cm_base)
print("Logistic Regression:\n", cm_log)

tn, fp, fn, tp = cm_log.ravel()
print("TN, FP, FN, TP:", tn, fp, fn, tp)
```

11.6.5 Precision

Precision trả lời: trong các flow mà mô hình gắn nhãn cần điều tra, có bao nhiêu flow thực sự thuộc positive class?

```
from sklearn.metrics import precision_score

precision = precision_score(
    y_test, y_pred_log, zero_division=0
)
print("Precision:", precision)
```

11.6.6 Recall và specificity

Recall tập trung vào positive class: trong các flow thực sự cần điều tra, mô hình phát hiện được bao nhiêu. Specificity nhìn theo hướng ngược lại đối với negative class.

```
from sklearn.metrics import recall_score

recall = recall_score(
    y_test, y_pred_log, zero_division=0
)
specificity = tn / (tn + fp) if (tn + fp) else 0.0

print("Recall:", recall)
print("Specificity:", specificity)
```

11.6.7 F1 và balanced accuracy

F1 cân bằng precision và recall bằng harmonic mean; balanced accuracy cho trọng số ngang nhau cho khả năng nhận diện các lớp, hữu ích khi dữ liệu mất cân bằng.

```
from sklearn.metrics import f1_score, balanced_accuracy_score

f1 = f1_score(y_test, y_pred_log, zero_division=0)
bal_acc = balanced_accuracy_score(y_test, y_pred_log)

print("F1:", f1)
print("Balanced accuracy:", bal_acc)
```

11.6.8 Mất cân bằng lớp

Khi lớp dương hiếm, accuracy có thể gây ảo giác chất lượng. Có thể cân nhắc tham số `class_weight` với giá trị "balanced". Tuy nhiên, đây không phải phương thuốc tự động; metric và threshold vẫn phải phản ánh chi phí của từng loại lỗi.

Một mô hình cây quyết định cung cấp cách so sánh hữu ích với Logistic Regression vì nó học các rule phi tuyến theo threshold.

```
from sklearn.tree import DecisionTreeClassifier

tree_model = Pipeline([
    ("preprocessor", preprocessor),
    ("classifier", DecisionTreeClassifier(
        max_depth=4,
        min_samples_leaf=15,
        class_weight="balanced",
        random_state=RANDOM_STATE,
    )),
])

tree_model.fit(X_train, y_train)
y_pred_tree = tree_model.predict(X_test)

print("Tree balanced accuracy:",
      balanced_accuracy_score(y_test, y_pred_tree))
```

Độ sâu được giới hạn để giảm overfitting và giữ khả năng diễn giải. Kết quả tốt hơn trên một test set không tự động chứng minh cây phù hợp hơn trong vận hành; vẫn phải xem lỗi theo nhóm và drift theo thời gian.

11.6.9 Decision threshold

Ngưỡng 0.5 không phải quy luật tự nhiên. Hạ threshold thường làm recall tăng nhưng có thể làm precision giảm. Ngưỡng phải được chọn trên validation data theo chi phí lỗi và năng lực xử lý cảnh báo, không được tối ưu trực tiếp trên test set.

```

from sklearn.metrics import precision_score, recall_score

def predict_with_threshold(probabilities, threshold):
    return (probabilities >= threshold).astype("int8")

for threshold in [0.30, 0.50, 0.70]:
    y_pred_t = predict_with_threshold(y_prob_log, threshold)
    precision = precision_score(
        y_test, y_pred_t, zero_division=0
    )
    recall = recall_score(
        y_test, y_pred_t, zero_division=0
    )
    print(threshold, precision, recall)

```

Trong một quy trình đánh giá nghiêm túc, đoạn trên chỉ để minh họa quan hệ threshold–metric. Khi chọn threshold thực tế, phải có validation set riêng rồi mới đánh giá một lần trên test set.

11.7 Cơ sở máy học 2: clustering và anomaly detection

11.7.1 Mỗi flow là một điểm trong không gian feature

Giả sử ta dùng ba feature:

$$\mathbf{x}_i = [\text{duration}_i, \text{retransmission}_i, \text{destination ports}_i].$$

Mỗi flow là một điểm trong không gian ba chiều. Với p feature, sample là một vector trong không gian p chiều:

$$\mathbf{x}_i = [x_{i1}, x_{i2}, \dots, x_{ip}].$$

Thuật toán không nhìn thấy “flow tải tệp” hoặc “flow quét cổng”. Nó chỉ nhìn các tọa độ số. Vì vậy, chất lượng feature và đơn vị đo quyết định hình học mà thuật toán quan sát.

11.7.2 Vì sao scaling là bắt buộc trong ví dụ này

Giả sử feature `bytes` có giá trị 2,000,000, còn tỷ lệ `retransmission` có giá trị 0.08. Nếu dùng trực tiếp, chênh lệch byte có thể lấn át gần như hoàn toàn chênh lệch của feature tỷ lệ. Standardization biến mỗi feature theo:

$$z = \frac{x - \mu}{\sigma},$$

trong đó μ và σ được học từ dữ liệu dùng để `fit`.

Ví dụ: so sánh chiều cao và thu nhập

Nếu phân nhóm người bằng chiều cao tính theo mét và thu nhập tính theo đồng, con số thu nhập lớn hơn hàng triệu lần. Khoảng cách sẽ gần như chỉ phản ánh thu nhập, dù chiều cao vẫn có ý nghĩa trong bài toán giả định. Chuẩn hóa đưa các biến về thang đo có thể so sánh hơn.

Giới hạn: scaling không biến mọi feature thành hữu ích và không loại bỏ outlier. Nó chỉ thay đổi thang đo.

11.7.3 Ý tưởng của K-means

K-means chia n sample thành k cluster. Mỗi cluster có một *tâm cụm* (centroid) là mean vector của các sample trong cluster. Thuật toán tối thiểu hóa tổng bình phương khoảng cách từ sample tới centroid được gán:

$$J = \sum_{i=1}^n \|\mathbf{x}_i - \boldsymbol{\mu}_{c_i}\|^2.$$

Trong scikit-learn, đại lượng này được báo cáo qua thuộc tính `inertia_`.

11.7.4 Pipeline gồm imputation, scaling và KMeans

K-means dựa trên khoảng cách nên ví dụ này chỉ dùng các feature số. Ta định nghĩa rõ ma trận `X_cluster` trước khi xây pipeline.

```
from sklearn.cluster import KMeans
from sklearn.impute import SimpleImputer
from sklearn.preprocessing import StandardScaler
from sklearn.pipeline import Pipeline

feature_cols = numeric_features
X_cluster = df[feature_cols].copy()

cluster_pipe = Pipeline([
    ("imputer", SimpleImputer(strategy="median")),
    ("scaler", StandardScaler()),
    ("kmeans", KMeans(
        n_clusters=3,
        init="k-means++",
        n_init="auto",
        random_state=RANDOM_STATE,
    )),
])

cluster_id = cluster_pipe.fit_predict(X_cluster)
df_clustered = df.assign(cluster=cluster_id)

print(X_cluster.shape)
print(df_clustered["cluster"].value_counts().sort_index())
```

11.7.5 Các giả định và giới hạn của K-means

K-means hoạt động tốt nhất khi:

- cluster tương đối đặc và có dạng gần hình cầu trong không gian đã scale;

- các cluster có độ phân tán không quá khác nhau;
- mean là đại diện có ý nghĩa;
- outlier không chi phối centroid quá mạnh.

Nó có thể hoạt động kém với cluster kéo dài, mật độ khác nhau, hình dạng phi tuyến hoặc nhiều outlier. K-means cũng yêu cầu chọn k trước.

Nhầm lẫn thường gặp

Không được kết luận “K-means tìm ra đúng ba loại lưu lượng” chỉ vì ta đặt `n_clusters=3`. Thuật toán luôn cố tạo đủ k cluster, kể cả khi dữ liệu không có ba nhóm tự nhiên rõ ràng.

11.7.6 Cluster label không có ý nghĩa sẵn

Label 0, 1, 2 không mang thứ tự và không phải mức rủi ro. Ta phải lập hồ sơ cluster bằng feature gốc, metadata và sample đại diện trước khi đặt tên.

11.7.7 Lập hồ sơ bằng thống kê feature

```
cluster_profile = (
    df_clustered
    .groupby("cluster")[feature_cols]
    .agg(["count", "mean", "median"])
)
print(cluster_profile.round(3))
```

Để bảng dễ đọc hơn, có thể chỉ lấy mean:

```
profile_mean = (
    df_clustered
    .groupby("cluster")[feature_cols]
    .mean()
    .round(3)
)
print(profile_mean)
```

Cần quan sát duration, packet count, bytes per packet, SYN ratio, retransmission, số port đích và utilization như một tổ hợp; không đặt tên chỉ từ một feature.

11.7.8 Isolation Forest ở mức định hướng

Isolation Forest đưa ra một góc nhìn khác: thay vì chia toàn bộ dữ liệu thành cluster, nó tìm các observation dễ bị cô lập khỏi phần lớn dữ liệu.

```
from sklearn.ensemble import IsolationForest

isolation_pipe = Pipeline([
    ("imputer", SimpleImputer(strategy="median")),
```

```

("scaler", StandardScaler()),
("model", IsolationForest(
    n_estimators=200,
    contamination=0.02,
    random_state=RANDOM_STATE,
)),
])

isolation_label = isolation_pipe.fit_predict(X_cluster)
isolation_score = isolation_pipe.decision_function(X_cluster)

df_compare = df_clustered.assign(
    isolation_label=isolation_label,
    isolation_score=isolation_score,
)
print(df_compare["isolation_label"].value_counts())

```

Trong scikit-learn, -1 thường biểu diễn observation bị xem là outlier và 1 biểu diễn inlier. Đây vẫn chỉ là tín hiệu để điều tra, không phải nhãn tấn công.

11.7.9 Bất thường không đồng nghĩa tấn công

Một flow được xếp hạng khác biệt có thể do:

- sao lưu định kỳ;
- cập nhật phần mềm;
- kiểm thử hiệu năng;
- thay đổi topology hoặc phiên bản ứng dụng;
- lỗi timestamp, đơn vị hoặc sensor;
- sự cố mạng;
- hoạt động tấn công.

Góc nhìn an toàn, an ninh mạng

Không dùng cluster ID hoặc anomaly score làm căn cứ duy nhất để chặn kết nối, cô lập thiết bị hoặc kết luận người dùng vi phạm. Cần đối chiếu log, vai trò tài sản, lịch thay đổi, dữ liệu packet/flow, thông tin ứng dụng và phê duyệt phù hợp.

11.8 Phân tích lỗi, drift và sử dụng có trách nhiệm

11.8.1 Phân tích false positive

Trước khi xem riêng false positive và false negative, tạo một bảng lỗi giữ nguyên feature gốc cùng nhãn thật, nhãn dự đoán và xác suất.

```

error_table = X_test.copy()
error_table["y_true"] = y_test.to_numpy()
error_table["y_pred"] = y_pred_log
error_table["probability"] = y_prob_log

false_positives = error_table.loc[
    (error_table["y_true"] == 0)
    & (error_table["y_pred"] == 1)
]

print(false_positives.sort_values(
    "probability", ascending=False
).head(10))

```

False positive làm tăng tải điều tra. Cần tìm xem chúng tập trung ở protocol, loại traffic hoặc khoảng giá trị feature nào thay vì chỉ nhìn một con số tổng hợp.

11.8.2 Phân tích false negative

False negative thường đáng chú ý hơn trong nhiều bài toán phát hiện vì đó là các positive case bị bỏ sót.

```

false_negatives = error_table.loc[
    (error_table["y_true"] == 1)
    & (error_table["y_pred"] == 0)
]

print(false_negatives.sort_values(
    "probability", ascending=False
).head(10))

```

Nếu false negative tập trung ở một kiểu traffic cụ thể, có thể cần xem lại feature, chất lượng label, threshold hoặc chính phạm vi bài toán; không nên phản xạ bằng cách thêm ngay một mô hình phức tạp hơn.

11.8.3 Temporal leakage và entity leakage

Nếu flow của cùng một phiên, cùng host hoặc cùng sự cố xuất hiện ở cả train và test, mô hình có thể ghi nhớ đặc điểm thực thể. Nếu feature chứa thông tin chỉ xuất hiện sau khi điều tra, đó là temporal leakage. Split và feature phải phản ánh đúng thời điểm triển khai.

11.8.4 Data drift, concept drift và performance drift

Loại thay đổi	Mô tả	Ví dụ mạng
Input/data drift	Phân phối feature thay đổi	Tỷ lệ QUIC tăng, RTT thay đổi do site mới
Prediction drift	Phân phối prediction thay đổi	Tỷ lệ cảnh báo tăng từ 2% lên 12%
Concept drift	Quan hệ giữa feature và target thay đổi	Pattern SYN cũ không còn đại diện cho hành vi cần điều tra
Performance drift	Metric trên label xác minh giảm	Recall giảm từ 0.88 xuống 0.65
Schema drift	Cột, kiểu hoặc đơn vị thay đổi	<code>rtt_ms</code> chuyển sang microsecond nhưng tên không đổi

11.8.5 Quyền riêng tư và giảm thiểu dữ liệu

Cần hỏi:

- Có thật sự cần payload, domain đầy đủ hoặc user identifier không?
- Có thể dùng aggregation, pseudonymization hoặc hashing không?
- Thời gian lưu dữ liệu và prediction là bao lâu?
- Ai được truy cập raw data, feature và explanation?
- Có nguy cơ tái nhận dạng khi ghép nhiều nguồn không?
- Mục đích sử dụng mới có phù hợp với mục đích thu thập ban đầu không?

11.8.6 Human-in-the-loop và trách nhiệm cuối cùng

Con người không chỉ “bấm xác nhận”. Cần xác định:

- ai hiểu ngữ cảnh để review;
- thông tin nào được hiển thị để kiểm chứng;
- analyst có thể override hay không;
- feedback được thu thập và kiểm tra thế nào;
- ai chịu trách nhiệm khi sai;
- khi nào phải ngừng tự động hóa.

Góc nhìn an toàn, an ninh mạng

Không dùng một prediction đơn lẻ làm bằng chứng duy nhất để khóa tài khoản, cô lập thiết bị hoặc quy kết hành vi. Mức tự động hóa phải tương xứng với độ tin cậy, khả năng đảo ngược và mức tác động của quyết định.

11.9 Tổng kết chương

11.9.1 Tóm tắt chương

- Tấn công thường là chuỗi hành vi; một packet hoặc alert hiếm khi đủ để kết luận.
- Event, alert, incident và compromise có ý nghĩa khác nhau.
- Scanning, spoofing, credential attack, lateral movement, C2, exfiltration và DoS tạo các dấu vết khả dĩ nhưng không độc quyền.
- Packet, flow, identity, endpoint, application và cloud log bổ sung cho nhau.
- Signature dễ giải thích; anomaly có thể phát hiện khác biệt mới nhưng cần baseline và tuning.
- IDS cảnh báo; IPS có thể ngăn chặn và vì vậy có rủi ro chặn nhầm cao hơn.
- SIEM chuẩn hóa, làm giàu, tương quan và hỗ trợ workflow; không thay thế phân tích và quản trị dữ liệu.
- Precision và recall phản ánh hai loại sai lệch khác nhau; accuracy đơn lẻ có thể gây hiểu nhầm.
- Triage cần xét confidence, impact, asset criticality và activity được phép.
- Incident response phải gắn với chuẩn bị, bảo toàn bằng chứng, phục hồi và cải tiến liên tục.

11.9.2 Bài tập tự học

Bài tập 1

1. Phân biệt event, alert và incident bằng một ví dụ.
2. Nêu hai dấu hiệu scan và một nguyên nhân hợp lệ có thể tạo dấu hiệu đó.
3. Phân biệt IOC và IOA.
4. Nêu khác biệt giữa IDS và IPS.
5. Giải thích vì sao flow không thay thế hoàn toàn packet capture.

Lời giải bài tập mức 1

1. Event: một login failure; alert: 100 failures/2 phút; incident: account bị chiếm và truy cập trái phép.
2. Nhiều port hoặc nhiều host, nhiều SYN không hoàn tất; scanner quản trị được phép có thể tạo cùng dấu hiệu.
3. IOC là dấu vết compromise cụ thể; IOA tập trung vào hành vi/tactic đang diễn ra.
4. IDS cảnh báo; IPS có thể ngăn chặn inline hoặc qua control tích hợp.
5. Flow giữ metadata tổng hợp, không có chi tiết từng packet/payload và có thể bỏ mất sequence protocol.

Bài tập 2

1. Một rule có TP=80, FP=20, FN=40. Tính precision và recall.
2. Một source chạm 200 port của một server trong 30 giây nhưng nằm trong danh sách scanner. Nên xử lý thế nào?
3. Vì sao timestamp lệch 8 phút có thể phá hỏng correlation rule?
4. Nêu ba nguồn dữ liệu để điều tra lateral movement.
5. Một host gửi 8 GB ra cloud lúc 01:00. Cần hỏi những câu nào trước khi kết luận exfiltration?

Lời giải bài tập 2

1. Precision = $80 / (80 + 20) = 80\%$; recall = $80 / (80 + 40) = 66.7\%$.
2. Không tự đóng incident; xác minh lịch scan, owner và scope. Có thể suppress alert vận hành nhưng vẫn theo dõi sai lệch và dùng event kiểm thử sensor.
3. Failure và success có thể nằm ngoài cửa sổ; thứ tự event sai; analyst hiểu nhầm nguyên nhân-kết quả.
4. Authentication log, endpoint process/remote service event, east-west flow hoặc firewall log.
5. Host owner, lịch backup, destination được phê duyệt, process tạo traffic, loại dữ liệu, baseline, user/session và change ticket.

Bài tập 3

1. Một NIPS chặn nhầm 1% giao dịch hợp lệ nhưng giảm 95% request độc hại. Hãy phân tích trade-off trước khi bật inline.
2. Xây dựng timeline tối thiểu cho incident gồm phishing, login success, privilege change, lateral movement và exfiltration.
3. Phê bình phát biểu: “Mô hình anomaly đạt accuracy 99%, do đó có thể tự động khóa mọi host bị đánh dấu.”
4. Đề xuất cách kiểm tra một alert beaconing mà không đọc payload TLS.
5. Viết checklist bảo toàn bằng chứng cho file log và PCAP.

Lời giải bài tập 3

1. Cần biết volume giao dịch, chi phí chặn nhầm, khả năng fail-open/fail-close, rollback, test subset, allowlist, latency và monitoring. Một phần trăm trên hàng triệu giao dịch có thể không chấp nhận được.
2. Chuẩn hóa UTC; ghi email/link, identity event, token/MFA, thay đổi quyền, source/destination, process, remote service, data volume và containment action.
3. Accuracy không đủ khi class imbalance; cần precision/recall, cost, drift, interpretability và human review. Auto-block có thể gây outage và bị attacker lợi dụng.
4. Phân tích periodicity, destination rarity, SNI/certificate, byte ratio, connection duration, DNS

history, endpoint process và peer group baseline.

5. Giữ bản gốc read-only, ghi nguồn/thời gian, tính hash, tạo bản sao làm việc, phân quyền, log thao tác, giữ timezone/schema và chain of custody khi cần.

Bài tập 4

Bài 1. Cho biết các bài toán sau là hồi quy hay phân loại:

- a) dự đoán RTT theo millisecond;
- b) dự đoán flow bình thường hoặc cần điều tra;
- c) dự đoán giao thức ứng dụng;
- d) dự đoán throughput Mbps.

Lời giải

a) Hồi quy; b) phân loại nhị phân; c) phân loại đa lớp; d) hồi quy.

Bài 2. Với $TP = 24$, $FP = 6$, $TN = 150$, $FN = 20$, hãy tính accuracy, precision và recall.

Lời giải

Tổng $N = 200$. $Accuracy = (24 + 150)/200 = 0.87$. $Precision = 24/(24 + 6) = 0.80$. $Recall = 24/(24 + 20) \approx 0.545$. Accuracy khá cao nhưng mô hình bỏ sót gần 45.5% positive sample.

Bài 3. Một classifier luôn dự đoán class 0 trên tập có 900 sample class 0 và 100 sample class 1. Tính accuracy và recall của class 1.

Lời giải

$Accuracy = 900/1000 = 0.90$. Recall class 1 bằng $0/100 = 0$. Đây là ví dụ accuracy cao nhưng classifier vô dụng đối với positive class.

Bài 4. Giải thích vì sao `predict()` và `predict_proba()` không giống nhau.

Lời giải

`predict_proba()` trả điểm xác suất cho từng class. `predict()` chuyển điểm thành class theo quy tắc threshold của classifier. Cùng một xác suất có thể cho prediction khác nếu threshold thay đổi.

Bài 5. Positive class là “flow cần điều tra”. FP và FN có ý nghĩa gì?

Lời giải

FP là flow bình thường nhưng bị cảnh báo, làm tăng tải điều tra. FN là flow cần điều tra nhưng bị bỏ qua, có thể làm bỏ sót sự cố hoặc suy giảm quan trọng.

Bài tập 5

Bài 6. Mô hình A có precision 0.90, recall 0.35. Mô hình B có precision 0.62, recall 0.82. Hệ thống nào phù hợp hơn?

Lời giải

Không đủ thông tin để kết luận. A phù hợp khi nguồn lực điều tra rất hạn chế và FP đắt; B phù hợp hơn khi bỏ sót sự cố gây hậu quả lớn. Cần biết prevalence, số cảnh báo, chi phí FP/FN và quy trình kiểm tra thứ hai.

Bài 7. Tại threshold 0.3, mô hình có 60 cảnh báo, precision 0.50 và recall 0.75. Tính số TP và FP nếu các tỷ lệ chính xác tuyệt đối.

Lời giải

Precision = $TP/(TP + FP) = 0.50$ và tổng cảnh báo là 60, nên $TP = 30$, $FP = 30$. Recall cho biết $30/(TP + FN) = 0.75$, nên $TP + FN = 40$, do đó $FN = 10$.

Bài 8. Vì sao không được chọn threshold tốt nhất trực tiếp trên test set?

Lời giải

Vì threshold là một tham số được tinh chỉnh. Nếu dùng test để chọn threshold, thông tin test đã ảnh hưởng quyết định và kết quả đánh giá cuối không còn độc lập. Nên chọn threshold trên validation hoặc bằng cross-validation trong train.

Bài 9. Khi thêm `class_weight="balanced"`, recall tăng nhưng precision giảm. Đây có phải lỗi không?

Lời giải

Không nhất thiết. Mô hình đã ưu tiên class hiếm hơn, tạo nhiều prediction dương hơn. Điều đó có thể tăng TP đồng thời tăng FP. Cần đánh giá trade-off theo mục tiêu vận hành.

Bài 10. Một cây có train $F1 = 1.00$ và test $F1 = 0.58$. Hãy nhận xét.

Lời giải

Khoảng cách lớn cho thấy overfitting. Cần giới hạn độ sâu, tăng `min_samples_leaf`, dùng validation/cross-validation và kiểm tra leakage hoặc sample trùng.

11.9.3 Câu hỏi trắc nghiệm

- Điều nào mô tả đúng nhất một alert?
 - Một event hoặc tập event được cơ chế phát hiện đánh dấu cần chú ý
 - Bằng chứng chắc chắn rằng attacker đã thành công
 - Mọi packet đi qua firewall
 - Chỉ sự cố đã gây mất dữ liệu
- Dấu hiệu nào phù hợp nhất với password spraying?

- A. Một source thử ít mật khẩu trên nhiều account
 - B. Một account tải file lớn
 - C. Một server gửi DNS response
 - D. Nhiều user đăng nhập thành công vào giờ làm việc
3. Ưu điểm chính của flow so với full packet capture là gì?
- A. Có thể bao phủ rộng và lưu lâu hơn với dung lượng thấp hơn
 - B. Luôn đọc được payload đã mã hóa
 - C. Luôn xác định chính xác user
 - D. Không bao giờ có missing data
4. Signature-based detection thường có hạn chế nào?
- A. Khó phát hiện biến thể chưa có mẫu phù hợp
 - B. Không thể giải thích rule
 - C. Không dùng được IOC
 - D. Chỉ hoạt động trên endpoint
5. Nếu TP=90 và FP=30, precision bằng bao nhiêu?
- A. 75%
 - B. 90%
 - C. 60%
 - D. 30%
6. Vì sao chỉ đặt NIDS ở Internet edge là chưa đủ?
- A. Có thể không thấy east-west traffic và activity nội bộ host
 - B. NIDS không đọc được địa chỉ IP
 - C. Internet edge không có packet
 - D. NIDS chỉ dùng cho Wi-Fi
7. Tác dụng chính của normalization trong SIEM là gì?
- A. Đưa các nguồn khác nhau về schema trường nhất quán hơn
 - B. Mã hóa mọi payload
 - C. Tự động kết luận incident
 - D. Loại bỏ nhu cầu đồng bộ thời gian
8. Hoạt động nào thuộc containment?
- A. Cô lập host bị nghi compromise để giảm lan rộng
 - B. Viết báo cáo bài học sau sự cố
 - C. Xóa toàn bộ log gốc
 - D. Bỏ qua cảnh báo để tránh gián đoạn

9. Phát biểu nào đúng về anomaly?

- A. Là khác biệt cần kiểm tra, không tự động là tấn công
- B. Luôn là IOC đã xác minh
- C. Không phụ thuộc baseline
- D. Có thể dùng để tự động kết tội người dùng

10. Khi làm việc với file log gốc, lựa chọn phù hợp nhất là gì?

- A. Giữ bản gốc read-only, tính hash và phân tích trên bản sao
- B. Sửa trực tiếp để chuẩn hóa nhanh
- C. Xóa timestamp để bảo vệ riêng tư
- D. Chỉ chụp màn hình rồi bỏ file

11.9.4 Đáp án và giải thích

1. **Đáp án đúng:** A. Alert là event hoặc tập event được detection đánh dấu; vẫn cần xác minh.
2. **Đáp án đúng:** A. Spraying phân tán thử nghiệm trên nhiều account để tránh lockout theo từng account.
3. **Đáp án đúng:** A. Flow là dữ liệu tổng hợp nên thường nhỏ hơn và phù hợp coverage rộng.
4. **Đáp án đúng:** A. Signature phụ thuộc mẫu; biến thể mới có thể không khớp.
5. **Đáp án đúng:** A. $\text{Precision} = 90 / (90 + 30) = 0.75 = 75\%$.
6. **Đáp án đúng:** A. Edge sensor có blind spot với east-west và process/user context.
7. **Đáp án đúng:** A. Normalization ánh xạ trường khác nhau về schema chung để tìm kiếm và tương quan.
8. **Đáp án đúng:** A. Cô lập host là hành động giảm lan rộng; phải cân nhắc bằng chứng và nghiệp vụ.
9. **Đáp án đúng:** A. Anomaly là độ lệch; cần context để xác định benign hay malicious.
10. **Đáp án đúng:** A. Bản gốc cần bảo toàn; hash và bản sao giúp kiểm tra tính toàn vẹn.

Phần IV

Tổng hợp

Chương 12

Quy trình phân tích mạng

12.1 Mục tiêu và nguyên tắc tổng hợp

12.1.1 Câu hỏi mở đầu

Câu hỏi mở đầu

Một nhóm phân tích mạng được giao ba nhiệm vụ: dự đoán thời gian tải trang web, phát hiện flow cần điều tra và khám phá những nhóm hành vi lưu lượng chưa biết trước. Nhóm đã biết cách dùng pandas, pipeline, hồi quy, phân loại và phân cụm. Tuy nhiên, làm thế nào để biến các kỹ thuật rời rạc đó thành ba quy trình có câu hỏi rõ ràng, dữ liệu phù hợp, kết quả kiểm chứng được và khuyến nghị vận hành có trách nhiệm?

Ví dụ: từ học từng kỹ năng đến hoàn thành một chuyến đi

Biết đọc bản đồ, lái xe, kiểm tra nhiên liệu và xử lý sự cố là các kỹ năng riêng lẻ. Một chuyến đi hoàn chỉnh còn đòi hỏi xác định điểm đến, chọn lộ trình, chuẩn bị phương tiện, theo dõi tiến độ, ứng phó khi điều kiện thay đổi và đánh giá sau hành trình.

Ánh xạ sang phân tích mạng:

- Điểm đến tương ứng câu hỏi phân tích;
- Bản đồ và lộ trình tương ứng thiết kế dữ liệu và phương pháp;
- Kiểm tra phương tiện tương ứng kiểm tra schema và chất lượng dữ liệu;
- Đồng hồ và biển báo tương ứng metric và biểu đồ;
- Đổi đường khi tắc tương ứng điều chỉnh mô hình hoặc threshold;
- Nhật ký chuyến đi tương ứng provenance và báo cáo thí nghiệm.

Giới hạn của mạng: phân tích dữ liệu không có một lộ trình duy nhất đúng cho mọi tình huống. Mỗi quyết định phải dựa trên câu hỏi, cấu trúc dữ liệu, giao thức mạng và chi phí sai cụ thể.

12.1.2 Mục tiêu của chương

Sau khi hoàn thành phần này, người học có thể

- Chuyển được một yêu cầu vận hành mạng thành câu hỏi phân tích và đại lượng cần đo.
- Xác định được đơn vị quan sát, target, feature, metadata và thời điểm dự đoán.
- Xây dựng được một quy trình hồi quy hoàn chỉnh cho hiệu năng web.
- Xây dựng được một quy trình phân loại hoàn chỉnh cho flow cần điều tra.
- Xây dựng được một quy trình phân cụm và phát hiện hành vi khác biệt khi không có nhãn.
- Thiết kế được baseline, phép chia dữ liệu và metric phù hợp cho từng bài toán.
- Đọc được bảng kết quả, residual, confusion matrix, cluster profile và danh sách flow khác biệt.
- Phân biệt được kết luận thống kê, kết luận kỹ thuật và quyết định vận hành.
- Trình bày được các giới hạn về dữ liệu, nhãn, drift, quyền riêng tư và chi phí cảnh báo.
- Tạo được một báo cáo phân tích có thể tái lập, kiểm tra và chuyển giao.

12.1.3 Ba nghiên cứu tình huống

Mã	Câu hỏi	Phương pháp	Kết quả chính
CS1	Thời gian tải trang web có thể được dự đoán từ đặc trưng giao dịch và mạng không?	Hồi quy	MAE, RMSE, R^2 , residual và sai số theo nhóm
CS2	Flow nào cần được ưu tiên điều tra?	Phân loại	Confusion matrix, precision, recall, F1 và threshold
CS3	Lưu lượng hình thành các nhóm hành vi nào và flow nào khác biệt?	Phân cụm và anomaly scoring	Silhouette, cluster profile, khoảng cách tới centroid và Isolation Forest

12.1.4 Nguyên tắc

- Ba tình huống đều tuân theo tám bước:
1. Xác định quyết định cần hỗ trợ;
 2. Xác định đơn vị quan sát và thời điểm dự đoán;
 3. Thiết kế schema và data dictionary;
 4. Kiểm tra, làm sạch và chia dữ liệu;
 5. Xây dựng baseline trước mô hình chính;
 6. Đánh giá bằng metric phù hợp và theo các nhóm quan trọng;
 7. Giải thích kết quả bằng cả thống kê và logic mạng;

8. Nêu giới hạn, rủi ro, cách giám sát và điều kiện sử dụng.

12.2 Quy trình phân tích mạng thông thường

12.2.1 Bắt đầu từ quyết định, không bắt đầu từ thuật toán

Một yêu cầu như “hãy dùng AI phân tích mạng” chưa đủ để thiết kế bài toán. Cần chuyển thành câu hỏi có quyết định đi kèm.

Yêu cầu còn mơ hồ	Câu hỏi phân tích	Quyết định được hỗ trợ
Dự đoán mạng chậm	Dự đoán page load time trước khi giao dịch hoàn tất	Cảnh báo hoặc điều phối tài nguyên
Tìm lưu lượng xấu	Flow nào cần ưu tiên điều tra trong ca trực?	Xếp hàng cảnh báo cho chuyên gia
Tìm hành vi lạ	Những flow nào khác biệt so với nhóm hành vi gần nhất?	Chọn mẫu để phân tích sâu

Quy tắc

Nếu không thể mô tả hành động sau khi nhận prediction hoặc cluster, bài toán có thể chưa đủ rõ để xây dựng mô hình.

12.2.2 Đơn vị quan sát và thời điểm dự đoán

Cần trả lời hai câu hỏi:

- 1. Một hàng biểu diễn packet, flow, transaction, host hay time window?
- 2. Tại thời điểm dự đoán, những feature nào đã thực sự có sẵn?

Ví dụ, nếu cần dự đoán page load time ngay khi request bắt đầu, không được sử dụng số retransmission của toàn bộ giao dịch vì giá trị đó chỉ biết sau khi giao dịch kết thúc. Trong chương này, CS1 được xem như bài toán *phân tích và ước lượng sau khi đã quan sát các đặc trưng giao dịch*; nếu chuyển sang dự đoán sớm, schema phải được thiết kế lại.

12.2.3 Data dictionary tối thiểu

Mỗi case study phải có bảng mô tả:

Trường	Kiểu	Đơn vị	Ý nghĩa
timestamp	datetime	thời gian	Thời điểm bắt đầu quan sát
flow_id	string	không có	Mã định danh dùng để truy vết, không đưa vào mô hình
protocol	category	không có	Giao thức hoặc phiên bản giao thức

Trường	Kiểu	Đơn vị	Ý nghĩa
retransmission_rate	float	tỷ lệ	Tỷ lệ retransmission trong phạm vi quan sát
site	category	không có	Vị trí logic dùng cho đánh giá theo nhóm

12.2.4 Phân chia dữ liệu theo cấu trúc thật

Random split chỉ phù hợp khi các sample có thể xem là độc lập và phân phối tương đối ổn định. Trong ba tình huống:

- CS1 dùng time split: 75% thời gian đầu cho train và 25% cuối cho test;
- CS2 dùng train-validation-test theo thời gian để chọn threshold mà không xem test;
- CS3 không có label nên dùng toàn bộ dữ liệu để khám phá, nhưng đánh giá độ ổn định bằng nhiều seed và giai đoạn thời gian.

12.2.5 Baseline, mô hình và tiêu chí dừng

Mỗi case có một baseline rõ ràng:

- CS1: dự đoán median page load time;
- CS2: luôn dự đoán lớp phổ biến;
- CS3: so sánh nhiều giá trị k và kiểm tra xem cluster có profile diễn giải được hay không.

Một mô hình phức tạp chỉ đáng sử dụng khi cải thiện đủ lớn so với baseline, ổn định theo nhóm và có chi phí triển khai chấp nhận được.

12.2.6 Tách ba loại kết luận

1. **Kết luận thống kê:** mô hình đạt MAE, recall hoặc silhouette bao nhiêu.
2. **Kết luận kỹ thuật:** sai số cao hơn ở Wi-Fi, flow có SYN ratio lớn tập trung trong cluster nào.
3. **Quyết định vận hành:** có nên cảnh báo, điều tra, thu thập thêm dữ liệu hay thay đổi cấu hình.

Không được nhảy trực tiếp từ một metric tốt sang quyết định tự động hóa hoàn toàn.

12.2.7 Báo cáo kết quả và giới hạn

Một báo cáo tối thiểu phải chứa:

- Câu hỏi và phạm vi;
- Nguồn dữ liệu, thời gian và đơn vị quan sát;
- Schema và bước làm sạch;
- Phương pháp chia dữ liệu;

- Baseline, mô hình và hyperparameter chính;
- Metric tổng thể và theo nhóm;
- Hình hoặc bảng giải thích;
- Giới hạn, rủi ro và khuyến nghị tiếp theo.

12.3 Nghiên cứu tình huống 1: hồi quy hiệu năng

12.3.1 Bài toán và ý nghĩa mạng

Mục tiêu là ước lượng `page_load_ms` từ các đặc trưng của giao dịch web và điều kiện mạng. Kết quả có thể giúp:

- Xác định yếu tố liên quan mạnh đến thời gian tải;
- So sánh trải nghiệm theo protocol và access network;
- Xây dựng mức tham chiếu cho giám sát hiệu năng;
- Phát hiện giao dịch có residual lớn để điều tra thêm.

Ví dụ: ước lượng thời gian giao hàng

Thời gian giao hàng phụ thuộc khoảng cách, số kiện, số điểm trung chuyển, loại phương tiện và tình trạng tắc nghẽn. Dự đoán thời gian tải trang cũng sử dụng nhiều yếu tố: khoảng cách logic, tổng dữ liệu, số object, số flow đồng thời, retransmission, protocol và access network.

Giới hạn: page load time còn phụ thuộc server processing, browser, cache, DNS, TLS và nội dung động. Tập feature trong ví dụ không đại diện đầy đủ mọi nguyên nhân.

12.3.2 Schema và dữ liệu tổng hợp

Tập dữ liệu gồm 720 transaction, cách nhau 15 phút. Một hàng là một lần tải trang.

Feature	Kiểu	Đơn vị	Ý nghĩa
<code>distance_km</code>	float	km	Khoảng cách đại diện tới dịch vụ
<code>object_count</code>	integer	object	Số tài nguyên của trang
<code>total_kb</code>	float	KB	Tổng dữ liệu tải
<code>concurrent_flows</code>	integer	flow	Số flow đồng thời
<code>retransmission_rate</code>	float	tỷ lệ	Tỷ lệ retransmission
<code>protocol</code>	category	–	HTTP/1.1, HTTP/2 hoặc HTTP/3
<code>access</code>	category	–	Ethernet, Wi-Fi hoặc 5G
<code>cache_hit</code>	category	–	Có sử dụng cache hay không
<code>page_load_ms</code>	float	ms	Target hồi quy

12.3.3 Chia dữ liệu và xây pipeline

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Train có 540 transaction và test có 180 transaction. Time split mô phỏng câu hỏi: mô hình học từ giai đoạn trước có hoạt động tốt ở giai đoạn sau hay không?

12.3.4 Baseline và hai mô hình

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Linear Regression kiểm tra xem quan hệ gần tuyến tính có đủ hay không. Decision Tree có thể học threshold và interaction nhưng dễ overfit hơn.

12.3.5 Đánh giá bằng MAE, RMSE và R-squared

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Kết quả kiểm chứng của dữ liệu minh họa:

Mô hình	MAE (ms)	RMSE (ms)	R^2
Baseline median	500.1	628.5	-0.001
Linear Regression	107.7	137.3	0.952
Decision Tree	274.6	356.4	0.678

Diễn giải

Linear Regression tốt hơn rõ rệt baseline và Decision Tree trong tập dữ liệu này. Điều đó không chứng minh Linear Regression luôn tốt hơn cây. Nó chỉ cho thấy cơ chế sinh dữ liệu hiện tại phần lớn có quan hệ cộng tuyến tính, trong khi cây bị giới hạn độ sâu và leaf để tránh overfitting.

12.3.6 Residual và sai số theo nhóm

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Residual dương nghĩa là mô hình dự đoán thấp hơn thực tế. Residual âm nghĩa là mô hình dự đoán cao hơn. Cần kiểm tra residual theo thời gian, protocol, access và dải tải để tránh che giấu nhóm có sai số lớn.

12.3.7 Kết luận, giới hạn và khuyến nghị

Kết luận thống kê: mô hình tuyến tính đạt MAE khoảng 108 ms và R^2 khoảng 0.95 trên giai đoạn test.

Kết luận kỹ thuật: total size, object count, concurrent flow và retransmission có quan hệ rõ với page load time trong dữ liệu minh họa. Cache hit làm giảm target.

Giới hạn:

- dữ liệu là tổng hợp, không thay thế đo lường thực;
- chưa có server processing time, DNS time, TLS time và browser rendering;
- feature có thể chỉ biết sau giao dịch nên chưa phải mô hình dự đoán sớm;
- R^2 cao không chứng minh quan hệ nhân quả.

Khuyến nghị: khi áp dụng thật, cần time split theo tuần hoặc tháng, đánh giá theo site và device, theo dõi residual drift và lưu lại phiên bản pipeline.

12.4 Nghiên cứu tình huống 2: phân loại trạng thái kết nối

12.4.1 Bài toán và định nghĩa positive class

Mục tiêu là dự đoán `needs_review`: flow có cần được chuyên gia xem xét hay không. Positive class không đồng nghĩa “tấn công”. Nó chỉ có nghĩa flow đáp ứng tiêu chí ưu tiên điều tra đã được xác định.

Vì sao phải định nghĩa nhãn thận trọng?

Nếu nhãn được tạo từ một rule yếu, mô hình sẽ học bắt chước rule yếu. Nếu nhãn chỉ gồm các incident đã phát hiện, nhiều false negative lịch sử có thể bị ghi thành benign. Ground truth cần gắn với quy trình xác minh và phiên bản tiêu chí.

12.4.2 Feature, nhãn và chi phí sai

Feature	Kiểu	Ý nghĩa
syn_ratio	float	Tỷ lệ packet SYN trong flow/window
rst_ratio	float	Tỷ lệ packet RST
retransmission_rate	float	Tỷ lệ retransmission
dst_port_count	integer	Số port đích khác nhau
dns_qps	float	Tốc độ DNS query đại diện
packets, bytes	numeric	Quy mô flow
duration_ms	float	Thời lượng flow
protocol, site	category	Metadata kỹ thuật và vị trí

Trong ví dụ, bỏ sót flow cần điều tra có chi phí cao hơn tạo thêm một cảnh báo, nhưng precision vẫn quan trọng vì năng lực chuyên gia có giới hạn.

12.4.3 Thiết kế train-validation-test theo thời gian

Tập dữ liệu có 1.000 flow:

- 600 flow đầu: train;
- 200 flow tiếp: validation để chọn threshold;
- 200 flow cuối: test độc lập.

Positive rate trong ba phần lần lượt khoảng 17.8%, 18.0% và 18.5%. Tỷ lệ gần nhau trong dữ liệu tổng hợp, nhưng trong dữ liệu thật cần kiểm tra drift.

Các feature và transformer được khai báo như sau:

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

12.4.4 Pipeline và baseline

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Baseline luôn dự đoán lớp 0 nên accuracy có thể cao, nhưng recall của positive class bằng 0.

12.4.5 Confusion matrix và metric tại threshold 0.5

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Kết quả kiểm chứng:

Mô hình	TN	FP	FN	TP	F1
Baseline	163	0	37	0	0.000
Logistic, threshold 0.5	146	17	4	33	0.759
Decision Tree	134	29	11	26	0.565

Logistic Regression đạt precision 0.66, recall 0.892 và balanced accuracy khoảng 0.894 ở threshold 0.5.

12.4.6 Chọn threshold trên validation set

Yêu cầu vận hành đặt recall tối thiểu 0.80. Trong các threshold đáp ứng yêu cầu, chọn threshold có precision cao nhất trên validation set.

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Threshold được chọn là 0.70. Sau khi fit lại trên train+validation và chỉ đánh giá một lần trên test:

Threshold	TN	FP	FN	TP	Precision	Recall
0.70	155	8	7	30	0.789	0.811

F1 đạt 0.800 và balanced accuracy khoảng 0.881.

12.4.7 Đánh giá theo site và phân tích lỗi

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Metric tổng thể có thể che giấu site có recall thấp. Nếu một chi nhánh có rất ít positive sample, khoảng bất định lớn; không nên đưa ra kết luận mạnh chỉ từ vài trường hợp.

12.4.8 Kết luận, giới hạn và điều kiện sử dụng

Kết luận thống kê: threshold 0.70 đáp ứng recall khoảng 0.81 và precision khoảng 0.79 trên test tổng hợp.

Kết luận vận hành: prediction phù hợp để xếp hạng hoặc ưu tiên điều tra, không phù hợp để tự động cô lập thiết bị chỉ dựa trên một flow.

Giới hạn:

- nhãn tổng hợp dễ hơn ground truth thực;
- distribution có thể thay đổi theo site và thời gian;
- class weight và threshold ảnh hưởng workload;
- xác suất mô hình không mặc nhiên là xác suất đã calibration tốt.

Điều kiện sử dụng: cần human review, lưu lý do cảnh báo, giám sát false negative, đánh giá lại threshold và có cơ chế rollback.

12.5 Nghiên cứu tình huống 3: phân cụm và hành vi khác biệt

12.5.1 Bài toán khi không có nhãn

Tổ chức có dữ liệu flow nhưng chưa có nhãn đáng tin cậy. Hai mục tiêu được đặt ra:

1. khám phá các nhóm hành vi có profile khác nhau;
2. xếp hạng flow khác biệt để chọn mẫu phân tích sâu.

Không được gọi một cluster là “tấn công” chỉ vì cluster đó nhỏ hoặc có centroid khác biệt.

12.5.2 Feature và vai trò của scaling

Tập dữ liệu gồm 760 flow với 8 feature số:

- duration, packets, bytes và mean packet size;
- destination port count và SYN ratio;
- DNS query rate và inter-arrival time.

Bytes có thể lớn hơn SYN ratio hàng triệu lần về trị số. Nếu không scaling, khoảng cách Euclid gần như chỉ phản ánh feature có thang lớn.

12.5.3 Pipeline tiền xử lý

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Kết quả có shape (760, 8). Cột `hidden_profile` chỉ tồn tại trong dữ liệu tổng hợp để kiểm chứng sự phạm và không được đưa vào X .

12.5.4 Chọn số cụm bằng nhiều bằng chứng

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Kết quả minh họa:

k	Inertia	Silhouette
2	4613.8	0.446
3	3103.2	0.352
4	2096.7	0.426
5	1944.1	0.419
6	1615.7	0.424

Silhouette cao nhất ở $k = 2$, nhưng $k = 4$ cho bốn profile kỹ thuật rõ hơn và gần với các cơ chế sinh dữ liệu. Việc chọn k không nên chỉ dựa vào một số duy nhất.

12.5.5 Fit K-means và lập hồ sơ cluster

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Kích thước bốn cluster là 214, 205, 249 và 92 flow. Median profile cho phép đặt tên mô tả:

- Cluster có packets, bytes và duration cao: *bulk transfer*;
- Cluster có DNS QPS cao và packet nhỏ: *DNS/service intensive*;
- Cluster cân bằng, packet size trung bình: *interactive web*;
- Cluster có nhiều port đích và SYN ratio cao: *broad probing-like*.

Tên “probing-like” mô tả hình dạng dữ liệu, không khẳng định động cơ tấn công.

12.5.6 Khoảng cách tới centroid và percentile

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Khoảng cách percentile 95, 99 và maximum lần lượt khoảng 2.70, 7.20 và 12.62 trong không gian đã chuẩn hóa. Flow xa centroid là khác biệt so với cluster gần nhất, nhưng có thể là dữ liệu lỗi, trường hợp hợp lệ hiếm hoặc thay đổi vận hành.

12.5.7 So sánh với Isolation Forest

Mã đầy đủ trong notebook

Đoạn mã thực thi đầy đủ được chuyển sang notebook thực hành; phần thân giáo trình tập trung vào dữ liệu đầu vào, phép biến đổi và cách diễn giải kết quả.

Isolation Forest đánh dấu 19 flow theo tỷ lệ cấu hình 2.5%. Trong 20 flow xa centroid nhất, 13 flow đồng thời được Isolation Forest đánh dấu. Hai phương pháp đồng thuận ở một phần, nhưng không giống nhau vì chúng đo khái niệm khác nhau.

12.5.8 Kết luận, giới hạn và quy trình điều tra

Kết luận thống kê: bốn cluster có silhouette khoảng 0.426 và profile kỹ thuật diễn giải được.

Kết luận kỹ thuật: một nhóm nhỏ có destination port count và SYN ratio cao; nhóm khác có DNS QPS cao; nhóm bulk có duration và bytes lớn.

Quy trình tiếp theo:

1. Chọn flow đồng thuận giữa distance và Isolation Forest;
2. Kiểm tra dữ liệu gốc và missing value;
3. Đối chiếu asset, site, time, protocol và thay đổi cấu hình;
4. Đọc packet hoặc log liên quan khi được phép;
5. Chuyên gia xác nhận và tạo label nếu có đủ bằng chứng.

Giới hạn: cluster phụ thuộc feature, scaling, thời gian và tham số. Silhouette không đo ý nghĩa an ninh. Anomaly score không phải xác suất tấn công.

12.6 So sánh các quy trình và chuyển sang báo cáo

12.6.1 Điểm giống và khác nhau

Tiêu chí	Hỏi quy	Phân loại	Phân cụm
Target	Số thực	Nhãn lớp	Không có
Baseline	Mean/median	Lớp phổ biến	So sánh k , profile đơn giản
Metric	MAE, RMSE, R^2	Precision, recall, F1	Silhouette, stability
Output	Giá trị dự đoán	Nhãn/xác suất	Cluster/anomaly score
Lỗi trọng tâm	Residual lớn	FP và FN	Cụm khó diễn giải
Quyết định	Dự báo/cảnh báo hiệu năng	Ưu tiên điều tra	Chọn mẫu khám phá

12.6.2 Không có metric chung cho mọi bài toán

Không thể so sánh trực tiếp $R^2 = 0.95$, $F1=0.80$ và $silhouette=0.43$ để nói mô hình nào “tốt nhất”. Ba metric đo ba câu hỏi khác nhau.

Nhầm lẫn thường gặp

Sai: “Silhouette thấp hơn F1 nên phân cụm kém hơn phân loại.”

Đúng: phải đánh giá mỗi phương pháp theo mục tiêu, baseline, dữ liệu và chi phí sai của nó.

12.6.3 Từ notebook sang pipeline tái lập

Một pipeline có thể chuyển giao cần:

- File cấu hình feature và target;
- Phiên bản dữ liệu hoặc query tạo dữ liệu;
- Pipeline tiền xử lý và mô hình đã serialize;
- Metric, threshold và phạm vi áp dụng;
- Kiểm thử schema, dtype, range và category mới;
- Nhật ký prediction và phiên bản mô hình;
- Hướng dẫn fallback khi pipeline lỗi.

Không đưa notebook thử nghiệm trực tiếp vào production mà không tách cấu hình, kiểm thử và logging.

12.6.4 Kiểm soát quyền riêng tư và phạm vi dữ liệu

Ba case study không cần payload nội dung. Nên ưu tiên feature thống kê và metadata cần thiết. IP hoặc device ID có thể dùng để group split và điều tra nhưng cần:

- Phân quyền truy cập;
- Pseudonymization khi phù hợp;
- Retention giới hạn;
- Tách dữ liệu định danh khỏi tập huấn luyện;
- Ghi nhận mục đích sử dụng.

12.6.5 Giám sát sau triển khai

Nhóm giám sát	Ví dụ chỉ số	Hành động khi lệch
Schema	thiếu cột, dtype sai, category mới	chặn pipeline hoặc chuyển fallback
Input drift	median, percentile, PSI hoặc khoảng cách phân phối	điều tra nguồn dữ liệu và retrain khi cần
Prediction drift	mean prediction, positive rate, cluster size	kiểm tra thay đổi vận hành
Performance	MAE, recall, precision khi label đến	điều chỉnh threshold hoặc retrain
Hệ thống	latency, memory, error rate	rollback hoặc giảm tải

12.6.6 Human-in-the-loop và escalation

Human-in-the-loop không chỉ là “con người bấm duyệt”. Người review cần:

- Có thông tin để hiểu vì sao mẫu được chọn;
- Có quyền sửa hoặc từ chối quyết định;
- Cung cấp feedback có cấu trúc;
- Biết giới hạn và phạm vi của mô hình;
- Không bị quá tải bởi cảnh báo chất lượng thấp.

12.6.7 Mẫu báo cáo kết thúc nghiên cứu tình huống

1. Tóm tắt điều hành: câu hỏi, kết quả chính và khuyến nghị.
2. Dữ liệu: nguồn, thời gian, đơn vị quan sát, schema và giới hạn.
3. Phương pháp: split, baseline, pipeline và hyperparameter.
4. Kết quả: metric tổng thể, theo nhóm và biểu đồ.
5. Phân tích lỗi: residual, FP/FN hoặc flow khác biệt.
6. Rủi ro: leakage, drift, privacy, security và misuse.
7. Quyết định: sử dụng, thử nghiệm bóng, thu thập thêm dữ liệu hoặc dừng.

12.7 Bài tập tổng hợp

12.7.1 Nhóm A: xác định bài toán và dữ liệu

Bài 1. Một đơn vị muốn “dự đoán mạng có tốt không”. Hãy chuyển thành hai câu hỏi định lượng khác nhau.

Lời giải

Ví dụ 1: dự đoán RTT trung vị của 5 phút tiếp theo từ tải hiện tại, retransmission và access type. Đây là hồi quy.

Ví dụ 2: dự đoán time window có vi phạm ngưỡng SLA hay không. Đây là phân loại. Hai câu hỏi cần target, metric và quyết định khác nhau.

Bài 2. Vì sao flow_id thường không nên đưa vào mô hình?

Lời giải

Flow ID là định danh gần như duy nhất, ít có ý nghĩa khái quát và có thể làm mô hình ghi nhớ. Nó hữu ích cho truy vết kết quả về dữ liệu gốc nhưng nên giữ ở metadata.

Bài 3. Một feature “total retransmission của transaction” có dùng được để dự đoán page load ngay lúc request bắt đầu không?

Lời giải

Không. Feature đó chỉ hoàn tất sau transaction, nên gây temporal leakage cho dự đoán sớm. Có thể thay bằng retransmission gần đây của connection hoặc time window trước thời điểm dự đoán.

12.7.2 Nhóm B: hồi quy và residual

Bài 4. Baseline MAE là 500 ms, mô hình MAE là 108 ms. Mức giảm tương đối là bao nhiêu?

Lời giải

$$\frac{500 - 108}{500} \times 100\% = 78.4\%.$$

Mô hình giảm MAE khoảng 78.4% so với baseline. Cần báo cáo thêm RMSE và sai số theo nhóm.

Bài 5. Actual page load là 2.400 ms, prediction là 2.100 ms. Residual theo định nghĩa actual minus predicted bằng bao nhiêu?

Lời giải

$$2400 - 2100 = 300 \text{ ms.}$$

Residual dương cho biết mô hình dự đoán thấp hơn thực tế 300 ms.

Bài 6. R^2 cao nhưng MAE ở site mới gấp ba site cũ. Có nên triển khai đồng đều không?

Lời giải

Không nên chỉ dựa vào R^2 tổng thể. Cần kiểm tra số sample, distribution shift, feature availability và residual ở site mới; có thể triển khai bóng hoặc giới hạn phạm vi trước.

12.7.3 Nhóm C: phân loại và threshold

Bài 7. Với $TN=155$, $FP=8$, $FN=7$, $TP=30$, hãy tính precision và recall.

Lời giải

$$\text{Precision} = \frac{30}{30 + 8} = 0.789.$$

$$\text{Recall} = \frac{30}{30 + 7} = 0.811.$$

Precision phản ánh tỷ lệ cảnh báo đúng trong các prediction positive; recall phản ánh tỷ lệ positive thật được phát hiện.

Bài 8. Hạ threshold thường ảnh hưởng precision và recall thế nào?

Lời giải

Nhiều sample được dự đoán positive hơn, nên recall thường tăng và precision có thể giảm. Đây là xu hướng thường gặp, không phải định luật tuyệt đối cho mọi tập nhỏ.

Bài 9. Vì sao không được chọn threshold trực tiếp trên test set?

Lời giải

Vì test set sẽ tham gia vào quá trình tối ưu và không còn độc lập. Threshold nên chọn trên validation hoặc qua cross-validation phù hợp, sau đó test một lần.

12.7.4 Nhóm D: phân cụm và flow khác biệt

Bài 10. Silhouette của $k = 2$ cao hơn $k = 4$. Có bắt buộc chọn $k = 2$ không?

Lời giải

Không. Cần xem inertia, stability, cluster size, profile và mục tiêu sử dụng. $k = 4$ có thể hữu ích hơn nếu tạo ra các nhóm kỹ thuật rõ ràng và ổn định.

Bài 11. Một flow vừa nằm trong top 1% khoảng cách tới centroid vừa được Isolation Forest đánh dấu. Có thể kết luận là tấn công không?

Lời giải

Không. Hai phương pháp đồng thuận rằng flow khác biệt theo feature hiện tại. Cần kiểm tra dữ liệu gốc, asset, thời gian, giao thức và bằng chứng bổ sung.

Bài 12. Vì sao nên tính percentile trong từng cluster ngoài percentile toàn cục?

Lời giải

Cluster có độ phân tán khác nhau. Một khoảng cách vừa phải trong cluster rất chặt có thể đáng chú ý hơn khoảng cách lớn trong cluster vốn phân tán rộng.

12.7.5 Nhóm E: vận hành và trách nhiệm

Bài 13. Nêu ba thành phần cần giám sát sau triển khai.

Lời giải

Có thể chọn: schema/input, prediction distribution, performance khi label đến, latency hệ thống, error rate, workload cảnh báo và drift theo site.

Bài 14. Khi mô hình phân loại lỗi, fallback nào phù hợp?

Lời giải

Chuyển sang rule an toàn hoặc hàng đợi review thủ công, đồng thời ghi nhật ký lỗi và giữ phiên bản trước để rollback. Không nên âm thầm bỏ qua mọi flow.

Bài 15. Viết một cảnh báo sử dụng có trách nhiệm cho CS3.

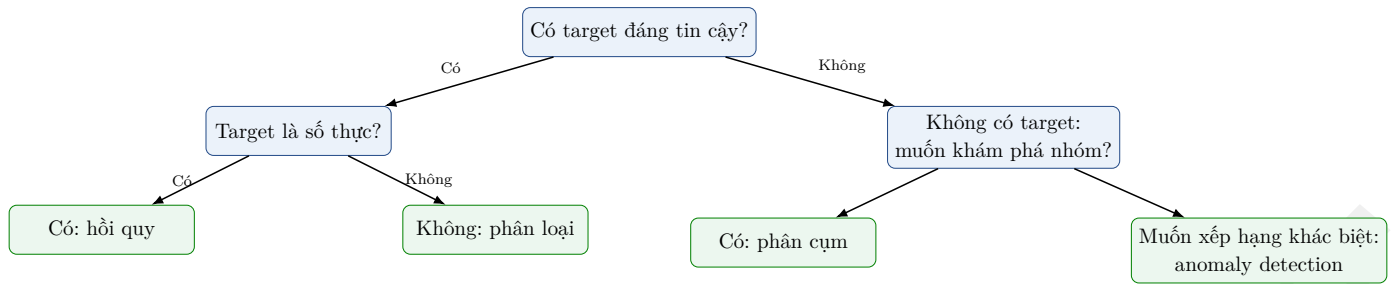
Lời giải

“Anomaly score và cluster chỉ dùng để ưu tiên mẫu kiểm tra. Kết quả không phải bằng chứng tấn công và không được dùng đơn độc để chặn thiết bị hoặc quy kết người dùng.”

12.8 Tổng kết chương**12.8.1 Tóm tắt chương**

- Một quy trình hoàn chỉnh bắt đầu từ quyết định và câu hỏi, không bắt đầu từ thuật toán.
- Đơn vị quan sát và thời điểm dự đoán quyết định feature nào hợp lệ.
- CS1 dùng hồi quy để ước lượng page load time và phân tích residual.
- CS2 dùng phân loại để ưu tiên flow cần điều tra và chọn threshold trên validation.
- CS3 dùng K-means và Isolation Forest để khám phá nhóm và xếp hạng flow khác biệt.
- Baseline là điều kiện bắt buộc để biết mô hình có tạo giá trị hay không.
- Metric phải gắn với chi phí sai và không thể so sánh trực tiếp giữa ba loại bài toán.
- Kết luận thống kê, kết luận kỹ thuật và quyết định vận hành phải được tách rõ.
- Mọi mô hình cần kiểm tra theo time, site, protocol hoặc entity quan trọng.
- Triển khai đòi hỏi pipeline tái lập, monitoring, fallback, rollback và human review.
- Quyền riêng tư, data minimization và phạm vi sử dụng phải được thiết kế từ đầu.

12.8.2 Bản đồ lựa chọn phương pháp



12.8.3 Câu hỏi trắc nghiệm

- Bước đầu tiên của một quy trình phân tích mạng nên là gì?
 - Chọn thuật toán phức tạp nhất.
 - Xác định câu hỏi và quyết định cần hỗ trợ.
 - Xóa mọi missing value.
 - Vẽ confusion matrix.
- CS1 sử dụng loại bài toán nào?
 - Hồi quy.
 - Phân loại.
 - Phân cụm.
 - Association rule.
- Residual được định nghĩa trong chương là gì?
 - Predicted trừ actual.
 - Actual trừ predicted.
 - Actual chia predicted.
 - MAE chia RMSE.
- Vì sao cần validation set trong CS2?
 - Để chọn threshold mà không sử dụng test set.
 - Để thay thế hoàn toàn training set.
 - Để không cần ground truth.
 - Để tăng số feature.
- Threshold 0.70 trong CS2 đạt recall xấp xỉ bao nhiêu?
 - 0.81.
 - 0.10.
 - 0.50.
 - 1.00.

6. Vì sao K-means cần scaling trong CS3?
 - A. Vì khoảng cách sẽ bị feature có thang lớn chi phối.
 - B. Vì scaling tạo nhân thật.
 - C. Vì K-means chỉ nhận số nguyên.
 - D. Vì scaling luôn làm silhouette bằng 1.
7. Flow xa centroid có ý nghĩa chắc chắn nào?
 - A. Chắc chắn là tấn công.
 - B. Khác biệt so với centroid của cluster gần nhất theo feature hiện tại.
 - C. Chắc chắn là dữ liệu lỗi.
 - D. Luôn phải bị chặn.
8. Metric nào phù hợp nhất để đo sai số hồi quy theo đơn vị millisecond?
 - A. MAE.
 - B. Precision.
 - C. Recall.
 - D. Silhouette.
9. Fallback có vai trò gì?
 - A. Cung cấp quy trình thay thế khi mô hình hoặc pipeline lỗi.
 - B. Làm mô hình không cần test.
 - C. Tự động gán mọi flow là positive.
 - D. Thay thế quyền riêng tư.
10. Kết luận nào đúng về ba case study?
 - A. Metric cao tự động cho phép ra quyết định hoàn toàn tự động.
 - B. Kết quả cần được đọc cùng bối cảnh mạng, giới hạn dữ liệu và chi phí sai.
 - C. Cluster nhỏ luôn là tấn công.
 - D. R^2 và F1 có thể so sánh trực tiếp.

12.8.4 Đáp án và giải thích

1. **Đáp án đúng:** B. Câu hỏi và quyết định xác định dữ liệu, target, metric và phạm vi.
2. **Đáp án đúng:** A. Target page load time là biến số thực nên dùng hồi quy.
3. **Đáp án đúng:** B. Chương dùng residual bằng actual trừ predicted.
4. **Đáp án đúng:** A. Threshold là một lựa chọn mô hình; test phải giữ độc lập.
5. **Đáp án đúng:** A. Recall test xấp xỉ 0.811.
6. **Đáp án đúng:** A. Feature có thang lớn sẽ chi phối khoảng cách Euclid nếu không scaling.
7. **Đáp án đúng:** B. Khoảng cách chỉ phản ánh khác biệt hình học trong representation hiện tại.

8. **Đáp án đúng:** A. MAE có cùng đơn vị với target, ở đây là millisecond.
9. **Đáp án đúng:** A. Fallback giúp hệ thống tiếp tục hoạt động an toàn khi mô hình lỗi.
10. **Đáp án đúng:** B. Mọi kết quả phải được diễn giải trong bối cảnh và giới hạn cụ thể.

Phụ lục A

Phân tích gói tin với Wireshark

Sau khi hoàn thành phần này, người học có thể

- Hiểu Wireshark là công cụ quan sát packet, không phải một nội dung độc lập thay thế kiến thức TCP/IP.
- Chọn đúng interface, phân biệt capture filter và display filter, đọc ba vùng Packet List–Packet Details–Packet Bytes.
- Đọc được các field cốt lõi của Ethernet, IPv4/IPv6, ARP, ICMP, TCP, UDP, DNS và TLS ở mức phục vụ giáo trình.
- Sử dụng một số filter tối thiểu để thu hẹp dữ liệu và theo dõi một conversation/stream.
- Xuất một bảng nhỏ phục vụ phân tích bằng Python mà không làm mất ngữ cảnh của dữ liệu.
- Nhận biết các giới hạn của packet capture và tránh suy luận vượt quá bằng chứng quan sát được.

Vai trò của công cụ Wireshark trong giáo trình

Người học không cần thành thạo Wireshark để hiểu 12 chương chính, Wireshark chỉ giúp người học quan sát trực tiếp những header/field đã học và, khi cần, chuyển một lượng dữ liệu nhỏ từ packet capture sang dạng bảng. Wireshark không được coi là nguồn thông tin tuyệt đối: kết quả luôn phụ thuộc vị trí capture, interface, filter, offloading và khoảng thời gian quan sát.

A.1 Vai trò, phạm vi và nguyên tắc sử dụng

A.1.1 Wireshark quan sát điều gì?

Wireshark (Wireshark) là phần mềm phân tích giao thức mạng có khả năng đọc packet từ một interface đang hoạt động hoặc từ tệp capture như PCAP/PCAPNG. Nó hiển thị packet theo nhiều tầng, giải mã các trường header và cung cấp công cụ lọc, thống kê, theo dõi stream.

Một packet capture khác với một flow record. Capture giữ nhiều byte/header ở mức packet; flow thường tổng hợp nhiều packet thành một bản ghi như số packet, số byte, thời lượng, địa chỉ và port. Log lại mô tả sự kiện do hệ thống hoặc ứng dụng ghi nhận. Ba loại dữ liệu trả lời các câu hỏi khác nhau.

Ví dụ đời thường: camera tại một nút giao

Một camera ở một nút giao chỉ thấy phương tiện đi qua vị trí đó trong thời gian camera hoạt động. Nó không tự biết toàn bộ hành trình của xe trước và sau nút giao. Packet capture cũng vậy: dữ liệu chỉ phản ánh những gì đi qua điểm quan sát.

Giới hạn của phép so sánh: packet capture còn phụ thuộc driver, offloading, encryption và filter; vì vậy ngay cả packet đi qua máy cũng có thể không xuất hiện đúng như người dùng kỳ vọng.

A.1.2 Phạm vi hợp pháp, quyền riêng tư và tối thiểu hóa dữ liệu

Chỉ capture trên hệ thống, mạng hoặc dữ liệu mà người học được phép quan sát. Không đưa tệp capture của hệ thống thật vào báo cáo công khai nếu chưa loại bỏ thông tin nhạy cảm. Payload có thể chứa credential, cookie, token, tên miền nội bộ, địa chỉ và dữ liệu cá nhân.

Góc nhìn an toàn, an ninh mạng

Ưu tiên capture ngắn, có mục tiêu; dùng filter để giảm dữ liệu không liên quan; lưu bản gốc trong vị trí kiểm soát; chỉ xuất các field cần thiết cho câu hỏi phân tích. Khi chia sẻ dữ liệu, cần xem cả metadata, không chỉ payload.

A.1.3 Quy trình bảy bước

1. Viết câu hỏi kỹ thuật cụ thể, ví dụ “máy đã nhận DNS response chưa?”.
2. Xác nhận quyền quan sát và dữ liệu cần bảo vệ.
3. Chọn điểm capture và interface phù hợp.
4. Capture trong khoảng thời gian ngắn; chỉ dùng capture filter khi có lý do rõ ràng.
5. Dùng display filter để thu hẹp packet sau khi capture.
6. Đọc Packet Details cùng bối cảnh trước/sau; chỉ dùng Statistics/Follow Stream khi cần.
7. Ghi kết luận kèm phạm vi, filter, thời gian và giới hạn của bằng chứng.

A.2 Giao diện, interface và phiên capture đầu tiên

A.2.1 Chọn interface đúng

Interface phù hợp thường là Ethernet khi nối dây, Wi-Fi khi dùng WLAN, loopback khi quan sát dịch vụ chạy trên cùng máy, hoặc adapter VPN/ảo hóa khi lưu lượng đi qua lớp đó. Không chọn interface chỉ dựa vào tên; hãy tạo một hoạt động nhỏ, ví dụ truy cập một trang web thử nghiệm hoặc ping gateway, rồi quan sát interface nào thay đổi lưu lượng.

A.2.2 Ba vùng đọc packet

Packet List: mỗi dòng là một packet và các cột tóm tắt

Packet Details: cây giao thức và các field theo tầng

Packet Bytes: byte thô tương ứng với vùng đang chọn

Khi học giao thức, Packet Details là vùng quan trọng nhất. Hãy mở lần lượt Frame, Ethernet, IP, TCP/UDP và Application protocol rồi đối chiếu với header diagram trong giáo trình. Packet Bytes hữu ích để thấy rằng các field cuối cùng được mã hóa thành byte, nhưng không cần ghi nhớ offset bằng tay trong môn học này.

A.2.3 Các cột tối thiểu cần hiểu

Cột	Ý nghĩa
No.	Số thứ tự packet trong tệp/capture, không phải số sequence TCP.
Time	Thời điểm tương đối hoặc tuyệt đối tùy cấu hình hiển thị.
Source / Destination	Địa chỉ được dissector chọn để tóm tắt, cần nhìn tầng để hiểu MAC hay IP.
Protocol	Giao thức Wireshark nhận diện ở mức hiển thị.
Length	Độ dài frame/packet theo ngữ cảnh cột; cần đọc tên field khi cần chính xác.
Info	Tóm tắt; hữu ích để định hướng nhưng không thay thế Packet Details.

Nhầm lẫn thường gặp

Cột “Protocol = TLS” không có nghĩa các tầng IP/TCP biến mất. Wireshark chọn một giao thức để tóm tắt ở cột Protocol; các tầng bên dưới vẫn tồn tại trong Packet Details.

A.3 Capture filter và display filter

A.3.1 Sự khác biệt

	Capture filter	Display filter
Thời điểm	Trước/khi capture	Sau khi packet đã được capture
Tác dụng	Quyết định packet nào được ghi	Quyết định packet nào được hiển thị
Cú pháp	BPF/libpcap style	Cú pháp field của Wireshark
Rủi ro	Filter sai có thể làm mất dữ liệu không thể phục hồi	Có thể thay đổi filter và quay lại toàn bộ tệp
Khuyến nghị	Dùng khi cần giảm dữ liệu ngay từ đầu	Ưu tiên cho bài học và phân tích ngắn

A.3.2 Capture filter tối thiểu

```
host 192.0.2.10
net 192.168.1.0/24
port 53
tcp port 443
udp port 53
arp or icmp
```

Port phải đi cùng ngữ cảnh transport. Ví dụ `port 53` có thể gồm TCP hoặc UDP; nếu câu hỏi chỉ quan tâm DNS qua UDP, dùng `udp port 53`.

A.3.3 Display filter tối thiểu

```
arp
icmp || icmpv6
ip.addr == 192.0.2.10
ipv6.addr == 2001:db8::10
tcp.port == 443
udp.port == 53
dns
tls
frame.len > 1000
tcp.flags.syn == 1 && tcp.flags.ack == 0
```

Một tên field như `ip.src` chỉ nguồn; `ip.dst` chỉ đích; `ip.addr` thường khớp cả hai hướng. Tương tự, `tcp.port` khớp source hoặc destination port.

Nhầm lẫn thường gặp

Không viết `tcp port 80 or 443` như một biểu thức mơ hồ. Với capture filter, hãy viết rõ `tcp port 80 or tcp port 443`. Với display filter, dùng `tcp.port == 80 || tcp.port == 443`.

A.4 Đọc các giao thức cốt lõi

A.4.1 Ethernet, ARP và IP

Khi chọn một frame Ethernet, kiểm tra *địa chỉ MAC đích* (destination MAC address), *địa chỉ MAC nguồn* (source MAC address) và EtherType. Với ARP, đối chiếu operation, sender/target protocol address và hardware address. Với IPv4, tập trung Version, Header Length, Total Length, TTL, Protocol, Source và Destination. Với IPv6, tập trung Version, Payload Length, Next Header, Hop Limit và địa chỉ nguồn/đích.

Filter gợi ý

```
eth.addr == 00:11:22:33:44:55 arp ip.ttl <= 5 ipv6
```

A.4.2 ICMP

Với ping, kiểm tra ICMP Echo Request/Echo Reply, identifier/sequence khi cần và cặp địa chỉ IP. Với traceroute, chú ý ICMP Time Exceeded có thể xuất hiện từ router trung gian. RTT hiển thị trong công cụ là kết quả của phép đo ở vị trí capture; không đồng nhất với toàn bộ delay một chiều.

A.4.3 TCP

Để đọc TCP, tập trung:

- source/destination port;
- sequence number và acknowledgment number;
- SYN, ACK, FIN, RST;
- window;
- TCP options như MSS, Window Scale, SACK Permitted khi xuất hiện.

Để tìm SYN mở kết nối:

```
tcp.flags.syn == 1 && tcp.flags.ack == 0
```

Wireshark có các field phân tích như `tcp.analysis.retransmission`; chúng là kết quả suy luận của dissector từ dữ liệu quan sát được, không phải bit nằm trong TCP header.

A.4.4 UDP, DNS và DHCP

UDP chỉ có bốn field header chính: source port, destination port, length và checksum. Với DNS, xem transaction ID, flags, Questions và Answers. Với DHCP, theo dõi chuỗi Discover–Offer–Request–Ack và các option quan trọng như địa chỉ cấp phát, gateway, DNS server và lease time.

A.4.5 HTTP và TLS

Với HTTP không mã hóa, có thể đọc method, URI, status code và header. Với HTTPS, payload ứng dụng thường được mã hóa sau handshake; vẫn có thể quan sát metadata ở các tầng thấp hơn. Khi xem TLS handshake, chỉ cần liên hệ các message/certificate với mục tiêu xác thực và thiết lập bí mật phiên; không suy ra nội dung HTTP từ payload mã hóa.

A.5 Theo dõi stream, thống kê và xuất dữ liệu

A.5.1 Follow Stream

Follow TCP/UDP Stream giúp gom dữ liệu thuộc một stream để đọc theo hướng hội thoại. Chỉ sử dụng khi nội dung được phép quan sát. Không đưa ảnh stream thật lên báo cáo công khai nếu có token, cookie, credential hoặc dữ liệu cá nhân.

A.5.2 Protocol Hierarchy, Endpoints và Conversations

- Protocol Hierarchy cho biết thành phần giao thức trong phạm vi capture.
- Endpoints tổng hợp theo địa chỉ/endpoint quan sát được.
- Conversations tổng hợp giữa cặp endpoint.

Các bảng này chỉ mô tả phạm vi capture, không cho phép suy luận rằng một host là “top talker của toàn mạng” nếu chỉ có 30 giây dữ liệu từ một điểm quan sát.

A.5.3 Xuất bảng nhỏ phục vụ Python

Khi cần chuyển sang phân tích dữ liệu, nên xác định trước một hàng đại diện cho gì và chỉ xuất field cần thiết, ví dụ:

Time	src IP	dst IP	protocol	length	TCP flags/port
0.000	192.0.2.10	198.51.100.20	TCP	74	SYN, 443
0.031	198.51.100.20	192.0.2.10	TCP	74	SYN-ACK
0.032	192.0.2.10	198.51.100.20	TCP	66	ACK

Nguyên tắc quan trọng

Một bảng CSV xuất từ Wireshark không tự động là “dataset ML”. Cần xác định observation, feature, target, phạm vi thời gian và nguy cơ leakage trước khi dùng cho mô hình. Các bước đó được học trong Chương 9 và Chương 11.

A.6 Một quy trình phân tích hoàn chỉnh

A.6.1 Tình huống: truy cập website không thành công

Giả sử trình duyệt báo không mở được website. Không bắt đầu bằng việc lọc hàng chục giao thức. Hãy tách câu hỏi theo chuỗi chức năng:

1. Máy đã có cấu hình IP/gateway chưa?
2. Máy có phân giải được tên miền không?
3. Có TCP/QUIC connection đến server không?
4. TLS handshake có hoàn tất không?
5. Nếu HTTP quan sát được, server trả status nào?

A.6.2 Các bước quan sát

1. Capture ngắn trong khi tái hiện lỗi.
2. Dùng `dns` để xem query/response. Nếu không có response, phân tích DNS trước khi nghĩ tới HTTP.

3. Nếu DNS thành công, lọc theo IP đích hoặc `tcp.port == 443 || udp.port == 443`.
4. Với TCP, kiểm tra SYN–SYN/ACK–ACK. Nếu chỉ có SYN lặp lại, chưa có bằng chứng rằng ứng dụng server đã nhận request.
5. Nếu handshake thành công, xem TLS. Nếu handshake thất bại, đọc alert/certificate ở mức được phép.
6. Ghi kết luận theo bằng chứng: “không thấy SYN/ACK trong phạm vi capture” tốt hơn “server chết”.

Kết luận đúng mức

“Trong capture tại laptop từ 10:00:00 đến 10:00:20, DNS trả về 198.51.100.20. Laptop gửi ba SYN tới 198.51.100.20:443 nhưng không quan sát được SYN/ACK. Dữ liệu này cho thấy TCP connection chưa thiết lập tại điểm quan sát; chưa đủ để kết luận nguyên nhân nằm ở server, firewall hay đường truyền.”

A.7 Tra cứu nhanh và giới hạn cần nhớ

Mục tiêu	Display filter gợi ý
ARP	<code>arp</code>
Ping IPv4	<code>icmp</code>
Ping/ICMPv6	<code>icmpv6</code>
Một IPv4 host	<code>ip.addr == 192.0.2.10</code>
Một TCP port	<code>tcp.port == 443</code>
Một UDP port	<code>udp.port == 53</code>
SYN mở kết nối	<code>tcp.flags.syn == 1 && tcp.flags.ack == 0</code>
TCP retransmission do Wireshark suy luận	<code>tcp.analysis.retransmission</code>
DNS	<code>dns</code>
TLS	<code>tls</code>
Frame lớn	<code>frame.len > 1000</code>

Sáu giới hạn cần nhớ

1. Không thấy packet không đồng nghĩa packet không tồn tại ở nơi khác trên đường đi.
2. Checksum bị đánh dấu sai trên endpoint có thể liên quan checksum offloading.
3. Encryption che payload nhưng không che toàn bộ metadata.
4. Port gợi ý dịch vụ, không chứng minh ứng dụng.
5. “Retransmission” trong Wireshark là suy luận phân tích, không phải TCP flag.
6. Thống kê chỉ đúng trong phạm vi capture, filter và thời gian đã chọn.

Phụ lục B

Thuật ngữ, bản đồ giao thức và port thường gặp

Sau khi hoàn thành phần này, người học có thể

- Tra nhanh tầng, PDU, địa chỉ và vai trò của các giao thức cốt lõi trong giáo trình.
- Phân biệt được những cặp thuật ngữ dễ nhầm như bandwidth–throughput–goodput, packet–frame, flow–connection, authentication–authorization.
- Tra cứu các port phổ biến nhưng hiểu rằng port chỉ là một dấu hiệu, không chứng minh ứng dụng đang chạy.
- Dùng thống nhất quy ước thuật ngữ của V2: lần đầu ưu tiên dạng *tiếng Việt* (English); tên API, tên field, biến và protocol identifier giữ nguyên khi cần chính xác.

B.1 Bản đồ TCP/IP năm tầng

Tầng	PDU hình	điểm	Định danh/địa chỉ	Ví dụ giao thức/công nghệ
Application	message		tên miền, URI, identifier ứng dụng	HTTP, DNS, DHCP, TLS, SSH, SMTP
Transport	TCP segment / UDP data-gram		port	TCP, UDP, QUIC ở cách nhìn kiến trúc phù hợp
Network	IP packet		IPv4/IPv6 address	IPv4, IPv6, ICMP, routing
Data Link	frame		MAC/BSSID	Ethernet, Wi-Fi, VLAN
Physical	bit/signal		–	cáp đồng/quang, radio PHY

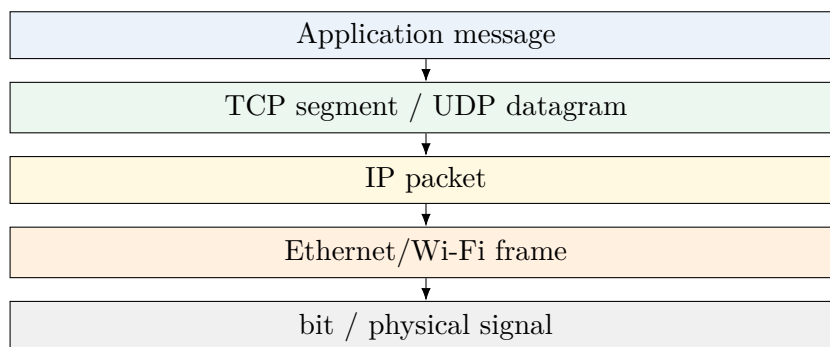
Ghi chú

ARP/Neighbor Discovery nằm ở ranh giới chức năng giữa Network và Data Link tùy mô hình trình bày. Trong giáo trình, điều quan trọng là hiểu chúng giải quyết ánh xạ/neighbor resolution trên liên kết cục bộ, thay vì tranh luận máy móc “thuộc tầng mấy”.

B.2 Protocol profiles tra cứu nhanh

Tầng	Protocol	PDU	Định danh chính	Port/ghi chú
Application	HTTP	message	Tên/URI; không có địa chỉ tầng riêng	80/TCP (HTTP), 443/TCP or UDP (HTTPS/HTTP3)
Application	DNS	DNS message	Domain name	53/UDP, 53/TCP
Application	DHCP	message	Client identifier/IP parameters	67/UDP server, 68/UDP client
Application	TLS	TLS message	Certificate/name theo ngữ cảnh	Thường 443/TCP khi dùng HTTPS
Transport	TCP	segment	Port	Nhiều application protocols
Transport	UDP	datagram	Port	Nhiều application protocols
Network	IPv4/IPv6	packet	IP address	Protocol/Next Header chỉ transport/control
Network	ICMP/ICMPv6	control message	IP address	Không dùng TCP/UDP port
Data Link	Ethernet	frame	MAC address	EtherType chỉ payload tầng trên
Data Link	Wi-Fi	frame	MAC/BSSID theo frame	Không dùng TCP/UDP port ở chính tầng này
Physical	Ethernet PHY/Wi-Fi PHY	bit/signal	Không có địa chỉ logic	Không dùng port

B.2.1 Chuỗi encapsulation cần nhớ



B.3 Port và dịch vụ thường gặp

Port không phải bằng chứng nhận dạng tuyệt đối

Server có thể chạy dịch vụ trên port không mặc định; proxy, NAT, tunnel và container có thể làm ánh xạ khác đi; một số protocol có thể dùng nhiều transport/port. Vì vậy, port là manh mối để phân tích, không phải nhãn tuyệt đối cho ứng dụng.

Port / Trans- port	Dịch vụ thường gặp	Ghi chú
20/TCP	FTP data (kiểu truyền chủ động, lịch sử)	Không nên nhận dạng ứng dụng chỉ theo port.
21/TCP	FTP control	FTP thường không phù hợp cho dữ liệu nhạy cảm nếu không có bảo vệ bổ sung.
22/TCP	SSH	Quản trị từ xa/SFTP/SCP tùy ứng dụng.
25/TCP	SMTP	Chuyển thư giữa mail server; submission hiện đại thường dùng port khác.
53/UDP, TCP	DNS	UDP phổ biến; TCP dùng cho trường hợp cần thiết như response lớn/zone transfer theo ngữ cảnh.
67/UDP	DHCPv4 server	Đi với port 68 client.
68/UDP	DHCPv4 client	Đi với port 67 server.
80/TCP	HTTP	Web không mã hóa ở transport/application payload.
110/TCP	POP3	Truy cập thư; bản bảo vệ thường dùng TLS/port khác.
123/UDP	NTP	Đồng bộ thời gian.
143/TCP	IMAP	Truy cập hộp thư; bản bảo vệ thường dùng 993.

Port / Trans- port	Dịch vụ thường gặp	Ghi chú
161/UDP	SNMP	Truy vấn/management; SNMPv3 cung cấp cơ chế bảo vệ tốt hơn phiên bản cũ.
162/UDP	SNMP Trap/Inform	Thông báo quản lý.
443/TCP	HTTPS	HTTP over TLS phổ biến.
443/UDP	HTTP/3/QUIC	QUIC chạy trên UDP; port 443 thường dùng cho HTTP/3.
465/TCP	Mail submission over implicit TLS (sử dụng phổ biến)	Cần kiểm tra cấu hình provider.
587/TCP	Message submission	SMTP submission; thường nâng cấp TLS bằng STARTTLS theo cấu hình.
993/TCP	IMAPS	IMAP over TLS.
995/TCP	POP3S	POP3 over TLS.

B.4 Các cặp thuật ngữ dễ nhầm

Thuật ngữ 1	Thuật ngữ 2	Phân biệt
<i>băng thông</i> (bandwidth)	<i>thông lượng</i> (throughput)	Bandwidth/capacity mô tả khả năng hoặc tài nguyên; throughput là tốc độ thực tế quan sát được.
<i>thông lượng</i> (throughput)	<i>thông lượng hữu ích</i> (goodput)	Throughput có thể gồm overhead/retransmission; goodput chỉ payload hữu ích theo định nghĩa.
<i>gói tin</i> (packet)	<i>khung</i> (frame)	Packet thuộc Network; frame thuộc Data Link và thay đổi theo từng liên kết.
<i>địa chỉ IP</i> (IP address)	<i>địa chỉ MAC</i> (MAC address)	IP dùng định tuyến end-to-end logic; MAC chủ yếu trong phạm vi link/LAN.
<i>chuyển tiếp</i> (forwarding)	<i>định tuyến</i> (routing)	Forwarding là quyết định per-packet; routing xây/chọn thông tin đường đi.
<i>luồng</i> (flow)	<i>kết nối TCP</i> (TCP connection)	Flow là khái niệm phân nhóm packet do người phân tích định nghĩa; TCP connection có state/protocol semantics cụ thể.

Thuật ngữ 1	Thuật ngữ 2	Phân biệt
<i>port</i> (port)	<i>socket</i> (socket)	Port là số định danh transport; socket là endpoint phần mềm có thêm protocol/address/context.
<i>điều khiển luồng</i> (flow control)	<i>điều khiển tắc nghẽn</i> (congestion control)	Flow control bảo vệ receiver; congestion control phản ứng khả năng đường/mạng.
<i>xác thực</i> (authentication)	<i>phân quyền</i> (authorization)	Authentication xác minh ai; authorization quyết định được phép làm gì.
<i>sự kiện</i> (event)	<i>cảnh báo</i> (alert)	Event là hoạt động quan sát được; alert là event/pattern được gán mức cần chú ý.
<i>cảnh báo</i> (alert)	<i>sự cố</i> (incident)	Alert chưa chắc là incident; incident cần đánh giá tác động và xử lý.
<i>đặc trưng</i> (feature)	<i>biến mục tiêu</i> (target)	Feature là đầu vào; target là giá trị cần dự đoán/học.
<i>fit</i> (fit)	<i>transform</i> (transform)	fit học tham số; transform áp dụng phép biến đổi đã học.
<i>phân loại</i> (classification)	<i>phân cụm</i> (clustering)	Classification học label; clustering nhóm dữ liệu không cần label có sẵn.
<i>bất thường</i> (anomaly)	<i>tấn công</i> (attack)	Anomaly chỉ khác biệt theo dữ liệu/model; không tự chứng minh malicious behavior.
<i>precision</i> (precision)	<i>recall</i> (recall)	Precision hỏi “các dự đoán dương đúng bao nhiêu”; recall hỏi “các ca dương thật bắt được bao nhiêu”.

B.5 Thuật ngữ Việt–Anh chọn lọc

B.5.1 Kiến trúc và phân tầng

Tiếng Việt	English	Nghĩa ngắn
<i>mạng máy tính</i>	computer network	Hệ thống các thiết bị và liên kết trao đổi dữ liệu theo giao thức.
<i>giao thức</i>	protocol	Quy tắc, định dạng và thủ tục trao đổi giữa các thực thể cùng tầng.
<i>tầng</i>	layer	Nhóm chức năng có ranh giới tương đối rõ trong kiến trúc mạng.

Tiếng Việt	English	Nghĩa ngắn
<i>dịch vụ</i>	service	Khả năng một tầng cung cấp cho tầng trên.
<i>giao diện</i>	interface	Ranh giới/cách tầng trên sử dụng dịch vụ tầng dưới.
<i>đóng gói</i>	encapsulation	Thêm header/trailer khi dữ liệu đi xuống các tầng.
<i>tháo gói</i>	decapsulation	Đọc/bỏ thông tin điều khiển khi dữ liệu đi lên các tầng.
<i>đơn vị dữ liệu giao thức</i>	Protocol Data Unit, PDU	Đơn vị dữ liệu được xử lý ở một tầng.
<i>dữ liệu dịch vụ</i>	Service Data Unit, SDU	Dữ liệu tầng trên giao cho tầng dưới trước khi thêm header.
<i>thông điệp</i>	message	Dữ liệu ở mức ứng dụng trong ngữ cảnh tổng quát.
<i>segment TCP</i>	TCP segment	PDU TCP.
<i>datagram UDP</i>	UDP datagram	PDU UDP.
<i>packet IP</i>	IP packet	PDU tầng Network.
<i>frame</i>	frame	PDU tầng Data Link.
<i>bit</i>	bit	Đơn vị nhị phân 0/1 ở mức biểu diễn cơ bản.
<i>payload</i>	payload	Phần dữ liệu được mang bởi một PDU, không gồm overhead của chính tầng đó.
<i>header</i>	header	Thông tin điều khiển đặt trước payload.
<i>trailer</i>	trailer	Thông tin điều khiển đặt sau payload, ví dụ FCS.
<i>overhead</i>	overhead	Phần dữ liệu điều khiển không phải payload ứng dụng.
<i>mô hình OSI</i>	OSI model	Mô hình tham chiếu bảy tầng.
<i>mô hình TCP/IP</i>	TCP/IP model	Mô hình kiến trúc gắn với bộ giao thức Internet.
<i>mô hình Internet năm tầng</i>	five-layer Internet model	Application, Transport, Network, Data Link, Physical.

B.5.2 Truyền dẫn và liên kết

Tiếng Việt	English	Nghĩa ngắn
<i>tầng vật lý</i>	Physical layer	Truyền bit bằng tín hiệu trên môi trường vật lý.
<i>tầng liên kết dữ liệu</i>	Data Link layer	Truyền frame trên một liên kết cục bộ.

Tiếng Việt	English	Nghĩa ngắn
<i>Ethernet</i>	Ethernet	Họ công nghệ LAN IEEE 802.3.
<i>địa chỉ MAC</i>	MAC address	Địa chỉ lớp liên kết dùng trong phạm vi liên kết/LAN.
<i>EtherType</i>	EtherType	Trường Ethernet chỉ giao thức payload tầng trên.
<i>FCS</i>	Frame Check Sequence, FCS	Trường kiểm tra lỗi frame Ethernet.
<i>MTU</i>	Maximum Transmission Unit, MTU	Kích thước payload tối đa một công nghệ liên kết chuyển mà không cần phân mảnh ở lớp phù hợp.
<i>switch</i>	switch	Thiết bị chuyển frame theo thông tin tầng liên kết.
<i>bảng MAC</i>	MAC address table	Bảng switch ánh xạ MAC với port.
<i>học địa chỉ MAC</i>	MAC learning	Switch học source MAC từ frame đến.
<i>VLAN</i>	Virtual LAN, VLAN	Phân đoạn logic ở tầng liên kết.
<i>broadcast</i>	broadcast	Truyền tới mọi nút trong phạm vi broadcast domain phù hợp.
<i>unicast</i>	unicast	Truyền từ một nguồn tới một đích.
<i>multicast</i>	multicast	Truyền tới một nhóm đích đăng ký/quan tâm.
<i>thời gian truyền dẫn</i>	transmission delay	Thời gian đẩy L bit lên link, L/R.
<i>thời gian lan truyền</i>	propagation delay	Thời gian tín hiệu lan qua khoảng cách vật lý.
<i>mạng LAN</i>	Local Area Network, LAN	Mạng trong phạm vi cục bộ.
<i>mạng WLAN</i>	Wireless LAN, WLAN	LAN sử dụng liên kết vô tuyến.
<i>điểm truy cập</i>	access point, AP	Thiết bị kết nối client Wi-Fi vào hạ tầng WLAN.
<i>SSID</i>	Service Set Identifier, SSID	Tên logic của mạng Wi-Fi.
<i>BSSID</i>	Basic Service Set Identifier, BSSID	Định danh BSS, thường liên quan MAC của radio/AP.
<i>RSSI</i>	Received Signal Strength Indicator, RSSI	Chỉ số cường độ tín hiệu nhận.
<i>SNR</i>	Signal-to-Noise Ratio, SNR	Tỷ số tín hiệu trên nhiễu.
<i>CSMA/CA</i>	Carrier Sense Multiple Access with Collision Avoidance	Cơ chế truy nhập kênh của Wi-Fi theo hướng tránh va chạm.
<i>retry</i>	retry	Truyền lại frame/packet theo cơ chế của tầng tương ứng.

Tiếng Việt	English	Nghĩa ngắn
<i>roaming</i>	roaming	Client chuyển giữa các AP/BSS trong cùng hệ thống WLAN.

B.5.3 IP và định tuyến

Tiếng Việt	English	Nghĩa ngắn
<i>tầng mạng</i>	Network layer	Địa chỉ logic và chuyển packet qua nhiều mạng.
<i>địa chỉ IPv4</i>	IPv4 address	Địa chỉ 32 bit của IPv4.
<i>địa chỉ IPv6</i>	IPv6 address	Địa chỉ 128 bit của IPv6.
<i>prefix</i>	prefix	Phần bit đầu dùng để xác định mạng/subnet.
<i>CIDR</i>	Classless Inter-Domain Routing, CIDR	Biểu diễn địa chỉ/prefix không phụ thuộc classful addressing.
<i>subnet</i>	subnet	Mạng con xác định bởi prefix.
<i>subnet mask</i>	subnet mask	Mask IPv4 biểu diễn bit network/host.
<i>địa chỉ mạng</i>	network address	Địa chỉ đại diện prefix/subnet.
<i>địa chỉ broadcast</i>	broadcast address	Địa chỉ broadcast IPv4 của subnet truyền thống.
<i>default gateway</i>	default gateway	Router mà host gửi packet khi đích ngoài subnet trực tiếp.
<i>TTL</i>	Time To Live, TTL	Trường IPv4 giảm qua mỗi router để giới hạn vòng lặp.
<i>Hop Limit</i>	Hop Limit	Trường IPv6 tương đương chức năng TTL theo hop.
<i>ARP</i>	Address Resolution Protocol, ARP	Ánh xạ IPv4 cục bộ sang địa chỉ lớp liên kết.
<i>Neighbor Discovery</i>	Neighbor Discovery, ND	Cơ chế IPv6 cho discovery/neighbor resolution và chức năng liên quan.
<i>ICMP</i>	Internet Control Message Protocol, ICMP	Thông điệp điều khiển/chẩn đoán cho IP.
<i>ping</i>	ping	Công cụ thường dùng ICMP Echo để kiểm tra reachability/RTT.
<i>traceroute</i>	traceroute	Kỹ thuật suy ra các hop bằng TTL/Hop Limit và phản hồi điều khiển.
<i>router</i>	router	Thiết bị chuyển packet giữa các mạng.
<i>chuyển tiếp</i>	forwarding	Quyết định per-packet chọn next hop/output interface.

Tiếng Việt	English	Nghĩa ngắn
<i>định tuyến</i>	routing	Quá trình xây dựng/chọn đường và thông tin trong routing table.
<i>bảng định tuyến</i>	routing table	Bảng prefix/next hop/interface/-metric phục vụ forwarding.
<i>khớp tiền tố dài nhất</i>	longest-prefix matching	Chọn route có prefix khớp cụ thể nhất.
<i>default route</i>	default route	Route dùng khi không có prefix cụ thể hơn.
<i>next hop</i>	next hop	Router/nút kế tiếp trên đường chuyển packet.
<i>metric định tuyến</i>	routing metric	Giá trị dùng so sánh/chọn route trong một giao thức.
<i>OSPF</i>	Open Shortest Path First, OSPF	IGP link-state phổ biến.
<i>BGP</i>	Border Gateway Protocol, BGP	Giao thức định tuyến liên miền dựa trên chính sách/path attributes.
<i>NAT</i>	Network Address Translation, NAT	Biến đổi địa chỉ IP qua thiết bị trung gian.
<i>PAT</i>	Port Address Translation, PAT	NAT dùng thêm port để ghép nhiều kết nối.
<i>địa chỉ riêng</i>	private address	Địa chỉ dành cho sử dụng nội bộ theo các prefix quy định.
<i>địa chỉ công cộng</i>	public address	Địa chỉ định tuyến công khai trong phạm vi Internet khi được phân bổ phù hợp.

B.5.4 Transport

Tiếng Việt	English	Nghĩa ngắn
<i>tầng vận chuyển</i>	Transport layer	Truyền dữ liệu process-to-process giữa endpoint.
<i>port</i>	port	Số định danh endpoint logic của TCP/UDP.
<i>socket</i>	socket	Endpoint phần mềm gồm địa chỉ/protocol/port theo ngữ cảnh hệ điều hành.
<i>ghép kênh</i>	multiplexing	Nhiều process/flow cùng sử dụng dịch vụ transport/network.
<i>phân kênh</i>	demultiplexing	Phân phối dữ liệu nhận tới đúng process/socket.

Tiếng Việt	English	Nghĩa ngắn
<i>UDP</i>	User Datagram Protocol, UDP	Transport không kết nối, bảo toàn ranh giới datagram, ít overhead.
<i>TCP</i>	Transmission Control Protocol, TCP	Transport byte-stream tin cậy có connection state.
<i>sequence number</i>	sequence number	Số thứ tự byte trong TCP.
<i>acknowledgment number</i>	acknowledgment number	Số byte kế tiếp TCP receiver mong đợi theo ACK tích lũy.
<i>SYN</i>	SYN flag	Cờ TCP dùng khi thiết lập sequence space/connection.
<i>ACK</i>	ACK flag	Cờ TCP cho biết acknowledgment field có hiệu lực.
<i>FIN</i>	FIN flag	Cờ TCP yêu cầu kết thúc một chiều byte stream.
<i>RST</i>	RST flag	Cờ TCP reset/abort connection theo tình huống.
<i>three-way handshake</i>	three-way handshake	Trao đổi SYN, SYN-ACK, ACK để thiết lập TCP connection.
<i>truyền lại</i>	retransmission	Gửi lại dữ liệu/segment khi cần khôi phục mất mát.
<i>cửa sổ nhận</i>	receive window	Khả năng nhận còn lại do receiver quảng bá.
<i>điều khiển luồng</i>	flow control	Ngăn sender làm tràn buffer receiver.
<i>điều khiển tắc nghẽn</i>	congestion control	Điều chỉnh tốc độ theo trạng thái đường/mạng.
<i>MSS</i>	Maximum Segment Size, MSS	Payload TCP tối đa receiver quảng bá trong option MSS.
<i>BDP</i>	bandwidth-delay product, BDP	Lượng dữ liệu tương ứng capacity nhân RTT.
<i>flow</i>	flow	Nhóm packet thuộc cùng phiên/quan hệ theo flow key định nghĩa.

B.5.5 Application

Tiếng Việt	English	Nghĩa ngắn
<i>tầng ứng dụng</i>	Application layer	Giao thức/dịch vụ gần ứng dụng người dùng.
<i>DNS</i>	Domain Name System, DNS	Hệ thống đặt tên phân cấp và phân giải tên.
<i>resolver</i>	DNS resolver	Thành phần nhận/giải quyết truy vấn DNS.

Tiếng Việt	English	Nghĩa ngắn
<i>authoritative server</i>	authoritative server	DNS DNS server có thẩm quyền cho zone.
<i>A record</i>	A record	Bản ghi DNS ánh xạ tên sang IPv4.
<i>AAAA record</i>	AAAA record	Bản ghi DNS ánh xạ tên sang IPv6.
<i>CNAME</i>	Canonical Name, CNAME	Bản ghi alias tới canonical name.
<i>MX</i>	Mail Exchange, MX	Bản ghi DNS chỉ mail exchanger.
<i>TTL DNS</i>	DNS TTL	Thời gian cache gợi ý cho record DNS.
<i>DHCP</i>	Dynamic Host Configuration Protocol, DHCP	Cấp cấu hình IP động.
<i>DORA</i>	Discover-Offer-Request-Acknowledge, DORA	Chuỗi message điển hình của DHCPv4.
<i>HTTP</i>	Hypertext Transfer Protocol, HTTP	Giao thức request/response cho web và API.
<i>phương thức HTTP</i>	HTTP method	GET, POST, PUT, DELETE... biểu thị hành động request.
<i>mã trạng thái HTTP</i>	HTTP status code	Mã ba chữ số mô tả kết quả response.
<i>HTTP header</i>	HTTP header	Metadata của request/response HTTP.
<i>cookie</i>	cookie	Dữ liệu nhỏ client lưu/gửi theo quy tắc HTTP để duy trì trạng thái và mục đích khác.
<i>TLS</i>	Transport Layer Security, TLS	Giao thức bảo vệ kênh truyền cho confidentiality, integrity và authentication.
<i>HTTPS</i>	HTTP over TLS, HTTPS	HTTP được bảo vệ bằng TLS.
<i>chứng thư số</i>	digital certificate	Cấu trúc liên kết public key với danh tính/thuộc tính theo PKI.
<i>QUIC</i>	QUIC	Transport bảo mật chạy trên UDP, nền tảng HTTP/3.
<i>HTTP/3</i>	HTTP/3	HTTP mapping trên QUIC.
<i>SSH</i>	Secure Shell, SSH	Giao thức quản trị từ xa an toàn.
<i>SMTP</i>	Simple Mail Transfer Protocol, SMTP	Giao thức gửi/chuyển thư điện tử.
<i>IMAP</i>	Internet Message Access Protocol, IMAP	Giao thức truy cập/hộp thư trên server.

Tiếng Việt	English	Nghĩa ngắn
<i>SNMP</i>	Simple Network Management Protocol, SNMP	Giao thức quản lý/giám sát thiết bị.

B.5.6 Hiệu năng

Tiếng Việt	English	Nghĩa ngắn
<i>băng thông</i>	bandwidth	Khả năng dải tần hoặc, trong ngữ cảnh thông dụng, capacity danh nghĩa của link.
<i>tốc độ bit</i>	bit rate	Số bit trên đơn vị thời gian.
<i>dung lượng</i>	capacity	Tốc độ tối đa theo mô hình/điều kiện định nghĩa.
<i>thông lượng</i>	throughput	Tốc độ dữ liệu thực tế được truyền trong cửa sổ đo.
<i>thông lượng hữu ích</i>	goodput	Tốc độ payload hữu ích tới ứng dụng.
<i>mức sử dụng</i>	utilization	Tỷ lệ tài nguyên/capacity được sử dụng.
<i>độ trễ</i>	delay	Thời gian dữ liệu/tác vụ đi từ mốc này tới mốc khác.
<i>độ trễ xử lý</i>	processing delay	Thời gian xử lý tại node.
<i>độ trễ hàng đợi</i>	queueing delay	Thời gian chờ trong queue.
<i>RTT</i>	round-trip time, RTT	Thời gian khứ hồi.
<i>jitter</i>	jitter	Biến động delay theo định nghĩa/cửa sổ đo.
<i>tỷ lệ mất packet</i>	packet loss rate	Tỷ lệ packet không tới theo tiêu chí đo.
<i>bottleneck</i>	bottleneck	Tài nguyên giới hạn throughput của đường/quy trình.
<i>tắc nghẽn</i>	congestion	Trạng thái demand vượt khả năng phục vụ, gây queue/loss/delay.
<i>bufferbloat</i>	bufferbloat	Delay lớn do queue/buffer quá sâu trong tải cao.
<i>QoS</i>	Quality of Service, QoS	Cơ chế/chính sách phân biệt và quản lý chất lượng lưu lượng.
<i>QoE</i>	Quality of Experience, QoE	Chất lượng người dùng/cảm nhận ở mức dịch vụ.
<i>SLA</i>	Service Level Agreement, SLA	Cam kết mức dịch vụ/metric giữa các bên.

Tiếng Việt	English	Nghĩa ngắn
<i>percentile</i>	percentile	Phân vị biểu diễn theo phần trăm, ví dụ p95 latency.

B.5.7 An toàn và giám sát

Tiếng Việt	English	Nghĩa ngắn
<i>tài sản</i>	asset	Thứ có giá trị cần bảo vệ.
<i>mối đe dọa</i>	threat	Tác nhân/sự kiện có khả năng gây hại.
<i>lỗ hổng</i>	vulnerability	Điểm yếu có thể bị khai thác.
<i>rủi ro</i>	risk	Tổ hợp khả năng và tác động của sự kiện bất lợi trong bối cảnh.
<i>tính bí mật</i>	confidentiality	Ngăn truy cập/tiết lộ trái phép.
<i>tính toàn vẹn</i>	integrity	Bảo đảm dữ liệu/hệ thống không bị thay đổi trái phép.
<i>tính sẵn sàng</i>	availability	Khả năng cung cấp dịch vụ khi cần.
<i>xác thực</i>	authentication	Xác minh danh tính/claim.
<i>phân quyền</i>	authorization	Quyết định chủ thể được phép làm gì.
<i>đặc quyền tối thiểu</i>	least privilege	Chỉ cấp quyền cần thiết cho nhiệm vụ.
<i>phòng vệ nhiều lớp</i>	defense in depth	Kết hợp nhiều lớp kiểm soát.
<i>phân đoạn mạng</i>	network segmentation	Chia mạng thành vùng để kiểm soát luồng/trust boundary.
<i>firewall</i>	firewall	Cơ chế kiểm soát lưu lượng theo policy.
<i>ACL</i>	Access Control List, ACL	Danh sách quy tắc cho phép/chặn theo thuộc tính.
<i>IDS</i>	Intrusion Detection System, IDS	Hệ thống phát hiện dấu hiệu xâm nhập/bất thường.
<i>IPS</i>	Intrusion Prevention System, IPS	Hệ thống có khả năng phát hiện và ngăn/chặn theo chính sách.
<i>sự kiện</i>	event	Bản ghi/quan sát một hoạt động xảy ra.
<i>cảnh báo</i>	alert	Tín hiệu cho rằng event/pattern cần chú ý.
<i>sự cố</i>	incident	Sự kiện hoặc chuỗi sự kiện ảnh hưởng an toàn/vận hành và cần xử lý.
<i>log</i>	log	Bản ghi sự kiện do hệ thống/ứng dụng tạo.

Tiếng Việt	English	Nghĩa ngắn
<i>telemetry</i>	telemetry	Dữ liệu quan sát/đo lường được thu tự động.
<i>SIEM</i>	Security Information and Event Management, SIEM	Nền tảng thu thập/tương quan/phân tích dữ liệu an toàn.
<i>quét port</i>	port scanning	Thăm dò port/dịch vụ trên host trong phạm vi được phép.
<i>tấn công từ chối dịch vụ</i>	Denial of Service, DoS	Làm suy giảm/gián đoạn availability.
<i>DDoS</i>	Distributed Denial of Service, DDoS	DoS từ nhiều nguồn phân tán.
<i>spoofing</i>	spoofing	Giả mạo một định danh/thuộc tính như địa chỉ nguồn.

B.5.8 Dữ liệu và ML

Tiếng Việt	English	Nghĩa ngắn
<i>quan sát</i>	observation	Một đơn vị/hàng dữ liệu được phân tích.
<i>biến</i>	variable	Đặc tính được đo/lưu cho observation.
<i>kiểu dữ liệu</i>	data type, dtype	Kiểu biểu diễn dữ liệu như số, chuỗi, Boolean.
<i>mảng NumPy</i>	NumPy array	Cấu trúc ndarray nhiều chiều cho dữ liệu đồng nhất.
<i>số chiều</i>	number of dimensions, ndim	Số trục của array.
<i>hình dạng</i>	shape	Kích thước theo từng trục.
<i>Series</i>	pandas Series	Cấu trúc một chiều có index.
<i>DataFrame</i>	pandas DataFrame	Bảng hai chiều có hàng/cột/index.
<i>giá trị thiếu</i>	missing value	Giá trị không quan sát/không có, thường biểu diễn NaN/NA.
<i>mặt nạ Boolean</i>	Boolean mask	Dãy True/False dùng lọc/chọn phần tử/hàng.
<i>đặc trưng</i>	feature	Biến đầu vào dùng cho mô hình.
<i>biến mục tiêu</i>	target	Biến model cần dự đoán/học.
<i>nhãn</i>	label	Giá trị lớp trong classification.
<i>ma trận đặc trưng</i>	feature matrix, X	Tập feature đầu vào theo hàng observation.
<i>vector mục tiêu</i>	target vector, y	Dãy target/label tương ứng observations.

Tiếng Việt	English	Nghĩa ngắn
<i>tập huấn luyện</i>	training set	Dữ liệu dùng để fit model/preprocessing phù hợp.
<i>tập kiểm tra</i>	test set	Dữ liệu độc lập dùng đánh giá sau khi thiết kế/fit.
<i>tiền xử lý</i>	preprocessing	Biến đổi dữ liệu trước khi đưa vào estimator.
<i>điền giá trị thiếu</i>	imputation	Ước lượng/thay thế missing theo quy tắc học từ dữ liệu phù hợp.
<i>chuẩn hóa theo độ lệch chuẩn</i>	standardization	Biến đổi thường dùng mean 0, std 1 từ tham số học trên train.
<i>mã hóa one-hot</i>	one-hot encoding	Biến categorical thành các cột chỉ báo.
<i>pipeline</i>	pipeline	Chuỗi preprocessing/estimator vận hành như một quy trình.
<i>rò rỉ dữ liệu</i>	data leakage	Thông tin không hợp lệ từ test/future/target đi vào quá trình học.
<i>mô hình cơ sở</i>	baseline	Phương pháp đơn giản làm mốc so sánh.
<i>hồi quy</i>	regression	Dự đoán target số liên tục.
<i>hồi quy tuyến tính</i>	linear regression	Mô hình hồi quy tuyến tính theo feature.
<i>phân loại</i>	classification	Dự đoán nhãn/lớp rời rạc.
<i>hồi quy logistic</i>	logistic regression	Mô hình tuyến tính cho xác suất/phân loại nhị phân/đa lớp theo cấu hình.
<i>cây quyết định</i>	decision tree	Mô hình chia không gian feature bằng các điều kiện ngưỡng.
<i>phân cụm</i>	clustering	Nhóm observation không cần label có sẵn.
<i>K-means</i>	K-means	Thuật toán phân cụm quanh K centroid.
<i>centroid</i>	centroid	Tâm đại diện của cluster trong K-means.
<i>phát hiện bất thường</i>	anomaly detection	Tìm observation khác biệt so với mẫu thông thường.
<i>Isolation Forest</i>	Isolation Forest	Thuật toán anomaly detection dựa trên khả năng cô lập observation.
<i>fit</i>	fit	Học tham số từ dữ liệu.
<i>transform</i>	transform	Áp dụng phép biến đổi đã học.
<i>predict</i>	predict	Tạo dự đoán từ model đã fit.
<i>phần dư</i>	residual	Sai khác $y - \hat{y}$ theo quy ước.

Tiếng Việt	English	Nghĩa ngắn
<i>MAE</i>	Mean Absolute Error, MAE	Trung bình trị tuyệt đối sai số regression.
<i>RMSE</i>	Root Mean Squared Error, RMSE	Căn trung bình bình phương sai số regression.
<i>ma trận nhầm lẫn</i>	confusion matrix	Bảng TP/FP/TN/FN cho classification.
<i>độ chính xác dương</i>	precision	$TP/(TP+FP)$.
<i>độ bao phủ dương</i>	recall	$TP/(TP+FN)$.
<i>F1-score</i>	F1-score	Trung bình điều hòa precision và recall.
<i>ngưỡng phân loại</i>	classification threshold	Ngưỡng chuyển score/probability thành nhãn.
<i>quá khớp</i>	overfitting	Model phù hợp train quá mức nhưng tổng quát hóa kém.
<i>trôi dữ liệu</i>	data drift	Phân bố đầu vào thay đổi theo thời gian/ngữ cảnh.
<i>khả năng tái lập</i>	reproducibility	Khả năng lặp lại quy trình/kết quả trong điều kiện được mô tả.